

Tenable Vulnerability Management Report

Tenable Vulnerability Management

Thu, 05 Mar 2026 03:31:05 UTC

Table Of Contents

Vulnerabilities By Host.....	14
•linuxred-01.....	15
Assets Summary (Executive).....	18
•linuxred-01.....	19
Audits FAILED.....	20
•RHEL-08-010020 - RHEL 8 must implement a FIPS 140-3-compliant systemwide cryptographic policy.....	21
•RHEL-08-010040 - RHEL 8 must display the Standard Mandatory DOD Notice and Consent Banner before granting local or remote access to the system via a ssh login.....	24
•RHEL-08-010060 - RHEL 8 must display the Standard Mandatory DoD Notice and Consent Banner before granting local or remote access to the system via a command line user login.....	26
•RHEL-08-010070 - All RHEL 8 remote access methods must be monitored.....	28
•RHEL-08-010130 - The RHEL 8 shadow password suite must be configured to use a sufficient number of hashing rounds.....	30
•RHEL-08-010140 - RHEL 8 operating systems booted with United Extensible Firmware Interface (UEFI) must require authentication upon booting into single-user mode and maintenance.....	32
•RHEL-08-010141 - RHEL 8 operating systems booted with United Extensible Firmware Interface (UEFI) must require a unique superusers name upon booting into single-user mode and maintenance.....	34
•RHEL-08-010190 - A sticky bit must be set on all RHEL 8 public directories to prevent unauthorized and unintended information transferred via shared system resources.....	36
•RHEL-08-010200 - RHEL 8 must be configured so that all network connections associated with SSH traffic terminate after becoming unresponsive.....	38
•RHEL-08-010201 - RHEL 8 must be configured so that all network connections associated with SSH traffic are terminated after 10 minutes of becoming unresponsive.....	40
•RHEL-08-010290 - The RHEL 8 SSH server must be configured to use only Message Authentication Codes (MACs) employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH server connections.....	42
•RHEL-08-010291 - The RHEL 8 SSH server must be configured to use only DOD-approved encryption ciphers employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH server connections.....	44
•RHEL-08-010296 - The RHEL 8 SSH client must be configured to use only DOD-approved Message Authentication Codes (MACs) employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH client connections.....	46
•RHEL-08-010297 - The RHEL 8 SSH client must be configured to use only DOD-approved encryption ciphers employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH client connections.....	48
•RHEL-08-010358 - RHEL 8 must be configured to allow sending email notifications of unauthorized configuration changes to designated personnel.....	50
•RHEL-08-010359 - The RHEL 8 operating system must use a file integrity tool to verify correct operation of all security functions.....	52
•RHEL-08-010360 - The RHEL 8 file integrity tool must notify the system administrator when changes to the baseline configuration or anomalies in the operation of any security functions are discovered within an organizationally defined frequency.....	54
•RHEL-08-010371 - RHEL 8 must prevent the installation of software, patches, service packs, device drivers, or operating system components of local packages without verification they have been digitally signed using a certificate that is issued by a Certificate Authority (CA) that is recognized and approved by the organization.....	57
•RHEL-08-010372 - RHEL 8 must prevent the loading of a new kernel for later execution.....	59
•RHEL-08-010373 - RHEL 8 must enable kernel parameters to enforce discretionary access control on symlinks.....	61
•RHEL-08-010374 - RHEL 8 must enable kernel parameters to enforce discretionary access control on hardlinks.....	64
•RHEL-08-010375 - RHEL 8 must restrict access to the kernel message buffer.....	67

•RHEL-08-010376 - RHEL 8 must prevent kernel profiling by unprivileged users.....	69
•RHEL-08-010383 - RHEL 8 must use the invoking user's password for privilege escalation when using "sudo".....	71
•RHEL-08-010384 - RHEL 8 must require re-authentication when using the "sudo" command.....	73
•RHEL-08-010400 - RHEL 8 must implement certificate status checking for multifactor authentication.....	74
•RHEL-08-010410 - RHEL 8 must accept Personal Identity Verification (PIV) credentials.....	76
•RHEL-08-010421 - RHEL 8 must clear the page allocator to prevent use-after-free attacks.....	78
•RHEL-08-010422 - RHEL 8 must disable virtual syscalls.....	80
•RHEL-08-010423 - RHEL 8 must clear memory when it is freed to prevent use-after-free attacks.....	82
•RHEL-08-010430 - RHEL 8 must implement address space layout randomization (ASLR) to protect its memory from unauthorized code execution.....	84
•RHEL-08-010455 - RHEL 8 must elevate the SELinux context when an administrator calls the sudo command.....	86
•RHEL-08-010471 - RHEL 8 must enable the hardware random number generator entropy gatherer service.....	88
•RHEL-08-010500 - The RHEL 8 SSH daemon must perform strict mode checking of home directory configuration files.....	90
•RHEL-08-010520 - The RHEL 8 SSH daemon must not allow authentication using known host's authentication.....	92
•RHEL-08-010521 - The RHEL 8 SSH daemon must not allow Kerberos authentication, except to fulfill documented and validated mission requirements.....	94
•RHEL-08-010522 - The RHEL 8 SSH daemon must not allow GSSAPI authentication, except to fulfill documented and validated mission requirements.....	96
•RHEL-08-010541 - RHEL 8 must use a separate file system for /var/log.....	98
•RHEL-08-010542 - RHEL 8 must use a separate file system for the system audit data path.....	99
•RHEL-08-010544 - RHEL 8 must use a separate file system for /var/tmp.....	100
•RHEL-08-010550 - RHEL 8 must not permit direct logons to the root account using remote access via SSH.....	101
•RHEL-08-010570 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on file systems that contain user home directories.....	103
•RHEL-08-010572 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on the /boot/efi directory.....	104
•RHEL-08-010580 - RHEL 8 must prevent special devices on non-root local partitions.....	105
•RHEL-08-010590 - RHEL 8 must prevent code from being executed on file systems that contain user home directories.....	107
•RHEL-08-010670 - RHEL 8 must disable kernel dumps unless needed.....	108
•RHEL-08-010671 - RHEL 8 must disable the kernel.core_pattern.....	110
•RHEL-08-010672 - RHEL 8 must disable acquiring, saving, and processing core dumps.....	112
•RHEL-08-010673 - RHEL 8 must disable core dumps for all users.....	114
•RHEL-08-010674 - RHEL 8 must disable storing core dumps.....	115
•RHEL-08-010675 - RHEL 8 must disable core dump backtraces.....	116
•RHEL-08-010680 - For RHEL 8 systems using Domain Name Servers (DNS) resolution, at least two name servers must be configured.....	117
•RHEL-08-010770 - All RHEL 8 local initialization files must have mode 0740 or less permissive.....	119
•RHEL-08-010830 - RHEL 8 must not allow users to override SSH environment variables.....	121
•RHEL-08-020011 - RHEL 8 must automatically lock an account when three unsuccessful logon attempts occur.....	122
•RHEL-08-020013 - RHEL 8 must automatically lock an account when three unsuccessful logon attempts occur during a 15-minute time period.....	124
•RHEL-08-020015 - RHEL 8 must automatically lock an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.....	126
•RHEL-08-020017 - RHEL 8 must ensure account lockouts persist.....	128

•RHEL-08-020019 - RHEL 8 must prevent system messages from being presented when three unsuccessful logon attempts occur.....	130
•RHEL-08-020021 - RHEL 8 must log user name information when unsuccessful logon attempts occur.....	132
•RHEL-08-020023 - RHEL 8 must include root when automatically locking an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.....	134
•RHEL-08-020024 - RHEL 8 must limit the number of concurrent sessions to ten for all accounts and/or account types.....	136
•RHEL-08-020025 - RHEL 8 must configure the use of the pam_faillock.so module in the /etc/pam.d/system-auth file.....	137
•RHEL-08-020026 - RHEL 8 must configure the use of the pam_faillock.so module in the /etc/pam.d/password-auth file.....	139
•RHEL-08-020027 - RHEL 8 systems, versions 8.2 and above, must configure SELinux context type to allow the use of a non-default faillock tally directory.....	141
•RHEL-08-020035 - RHEL 8.7 and higher must terminate idle user sessions.....	143
•RHEL-08-020090 - RHEL 8 must map the authenticated identity to the user or group account for PKI-based authentication.....	144
•RHEL-08-020104 - RHEL 8 systems, version 8.4 and above, must ensure the password complexity module is configured for three retries or less.....	146
•RHEL-08-020110 - RHEL 8 must enforce password complexity by requiring that at least one uppercase character be used.....	148
•RHEL-08-020120 - RHEL 8 must enforce password complexity by requiring that at least one lower-case character be used.....	150
•RHEL-08-020130 - RHEL 8 must enforce password complexity by requiring that at least one numeric character be used.....	152
•RHEL-08-020140 - RHEL 8 must require the maximum number of repeating characters of the same character class be limited to four when passwords are changed.....	154
•RHEL-08-020150 - RHEL 8 must require the maximum number of repeating characters be limited to three when passwords are changed.....	156
•RHEL-08-020160 - RHEL 8 must require the change of at least four character classes when passwords are changed.....	158
•RHEL-08-020170 - RHEL 8 must require the change of at least 8 characters when passwords are changed.....	160
•RHEL-08-020180 - RHEL 8 passwords must have a 24 hours/1 day minimum password lifetime restriction in /etc/shadow.....	162
•RHEL-08-020190 - RHEL 8 passwords for new users or password changes must have a 24 hours/1 day minimum password lifetime restriction in /etc/login.defs.....	164
•RHEL-08-020200 - RHEL 8 user account passwords must have a 60-day maximum password lifetime restriction.....	166
•RHEL-08-020210 - RHEL 8 user account passwords must be configured so that existing passwords are restricted to a 60-day maximum lifetime.....	168
•RHEL-08-020230 - RHEL 8 passwords must have a minimum of 15 characters.....	170
•RHEL-08-020231 - RHEL 8 passwords for new users must have a minimum of 15 characters.....	172
•RHEL-08-020250 - RHEL 8 must implement smart card logon for multifactor authentication for access to interactive accounts.....	174
•RHEL-08-020260 - RHEL 8 account identifiers (individuals, groups, roles, and devices) must be disabled after 35 days of inactivity.....	176
•RHEL-08-020280 - All RHEL 8 passwords must contain at least one special character.....	178
•RHEL-08-020300 - RHEL 8 must prevent the use of dictionary words for passwords.....	180
•RHEL-08-020310 - RHEL 8 must enforce a delay of at least four seconds between logon prompts following a failed logon attempt.....	181
•RHEL-08-020330 - RHEL 8 must not allow accounts configured with blank or null passwords.....	183
•RHEL-08-020331 - RHEL 8 must not allow blank or null passwords in the system-auth file.....	184
•RHEL-08-020332 - RHEL 8 must not allow blank or null passwords in the password-auth file.....	185

•RHEL-08-020350 - RHEL 8 must display the date and time of the last successful account logon upon an SSH logon.....	186
•RHEL-08-020351 - RHEL 8 must define default permissions for all authenticated users in such a way that the user can only read and modify their own files.....	187
•RHEL-08-020353 - RHEL 8 must define default permissions for logon and non-logon shells.....	188
•RHEL-08-020360 - RHEL 8 must automatically exit interactive command shell user sessions after 10 minutes of inactivity.....	190
•RHEL-08-030000 - The RHEL 8 audit system must be configured to audit the execution of privileged functions and prevent all software from executing at higher privilege levels than users executing the software.....	191
•RHEL-08-030020 - The RHEL 8 System Administrator (SA) and Information System Security Officer (ISSO) (at a minimum) must be alerted of an audit processing failure event.....	194
•RHEL-08-030040 - The RHEL 8 System must take appropriate action when an audit processing failure occurs.....	195
•RHEL-08-030060 - The RHEL 8 audit system must take appropriate action when the audit storage volume is full.....	197
•RHEL-08-030061 - The RHEL 8 audit system must audit local events.....	199
•RHEL-08-030062 - RHEL 8 must label all off-loaded audit logs before sending them to the central log server.....	200
•RHEL-08-030063 - RHEL 8 must resolve audit information before writing to disk.....	202
•RHEL-08-030070 - RHEL 8 audit logs must have a mode of 0600 or less permissive to prevent unauthorized read access.....	203
•RHEL-08-030080 - RHEL 8 audit logs must be owned by root to prevent unauthorized read access.....	205
•RHEL-08-030090 - RHEL 8 audit logs must be group-owned by root to prevent unauthorized read access.....	207
•RHEL-08-030100 - RHEL 8 audit log directory must be owned by root to prevent unauthorized read access.....	209
•RHEL-08-030110 - RHEL 8 audit log directory must be group-owned by root to prevent unauthorized read access.....	211
•RHEL-08-030120 - RHEL 8 audit log directory must have a mode of 0700 or less permissive to prevent unauthorized read access.....	213
•RHEL-08-030121 - RHEL 8 audit system must protect auditing rules from unauthorized change.....	215
•RHEL-08-030122 - RHEL 8 audit system must protect logon UIDs from unauthorized change.....	217
•RHEL-08-030130 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/shadow.....	219
•RHEL-08-030140 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/security/opasswd.....	221
•RHEL-08-030150 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/passwd.....	223
•RHEL-08-030160 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/gshadow.....	225
•RHEL-08-030170 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/group.....	227
•RHEL-08-030171 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/sudoers.....	229
•RHEL-08-030172 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/sudoers.d/.....	231
•RHEL-08-030190 - Successful/unsuccessful uses of the su command in RHEL 8 must generate an audit record.....	233
•RHEL-08-030200 - The RHEL 8 audit system must be configured to audit any usage of the setxattr, fsetxattr, lsetxattr, removexattr, fremovexattr, and lremovexattr system calls.....	235
•RHEL-08-030250 - Successful/unsuccessful uses of the chage command in RHEL 8 must generate an audit record.....	238
•RHEL-08-030260 - Successful/unsuccessful uses of the chcon command in RHEL 8 must generate an audit record.....	240
•RHEL-08-030280 - Successful/unsuccessful uses of the ssh-agent in RHEL 8 must generate an audit record.....	242

•RHEL-08-030290 - Successful/unsuccessful uses of the passwd command in RHEL 8 must generate an audit record.....	244
•RHEL-08-030300 - Successful/unsuccessful uses of the mount command in RHEL 8 must generate an audit record.....	246
•RHEL-08-030301 - Successful/unsuccessful uses of the umount command in RHEL 8 must generate an audit record.....	248
•RHEL-08-030302 - Successful/unsuccessful uses of the mount syscall in RHEL 8 must generate an audit record.....	250
•RHEL-08-030310 - Successful/unsuccessful uses of the unix_update in RHEL 8 must generate an audit record.....	252
•RHEL-08-030311 - Successful/unsuccessful uses of postdrop in RHEL 8 must generate an audit record.....	254
•RHEL-08-030312 - Successful/unsuccessful uses of postqueue in RHEL 8 must generate an audit record.....	256
•RHEL-08-030313 - Successful/unsuccessful uses of semanage in RHEL 8 must generate an audit record.....	258
•RHEL-08-030314 - Successful/unsuccessful uses of setfiles in RHEL 8 must generate an audit record.....	260
•RHEL-08-030315 - Successful/unsuccessful uses of userhelper in RHEL 8 must generate an audit record.....	262
•RHEL-08-030316 - Successful/unsuccessful uses of setsebool in RHEL 8 must generate an audit record.....	264
•RHEL-08-030317 - Successful/unsuccessful uses of unix_chkpwd in RHEL 8 must generate an audit record.....	266
•RHEL-08-030320 - Successful/unsuccessful uses of the ssh-keysign in RHEL 8 must generate an audit record.....	268
•RHEL-08-030330 - Successful/unsuccessful uses of the setfacl command in RHEL 8 must generate an audit record.....	270
•RHEL-08-030340 - Successful/unsuccessful uses of the pam_timestamp_check command in RHEL 8 must generate an audit record.....	272
•RHEL-08-030350 - Successful/unsuccessful uses of the newgrp command in RHEL 8 must generate an audit record.....	274
•RHEL-08-030360 - Successful/unsuccessful uses of the init_module and finit_module system calls in RHEL 8 must generate an audit record.....	276
•RHEL-08-030361 - Successful/unsuccessful uses of the rename, unlink, rmdir, renameat, and unlinkat system calls in RHEL 8 must generate an audit record.....	278
•RHEL-08-030370 - Successful/unsuccessful uses of the gpasswd command in RHEL 8 must generate an audit record.....	281
•RHEL-08-030390 - Successful/unsuccessful uses of the delete_module command in RHEL 8 must generate an audit record.....	283
•RHEL-08-030400 - Successful/unsuccessful uses of the crontab command in RHEL 8 must generate an audit record.....	285
•RHEL-08-030410 - Successful/unsuccessful uses of the chsh command in RHEL 8 must generate an audit record.....	287
•RHEL-08-030420 - Successful/unsuccessful uses of the truncate, ftruncate, creat, open, openat, and open_by_handle_at system calls in RHEL 8 must generate an audit record.....	289
•RHEL-08-030480 - Successful/unsuccessful uses of the chown, fchown, fchownat, and lchown system calls in RHEL 8 must generate an audit record.....	292
•RHEL-08-030490 - Successful/unsuccessful uses of the chmod, fchmod, and fchmodat system calls in RHEL 8 must generate an audit record.....	294
•RHEL-08-030550 - Successful/unsuccessful uses of the sudo command in RHEL 8 must generate an audit record.....	296
•RHEL-08-030560 - Successful/unsuccessful uses of the usermod command in RHEL 8 must generate an audit record.....	298
•RHEL-08-030570 - Successful/unsuccessful uses of the chacl command in RHEL 8 must generate an audit record.....	300
•RHEL-08-030580 - Successful/unsuccessful uses of the kmod command in RHEL 8 must generate an audit record.....	302
•RHEL-08-030590 - Successful/unsuccessful modifications to the faillock log file in RHEL 8 must generate an audit record.....	304

•RHEL-08-030600 - Successful/unsuccessful modifications to the lastlog file in RHEL 8 must generate an audit record.....	306
•RHEL-08-030601 - RHEL 8 must enable auditing of processes that start prior to the audit daemon.....	308
•RHEL-08-030602 - RHEL 8 must allocate an audit_backlog_limit of sufficient size to capture processes that start prior to the audit daemon.....	310
•RHEL-08-030610 - RHEL 8 must allow only the Information System Security Manager (ISSM) (or individuals or roles appointed by the ISSM) to select which auditable events are to be audited.....	312
•RHEL-08-030650 - RHEL 8 must use cryptographic mechanisms to protect the integrity of audit tools.....	314
•RHEL-08-030655 - RHEL 8 must audit any script or executable called by cron as root or by any privileged user.....	316
•RHEL-08-030690 - The RHEL 8 audit records must be off-loaded onto a different system or storage media from the system being audited.....	318
•RHEL-08-030700 - RHEL 8 must take appropriate action when the internal event queue is full.....	320
•RHEL-08-030710 - RHEL 8 must encrypt the transfer of audit records off-loaded onto a different system or media from the system being audited.....	321
•RHEL-08-030730 - RHEL 8 must take action when allocated audit record storage volume reaches 75 percent of the repository maximum audit record storage capacity.....	323
•RHEL-08-030731 - RHEL 8 must notify the System Administrator (SA) and Information System Security Officer (ISSO) (at a minimum) when allocated audit record storage volume 75 percent utilization.....	324
•RHEL-08-030740 - RHEL 8 must securely compare internal information system clocks at least every 24 hours with a server synchronized to an authoritative time source, such as the United States Naval Observatory (USNO) time servers, or a time server designated for the appropriate DoD network (NIPRNet/SIPRNet), and/or the Global Positioning System (GPS).....	325
•RHEL-08-030741 - RHEL 8 must disable the chrony daemon from acting as a server.....	327
•RHEL-08-030742 - RHEL 8 must disable network management of the chrony daemon.....	329
•RHEL-08-040004 - RHEL 8 must enable mitigations against processor-based vulnerabilities.....	331
•RHEL-08-040021 - RHEL 8 must disable the asynchronous transfer mode (ATM) protocol.....	333
•RHEL-08-040022 - RHEL 8 must disable the controller area network (CAN) protocol.....	335
•RHEL-08-040023 - RHEL 8 must disable the stream control transmission protocol (SCTP).....	337
•RHEL-08-040024 - RHEL 8 must disable the transparent inter-process communication (TIPC) protocol.....	339
•RHEL-08-040025 - RHEL 8 must disable mounting of cramfs.....	341
•RHEL-08-040026 - RHEL 8 must disable IEEE 1394 (FireWire) Support.....	343
•RHEL-08-040080 - RHEL 8 must be configured to disable USB mass storage.....	345
•RHEL-08-040090 - A RHEL 8 firewall must employ a deny-all, allow-by-exception policy for allowing connections to other systems.....	347
•RHEL-08-040111 - RHEL 8 Bluetooth must be disabled.....	349
•RHEL-08-040123 - RHEL 8 must mount /tmp with the nodev option.....	351
•RHEL-08-040124 - RHEL 8 must mount /tmp with the nosuid option.....	353
•RHEL-08-040125 - RHEL 8 must mount /tmp with the noexec option.....	355
•RHEL-08-040126 - RHEL 8 must mount /var/log with the nodev option.....	357
•RHEL-08-040127 - RHEL 8 must mount /var/log with the nosuid option.....	359
•RHEL-08-040128 - RHEL 8 must mount /var/log with the noexec option.....	361
•RHEL-08-040129 - RHEL 8 must mount /var/log/audit with the nodev option.....	363
•RHEL-08-040130 - RHEL 8 must mount /var/log/audit with the nosuid option.....	365
•RHEL-08-040131 - RHEL 8 must mount /var/log/audit with the noexec option.....	367
•RHEL-08-040132 - RHEL 8 must mount /var/tmp with the nodev option.....	369
•RHEL-08-040133 - RHEL 8 must mount /var/tmp with the nosuid option.....	371
•RHEL-08-040134 - RHEL 8 must mount /var/tmp with the noexec option.....	373
•RHEL-08-040135 - The RHEL 8 fapolicy module must be installed.....	375
•RHEL-08-040136 - The RHEL 8 fapolicy module must be enabled.....	377

•RHEL-08-040137 - The RHEL 8 fapolicy module must be configured to employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs.....	379
•RHEL-08-040150 - A firewall must be able to protect against or limit the effects of Denial of Service (DoS) attacks by ensuring RHEL 8 can implement rate-limiting measures on impacted network interfaces.....	381
•RHEL-08-040161 - RHEL 8 must force a frequent session key renegotiation for SSH connections to the server.....	383
•RHEL-08-040170 - The x86 Ctrl-Alt-Delete key sequence must be disabled on RHEL 8.....	385
•RHEL-08-040172 - The systemd Ctrl-Alt-Delete burst key sequence in RHEL 8 must be disabled.....	387
•RHEL-08-040180 - The debug-shell systemd service must be disabled on RHEL 8.....	389
•RHEL-08-040209 - RHEL 8 must prevent IPv4 Internet Control Message Protocol (ICMP) redirect messages from being accepted.....	391
•RHEL-08-040210 - RHEL 8 must prevent IPv6 Internet Control Message Protocol (ICMP) redirect messages from being accepted.....	393
•RHEL-08-040220 - RHEL 8 must not send Internet Control Message Protocol (ICMP) redirects.....	395
•RHEL-08-040230 - RHEL 8 must not respond to Internet Control Message Protocol (ICMP) echoes sent to a broadcast address.....	397
•RHEL-08-040240 - RHEL 8 must not forward IPv6 source-routed packets.....	399
•RHEL-08-040249 - RHEL 8 must not forward IPv4 source-routed packets by default.....	401
•RHEL-08-040250 - RHEL 8 must not forward IPv6 source-routed packets by default.....	403
•RHEL-08-040259 - RHEL 8 must not enable IPv4 packet forwarding unless the system is a router.....	405
•RHEL-08-040260 - RHEL 8 must not enable IPv6 packet forwarding unless the system is a router.....	407
•RHEL-08-040261 - RHEL 8 must not accept router advertisements on all IPv6 interfaces.....	409
•RHEL-08-040262 - RHEL 8 must not accept router advertisements on all IPv6 interfaces by default.....	411
•RHEL-08-040270 - RHEL 8 must not allow interfaces to perform Internet Control Message Protocol (ICMP) redirects by default.....	413
•RHEL-08-040279 - RHEL 8 must ignore IPv4 Internet Control Message Protocol (ICMP) redirect messages.....	415
•RHEL-08-040280 - RHEL 8 must ignore IPv6 Internet Control Message Protocol (ICMP) redirect messages.....	417
•RHEL-08-040281 - RHEL 8 must disable access to network bpf syscall from unprivileged processes.....	419
•RHEL-08-040282 - RHEL 8 must restrict usage of ptrace to descendant processes.....	421
•RHEL-08-040284 - RHEL 8 must disable the use of user namespaces.....	423
•RHEL-08-040285 - RHEL 8 must use reverse path filtering on all IPv4 interfaces.....	425
•RHEL-08-040286 - RHEL 8 must enable hardening for the Berkeley Packet Filter Just-in-time compiler.....	427
•RHEL-08-040340 - RHEL 8 remote X connections for interactive users must be disabled unless to fulfill documented and validated mission requirements.....	429
•RHEL-08-040341 - The RHEL 8 SSH daemon must prevent remote hosts from connecting to the proxy display.....	431
•RHEL-08-040390 - The tuned package must not be installed unless mission essential on RHEL 8.....	433

Audits SKIPPED..... 435

Audits PASSED..... 436

•DISA_STIG_Red_Hat_Enterprise_Linux_8_v2r6.audit from DISA Red Hat Enterprise Linux 8 STIG v2r6.....	437
•RHEL-08-010000 - RHEL 8 must be a vendor-supported release.....	438
•RHEL-08-010015 - RHEL 8 must have the crypto-policies package installed.....	440
•RHEL-08-010019 - RHEL 8 must ensure cryptographic verification of vendor software packages.....	442
•RHEL-08-010049 - RHEL 8 must display a banner before granting local or remote access to the system via a graphical user logon.....	444
•RHEL-08-010050 - RHEL 8 must display the Standard Mandatory DoD Notice and Consent Banner before granting local or remote access to the system via a graphical user logon.....	446
•RHEL-08-010110 - RHEL 8 must encrypt all stored passwords with a FIPS 140-2 approved cryptographic hashing algorithm.....	448

•RHEL-08-010120 - RHEL 8 must employ FIPS 140-2 approved cryptographic hashing algorithms for all stored passwords.....	450
•RHEL-08-010121 - The RHEL 8 operating system must not have accounts configured with blank or null passwords.....	452
•RHEL-08-010149 - RHEL 8 operating systems booted with a BIOS must require a unique superusers name upon booting into single-user and maintenance modes.....	454
•RHEL-08-010150 - RHEL 8 operating systems booted with a BIOS must require authentication upon booting into single-user and maintenance modes.....	456
•RHEL-08-010151 - RHEL 8 operating systems must require authentication upon booting into rescue mode.....	458
•RHEL-08-010152 - RHEL 8 operating systems must require authentication upon booting into emergency mode.....	460
•RHEL-08-010159 - The RHEL 8 pam_unix.so module must be configured in the system-auth file to use a FIPS 140-2 approved cryptographic hashing algorithm for system authentication.....	462
•RHEL-08-010160 - The RHEL 8 pam_unix.so module must be configured in the password-auth file to use a FIPS 140-2 approved cryptographic hashing algorithm for system authentication.....	464
•RHEL-08-010161 - RHEL 8 must prevent system daemons from using Kerberos for authentication.....	466
•RHEL-08-010162 - The krb5-workstation package must not be installed on RHEL 8.....	468
•RHEL-08-010163 - The krb5-server package must not be installed on RHEL 8.....	470
•RHEL-08-010170 - RHEL 8 must use a Linux Security Module configured to enforce limits on system services.....	472
•RHEL-08-010171 - RHEL 8 must have polycoreutils package installed.....	473
•RHEL-08-010210 - The RHEL 8 /var/log/messages file must have mode 0640 or less permissive.....	474
•RHEL-08-010220 - The RHEL 8 /var/log/messages file must be owned by root.....	475
•RHEL-08-010230 - The RHEL 8 /var/log/messages file must be group-owned by root.....	476
•RHEL-08-010240 - The RHEL 8 /var/log directory must have mode 0755 or less permissive.....	477
•RHEL-08-010250 - The RHEL 8 /var/log directory must be owned by root.....	478
•RHEL-08-010260 - The RHEL 8 /var/log directory must be group-owned by root.....	479
•RHEL-08-010270 - RHEL 8 cryptographic policy must not be overridden.....	480
•RHEL-08-010275 - RHEL 8 must implement DOD-approved encryption in the bind package.....	482
•RHEL-08-010280 - RHEL 8 IP tunnels must use FIPS 140-3-approved cryptographic algorithms.....	484
•RHEL-08-010300 - RHEL 8 system commands must have mode 755 or less permissive.....	486
•RHEL-08-010310 - RHEL 8 system commands must be owned by root.....	488
•RHEL-08-010320 - RHEL 8 system commands must be group-owned by root or a system account.....	490
•RHEL-08-010330 - RHEL 8 library files must have mode 755 or less permissive.....	492
•RHEL-08-010331 - RHEL 8 library directories must have mode 755 or less permissive.....	494
•RHEL-08-010340 - RHEL 8 library files must be owned by root.....	496
•RHEL-08-010341 - RHEL 8 library directories must be owned by root.....	498
•RHEL-08-010350 - RHEL 8 library files must be group-owned by root.....	500
•RHEL-08-010351 - RHEL 8 library directories must be group-owned by root or a system account.....	502
•RHEL-08-010370 - RHEL 8 must prevent the installation of software, patches, service packs, device drivers, or operating system components from a repository without verification they have been digitally signed using a certificate that is issued by a Certificate Authority (CA) that is recognized and approved by the organization.....	504
•RHEL-08-010379 - RHEL 8 must specify the default "include" directory for the /etc/sudoers file.....	506
•RHEL-08-010385 - The RHEL 8 operating system must not be configured to bypass password requirements for privilege escalation.....	508
•RHEL-08-010390 - RHEL 8 must have the packages required for multifactor authentication installed.....	509
•RHEL-08-010420 - RHEL 8 must implement non-executable data to protect its memory from unauthorized code execution.....	511
•RHEL-08-010440 - YUM must remove all software components after updated versions have been installed on RHEL 8.....	513
•RHEL-08-010450 - RHEL 8 must enable the SELinux targeted policy.....	515

•RHEL-08-010460 - There must be no shosts.equiv files on the RHEL 8 operating system.....	517
•RHEL-08-010470 - There must be no .shosts files on the RHEL 8 operating system.....	518
•RHEL-08-010472 - RHEL 8 must have the packages required to use the hardware random number generator entropy gatherer service.....	519
•RHEL-08-010480 - The RHEL 8 SSH public host key files must have mode 0644 or less permissive.....	521
•RHEL-08-010490 - The RHEL 8 SSH private host key files must have mode 0640 or less permissive.....	523
•RHEL-08-010540 - RHEL 8 must use a separate file system for /var.....	525
•RHEL-08-010543 - A separate RHEL 8 filesystem must be used for the /tmp directory.....	526
•RHEL-08-010561 - The rsyslog service must be running in RHEL 8.....	527
•RHEL-08-010571 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on the /boot directory.....	529
•RHEL-08-010600 - RHEL 8 must prevent special devices on file systems that are used with removable media.....	530
•RHEL-08-010610 - RHEL 8 must prevent code from being executed on file systems that are used with removable media.....	531
•RHEL-08-010620 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on file systems that are used with removable media.....	532
•RHEL-08-010630 - RHEL 8 must prevent code from being executed on file systems that are imported via Network File System (NFS).....	533
•RHEL-08-010640 - RHEL 8 must prevent special devices on file systems that are imported via Network File System (NFS).....	534
•RHEL-08-010650 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on file systems that are imported via Network File System (NFS).....	535
•RHEL-08-010700 - All RHEL 8 world-writable directories must be owned by root, sys, bin, or an application user.....	536
•RHEL-08-010710 - All RHEL 8 world-writable directories must be group-owned by root, sys, bin, or an application group.....	538
•RHEL-08-010720 - All RHEL 8 local interactive users must have a home directory assigned in the /etc/passwd file.....	539
•RHEL-08-010730 - All RHEL 8 local interactive user home directories must have mode 0750 or less permissive.....	540
•RHEL-08-010731 - All RHEL 8 local interactive user home directory files must have mode 0750 or less permissive.....	541
•RHEL-08-010740 - All RHEL 8 local interactive user home directories must be group-owned by the home directory owner's primary group.....	542
•RHEL-08-010741 - RHEL 8 must be configured so that all files and directories contained in local interactive user home directories are group-owned by a group of which the home directory owner is a member.....	544
•RHEL-08-010750 - All RHEL 8 local interactive user home directories defined in the /etc/passwd file must exist.....	546
•RHEL-08-010760 - All RHEL 8 local interactive user accounts must be assigned a home directory upon creation.....	548
•RHEL-08-010780 - All RHEL 8 local files and directories must have a valid owner.....	549
•RHEL-08-010790 - All RHEL 8 local files and directories must have a valid group owner.....	550
•RHEL-08-010800 - A separate RHEL 8 filesystem must be used for user home directories (such as /home or an equivalent).....	551
•RHEL-08-010820 - Unattended or automatic login via the RHEL 8 graphical user interface must not be allowed.....	552
•RHEL-08-020010 - RHEL 8 must automatically lock an account when three unsuccessful login attempts occur.....	553
•RHEL-08-020012 - RHEL 8 must automatically lock an account when three unsuccessful login attempts occur during a 15-minute time period.....	555
•RHEL-08-020014 - RHEL 8 must automatically lock an account until the locked account is released by an administrator when three unsuccessful login attempts occur during a 15-minute time period.....	557

•RHEL-08-020016 - RHEL 8 must ensure account lockouts persist.....	559
•RHEL-08-020018 - RHEL 8 must prevent system messages from being presented when three unsuccessful logon attempts occur.....	561
•RHEL-08-020020 - RHEL 8 must log user name information when unsuccessful logon attempts occur.....	563
•RHEL-08-020022 - RHEL 8 must include root when automatically locking an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.....	565
•RHEL-08-020028 - RHEL 8 systems below version 8.2 must configure SELinux context type to allow the use of a non-default faillock tally directory.....	567
•RHEL-08-020030 - RHEL 8 must enable a user session lock until that user re-establishes access using established identification and authentication procedures for graphical user sessions.....	569
•RHEL-08-020031 - RHEL 8 must initiate a session lock for graphical user interfaces when the screensaver is activated.....	571
•RHEL-08-020032 - RHEL 8 must disable the user list at logon for graphical user interfaces.....	573
•RHEL-08-020050 - RHEL 8 must be able to initiate directly a session lock for all connection types using smartcard when the smartcard is removed.....	575
•RHEL-08-020060 - RHEL 8 must automatically lock graphical user sessions after 15 minutes of inactivity.....	577
•RHEL-08-020080 - RHEL 8 must prevent a user from overriding the session lock-delay setting for the graphical user interface.....	579
•RHEL-08-020081 - RHEL 8 must prevent a user from overriding the session idle-delay setting for the graphical user interface.....	581
•RHEL-08-020082 - RHEL 8 must prevent a user from overriding the screensaver lock-enabled setting for the graphical user interface.....	583
•RHEL-08-020100 - RHEL 8 must ensure the password complexity module is enabled in the password-auth file.....	585
•RHEL-08-020101 - RHEL 8 must ensure the password complexity module is enabled in the system-auth file.....	587
•RHEL-08-020240 - RHEL 8 duplicate User IDs (UIDs) must not exist for interactive users.....	589
•RHEL-08-020290 - RHEL 8 must prohibit the use of cached authentications after one day.....	591
•RHEL-08-020352 - RHEL 8 must set the umask value to 077 for all local interactive user accounts.....	593
•RHEL-08-030010 - Cron logging must be implemented in RHEL 8.....	594
•RHEL-08-030030 - The RHEL 8 Information System Security Officer (ISSO) and System Administrator (SA) (at a minimum) must have mail aliases to be notified of an audit processing failure.....	596
•RHEL-08-030180 - The RHEL 8 audit package must be installed.....	598
•RHEL-08-030181 - RHEL 8 audit records must contain information to establish what type of events occurred, the source of events, where events occurred, and the outcome of events.....	600
•RHEL-08-030603 - RHEL 8 must enable Linux audit logging for the USBGuard daemon.....	602
•RHEL-08-030620 - RHEL 8 audit tools must have a mode of 0755 or less permissive.....	604
•RHEL-08-030630 - RHEL 8 audit tools must be owned by root.....	607
•RHEL-08-030640 - RHEL 8 audit tools must be group-owned by root.....	610
•RHEL-08-030670 - RHEL 8 must have the packages required for offloading audit logs installed.....	613
•RHEL-08-030680 - RHEL 8 must have the packages required for encrypting offloaded audit logs installed.....	615
•RHEL-08-040000 - RHEL 8 must not have the telnet-server package installed.....	617
•RHEL-08-040001 - RHEL 8 must not have any automated bug reporting tools installed.....	619
•RHEL-08-040002 - RHEL 8 must not have the sendmail package installed.....	621
•RHEL-08-040010 - RHEL 8 must not install packages from the Extra Packages for Enterprise Linux (EPEL) repository.....	623
•RHEL-08-040020 - RHEL 8 must cover or disable the built-in or attached camera when not in use.....	625
•RHEL-08-040070 - The RHEL 8 file system automounter must be disabled.....	627
•RHEL-08-040100 - A firewall must be installed on RHEL 8.....	629
•RHEL-08-040101 - A firewall must be active on RHEL 8.....	631
•RHEL-08-040110 - RHEL 8 wireless network adapters must be disabled.....	633
•RHEL-08-040120 - RHEL 8 must mount /dev/shm with the nodev option.....	635

•RHEL-08-040121 - RHEL 8 must mount /dev/shm with the nosuid option.....	637
•RHEL-08-040122 - RHEL 8 must mount /dev/shm with the noexec option.....	639
•RHEL-08-040139 - RHEL 8 must have the USBGuard installed.....	641
•RHEL-08-040140 - RHEL 8 must block unauthorized peripherals before establishing a connection.....	643
•RHEL-08-040141 - RHEL 8 must enable the USBGuard.....	645
•RHEL-08-040159 - All RHEL 8 networked systems must have SSH installed.....	647
•RHEL-08-040160 - All RHEL 8 networked systems must have and implement SSH to protect the confidentiality and integrity of transmitted and received information, as well as information during preparation for transmission.....	649
•RHEL-08-040171 - The x86 Ctrl-Alt-Delete key sequence in RHEL 8 must be disabled if a graphical user interface is installed.....	652
•RHEL-08-040190 - The Trivial File Transfer Protocol (TFTP) server package must not be installed if not required for RHEL 8 operational support.....	654
•RHEL-08-040200 - The root account must be the only account having unrestricted access to the RHEL 8 system.....	655
•RHEL-08-040239 - RHEL 8 must not forward IPv4 source-routed packets.....	656
•RHEL-08-040283 - RHEL 8 must restrict exposed kernel pointer addresses access.....	658
•RHEL-08-040290 - RHEL 8 must be configured to prevent unrestricted mail relaying.....	660
•RHEL-08-040310 - The RHEL 8 file integrity tool must be configured to verify Access Control Lists (ACLs).....	661
•RHEL-08-040320 - The graphical display manager must not be installed on RHEL 8 unless approved.....	663
•RHEL-08-040321 - The graphical display manager must not be the default target on RHEL 8 unless approved.....	664
•RHEL-08-040330 - RHEL 8 network interfaces must not be in promiscuous mode.....	666
•RHEL-08-040350 - If the Trivial File Transfer Protocol (TFTP) server is required, the RHEL 8 TFTP daemon must be configured to operate in secure mode.....	668
•RHEL-08-040360 - A File Transfer Protocol (FTP) server package must not be installed unless mission essential on RHEL 8.....	669
•RHEL-08-040370 - The gssproxy package must not be installed unless mission essential on RHEL 8.....	670
•RHEL-08-040380 - The iprutils package must not be installed unless mission essential on RHEL 8.....	672

Audits INFO,WARNING,ERROR.....674

•RHEL-08-010010 - RHEL 8 vendor packaged system security patches and updates must be installed and up to date.....	675
•RHEL-08-010030 - All RHEL 8 local disk partitions must implement cryptographic mechanisms to prevent unauthorized disclosure or modification of all information that requires at rest protection.....	677
•RHEL-08-010090 - RHEL 8, for PKI-based authentication, must validate certificates by constructing a certification path (which includes status information) to an accepted trust anchor.....	679
•RHEL-08-010100 - RHEL 8, for certificate-based authentication, must enforce authorized access to the corresponding private key.....	681
•RHEL-08-010292 - RHEL 8 must ensure the SSH server uses strong entropy.....	683
•RHEL-08-010380 - RHEL 8 must require users to provide a password for privilege escalation.....	685
•RHEL-08-010381 - RHEL 8 must require users to reauthenticate for privilege escalation.....	686
•RHEL-08-010382 - RHEL 8 must restrict privilege elevation to authorized personnel.....	687
•RHEL-08-010690 - Executable search paths within the initialization files of all local interactive RHEL 8 users must only contain paths that resolve to the system default or the users home directory.....	688
•RHEL-08-020270 - RHEL 8 must automatically expire temporary accounts within 72 hours.....	690
•RHEL-08-020320 - RHEL 8 must not have unnecessary accounts.....	692
•RHEL-08-030660 - RHEL 8 must allocate audit record storage capacity to store at least one week of audit records, when audit records are not immediately sent to a central audit record storage facility.....	694
•RHEL-08-030720 - RHEL 8 must authenticate the remote logging server for off-loading audit logs.....	696
•RHEL-08-040030 - RHEL 8 must be configured to prohibit or restrict the use of functions, ports, protocols, and/or services, as defined in the Ports, Protocols, and Services Management (PPSM) Category Assignments List (CAL) and vulnerability assessments.....	698

- RHEL-08-040300 - The RHEL 8 file integrity tool must be configured to verify extended attributes.....700
- RHEL-08-040400 - RHEL 8 must prevent nonprivileged users from executing privileged functions, including disabling, circumventing, or altering implemented security safeguards/countermeasures..... 701

Vulnerabilities By Host

linuxred-01

Scan Information

Start time:

2026/03/05 03:26

End time:

2026/03/05 03:31

Host Information

DNS Name:

linuxred-01.internal.cloudapp.net

OS:

Linux Kernel 4.18.0-553.53.1.el8_10.x86_64 on Red Hat Enterprise Linux release 8.10 (Ootpa)

Results Summary

Critical	High	Medium	Low	Info	Total
0	0	0	0	3	3

Results Details

/

19506 - Nessus Scan Information

Synopsis

This plugin displays information about the Nessus scan.

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.

- The type of scanner (Nessus or Nessus Home).

- The version of the Nessus Engine.

- The port scanner(s) used.

- The port range scanned.

- The ping round trip time

- Whether credentialed or third-party patch management checks are possible.

- Whether the display of superseded patches is enabled

- The date of the scan.

- The duration of the scan.

- The number of hosts scanned in parallel.

- The number of checks done in parallel.

Solution

N/A

Risk Factor

None

Plugin Information:

Publication date: 2005/08/26, Modification date: 2026/03/04

Ports

linuxred-01 (TCP/0) Vulnerability State: Active

Information about this scan :

Nessus version : 10.11.3

Nessus build : 20047

Plugin feed version : 202603031148

Scanner edition used : Nessus

Scanner OS : WINDOWS

Scanner distribution : win-x86-64

Scan type : Normal

Scan name : RHEL8_STIG-cddar

Scan policy used : RHEL8_STIG Template____

Scanner IP : 10.0.0.8

Port scanner(s) : netstat

Port range : default

Ping RTT : 15.625 ms

Thorough tests : yes

```

Experimental tests : no
Scan for Unpatched Vulnerabilities : no
Plugin debugging enabled : no
Paranoia level : 1
Report verbosity : 1
Safe checks : yes
Optimize the test : yes
Credentialed checks : yes, as 'cddar' via ssh
Attempt Least Privilege : yes
Patch management checks : None
Display superseded patches : yes (supersedence plugin did not launch)
CGI scanning : disabled
Web application tests : disabled
Max hosts : 80
Max checks : 5
Recv timeout : 5
Backports : None
Allow post-scan editing : Yes
Nessus Plugin Signature Checking : Enabled
Audit File Signature Checking : Disabled
Scan Start Date : 2026/3/5 3:27 UTC
Scan duration : 213 sec
Scan for malware : no

```

102094 - SSH Commands Require Privilege Escalation

Synopsis

This plugin reports the SSH commands that failed with a response indicating that privilege escalation is required to run them.

Description

This plugin reports the SSH commands that failed with a response indicating that privilege escalation is required to run them. Either privilege escalation credentials were not provided, or the command failed to run with the provided privilege escalation credentials.

NOTE: Due to limitations inherent to the majority of SSH servers, this plugin may falsely report failures for commands containing error output expected by sudo, such as 'incorrect password', 'not in the sudoers file', or 'not allowed to execute'.

Solution

N/A

Risk Factor

None

References

XREF IAVB-0001-B-0507

Plugin Information:

Publication date: 2017/08/01, Modification date: 2020/09/22

Ports

linuxred-01 (TCP/0) Vulnerability State: Active

```

Login account : cddar
Commands failed due to lack of privilege escalation :
- Escalation account : (none)
  Escalation method : (none)
  Plugins :
    - Plugin Filename : host_tag_nix.nbin
      Plugin ID       : 87414
      Plugin Name      : Host Tagging (Linux)
      - Command       : "sh -c \"echo 9b7c56581f6c4afcbb07e2f9a52036da > /etc/tenable_tag && echo OK\""
        Response      : null
        Error         : "\nsh: /etc/tenable_tag: Permission denied"
    - Plugin Filename : unix_compliance_check.nbin
      Plugin ID       : 21157
      Plugin Name      : Unix Compliance Checks
      - Command       : "LANG=C; /sbin/sshd -T | /bin/grep -i Banner|cat"
        Response      : null
        Error         : "\n/etc/ssh/sshd_config: Permission denied"
      - Command       : "LANG=C; /bin/openssl x509 -text -in /etc/sssdpki/sssdpki_auth_ca_db.pem | /bin/
grep -Ei '^\\s*(issuer|subject|not before|not after)'|cat"

```

```

Response : null
Error    : "\nCan't open /etc/sssdpki/sssdpki_auth_ca_db.pem for reading, Permission
denied\n140314794895168:error:0200100D:system library:fopen:Permission denied:crypto/bio/
bss_file.c:69:fopen('/etc/sssdpki/sssdpki_auth_ca_db.pem','r')\n140314794895168:error:2006D002:BIORoutines:
BIORoutines:BIORoutines:system lib:crypto/bio/bss_file.c:78:\nunable to load certificate"
- Command : "LANG=C; /bin/cut -d: -f1,2 /etc/shadow | /bin/grep -Pv ':[*!\\$]' | /bin/grep -
Pv '^\\$6\\$' | /bin/awk -F: '{print $1}' END {if (NR == 0) print \"All interactive user passwords
are encrypted\"; else print \"There are interactive user passwords that are not encrypted\"}'|
cat"
Response : "All interactive user passwords are encrypted"
Error    : "\n/bin/cut: /etc/shadow: Permission denied"
- Command : "LANG=C; /bin/awk -F: '{print $1}' /etc/shadow | /bin/awk '{print} END
{if (NR == 0) print \"No accounts have blank or null passwords\"; else print \"Blank or null
passwords found on system\"}'|cat"
Response : "No accounts have blank or null passwords"
Error    : "\nawk: fatal: cannot open file '/etc/shadow' for reading (Permission denied)"
[...]
```

14272 - Netstat Portscanner (SSH)

Synopsis

Remote open ports can be enumerated via SSH.

Description

Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.

See the section 'plugins options' about configuring this plugin.

Note: This plugin runs on Windows using netstat.exe if the target is localhost (scanner scanning itself) or a Windows host authenticated via SSH with the ability to run netstat.exe.

See Also

<https://en.wikipedia.org/wiki/Netstat>

Solution

N/A

Risk Factor

None

Plugin Information:

Publication date: 2004/08/15, Modification date: 2025/10/29

Ports

linuxred-01 (TCP/0) Vulnerability State: Active

```

{"listening":
[{"port":22,"protocol":"TCP","interfaces":null,"all_interfaces":false,"service_name":"ssh","plugin_output":nul
{"port":5355,"protocol":"TCP","interfaces":null,"all_interfaces":false,"service_name":null,"plugin_output":nul
{"port":68,"protocol":"UDP","interfaces":null,"all_interfaces":false,"service_name":null,"plugin_output":nul}
{"port":5355,"protocol":"UDP","interfaces":null,"all_interfaces":false,"service_name":null,"plugin_output":nul
{"TCP":{"discrete":[],"ranges":[[1,21],[23,5354],[5356,65535]]},"UDP":{"discrete":[],"ranges":
[[1,67],[69,5354],[5356,65535]]},"ICMP":{"discrete":[],"ranges":[[1,65535]]},"UNKNOWN":
{"discrete":[],"ranges":[[1,65535]]}]}
```

Assets Summary (Executive)

linuxred-01					
Summary					
Critical	High	Medium	Low	Info	Total
0	0	0	0	3	3
Details					
Severity	Plugin Id	Name			
Info	102094	SSH Commands Require Privilege Escalation			
Info	19506	Nessus Scan Information			
Info	14272	Netstat Portscanner (SSH)			

Audits FAILED

RHEL-08-010020 - RHEL 8 must implement a FIPS 140-3-compliant systemwide cryptographic policy.

Info

Centralized cryptographic policies simplify applying secure ciphers across an operating system and the applications that run on that operating system. Use of weak or untested encryption algorithms undermines the purposes of using encryption to protect data.

Satisfies: SRG-OS-000033-GPOS-00014, SRG-OS-000125-GPOS-00065, SRG-OS-000396-GPOS-00176, SRG-OS-000423-GPOS-00187, SRG-OS-000478-GPOS-00223, SRG-OS-000393-GPOS-00173, SRG-OS-000394-GPOS-00174

Solution

Configure RHEL 8 to use a FIPS 140-3-compliant systemwide cryptographic policy.

Create a subpolicy for enhancements to the base systemwide crypto-policy by creating the file `/etc/crypto-policies/policies/modules/STIG.pmod` with the following content:

```
# Define ciphers and MACs for OpenSSH and libssh cipher@SSH=AES-256-GCM AES-256-CTR AES-128-GCM  
AES-128-CTR mac@SSH=HMAC-SHA2-512 HMAC-SHA2-256
```

Apply the policy enhancements to the FIPS systemwide cryptographic policy level with the following command:

```
$ sudo update-crypto-policies --set FIPS:STIG
```

Note: If additional subpolicies are being employed, they must be added to the `update-crypto-policies` command.

To make the cryptographic settings effective for already running services and applications, restart the system:

```
$ sudo reboot
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	I
CCI	CCI-000068
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.14
ISO-27001-2022	A.6.7
ISO/IEC-27001	A.6.2.2

ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230223r1155356_rule
STIG-ID	RHEL-08-010020
SWIFT-CSCV1	2.6
VULN-ID	V-230223

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - update-crypto-policies
The command '/bin/update-crypto-policies --show' returned :

DEFAULT

-----
PASSED - hash SHA2-256
Compliant file(s):
/etc/crypto-policies/state/CURRENT.pol - regex '^(?i)[\s]*hash[\s]*=[\s]*' found - expect
'^(?i)[\s]*hash[\s]*=[\s]*[^\n\r]+SHA2-256' found in the following lines:
9: hash = SHA2-256 SHA2-384 SHA2-512 SHA3-256 SHA3-384 SHA3-512 SHA2-224 SHA1

-----
PASSED - hash SHA2-384
Compliant file(s):
/etc/crypto-policies/state/CURRENT.pol - regex '^(?i)[\s]*hash[\s]*=[\s]*' found - expect
'^(?i)[\s]*hash[\s]*=[\s]*[^\n\r]+SHA2-384' found in the following lines:
9: hash = SHA2-256 SHA2-384 SHA2-512 SHA3-256 SHA3-384 SHA3-512 SHA2-224 SHA1

-----
PASSED - hash SHA2-512
Compliant file(s):
/etc/crypto-policies/state/CURRENT.pol - regex '^(?i)[\s]*hash[\s]*=[\s]*' found - expect
'^(?i)[\s]*hash[\s]*=[\s]*[^\n\r]+SHA2-512' found in the following lines:
9: hash = SHA2-256 SHA2-384 SHA2-512 SHA3-256 SHA3-384 SHA3-512 SHA2-224 SHA1

-----
PASSED - hash SHA2-224
Compliant file(s):
/etc/crypto-policies/state/CURRENT.pol - regex '^(?i)[\s]*hash[\s]*=[\s]*' found - expect
'^(?i)[\s]*hash[\s]*=[\s]*[^\n\r]+SHA2-224' found in the following lines:
9: hash = SHA2-256 SHA2-384 SHA2-512 SHA3-256 SHA3-384 SHA3-512 SHA2-224 SHA1

-----
PASSED - hash SHA3-256
Compliant file(s):
/etc/crypto-policies/state/CURRENT.pol - regex '^(?i)[\s]*hash[\s]*=[\s]*' found - expect
'^(?i)[\s]*hash[\s]*=[\s]*[^\n\r]+SHA3-256' found in the following lines:
9: hash = SHA2-256 SHA2-384 SHA2-512 SHA3-256 SHA3-384 SHA3-512 SHA2-224 SHA1
-----
```

PASSED - hash SHA3-384
Compliant file(s):
 /etc/crypto-policies/state/CURRENT.pol [...]

RHEL-08-010040 - RHEL 8 must display the Standard Mandatory DOD Notice and Consent Banner before granting local or remote access to the system via a ssh logon.

Info

Display of a standardized and approved use notification before granting access to the operating system ensures privacy and security notification verbiage used is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via logon interfaces with human users and are not required when such human interfaces do not exist.

The banner must be formatted in accordance with applicable DOD policy. Use the following verbiage for operating systems that can accommodate banners of 1300 characters:

"You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

- The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

- At any time, the USG may inspect and seize data stored on this IS.

- Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

- This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

- Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details."

Use the following verbiage for operating systems that have severe limitations on the number of characters that can be displayed in the banner:

"I've read & consent to terms in IS user agreem't."

Satisfies: SRG-OS-000023-GPOS-00006, SRG-OS-000228-GPOS-00088

Solution

Configure the operating system to display the Standard Mandatory DOD Notice and Consent Banner before granting access to the system via the ssh.

Edit the "/etc/ssh/sshd_config" file to uncomment the banner keyword and configure it to point to a file that will contain the logon banner (this file may be named differently or be in a different location if using a version of SSH that is provided by a third-party vendor). An example configuration line is:

```
banner /etc/issue
```

Either create the file containing the banner or replace the text in the file with the Standard Mandatory DOD Notice and Consent Banner. The DOD-required text is:

"You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

- The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

- At any time, the USG may inspect and seize data stored on this IS.

- Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

- This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

- Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details."

The SSH service must be restarted for changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.9
800-171R3	03.01.09
800-53	AC-8a.

800-53R5	AC-8a.
CAT	II
CCI	CCI-000048
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-8a.
NESA	M5.2.5
NESA	T5.5.1
NIAV2	AM10a
NIAV2	AM10b
NIAV2	AM10c
NIAV2	AM10d
NIAV2	AM10e
RULE-ID	SV-230225r1069297_rule
STIG-ID	RHEL-08-010040
TBA-FIISB	45.2.4
VULN-ID	V-230225

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - Ensure banner content is set correctly
First ERROR: S Kernel != You are
\S
Kernel \r on an \m

-----
FAILED - /etc/ssh/sshd_config
The command '/sbin/sshd -T | /bin/grep -i Banner' returned :

/etc/ssh/sshd_config: Permission denied
```

RHEL-08-010060 - RHEL 8 must display the Standard Mandatory DoD Notice and Consent Banner before granting local or remote access to the system via a command line user logon.

Info

Display of a standardized and approved use notification before granting access to the operating system ensures privacy and security notification verbiage used is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via logon interfaces with human users and are not required when such human interfaces do not exist.

The banner must be formatted in accordance with applicable DoD policy. Use the following verbiage for operating systems that can accommodate banners of 1300 characters:

"You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

- The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

- At any time, the USG may inspect and seize data stored on this IS.

- Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

- This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

- Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details."

Satisfies: SRG-OS-000023-GPOS-00006, SRG-OS-000228-GPOS-00088

Solution

Configure RHEL 8 to display the Standard Mandatory DoD Notice and Consent Banner before granting access to the system via command line logon.

Edit the "/etc/issue" file to replace the default text with the Standard Mandatory DoD Notice and Consent Banner. The DoD-required text is:

"You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

- The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

- At any time, the USG may inspect and seize data stored on this IS.

- Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

- This IS includes security measures (e.g., authentication and access controls) to protect USG interests -- not for your personal benefit or privacy.

- Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details."

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.9
800-171R3	03.01.09
800-53	AC-8a.
800-53R5	AC-8a.
CAT	II
CCI	CCI-000048
DISA_BENCHMARK	RHEL_8_STIG

GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-8a.
NESA	M5.2.5
NESA	T5.5.1
NIAV2	AM10a
NIAV2	AM10b
NIAV2	AM10c
NIAV2	AM10d
NIAV2	AM10e
RULE-ID	SV-230227r1017046_rule
STIG-ID	RHEL-08-010060
TBA-FIISB	45.2.4
VULN-ID	V-230227

Assets

linuxred-01

```
First ERROR: S Kernel != You are
\S
Kernel \r on an \m
```

RHEL-08-010070 - All RHEL 8 remote access methods must be monitored.

Info

Remote access services, such as those providing remote access to network devices and information systems, which lack automated monitoring capabilities, increase risk and make remote user access management difficult at best. Remote access is access to DOD nonpublic information systems by an authorized user (or an information system) communicating through an external, nonorganization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

Automated monitoring of remote access sessions allows organizations to detect cyber attacks and ensure ongoing compliance with remote access policies by auditing connection activities of remote access capabilities, such as Remote Desktop Protocol (RDP), on a variety of information system components (e.g., servers, workstations, notebook computers, smartphones, and tablets).

Solution

Configure RHEL 8 to monitor all remote access methods by installing rsyslog with the following command:

```
$ sudo yum install rsyslog
```

Then add or update the following lines to the "/etc/rsyslog.conf" file:

```
auth.*;authpriv.*;daemon.* /var/log/secure
```

The "rsyslog" service must be restarted for the changes to take effect. To restart the "rsyslog" service, run the following command:

```
$ sudo systemctl restart rsyslog.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.12
800-171R3	03.01.12
800-53	AC-17(1)
800-53R5	AC-17(1)
CAT	II
CCI	CCI-000067
CN-L3	8.1.4.4(c)
CN-L3	8.1.10.6(i)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.8.16
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(1)
NESA	T5.4.4

QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230228r1069299_rule
STIG-ID	RHEL-08-010070
SWIFT-CSCV1	2.6
VULN-ID	V-230228

RHEL-08-010130 - The RHEL 8 shadow password suite must be configured to use a sufficient number of hashing rounds.

Info

The system must use a strong hashing algorithm to store the password. The system must use a sufficient number of hashing rounds to ensure the required level of entropy.

Passwords need to be protected at all times, and encryption is the standard method for protecting passwords. If passwords are not encrypted, they can be plainly read (i.e., clear text) and easily compromised.

Solution

Configure RHEL 8 to encrypt all stored passwords with a strong cryptographic hash.

Edit/modify the following line in the "/etc/login.defs" file and set "SHA_CRYPT_MIN_ROUNDS" to a value no lower than "100000":

```
SHA_CRYPT_MIN_ROUNDS 100000
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.10
800-171R3	03.05.07c.
800-53	IA-5(1)(c)
800-53R5	IA-5(1)(d)
CAT	II
CCI	CCI-000196
CCI	CCI-004062
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(1)(c)
NESA	T5.2.3
NIAV2	CY6
QCSC-V1	5.2.2
QCSC-V1	13.2

RULE-ID	SV-230233r1044790_rule
STIG-ID	RHEL-08-010130
SWIFT-CSCV1	4.1
TBA-FIISB	26.1
VULN-ID	V-230233

Assets

linuxred-01

```
Non-compliant file(s):
/etc/login.defs - regex '^[\s]*SHA_CRYPT_(MIN|MAX)_ROUNDS' found - expect
'^[\s]*SHA_CRYPT_(MIN|MAX)_ROUNDS[\s]+[1-9][0-9]{5,}$' not found in the following lines:
97: SHA_CRYPT_MAX_ROUNDS 5000
```

RHEL-08-010140 - RHEL 8 operating systems booted with United Extensible Firmware Interface (UEFI) must require authentication upon booting into single-user mode and maintenance.

Info

If the system does not require valid authentication before it boots into single-user or maintenance mode, anyone who invokes single-user or maintenance mode is granted privileged access to all files on the system. GRUB 2 is the default boot loader for RHEL 8 and is designed to require a password to boot into single-user mode or make modifications to the boot menu.

Solution

Configure the system to require a grub bootloader password for the grub superusers account with the grub2-setpassword command, which creates/overwrites the /boot/efi/EFI/redhat/user.cfg file.

Generate an encrypted grub2 password for the grub superusers account with the following command:

```
$ sudo grub2-setpassword Enter password:
```

```
Confirm password:
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	I
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15

ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230234r1137691_rule
STIG-ID	RHEL-08-010140
TBA-FIISB	31.1
VULN-ID	V-230234

Assets

linuxred-01

No files found: /boot/efi/EFI/redhat/user.cfg

RHEL-08-010141 - RHEL 8 operating systems booted with United Extensible Firmware Interface (UEFI) must require a unique superusers name upon booting into single-user mode and maintenance.

Info

If the system does not require valid authentication before it boots into single-user or maintenance mode, anyone who invokes single-user or maintenance mode is granted privileged access to all files on the system. GRUB 2 is the default boot loader for RHEL 8 and is designed to require a password to boot into single-user mode or make modifications to the boot menu.

The GRUB 2 superuser account is an account of last resort. Establishing a unique username for this account hardens the boot loader against brute force attacks. Due to the nature of the superuser account database being distinct from the OS account database, this allows the use of a username that is not among those within the OS account database. Examples of non-unique superusers names are root, superuser, unlock, etc.

Solution

Configure the system to have a unique name for the grub superusers account.

Edit the `/etc/grub.d/01_users` file and add or modify the following lines:

```
set superusers="[someuniquestringhere]"
```

```
export superusers password_pbkdf2 [someuniquestringhere] ${GRUB2_PASSWORD}
```

Generate a new grub.cfg file with the following command:

```
$ sudo grub2-mkconfig -o /boot/efi/EFI/redhat/grub.cfg
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	II
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-244521r1137691_rule
STIG-ID	RHEL-08-010141
TBA-FIISB	31.1
VULN-ID	V-244521

Assets

linuxred-01

```
The command 'SUPERUSER=$( /bin/awk '/^\s*set superusers=/ {match($0, /"([^\"]*)"/, arr); print arr[1]} /boot/efi/EFI/redhat/grub.cfg);result="pass - superusers set to "$SUPERUSER"'; for i in $(/bin/awk -F: '{print $1}' /etc/passwd); do if [[ -z $SUPERUSER ]]; then result="fail - superusers is not set"; else if [[ $i == $SUPERUSER ]]; then result="fail - superusers set to "$SUPERUSER"'; break; fi; fi; done; echo $result' returned :
```

```
awk: fatal: cannot open file `/boot/efi/EFI/redhat/grub.cfg' for reading (Permission denied)
fail - superusers is not set
```

RHEL-08-010190 - A sticky bit must be set on all RHEL 8 public directories to prevent unauthorized and unintended information transferred via shared system resources.

Info

Preventing unauthorized information transfers mitigates the risk of information, including encrypted representations of information, produced by the actions of prior users/roles (or the actions of processes acting on behalf of prior users/roles) from being available to any current users/roles (or current processes) that obtain access to shared system resources (e.g., registers, main memory, hard disks) after those resources have been released back to information systems. The control of information in shared resources is also commonly referred to as object reuse and residual information protection.

This requirement generally applies to the design of an information technology product, but it can also apply to the configuration of particular information system components that are, or use, such products. This can be verified by acceptance/validation processes in DoD or other government agencies.

There may be shared resources with configurable protections (e.g., files in storage) that may be assessed on specific information system components.

Solution

Configure all world-writable directories to have the sticky bit set to prevent unauthorized and unintended information transferred via shared system resources.

Set the sticky bit on all world-writable directories using the command, replace "[World-Writable Directory]" with any directory path missing the sticky bit:

```
$ sudo chmod 1777 [World-Writable Directory]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.4
800-171R3	03.13.04
800-53	SC-4
800-53R5	SC-4
CAT	II
CCI	CCI-001090
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-4
ITSG-33	SC-4a.
RULE-ID	SV-230243r1137695_rule
STIG-ID	RHEL-08-010190
VULN-ID	V-230243

Assets

linuxred-01

The following 2 directories are world writeable and no sticky bit is set:

```
/tmp/.dotnet  
owner: root, group: root, permissions: 0777
```

```
/tmp/.dotnet/shm  
owner: root, group: root, permissions: 0777
```


RHEL-08-010200 - RHEL 8 must be configured so that all network connections associated with SSH traffic terminate after becoming unresponsive.

Info

Terminating an unresponsive SSH session within a short time period reduces the window of opportunity for unauthorized personnel to take control of a management session enabled on the console or console port that has been left unattended. In addition, quickly terminating an idle SSH session will also free up resources committed by the managed network element.

Terminating network connections associated with communications sessions includes, for example, deallocating associated TCP/IP address/port pairs at the operating system level and deallocating networking assignments at the application level if multiple application sessions are using a single operating system-level network connection. This does not mean the operating system terminates all sessions or network access; it only ends the unresponsive session and releases the resources associated with that session.

RHEL 8 uses `/etc/ssh/sshd_config` for configurations of OpenSSH. Within the `sshd_config`, the product of the values of "ClientAliveInterval" and "ClientAliveCountMax" is used to establish the inactivity threshold. The "ClientAliveInterval" is a timeout interval in seconds after which if no data has been received from the client, `sshd` will send a message through the encrypted channel to request a response from the client. The "ClientAliveCountMax" is the number of client alive messages that may be sent without `sshd` receiving any messages back from the client. If this threshold is met, `sshd` will disconnect the client. For more information on these settings and others, refer to the `sshd_config` man pages.

Satisfies: SRG-OS-000163-GPOS-00072, SRG-OS-000126-GPOS-00066, SRG-OS-000279-GPOS-00109

Solution

Note: This setting must be applied in conjunction with RHEL-08-010201 to function correctly.

Configure the SSH server to terminate a user session automatically after the SSH client has become unresponsive.

Modify or append the following lines in the `/etc/ssh/sshd_config` file:

```
ClientAliveCountMax 1
```

For the changes to take effect, the SSH daemon must be restarted:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.9
800-171R3	03.13.09
800-53	SC-10
800-53R5	SC-10
CAT	II
CCI	CCI-001133
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.20
ITSG-33	SC-10
ITSG-33	SC-10a.
NESA	T2.3.8
NESA	T4.5.1
NESA	T5.5.1

RULE-ID	SV-230244r1069300_rule
STIG-ID	RHEL-08-010200
SWIFT-CSCV1	2.6
VULN-ID	V-230244

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i ClientAliveCountMax' returned :
/etc/ssh/sshd_config: Permission denied

RHEL-08-010201 - RHEL 8 must be configured so that all network connections associated with SSH traffic are terminated after 10 minutes of becoming unresponsive.

Info

Terminating an unresponsive SSH session within a short time period reduces the window of opportunity for unauthorized personnel to take control of a management session enabled on the console or console port that has been left unattended. In addition, quickly terminating an idle SSH session will also free up resources committed by the managed network element.

Terminating network connections associated with communications sessions includes, for example, deallocating associated TCP/IP address/port pairs at the operating system level and deallocating networking assignments at the application level if multiple application sessions are using a single operating system-level network connection. This does not mean that the operating system terminates all sessions or network access; it only ends the unresponsive session and releases the resources associated with that session.

RHEL 8 uses `/etc/ssh/sshd_config` for configurations of OpenSSH. Within the `sshd_config`, the product of the values of "ClientAliveInterval" and "ClientAliveCountMax" is used to establish the inactivity threshold. The "ClientAliveInterval" is a timeout interval in seconds after which if no data has been received from the client, `sshd` will send a message through the encrypted channel to request a response from the client. The "ClientAliveCountMax" is the number of client alive messages that may be sent without `sshd` receiving any messages back from the client. If this threshold is met, `sshd` will disconnect the client. For more information on these settings and others, refer to the `sshd_config` man pages.

Satisfies: SRG-OS-000163-GPOS-00072, SRG-OS-000126-GPOS-00066, SRG-OS-000279-GPOS-00109

Solution

Note: This setting must be applied in conjunction with RHEL-08-010200 to function correctly.

Configure the SSH server to terminate a user session automatically after the SSH client has been unresponsive for 10 minutes.

Modify or append the following lines in the `/etc/ssh/sshd_config` file:

```
ClientAliveInterval 600
```

For the changes to take effect, the SSH daemon must be restarted.

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.9
800-171R3	03.13.09
800-53	SC-10
800-53R5	SC-10
CAT	II
CCI	CCI-001133
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.20
ITSG-33	SC-10
ITSG-33	SC-10a.
NESA	T2.3.8
NESA	T4.5.1

NESA	T5.5.1
RULE-ID	SV-244525r1017331_rule
STIG-ID	RHEL-08-010201
SWIFT-CSCV1	2.6
VULN-ID	V-244525

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i ClientAliveInterval' returned :
/etc/ssh/sshd_config: Permission denied

RHEL-08-010290 - The RHEL 8 SSH server must be configured to use only Message Authentication Codes (MACs) employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH server connections.

Info

Without cryptographic integrity protections, information can be altered by unauthorized users without detection. Remote access (e.g., RDP) is access to DOD nonpublic information systems by an authorized user (or an information system) communicating through an external, nonorganization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

Cryptographic mechanisms used for protecting the integrity of information include, for example, signed hash functions using asymmetric cryptography enabling distribution of the public key to verify the hash information while maintaining the confidentiality of the secret key used to generate the hash.

RHEL 8 incorporates systemwide crypto policies by default. The SSH configuration file has no effect on the ciphers, MACs, or algorithms unless specifically defined in the `/etc/sysconfig/sshd` file. The employed algorithms can be viewed in the `/etc/crypto-policies/back-ends/opensshserver.config` file.

Satisfies: SRG-OS-000250-GPOS-00093, SRG-OS-000393-GPOS-00173, SRG-OS-000394-GPOS-00174, SRG-OS-000125-GPOS-00065

Solution

Configure the RHEL 8 SSH server to use only MACs employing FIPS 140-3-approved algorithms.

Reinstall crypto-policies with the following command:

```
$ sudo dnf -y reinstall crypto-policies
```

Set the crypto-policy to FIPS with the following command:

```
$ sudo update-crypto-policies --set FIPS
```

Setting system policy to FIPS

Note: Systemwide crypto policies are applied on application startup. It is recommended to restart the system for the change of policies to fully take place.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	II
CCI	CCI-001453
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)

ISO-27001-2022	A.5.14
ISO-27001-2022	A.6.7
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230251r1155370_rule
STIG-ID	RHEL-08-010290
SWIFT-CSCV1	2.6
VULN-ID	V-230251

Assets

linuxred-01

```
Non-compliant file(s):
/etc/crypto-policies/back-ends/opensshserver.config - regex '^(?i)[^#\n\r]*-oMACs' found
- expect '^(?i)[^#\n\r]*-oMACs[\s]*=[\s]*hmac-sha2-512-etm@openssh.com,[\s]*hmac-sha2-256-etm@openssh.com,[\s]*hmac-sha2-512,[\s]*hmac-sha2-256\b' not found in the following lines:
1: CRYPTO_POLICY='-oCiphers=aes256-gcm@openssh.com,chacha20-poly1305@openssh.com,aes256-ctr,aes256-cbc,aes128-gcm@openssh.com,aes128-ctr,aes128-cbc -oMACs=hmac-sha2-256-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha1,umac-128@openssh.com,hmac-sha2-512 -oGSSAPIKexAlgorithms=gss-curve25519-sha256-,gss-nistp256-sha256-,gss-group14-sha256-,gss-group16-sha512-,gss-gex-sha1-,gss-group14-sha1- -oKexAlgorithms=curve25519-sha256,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group14-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1 -oHostKeyAlgorithms=ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519,ssh-ed25519-cert-v01@openssh.com,rsa-sha2-256,rsa-sha2-256-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-512-cert-v01@openssh.com,ssh-rsa,ssh-rsa-cert-v01@openssh.com -oPubkeyAcceptedKeyTypes=ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519,ssh-ed25519-cert-v01@openssh.com,rsa-sha2-256,rsa-sha2-256-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-512-cert-v01@openssh.com,ssh-rsa,ssh-rsa-cert-v01@openssh.com -oCASignatureAlgorithms=ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,ssh-ed25519,rsa-sha2-256,rsa-sha2-512,ssh-rsa'
```

RHEL-08-010291 - The RHEL 8 SSH server must be configured to use only DOD-approved encryption ciphers employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH server connections.

Info

Without cryptographic integrity protections, information can be altered by unauthorized users without detection. Remote access (e.g., RDP) is access to DOD nonpublic information systems by an authorized user (or an information system) communicating through an external, nonorganization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

Cryptographic mechanisms used for protecting the integrity of information include, for example, signed hash functions using asymmetric cryptography enabling distribution of the public key to verify the hash information while maintaining the confidentiality of the secret key used to generate the hash.

RHEL 8 incorporates systemwide crypto policies by default. The SSH configuration file has no effect on the ciphers, MACs, or algorithms unless specifically defined in the `/etc/sysconfig/sshd` file. The employed algorithms can be viewed in the `/etc/crypto-policies/back-ends/opensshserver.config` file.

Satisfies: SRG-OS-000250-GPOS-00093, SRG-OS-000393-GPOS-00173, SRG-OS-000394-GPOS-00174, SRG-OS-000125-GPOS-00065

Solution

Configure the RHEL 8 SSH server to use only ciphers employing FIPS 140-3-approved algorithms.

Reinstall crypto-policies with the following command:

```
$ sudo dnf -y reinstall crypto-policies
```

Set the crypto-policy to FIPS with the following command:

```
$ sudo update-crypto-policies --set FIPS
```

Setting system policy to FIPS

Note: Systemwide crypto policies are applied on application startup. It is recommended to restart the system for the change of policies to fully take place.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	II
CCI	CCI-001453
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)

ISO-27001-2022	A.5.14
ISO-27001-2022	A.6.7
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230252r1155364_rule
STIG-ID	RHEL-08-010291
SWIFT-CSCV1	2.6
VULN-ID	V-230252

Assets

linuxred-01

Non-compliant file(s):

```
/etc/crypto-policies/back-ends/opensshserver.config - regex '^(?i)[^#\n\r]*-oCiphers' found
- expect '^(?i)[^#\n\r]*-oCiphers[\s]*=[\s]*aes256-gcm@openssh.com,[\s]*aes256-ctr,[\s]*aes128-gcm@openssh.com,[\s]*aes128-ctr\b' not found in the following lines:
```

```
1: CRYPTO_POLICY='-oCiphers=aes256-gcm@openssh.com,chacha20-poly1305@openssh.com,aes256-ctr,aes256-cbc,aes128-gcm@openssh.com,aes128-ctr,aes128-cbc -oMACs=hmac-sha2-256-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha1,umac-128@openssh.com,hmac-sha2-512 -oGSSAPIKexAlgorithms=gss-curve25519-sha256-,gss-nistp256-sha256-,gss-group14-sha256-,gss-group16-sha512-,gss-gex-sha1-,gss-group14-sha1- -oKexAlgorithms=curve25519-sha256,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group14-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1 -oHostKeyAlgorithms=ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519,ssh-ed25519-cert-v01@openssh.com,rsa-sha2-256,rsa-sha2-256-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-512-cert-v01@openssh.com,ssh-rsa,ssh-rsa-cert-v01@openssh.com -oPubkeyAcceptedKeyTypes=ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519,ssh-ed25519-cert-v01@openssh.com,rsa-sha2-256,rsa-sha2-256-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-512-cert-v01@openssh.com,ssh-rsa,ssh-rsa-cert-v01@openssh.com -oCASignatureAlgorithms=ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,ssh-ed25519,rsa-sha2-256,rsa-sha2-512,ssh-rsa'
```


RHEL-08-010296 - The RHEL 8 SSH client must be configured to use only DOD-approved Message Authentication Codes (MACs) employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH client connections.

Info

Without cryptographic integrity protections, information can be altered by unauthorized users without detection. Remote access (e.g., RDP) is access to DOD nonpublic information systems by an authorized user (or an information system) communicating through an external, nonorganization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

Cryptographic mechanisms used for protecting the integrity of information include, for example, signed hash functions using asymmetric cryptography, enabling distribution of the public key to verify the hash information while maintaining the confidentiality of the secret key used to generate the hash.

RHEL 8 incorporates systemwide crypto policies by default. The SSH configuration file has no effect on the ciphers, MACs, or algorithms unless specifically defined in the `/etc/sysconfig/sshd` file. The employed algorithms can be viewed in the `/etc/crypto-policies/back-ends/openssh.config` file.

Solution

Configure the RHEL 8 SSH client to use only MACs employing FIPS 140-3-approved algorithms.

Reinstall crypto-policies with the following command:

```
$ sudo dnf -y reinstall crypto-policies
```

Set the crypto-policy to FIPS with the following command:

```
$ sudo update-crypto-policies --set FIPS
```

Setting system policy to FIPS

Note: Systemwide crypto policies are applied on application startup. It is recommended to restart the system for the change of policies to fully take place.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	II
CCI	CCI-001453
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.14

ISO-27001-2022	A.6.7
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-272482r1155367_rule
STIG-ID	RHEL-08-010296
SWIFT-CSCV1	2.6
VULN-ID	V-272482

Assets

linuxred-01

Non-compliant file(s):
 /etc/crypto-policies/back-ends/openssh.config - regex '(?i)^\s*MACs\s+' found - expect
 '(?i)^\s*MACs\s+\"?hmac-sha2-512-etm@openssh.com, [\s]*hmac-sha2-256-etm@openssh.com, [\s]*hmac-
 sha2-512, [\s]*hmac-sha2-256\"?\s*\$' not found in the following lines:
 2: MACs hmac-sha2-256-etm@openssh.com, hmac-sha1-etm@openssh.com, umac-128-
 etm@openssh.com, hmac-sha2-512-etm@openssh.com, hmac-sha2-256, hmac-sha1, umac-128@openssh.com, hmac-
 sha2-512

RHEL-08-010297 - The RHEL 8 SSH client must be configured to use only DOD-approved encryption ciphers employing FIPS 140-3-validated cryptographic hash algorithms to protect the confidentiality of SSH client connections.

Info

Without cryptographic integrity protections, information can be altered by unauthorized users without detection. Remote access (e.g., RDP) is access to DOD nonpublic information systems by an authorized user (or an information system) communicating through an external, nonorganization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

Cryptographic mechanisms used for protecting the integrity of information include, for example, signed hash functions using asymmetric cryptography, enabling distribution of the public key to verify the hash information while maintaining the confidentiality of the secret key used to generate the hash.

RHEL 8 incorporates systemwide crypto policies by default. The SSH configuration file has no effect on the ciphers, MACs, or algorithms unless specifically defined in the `/etc/sysconfig/sshd` file. The employed algorithms can be viewed in the `/etc/crypto-policies/back-ends/openssh.config` file.

Satisfies: SRG-OS-000250-GPOS-00093, SRG-OS-000393-GPOS-00173, SRG-OS-000394-GPOS-00174, SRG-OS-000125-GPOS-00066

Solution

Configure the RHEL 8 SSH client to use only ciphers employing FIPS 140-3-approved algorithms.

Reinstall crypto-policies with the following command:

```
$ sudo dnf -y reinstall crypto-policies
```

Set the crypto-policy to FIPS with the following command:

```
$ sudo update-crypto-policies --set FIPS
```

Setting system policy to FIPS

Note: Systemwide crypto policies are applied on application startup. It is recommended to restart the system for the change of policies to fully take place.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	II
CCI	CCI-001453
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)

ISO-27001-2022	A.5.14
ISO-27001-2022	A.6.7
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-272483r1155361_rule
STIG-ID	RHEL-08-010297
SWIFT-CSCV1	2.6
VULN-ID	V-272483

Assets

linuxred-01

Non-compliant file(s):
 /etc/crypto-policies/back-ends/openssh.config - regex '(?i)^\s*Ciphers\s+' found
 - expect '(?i)^\s*Ciphers\s+"aes256-gcm@openssh.com,\s*aes256-ctr,\s*aes128-gcm@openssh.com,\s*aes128-ctr"?[^\s]*\$' not found in the following lines:
 1: Ciphers aes256-gcm@openssh.com,chacha20-poly1305@openssh.com,aes256-ctr,aes256-cbc,aes128-gcm@openssh.com,aes128-ctr,aes128-cbc

RHEL-08-010358 - RHEL 8 must be configured to allow sending email notifications of unauthorized configuration changes to designated personnel.

Info

Unauthorized changes to the baseline configuration could make the system vulnerable to various attacks or allow unauthorized access to the operating system. Changes to operating system configurations can have unintended side effects, some of which may be relevant to security.

Detecting such changes and providing an automated response can help avoid unintended, negative consequences that could ultimately affect the security state of the operating system. The operating system's IMO/ISSO and SAs must be notified via email and/or monitoring system trap when there is an unauthorized modification of a configuration item.

Solution

Install the "mailx" package on the system:

```
$ sudo yum install mailx
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.3
800-171R3	03.04.03
800-53	CM-3(5)
800-53R5	CM-3(5)
CAT	II
CCI	CCI-001744
CN-L3	8.1.10.6(g)
CSF	DE.CM-1
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.IP-3
CSF2.0	DE.CM-01
CSF2.0	DE.CM-09
CSF2.0	ID.RA-07
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
GDPR	32.4
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.32
ISO-27001-2022	8.1

ISO-27001-2022	9.3.3
ISO/IEC-27001	A.12.1.2
ITSG-33	CM-3
NESA	T3.2.3
NESA	T3.3.2
NESA	T7.5.1
NESA	T7.6.1
NESA	T7.6.2
NESA	T7.6.3
NIAV2	CM1
NIAV2	CM1a
NIAV2	CM1b
NIAV2	CM1c
PCI-DSSV3.2.1	11.5
PCI-DSSV4.0	11.5.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	6.2
QCSC-V1	7.2
QCSC-V1	8.2.1
RULE-ID	SV-256974r1069321_rule
STIG-ID	RHEL-08-010358
VULN-ID	V-256974

Assets

linuxred-01

One of the following must pass to satisfy this requirement:

```
-----
FAILED - mailx installed
The package 'mailx-0.0.0-0' is not installed

-----
FAILED - s-nail installed
The package 's-nail-0.0.0-0' is not installed
```

RHEL-08-010359 - The RHEL 8 operating system must use a file integrity tool to verify correct operation of all security functions.

Info

Without verification of the security functions, security functions may not operate correctly, and the failure may go unnoticed. Security function is defined as the hardware, software, and/or firmware of the information system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based. Security functionality includes, but is not limited to, establishing system accounts, configuring access authorizations (i.e., permissions, privileges), setting events to be audited, and setting intrusion detection parameters.

This requirement applies to the RHEL 8 operating system performing security function verification/testing and/or systems and environments that require this functionality.

Solution

Install AIDE, initialize it, and perform a manual check.

Install AIDE:

```
$ sudo yum install aide
```

Initialize it:

```
$ sudo /usr/sbin/aide --init
```

Example output:

```
Number of entries: 48623
```

```
----- The attributes of the (uncompressed) database(s):
```

```
/var/lib/aide/aide.db.new.gz SHA1 : LTAVQ8tFJthsr4m9gfRpnf1vyc= SHA256 :  
NJ9+uzRQKSwmLQ8A6lpKNvYjVKGbhSjt BeJBVcmOVrl= SHA512 : 7d8l/F6A1b07E4ZuGeilZjefRgJJ/F20  
eC2xoag1OsOVpctt3Mi7Jjff3vFW4xoY 5mdS6/lmQpm0xtlTLOPeQQ==
```

```
End timestamp: 2022-10-20 10:50:52 -0700 (run time: 0m 46s)
```

The new database will need to be renamed to be read by AIDE:

```
$ sudo mv /var/lib/aide/aide.db.new.gz /var/lib/aide/aide.db.gz
```

Perform a manual check:

```
$ sudo /usr/sbin/aide --check
```

Example output:

```
Start timestamp: 2022-10-20 11:03:16 -0700 (AIDE 0.16) AIDE found differences between database and  
filesystem!! ...
```

```
Done.
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-6a.
800-53R5	SI-6a.
CAT	II
CCI	CCI-002696
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-6a.
RULE-ID	SV-251710r958944_rule
STIG-ID	RHEL-08-010359
VULN-ID	V-251710

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - aide

The package 'aide-0.0.0-0' is not installed

FAILED - initialized

No files found: /var/lib/aide/aide.db.gz

RHEL-08-010360 - The RHEL 8 file integrity tool must notify the system administrator when changes to the baseline configuration or anomalies in the operation of any security functions are discovered within an organizationally defined frequency.

Info

Unauthorized changes to the baseline configuration could make the system vulnerable to various attacks or allow unauthorized access to the operating system. Changes to operating system configurations can have unintended side effects, some of which may be relevant to security.

Detecting such changes and providing an automated response can help avoid unintended, negative consequences that could ultimately affect the security state of the operating system. The operating system's Information System Security Manager (ISSM)/Information System Security Officer (ISSO) and System Administrators (SAs) must be notified via email and/or monitoring system trap when there is an unauthorized modification of a configuration item. Notifications provided by information systems include messages to local computer consoles, and/or hardware indications, such as lights.

This capability must take into account operational requirements for availability for selecting an appropriate response. The organization may choose to shut down or restart the information system upon security function anomaly detection.

RHEL 8 comes with many optional software packages. A file integrity tool called Advanced Intrusion Detection Environment (AIDE) is one of those optional packages. This requirement assumes the use of AIDE; however, a different tool may be used if the requirements are met. Note that AIDE does not have a configuration that will send a notification, so a cron job is recommended that uses the mail application on the system to email the results of the file integrity check.

Satisfies: SRG-OS-000363-GPOS-00150, SRG-OS-000446-GPOS-00200, SRG-OS-000447-GPOS-00201

Solution

Configure the file integrity tool to run automatically on the system at least weekly and to notify designated personnel if baseline configurations are changed in an unauthorized manner. The AIDE tool can be configured to email designated personnel with the use of the cron system.

The following example output is generic. It will set cron to run AIDE daily and to send email at the completion of the analysis.

```
$ sudo more /etc/cron.daily/aide
```

```
#!/bin/bash
```

```
/usr/sbin/aide --check | /bin/mail -s "$HOSTNAME - Daily AIDE integrity check run" root@example_server_name.mil
```

Note: Per requirement RHEL-08-010358, the "mailx" package must be installed on the system to enable email functionality.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.3
800-171R3	03.04.03
800-53	CM-3(5)
800-53R5	CM-3(5)
CAT	II
CCI	CCI-001744
CN-L3	8.1.10.6(g)
CSF	DE.CM-1
CSF	DE.CM-7
CSF	PR.IP-1
CSF	PR.IP-3
CSF2.0	DE.CM-01

CSF2.0	DE.CM-09
CSF2.0	ID.RA-07
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
GDPR	32.4
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.32
ISO-27001-2022	8.1
ISO-27001-2022	9.3.3
ISO/IEC-27001	A.12.1.2
ITSG-33	CM-3
NESA	T3.2.3
NESA	T3.3.2
NESA	T7.5.1
NESA	T7.6.1
NESA	T7.6.2
NESA	T7.6.3
NIAV2	CM1
NIAV2	CM1a
NIAV2	CM1b
NIAV2	CM1c
PCI-DSSV3.2.1	11.5
PCI-DSSV4.0	11.5.2
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	6.2
QCSC-V1	7.2
QCSC-V1	8.2.1
RULE-ID	SV-230263r1017083_rule

STIG-ID

RHEL-08-010360

VULN-ID

V-230263

Assets

linuxred-01

One of the following must pass to satisfy this requirement:

```
-----  
FAILED - ls -la /etc/cron.* | grep aide  
The command '/bin/ls -la /etc/cron.* | /bin/grep aide' did not return any result
```

```
-----  
FAILED - aide /etc/crontab /var/spool/cron/root  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - /usr/sbin/aide --check  
No files found: /etc/cron.daily/aide
```

RHEL-08-010371 - RHEL 8 must prevent the installation of software, patches, service packs, device drivers, or operating system components of local packages without verification they have been digitally signed using a certificate that is issued by a Certificate Authority (CA) that is recognized and approved by the organization.

Info

Changes to any software components can have significant effects on the overall security of the operating system. This requirement ensures the software has not been tampered with and that it has been provided by a trusted vendor. Accordingly, patches, service packs, device drivers, or operating system components must be signed with a certificate recognized and approved by the organization. Verifying the authenticity of the software prior to installation validates the integrity of the patch or upgrade received from a vendor. This verifies the software has not been tampered with and that it has been provided by a trusted vendor. Self-signed certificates are disallowed by this requirement. The operating system should not have to verify the software again. This requirement does not mandate DoD certificates for this purpose; however, the certificate used to verify the software must be from an approved CA.

Solution

Configure the operating system to remove all software components after updated versions have been installed. Set the "localpkg_gpgcheck" option to "True" in the "/etc/dnf/dnf.conf" file:
localpkg_gpgcheck=True

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(3)
800-53R5	CM-14
CAT	I
CCI	CCI-001749
CCI	CCI-003992
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(3)

NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230265r1017378_rule
STIG-ID	RHEL-08-010371
VULN-ID	V-230265

Assets

linuxred-01

The following file(s) do not contain "(?i)^\[s]*localpkg_gpgcheck\[s]*=":
 /etc/dnf/dnf.conf

RHEL-08-010372 - RHEL 8 must prevent the loading of a new kernel for later execution.

Info

Changes to any software components can have significant effects on the overall security of the operating system. This requirement ensures the software has not been tampered with and that it has been provided by a trusted vendor. Disabling kexec_load prevents an unsigned kernel image (that could be a windows kernel or modified vulnerable kernel) from being loaded. Kexec can be used subvert the entire secureboot process and should be avoided at all costs especially since it can load unsigned kernel images.

The systemctl --system command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf

Solution

Configure the operating system to disable kernel image loading.

Add or edit the following line in a system configuration file, in the "/etc/sysctl.d/" directory:

kernel.kexec_load_disabled = 1

Remove any configurations that conflict with the above from the following locations:

/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf

Load settings from all system configuration files with the following command:

\$ sudo systemctl --system

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(3)
800-53R5	CM-14
CAT	II
CCI	CCI-001749
CCI	CCI-003992
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31

ISO-27001-2022	A.8.32
ITSG-33	CM-5(3)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230266r1017084_rule
STIG-ID	RHEL-08-010372
VULN-ID	V-230266

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - sysctl
The command '/sbin/sysctl kernel.kexec_load_disabled' returned :

kernel.kexec_load_disabled = 0

-----
FAILED - systemd-sysctl
No matching files were found
Less than 1 matches of regex found
```

RHEL-08-010373 - RHEL 8 must enable kernel parameters to enforce discretionary access control on symlinks.

Info

Discretionary Access Control (DAC) is based on the notion that individual users are "owners" of objects and therefore have discretion over who should be authorized to access the object and in which mode (e.g., read or write). Ownership is usually acquired as a consequence of creating the object or via specified ownership assignment. DAC allows the owner to determine who will have access to objects they control. An example of DAC includes user-controlled file permissions.

When discretionary access control policies are implemented, subjects are not constrained with regard to what actions they can take with information for which they have already been granted access. Thus, subjects that have been granted access to information are not prevented from passing (i.e., the subjects have the discretion to pass) the information to other subjects or objects. A subject that is constrained in its operation by Mandatory Access Control policies is still able to operate under the less rigorous constraints of this requirement. Thus, while Mandatory Access Control imposes constraints preventing a subject from passing information to another subject operating at a different sensitivity level, this requirement permits the subject to pass the information to any subject at the same sensitivity level. The policy is bounded by the information system boundary. Once the information is passed outside the control of the information system, additional means may be required to ensure the constraints remain in effect. While the older, more traditional definitions of discretionary access control require identity-based access control, that limitation is not required for this use of discretionary access control.

By enabling the `fs.protected_symlinks` kernel parameter, symbolic links are permitted to be followed only when outside a sticky world-writable directory, or when the UID of the link and follower match, or when the directory owner matches the symlink's owner. Disallowing such symlinks helps mitigate vulnerabilities based on insecure file system accessed by privileged programs, avoiding an exploitation vector exploiting unsafe use of `open()` or `creat()`.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Satisfies: SRG-OS-000312-GPOS-00122, SRG-OS-000312-GPOS-00123, SRG-OS-000312-GPOS-00124, SRG-OS-000324-GPOS-00125

Solution

Configure the operating system to enable DAC on symlinks.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
fs.protected_symlinks = 1
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3(4)
800-53R5	AC-3(4)
CAT	II
CCI	CCI-002165
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)

CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3(4)
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2

QCSC-V1	13.2
RULE-ID	SV-230267r1017085_rule
STIG-ID	RHEL-08-010373
TBA-FIISB	31.1
VULN-ID	V-230267

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
PASSED - systemd-sysctl
Compliant file(s):
/etc/sysctl.conf - regex not found
/etc/sysctl.d/99-sysctl.conf - regex not found
/lib/sysctl.d/10-default-yama-scope.conf - regex not found
/lib/sysctl.d/50-coredump.conf - regex not found
/lib/sysctl.d/50-default.conf - regex '(?i)^\s*fs\.protected_symlinks[\s]*=' found -
expect '(?i)^\s*fs\.protected_symlinks[\s]*=[\s]*1[\s]*$' found in the following lines:
    49: fs.protected_symlinks = 1
/lib/sysctl.d/50-libkcap-optmem_max.conf - regex not found
/lib/sysctl.d/50-pid-max.conf - regex not found
/usr/lib/sysctl.d/10-default-yama-scope.conf - regex not found
/usr/lib/sysctl.d/50-coredump.conf - regex not found
/usr/lib/sysctl.d/50-default.conf - regex '(?i)^\s*fs\.protected_symlinks[\s]*=' found -
expect '(?i)^\s*fs\.protected_symlinks[\s]*=[\s]*1[\s]*$' found in the following lines:
    49: fs.protected_symlinks = 1
/usr/lib/sysctl.d/50-libkcap-optmem_max.conf - regex not found
/usr/lib/sysctl.d/50-pid-max.conf - regex not found

-----
FAILED - sysctl
The command '/sbin/sysctl fs.protected_symlinks' returned :

sysctl: permission denied on key 'fs.protected_symlinks'
```

RHEL-08-010374 - RHEL 8 must enable kernel parameters to enforce discretionary access control on hardlinks.

Info

Discretionary Access Control (DAC) is based on the notion that individual users are "owners" of objects and therefore have discretion over who should be authorized to access the object and in which mode (e.g., read or write). Ownership is usually acquired as a consequence of creating the object or via specified ownership assignment. DAC allows the owner to determine who will have access to objects they control. An example of DAC includes user-controlled file permissions.

When discretionary access control policies are implemented, subjects are not constrained with regard to what actions they can take with information for which they have already been granted access. Thus, subjects that have been granted access to information are not prevented from passing (i.e., the subjects have the discretion to pass) the information to other subjects or objects. A subject that is constrained in its operation by Mandatory Access Control policies is still able to operate under the less rigorous constraints of this requirement. Thus, while Mandatory Access Control imposes constraints preventing a subject from passing information to another subject operating at a different sensitivity level, this requirement permits the subject to pass the information to any subject at the same sensitivity level. The policy is bounded by the information system boundary. Once the information is passed outside the control of the information system, additional means may be required to ensure the constraints remain in effect. While the older, more traditional definitions of discretionary access control require identity-based access control, that limitation is not required for this use of discretionary access control.

By enabling the `fs.protected_hardlinks` kernel parameter, users can no longer create soft or hard links to files they do not own. Disallowing such hardlinks mitigate vulnerabilities based on insecure file system accessed by privileged programs, avoiding an exploitation vector exploiting unsafe use of `open()` or `creat()`.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Satisfies: SRG-OS-000312-GPOS-00122, SRG-OS-000312-GPOS-00123, SRG-OS-000312-GPOS-00124, SRG-OS-000324-GPOS-00125

Solution

Configure the operating system to enable DAC on hardlinks.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
fs.protected_hardlinks = 1
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3(4)
800-53R5	AC-3(4)
CAT	II
CCI	CCI-002165
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)

CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3(4)
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2

RULE-ID	SV-230268r1017086_rule
STIG-ID	RHEL-08-010374
TBA-FIISB	31.1
VULN-ID	V-230268

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - systemd-sysctl

Compliant file(s):

```

/etc/sysctl.conf - regex not found
/etc/sysctl.d/99-sysctl.conf - regex not found
/lib/sysctl.d/10-default-yama-scope.conf - regex not found
/lib/sysctl.d/50-coreldump.conf - regex not found
/lib/sysctl.d/50-default.conf - regex '(?i)^\[s\]*fs\.protected_hardlinks\[s\]*=' found -
expect '(?i)^\[s\]*fs\.protected_hardlinks\[s\]*=\[s\]*1\[s\]*$' found in the following lines:
    48: fs.protected_hardlinks = 1
/lib/sysctl.d/50-libkcapl-optmem_max.conf - regex not found
/lib/sysctl.d/50-pid-max.conf - regex not found
/usr/lib/sysctl.d/10-default-yama-scope.conf - regex not found
/usr/lib/sysctl.d/50-coreldump.conf - regex not found
/usr/lib/sysctl.d/50-default.conf - regex '(?i)^\[s\]*fs\.protected_hardlinks\[s\]*=' found -
expect '(?i)^\[s\]*fs\.protected_hardlinks\[s\]*=\[s\]*1\[s\]*$' found in the following lines:
    48: fs.protected_hardlinks = 1
/usr/lib/sysctl.d/50-libkcapl-optmem_max.conf - regex not found
/usr/lib/sysctl.d/50-pid-max.conf - regex not found

```

FAILED - sysctl

The command '/sbin/sysctl fs.protected_hardlinks' returned :

sysctl: permission denied on key 'fs.protected_hardlinks'

RHEL-08-010375 - RHEL 8 must restrict access to the kernel message buffer.

Info

Preventing unauthorized information transfers mitigates the risk of information, including encrypted representations of information, produced by the actions of prior users/roles (or the actions of processes acting on behalf of prior users/roles) from being available to any current users/roles (or current processes) that obtain access to shared system resources (e.g., registers, main memory, hard disks) after those resources have been released back to information systems. The control of information in shared resources is also commonly referred to as object reuse and residual information protection.

This requirement generally applies to the design of an information technology product, but it can also apply to the configuration of particular information system components that are, or use, such products. This can be verified by acceptance/validation processes in DoD or other government agencies.

There may be shared resources with configurable protections (e.g., files in storage) that may be assessed on specific information system components.

Restricting access to the kernel message buffer limits access to only root. This prevents attackers from gaining additional system information as a non-privileged user.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure the operating system to restrict access to the kernel message buffer.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`kernel.dmesg_restrict = 1`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.4
800-171R3	03.13.04
800-53	SC-4
800-53R5	SC-4
CAT	III
CCI	CCI-001090
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

ITSG-33	SC-4
ITSG-33	SC-4a.
RULE-ID	SV-230269r1137695_rule
STIG-ID	RHEL-08-010375
VULN-ID	V-230269

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - systemd-sysctl
No matching files were found
Less than 1 matches of regex found
```

```
-----
FAILED - sysctl
The command '/sbin/sysctl kernel.dmesg_restrict' returned :

kernel.dmesg_restrict = 0
```

RHEL-08-010376 - RHEL 8 must prevent kernel profiling by unprivileged users.

Info

Preventing unauthorized information transfers mitigates the risk of information, including encrypted representations of information, produced by the actions of prior users/roles (or the actions of processes acting on behalf of prior users/roles) from being available to any current users/roles (or current processes) that obtain access to shared system resources (e.g., registers, main memory, hard disks) after those resources have been released back to information systems. The control of information in shared resources is also commonly referred to as object reuse and residual information protection.

This requirement generally applies to the design of an information technology product, but it can also apply to the configuration of particular information system components that are, or use, such products. This can be verified by acceptance/validation processes in DoD or other government agencies.

There may be shared resources with configurable protections (e.g., files in storage) that may be assessed on specific information system components.

Setting the kernel.perf_event_paranoid kernel parameter to "2" prevents attackers from gaining additional system information as a non-privileged user.

The sysctl --system command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf

Solution

Configure the operating system to prevent kernel profiling by unprivileged users.

Add or edit the following line in a system configuration file, in the "/etc/sysctl.d/" directory:

kernel.perf_event_paranoid = 2

Remove any configurations that conflict with the above from the following locations:

/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf

Load settings from all system configuration files with the following command:

\$ sudo sysctl --system

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.4
800-171R3	03.13.04
800-53	SC-4
800-53R5	SC-4
CAT	III
CCI	CCI-001090
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

ITSG-33	SC-4
ITSG-33	SC-4a.
RULE-ID	SV-230270r1137695_rule
STIG-ID	RHEL-08-010376
VULN-ID	V-230270

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - systemd-sysctl
No matching files were found
Less than 1 matches of regex found
```

```
-----
PASSED - sysctl
The command '/sbin/sysctl kernel.perf_event_paranoid' returned :

kernel.perf_event_paranoid = 2
```

RHEL-08-010383 - RHEL 8 must use the invoking user's password for privilege escalation when using "sudo".

Info

The sudoers security policy requires that users authenticate themselves before they can use sudo. When sudoers requires authentication, it validates the invoking user's credentials. If the rootpw, targetpw, or runaspw flags are defined and not disabled, by default the operating system will prompt the invoking user for the "root" user password. For more information on each of the listed configurations, reference the sudoers(5) manual page.

Solution

Define the following in the Defaults section of the /etc/sudoers file or a configuration file in the /etc/sudoers.d/ directory:

Defaults !targetpw Defaults !rootpw Defaults !runaspw

Remove any configurations that conflict with the above from the following locations:

/etc/sudoers /etc/sudoers.d/

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.5
800-171R3	03.01.06a.
800-53	AC-6(5)
800-53R5	AC-6(5)
CAT	II
CCI	CCI-002227
CN-L3	8.1.10.6(a)
CSF	PR.AC-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.18
ISO/IEC-27001	A.9.2.3
ITSG-33	AC-6(5)
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.6.1

NIAV2	AM32
NIAV2	AM33
NIAV2	VL3a
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-237642r991589_rule
STIG-ID	RHEL-08-010383
SWIFT-CSCV1	1.2
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3
VULN-ID	V-237642

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```

-----
FAILED - rootpw
No matching files were found
Less than 1 matches of regex found

-----
FAILED - runaspw
No matching files were found
Less than 1 matches of regex found

-----
FAILED - targetpw
No matching files were found
Less than 1 matches of regex found

```

RHEL-08-010384 - RHEL 8 must require re-authentication when using the "sudo" command.

Info

Without re-authentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to escalate a functional capability, it is critical the organization requires the user to re-authenticate when using the "sudo" command.

If the value is set to an integer less than 0, the user's time stamp will not expire and the user will not have to re-authenticate for privileged actions until the user's session is terminated.

Solution

Configure the "sudo" command to require re-authentication.

Edit the /etc/sudoers file:

```
$ sudo visudo
```

Add or modify the following line:

Defaults timestamp_timeout=[value] Note: The "[value]" must be a number that is greater than or equal to "0".

Remove any duplicate or conflicting lines from /etc/sudoers and /etc/sudoers.d/ files.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.01b.
800-53	IA-11
800-53R5	SC-11b.
CAT	II
CCI	CCI-002038
CCI	CCI-004895
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
QCSC-V1	13.2
RULE-ID	SV-237643r1050789_rule
STIG-ID	RHEL-08-010384
VULN-ID	V-237643

Assets

linuxred-01

No matching files were found

Less than 1 matches of regex found

RHEL-08-010400 - RHEL 8 must implement certificate status checking for multifactor authentication.

Info

Using an authentication device, such as a DoD Common Access Card (CAC) or token that is separate from the information system, ensures that even if the information system is compromised, credentials stored on the authentication device will not be affected.

Multifactor solutions that require devices separate from information systems gaining access include, for example, hardware tokens providing time-based or challenge-response authenticators and smart cards such as the U.S. Government Personal Identity Verification (PIV) card and the DoD CAC.

RHEL 8 includes multiple options for configuring certificate status checking, but for this requirement focuses on the System Security Services Daemon (SSSD). By default, sssd performs Online Certificate Status Protocol (OCSP) checking and certificate verification using a sha256 digest function.

Satisfies: SRG-OS-000375-GPOS-00160, SRG-OS-000377-GPOS-00162

Solution

Configure the operating system to implement certificate status checking for multifactor authentication.

Review the "/etc/sss/sss.conf" file to determine if the system is configured to prevent OCSP or certificate verification.

Add the following line to the [sss] section of the "/etc/sss/sss.conf" file:

```
certificate_verification = ocsp_dgst=sha1
```

The "sss" service must be restarted for the changes to take effect. To restart the "sss" service, run the following command:

```
$ sudo systemctl restart sss.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.1
800-171R3	03.05.01a.
800-53	IA-2(11)
800-53R5	IA-2(6)(a)
CAT	II
CCI	CCI-001948
CCI	CCI-004046
CN-L3	8.1.4.1(d)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ITSG-33	IA-2(100)

NESA	T5.4.2
NIAV2	AM2
NIAV2	AM8
NIAV2	AM14b
PCI-DSSV3.2.1	8.3
PCI-DSSV3.2.1	8.3.1
PCI-DSSV3.2.1	8.3.2
PCI-DSSV4.0	8.4.1
PCI-DSSV4.0	8.4.3
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230274r1017089_rule
STIG-ID	RHEL-08-010400
SWIFT-CSCV1	4.2
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-230274

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-010410 - RHEL 8 must accept Personal Identity Verification (PIV) credentials.

Info

The use of PIV credentials facilitates standardization and reduces the risk of unauthorized access. The DoD has mandated the use of the Common Access Card (CAC) to support identity management and personal authentication for systems covered under Homeland Security Presidential Directive (HSPD) 12, as well as making the CAC a primary component of layered protection for national security systems.

Solution

Configure RHEL 8 to accept PIV credentials.
Install the "opensc" package using the following command:
\$ sudo yum install opensc

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.1
800-171R3	03.05.01a.
800-53	IA-2(12)
800-53R5	IA-2(12)
CAT	II
CCI	CCI-001953
CN-L3	7.1.3.1(a)
CN-L3	7.1.3.1(e)
CN-L3	8.1.4.1(a)
CN-L3	8.1.4.2(a)
CN-L3	8.5.4.1(a)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ITSG-33	IA-2
ITSG-33	IA-2a.
NESA	T2.3.8

NESA	T5.3.1
NESA	T5.4.2
NESA	T5.5.1
NESA	T5.5.2
NESA	T5.5.3
NIAV2	AM2
NIAV2	AM8
NIAV2	AM14b
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230275r958816_rule
STIG-ID	RHEL-08-010410
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-230275

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - opensc installed
The package 'opensc-0.0.0-0' is not installed
```


RHEL-08-010421 - RHEL 8 must clear the page allocator to prevent use-after-free attacks.

Info

Some adversaries launch attacks with the intent of executing code in non-executable regions of memory or in memory locations that are prohibited. Security safeguards employed to protect memory include, for example, data execution prevention and address space layout randomization. Data execution prevention safeguards can be either hardware-enforced or software-enforced with hardware providing the greater strength of mechanism.

Poisoning writes an arbitrary value to freed pages, so any modification or reference to that page after being freed or before being initialized will be detected and prevented. This prevents many types of use-after-free vulnerabilities at little performance cost. Also prevents leak of data and detection of corrupted memory.

Satisfies: SRG-OS-000134-GPOS-00068, SRG-OS-000433-GPOS-00192

Solution

Configure RHEL 8 to enable page poisoning with the following commands:

```
$ sudo grubby --update-kernel=ALL --args="page_poison=1"
```

Add or modify the following line in "/etc/default/grub" to ensure the configuration survives kernel updates:

```
GRUB_CMDLINE_LINUX="page_poison=1"
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SC-3
800-53R5	SC-3
CAT	II
CCI	CCI-001084
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-3
ITSG-33	SC-3a.
NESA	T3.4.1
NESA	T4.3.1
NESA	T4.3.2
RULE-ID	SV-230277r1017090_rule
STIG-ID	RHEL-08-010421
VULN-ID	V-230277

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - Check that virtual system calls are disabled by default to persist in kernel updates

Non-compliant file(s):

/etc/default/grub - regex '^[s]*GRUB_CMDLINE_LINUX=' found - expect '^[^#]+

\bpage_poison=1\b' not found in the following lines:

6: GRUB_CMDLINE_LINUX="loglevel=3 crashkernel=auto console=tty1 console=ttyS0
earlyprintk=ttyS0 rootdelay=300 nvme_core.io_timeout=240"

FAILED - Check that the current GRUB 2 configuration has page poisoning enabled
The command '/bin/grub2-editenv list | /bin/grep page_poison' returned :
/bin/grub2-editenv: error: cannot open `/boot/grub2/grubenv.new': Permission denied.

RHEL-08-010422 - RHEL 8 must disable virtual syscalls.

Info

Syscalls are special routines in the Linux kernel, which userspace applications ask to do privileged tasks. Invoking a system call is an expensive operation because the processor must interrupt the currently executing task and switch context to kernel mode and then back to userspace after the system call completes. Virtual Syscalls map into userspace a page that contains some variables and the implementation of some system calls. This allows the system calls to be executed in userspace to alleviate the context switching expense.

Virtual Syscalls provide an opportunity of attack for a user who has control of the return instruction pointer. Disabling vsyscalls help to prevent return oriented programming (ROP) attacks via buffer overflows and overruns. If the system intends to run containers based on RHEL 6 components, then virtual syscalls will need enabled so the components function properly.

Satisfies: SRG-OS-000134-GPOS-00068, SRG-OS-000433-GPOS-00192

Solution

Document the use of vsyscalls with the ISSO as an operational requirement or disable them with the following command:

```
$ sudo grubby --update-kernel=ALL --args="vsyscall=none"
```

Add or modify the following line in "/etc/default/grub" to ensure the configuration survives kernel updates:

```
GRUB_CMDLINE_LINUX="vsyscall=none"
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SC-3
800-53R5	SC-3
CAT	II
CCI	CCI-001084
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-3
ITSG-33	SC-3a.
NESA	T3.4.1
NESA	T4.3.1
NESA	T4.3.2
RULE-ID	SV-230278r1017091_rule
STIG-ID	RHEL-08-010422
VULN-ID	V-230278

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - Check /etc/default/grub for vsyscall=none

Non-compliant file(s):

/etc/default/grub - regex '^[\s]*GRUB_CMDLINE_LINUX=' found - expect '^[^#]+\bvsyscall=none\b' not found in the following lines:

```
6: GRUB_CMDLINE_LINUX="loglevel=3 crashkernel=auto console=tty1 console=ttyS0  
earlyprintk=ttyS0 rootdelay=300 nvme_core.io_timeout=240"
```

```
-----
```

```
FAILED - grub2-editenv list
```

```
The command '/bin/grub2-editenv list | /bin/grep vsyscall' returned :
```

```
/bin/grub2-editenv: error: cannot open `/boot/grub2/grubenv.new': Permission denied.
```

RHEL-08-010423 - RHEL 8 must clear memory when it is freed to prevent use-after-free attacks.

Info

Some adversaries launch attacks with the intent of executing code in nonexecutable regions of memory or in memory locations that are prohibited. Security safeguards employed to protect memory include, for example, data execution prevention and address space layout randomization. Data execution prevention safeguards can be either hardware-enforced or software-enforced with hardware providing the greater strength of mechanism.

Poisoning writes an arbitrary value to freed pages, so any modification or reference to that page after being freed or before being initialized will be detected and prevented. This prevents many types of use-after-free vulnerabilities at little performance cost. Also prevents leak of data and detection of corrupted memory.

init_on_free is a Linux kernel boot parameter that enhances security by initializing memory regions when they are freed, preventing data leakage. This process ensures that stale data in freed memory cannot be accessed by malicious programs.

SLUB canaries add a randomized value (canary) at the end of SLUB-allocated objects to detect memory corruption caused by buffer overflows or underflows. Redzoning adds padding (red zones) around SLUB-allocated objects to detect overflows or underflows by triggering a fault when adjacent memory is accessed. SLUB canaries are often more efficient and provide stronger detection against buffer overflows compared to redzoning. SLUB canaries are supported in hardened Linux kernels like the ones provided by Linux-hardened.

SLAB objects are blocks of physically contiguous memory. SLUB is the unqueued SLAB allocator.

Satisfies: SRG-OS-000433-GPOS-00192, SRG-OS-000134-GPOS-00068

Solution

Configure RHEL 8 to enable init_on_free with the following command:

```
$ sudo grubby --update-kernel=ALL --args="init_on_free=1"
```

Regenerate the GRUB configuration:

```
$ sudo grub2-mkconfig -o /boot/grub2/grub.cfg
```

Reboot the system:

```
$ sudo reboot
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SC-3
800-53R5	SC-3
CAT	II
CCI	CCI-001084
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-3
ITSG-33	SC-3a.
NESA	T3.4.1
NESA	T4.3.1
NESA	T4.3.2
RULE-ID	SV-230279r1069286_rule
STIG-ID	RHEL-08-010423
VULN-ID	V-230279

Assets

linuxred-01

Non-compliant file(s):

```
/etc/default/grub - regex '^[\s]*GRUB_CMDLINE_LINUX=' found - expect '^[^#]+\n\binit_on_free=1\b' not found in the following lines:  
6: GRUB_CMDLINE_LINUX="loglevel=3 crashkernel=auto console=tty1 console=ttyS0  
earlyprintk=ttyS0 rootdelay=300 nvme_core.io_timeout=240"
```

RHEL-08-010430 - RHEL 8 must implement address space layout randomization (ASLR) to protect its memory from unauthorized code execution.

Info

Some adversaries launch attacks with the intent of executing code in non-executable regions of memory or in memory locations that are prohibited. Security safeguards employed to protect memory include, for example, data execution prevention and address space layout randomization. Data execution prevention safeguards can be either hardware-enforced or software-enforced with hardware providing the greater strength of mechanism.

Examples of attacks are buffer overflow attacks.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure the operating system to implement virtual address space randomization.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
kernel.randomize_va_space=2
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Issue the following command to make the changes take effect:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-16
800-53R5	SI-16
CAT	II
CCI	CCI-002824
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-16
RULE-ID	SV-230280r1017093_rule
STIG-ID	RHEL-08-010430
VULN-ID	V-230280

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - sysctl

The command `'/sbin/sysctl kernel.randomize_va_space'` returned :

```
kernel.randomize_va_space = 2
```

```
-----  
FAILED - systemd-sysctl  
No matching files were found  
Less than 1 matches of regex found
```


RHEL-08-010455 - RHEL 8 must elevate the SELinux context when an administrator calls the sudo command.

Info

Preventing nonprivileged users from executing privileged functions mitigates the risk that unauthorized individuals or processes may gain unnecessary access to information or privileges. Privileged functions include, for example, establishing accounts, performing system integrity checks, or administering cryptographic key management activities. Nonprivileged users are individuals who do not possess appropriate authorizations. Circumventing intrusion detection and prevention mechanisms or malicious code protection mechanisms are examples of privileged functions that require protection from nonprivileged users.

Solution

Configure the operating system to elevate the SELinux context when an administrator calls the sudo command. Edit a file in the "/etc/sudoers.d" directory with the following command:
\$ sudo visudo -f /etc/sudoers.d/<customfile>
Use the following example to build the <customfile> in the /etc/sudoers.d directory to allow any administrator belonging to a designated sudoers admin group to elevate their SELinux context with the use of the sudo command: {designated_group_or_user_name} ALL=(ALL) TYPE=sysadm_t ROLE=sysadm_r ALL
Remove any configurations that conflict with the above from the following locations:
/etc/sudoers /etc/sudoers.d/

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.7
800-171R3	03.01.07a.
800-53	AC-6(10)
800-53R5	AC-6(10)
CAT	II
CCI	CCI-002235
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.10.6(a)
CSF	PR.AC-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.18

ITSG-33	AC-6
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15c
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-272484r1134875_rule
STIG-ID	RHEL-08-010455
SWIFT-CSCV1	5.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3
VULN-ID	V-272484

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-010471 - RHEL 8 must enable the hardware random number generator entropy gatherer service.

Info

The most important characteristic of a random number generator is its randomness, namely its ability to deliver random numbers that are impossible to predict. Entropy in computer security is associated with the unpredictability of a source of randomness. The random source with high entropy tends to achieve a uniform distribution of random values. Random number generators are one of the most important building blocks of cryptosystems.

The rngd service feeds random data from hardware device to kernel random device. Quality (nonpredictable) random number generation is important for several security functions (i.e., ciphers).

Solution

Start the rngd service and enable the rngd service with the following commands:

```
$ sudo systemctl start rngd.service
```

```
$ sudo systemctl enable rngd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230285r1017096_rule
STIG-ID	RHEL-08-010471
SWIFT-CSCV1	2.3
VULN-ID	V-230285

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - grub2-editenv
The command '/bin/grub2-editenv list | /bin/grep fips' returned :

/bin/grub2-editenv: error: cannot open `/boot/grub2/grubenv.new': Permission denied.

-----
FAILED - fips-mode-setup --check
The command '/bin/fips-mode-setup --check' returned :

Installation of FIPS modules is not completed.
FIPS mode is disabled.

-----
FAILED - proc
The command '/bin/cat /proc/sys/crypto/fips_enabled' returned :

0
```

RHEL-08-010500 - The RHEL 8 SSH daemon must perform strict mode checking of home directory configuration files.

Info

If other users have access to modify user-specific SSH configuration files, they may be able to log on to the system as another user.

Solution

Configure SSH to perform strict mode checking of home directory configuration files. Uncomment the "StrictModes" keyword in "/etc/ssh/sshd_config" and set the value to "yes":

StrictModes yes

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230288r1069301_rule
STIG-ID	RHEL-08-010500
SWIFT-CSCV1	2.3
VULN-ID	V-230288

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i StrictModes' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-010520 - The RHEL 8 SSH daemon must not allow authentication using known host's authentication.

Info

Configuring this setting for the SSH daemon provides additional assurance that remote logon via SSH will require a password, even in the event of misconfiguration elsewhere.

Solution

Configure the SSH daemon to not allow authentication using known host's authentication.

Add the following line in "/etc/ssh/sshd_config", or uncomment the line and set the value to "yes":

IgnoreUserKnownHosts yes

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230290r1069302_rule
STIG-ID	RHEL-08-010520
SWIFT-CSCV1	2.3
VULN-ID	V-230290

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i IgnoreUserKnownHosts' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-010521 - The RHEL 8 SSH daemon must not allow Kerberos authentication, except to fulfill documented and validated mission requirements.

Info

Configuring these settings for the SSH daemon provides additional assurance that remote logon via SSH will not use unused methods of authentication, even in the event of misconfiguration elsewhere.

Solution

Configure the SSH daemon to not allow Kerberos authentication.

Add the following line in "/etc/ssh/sshd_config", or uncomment the line and set the value to "no":

KerberosAuthentication no

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230291r1069303_rule
STIG-ID	RHEL-08-010521
SWIFT-CSCV1	2.3
VULN-ID	V-230291

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i KerberosAuthentication' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-010522 - The RHEL 8 SSH daemon must not allow GSSAPI authentication, except to fulfill documented and validated mission requirements.

Info

Configuring this setting for the SSH daemon provides additional assurance that remote logon via SSH will require a password, even in the event of misconfiguration elsewhere.

Solution

Configure the SSH daemon to not allow GSSAPI authentication.

Add the following line in "/etc/ssh/sshd_config", or uncomment the line and set the value to "no":

GSSAPIAuthentication no

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244528r1017335_rule
STIG-ID	RHEL-08-010522
SWIFT-CSCV1	2.3
VULN-ID	V-244528

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i GSSAPIAuthentication' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-010541 - RHEL 8 must use a separate file system for /var/log.

Info

The use of separate file systems for different paths can protect the system from failures resulting from a file system becoming full or failing.

Solution

Migrate the "/var/log" path onto a separate file system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230293r1017104_rule
STIG-ID	RHEL-08-010541
SWIFT-CSCV1	2.3
VULN-ID	V-230293

Assets

linuxred-01

The following file(s) do not contain "[^#\n\r]+[\s]+/var/log[\s]+":
/etc/fstab

RHEL-08-010542 - RHEL 8 must use a separate file system for the system audit data path.

Info

The use of separate file systems for different paths can protect the system from failures resulting from a file system becoming full or failing.

Solution

Migrate the system audit data path onto a separate file system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230294r1017105_rule
STIG-ID	RHEL-08-010542
SWIFT-CSCV1	2.3
VULN-ID	V-230294

Assets

linuxred-01

The following file(s) do not contain "[^#\n\r]+[\s]+/var/log/audit[\s]+":
/etc/fstab

RHEL-08-010544 - RHEL 8 must use a separate file system for /var/tmp.

Info

The use of separate file systems for different paths can protect the system from failures resulting from a file system becoming full or failing.

Solution

Migrate the "/var/tmp" path onto a separate file system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244529r1017336_rule
STIG-ID	RHEL-08-010544
SWIFT-CSCV1	2.3
VULN-ID	V-244529

Assets

linuxred-01

The following file(s) do not contain "[^#\n\r]+[\s]+/var/tmp[\s]+":
/etc/fstab

RHEL-08-010550 - RHEL 8 must not permit direct logons to the root account using remote access via SSH.

Info

Even though the communications channel may be encrypted, an additional layer of security is gained by extending the policy of not logging on directly as root. In addition, logging on with a user-specific account provides individual accountability of actions performed on the system.

Solution

Configure RHEL 8 to stop users from logging on remotely as the "root" user via SSH.

Edit the appropriate "/etc/ssh/sshd_config" file to uncomment or add the line for the "PermitRootLogin" keyword and set its value to "no":

```
PermitRootLogin no
```

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.1
800-171R3	03.05.01a.
800-53	IA-2(5)
800-53R5	IA-2(5)
CAT	II
CCI	CCI-000770
CCI	CCI-004045
CN-L3	7.1.3.1(a)
CN-L3	7.1.3.1(e)
CN-L3	8.1.4.1(a)
CN-L3	8.1.4.2(a)
CN-L3	8.5.4.1(a)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16

ITSG-33	IA-2(5)
ITSG-33	IA-2(5)(a)
ITSG-33	IA-2(5)(b)
NESA	T2.3.8
NESA	T5.3.1
NESA	T5.4.2
NESA	T5.5.1
NESA	T5.5.2
NESA	T5.5.3
NIAV2	AM2
NIAV2	AM8
NIAV2	AM14b
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230296r1069322_rule
STIG-ID	RHEL-08-010550
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-230296

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i PermitRootLogin' returned :
 /etc/ssh/sshd_config: Permission denied

RHEL-08-010570 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on file systems that contain user home directories.

Info

The "nosuid" mount option causes the system not to execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nosuid" option on file systems that contain user home directories for interactive users.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230299r1017109_rule
STIG-ID	RHEL-08-010570
SWIFT-CSCV1	2.3
VULN-ID	V-230299

Assets

linuxred-01

```
Non-compliant file(s):
/etc/fstab - regex '^#[\n\r]+[\s]+/home[\s]' found - expect '^#[\n\r]+[\s]+/home[\s]+#[\n\r]*nosuid' not found in the following lines:
15: /dev/mapper/rootvg-home1v /home          xfs      defaults    0 0
```

RHEL-08-010572 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on the /boot/efi directory.

Info

The "nosuid" mount option causes the system not to execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nosuid" option on the /boot/efi directory.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244530r1155403_rule
STIG-ID	RHEL-08-010572
SWIFT-CSCV1	2.3
VULN-ID	V-244530

Assets

linuxred-01

```
Non-compliant file(s):
/etc/fstab - regex '^#[\n\r]+[\s]+/boot/efi[\s]\' found - expect '^#[\n\r]+[\s]+/boot/efi[\s]+[^\n\r]*nosuid\' not found in the following lines:
14: UUID=6E66-F38E /boot/efi vfat defaults,uid=0,gid=0,umask=077,shortname=winnt 0 2
```

RHEL-08-010580 - RHEL 8 must prevent special devices on non-root local partitions.

Info

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for nonprivileged users to attain unauthorized administrative access. The only legitimate location for device files is the /dev directory located on the root partition.

Solution

Configure the "/etc/fstab" to use the "nodev" option on all non-root local partitions.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230301r1155405_rule
STIG-ID	RHEL-08-010580
SWIFT-CSCV1	2.3
VULN-ID	V-230301

Assets

linuxred-01

```
The command '/bin/mount | /bin/grep -P '^/dev[\S]* on /[\S]+' | /bin/grep --invert-match 'nodev' | /bin/awk '{print} END {if (NR == 0) print "nodev has been set appropriately for mounted / dev file systems"; else print "fail - nodev option not found on the following file systems"}' returned :
```

```
/dev/mapper/rootvg-usrlv on /usr type xfs
(rw,relatime,seclabel,attr2,inode64,logbufs=8,logbsize=32k,noquota)
```

```
/dev/mapper/rootvg-tmplv on /tmp type xfs
(rw,relatime,seclabel,attr2,inode64,logbufs=8,logbsize=32k,noquota)
/dev/nvme0n1p1 on /boot type xfs
(rw,relatime,seclabel,attr2,inode64,logbufs=8,logbsize=32k,noquota)
/dev/mapper/rootvg-homelv on /home type xfs
(rw,relatime,seclabel,attr2,inode64,logbufs=8,logbsize=32k,noquota)
/dev/nvme0n1p15 on /boot/efi type vfat
(rw,relatime,fmask=0077,dmask=0077,codepage=437,iocharset=ascii,shortname=winnt,errors=remount-
ro)
/dev/mapper/rootvg-varlv on /var type xfs
(rw,relatime,seclabel,attr2,inode64,logbufs=8,logbsize=32k,noquota)
fail - nodev option not found on the following file systems
```

RHEL-08-010590 - RHEL 8 must prevent code from being executed on file systems that contain user home directories.

Info

The "noexec" mount option causes the system not to execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "noexec" option on file systems that contain user home directories for interactive users.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230302r1017112_rule
STIG-ID	RHEL-08-010590
SWIFT-CSCV1	2.3
VULN-ID	V-230302

Assets

linuxred-01

```
Non-compliant file(s):
/etc/fstab - regex '^#[\n\r]+[\s]+/home[\s]' found - expect '^#[\n\r]+[\s]+/home[\s]+^[#\n\r]*noexec' not found in the following lines:
15: /dev/mapper/rootvg-home1v /home                xfs      defaults      0 0
```

RHEL-08-010670 - RHEL 8 must disable kernel dumps unless needed.

Info

Kernel core dumps may contain the full contents of system memory at the time of the crash. Kernel core dumps may consume a considerable amount of disk space and may result in denial of service by exhausting the available space on the target file system partition.

RHEL 8 installation media presents the option to enable or disable the kdump service at the time of system installation.

Solution

If kernel core dumps are not required, disable the "kdump" service with the following command:

```
# systemctl disable kdump.service
```

If kernel core dumps are required, document the need with the ISSO.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230310r1155383_rule
STIG-ID	RHEL-08-010670
SWIFT-CSCV1	2.3
VULN-ID	V-230310

Assets

linuxred-01

The command `'/bin/systemctl status kdump.service | /bin/awk '{print} END {if(NR==0) print "No results found" }'` returned :

```
* kdump.service - Crash recovery kernel arming
  Loaded: loaded (/usr/lib/systemd/system/kdump.service; enabled; vendor preset: enabled)
  Active: active (exited) since Thu 2026-03-05 02:47:43 UTC; 42min ago
  Main PID: 1315 (code=exited, status=0/SUCCESS)
    Tasks: 0 (limit: 23179)
   Memory: 0B
    CGroup: /system.slice/kdump.service

Mar 05 02:47:41 linuxRed-01 systemd[1]: Starting Crash recovery kernel arming...
Mar 05 02:47:43 linuxRed-01 kdumpctl[1319]: kdump: kexec: loaded kdump kernel
Mar 05 02:47:43 linuxRed-01 kdumpctl[1319]: kdump: Starting kdump: [OK]
Mar 05 02:47:43 linuxRed-01 systemd[1]: Started Crash recovery kernel arming.
```


RHEL-08-010671 - RHEL 8 must disable the kernel.core_pattern.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore, may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographical order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to restrict usage of `ptrace` to descendant processes by adding the following line to a dropfile in the `"/etc/sysctl.d"` directory:

Create a dropfile if it does not already exist:

```
$ sudo vi /etc/sysctl.d/99-disable-coredump.conf
```

Add the following to the file:

```
kernel.core_pattern = /bin/false
```

The system configuration files need to be reloaded for the changes to take effect. To reload the contents of the files, run the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230311r1155408_rule

STIG-ID RHEL-08-010671

SWIFT-CSCV1 2.3

VULN-ID V-230311

Assets

linuxred-01

The command '/sbin/sysctl kernel.core_pattern' returned :

kernel.core_pattern = |/usr/lib/systemd/systemd-coredump %P %u %g %s %t %c %h %e

RHEL-08-010672 - RHEL 8 must disable acquiring, saving, and processing core dumps.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems.

When the kernel invokes systemd-coredump to handle a core dump, it runs in privileged mode, and will connect to the socket created by the systemd-coredump.socket unit. This, in turn, will spawn an unprivileged systemd-coredump@.service instance to process the core dump.

Solution

Configure the system to disable the systemd-coredump.socket with the following commands:

```
$ sudo systemctl disable --now systemd-coredump.socket
```

```
$ sudo systemctl mask systemd-coredump.socket
```

```
Created symlink /etc/systemd/system/systemd-coredump.socket -> /dev/null
```

Reload the daemon for this change to take effect.

```
$ sudo systemctl daemon-reload
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230312r1134877_rule
STIG-ID	RHEL-08-010672
SWIFT-CSCV1	2.3
VULN-ID	V-230312

Assets

linuxred-01

The command `'/bin/systemctl status systemd-coredump.socket | /bin/awk '{print} END {if(NR==0) print "No results found" }'` returned :

```
* systemd-coredump.socket - Process Core Dump Socket
   Loaded: loaded (/usr/lib/systemd/system/systemd-coredump.socket; static; vendor preset:
disabled)
   Active: active (listening) since Thu 2026-03-05 02:47:36 UTC; 42min ago
     Docs: man:systemd-coredump(8)
    Listen: /run/systemd/coredump (SequentialPacket)
  Accepted: 0; Connected: 0;
     Tasks: 0 (limit: 23179)
    Memory: 0B
    CGroup: /system.slice/systemd-coredump.socket
```

Warning: Journal has been rotated since unit was started. Log output is incomplete or unavailable.

RHEL-08-010673 - RHEL 8 must disable core dumps for all users.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore, may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems.

Solution

Configure the operating system to disable core dumps for all users.

Add the following line to the top of the /etc/security/limits.conf or in a single ".conf" file defined in /etc/security/limits.d/:

* hard core 0

Remove or comment out any entries for users or groups with a value set to anything other than "0".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230313r1155379_rule
STIG-ID	RHEL-08-010673
SWIFT-CSCV1	2.3
VULN-ID	V-230313

Assets

linuxred-01

No matching files were found

Less than 1 matches of regex found

RHEL-08-010674 - RHEL 8 must disable storing core dumps.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems.

Solution

Configure the operating system to disable storing core dumps for all users.

Add or modify the following line in `/etc/systemd/coredump.conf`:

`Storage=none`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230314r1134881_rule
STIG-ID	RHEL-08-010674
SWIFT-CSCV1	2.3
VULN-ID	V-230314

Assets

linuxred-01

The following file(s) do not contain `"^[\\s]*Storage[\\s]*=":`
`/etc/systemd/coredump.conf`

RHEL-08-010675 - RHEL 8 must disable core dump backtraces.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems.

Solution

Configure the operating system to disable core dump backtraces.
Add or modify the following line in `/etc/systemd/coredump.conf`:
`ProcessSizeMax=0`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230315r1134883_rule
STIG-ID	RHEL-08-010675
SWIFT-CSCV1	2.3
VULN-ID	V-230315

Assets

linuxred-01

The following file(s) do not contain `"^[\\s]*ProcessSizeMax[\\s]*=":`
`/etc/systemd/coredump.conf`

RHEL-08-010680 - For RHEL 8 systems using Domain Name Servers (DNS) resolution, at least two name servers must be configured.

Info

To provide availability for name resolution services, multiple redundant name servers are mandated. A failure in name resolution could lead to the failure of security functions requiring name resolution, which may include time synchronization, centralized authentication, and remote system logging.

Solution

Configure the operating system to use two or more name servers for DNS resolution.

By default, "NetworkManager" on RHEL 8 dynamically updates the `/etc/resolv.conf` file with the DNS settings from active "NetworkManager" connection profiles. However, this feature can be disabled to allow manual configurations. If manually configuring DNS, edit the `/etc/resolv.conf` file to uncomment or add the two or more "nameserver" option lines with the IP address of local authoritative name servers. If local host resolution is being performed, the `/etc/resolv.conf` file must be empty. An empty `/etc/resolv.conf` file can be created as follows:

```
$ sudo echo -n > /etc/resolv.conf
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230316r1044801_rule
STIG-ID	RHEL-08-010680
SWIFT-CSCV1	2.3
VULN-ID	V-230316

Assets

linuxred-01

Compliant file(s):
 /etc/resolv.conf - regex '^[\s]*nameserver[\s]+([0-9\.]+)\$' found - expect
 '^[\s]*nameserver[\s]+([0-9\.]+)\$' found in the following lines:
 3: nameserver 168.63.129.16
Less than 2 matches of regex found

RHEL-08-010770 - All RHEL 8 local initialization files must have mode 0740 or less permissive.

Info

Local initialization files are used to configure the user's shell environment upon logon. Malicious modification of these files could compromise accounts upon logon.

Solution

Set the mode of the local initialization files to "0740" with the following command:

Note: The example will be for the smithj user, who has a home directory of "/home/smithj".

```
$ sudo chmod 0740 /home/smithj/.<INIT_FILE>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230325r1017136_rule
STIG-ID	RHEL-08-010770
SWIFT-CSCV1	2.3
VULN-ID	V-230325

Assets

linuxred-01

```
The command '/bin/awk -F: '/^[^#]/ { print $(NF-1) }' /etc/passwd | /bin/sort -u | while read D;
do /bin/stat -c '%F:%a:%A %n' $D/.[!~]* 2>/dev/null; done | /bin/awk -F: '$1 !~ /directory/ &&
$2 !~ /^[01234567][04][0]$/' { print $3; n+=1 } END { if (n<1) print "none" }' returned :
```

```
-rw-r--r-- /home/cddar/.bash_logout
-rw-r--r-- /home/cddar/.bash_profile
```

-rw-r--r-- /home/cddar/.bashrc

RHEL-08-010830 - RHEL 8 must not allow users to override SSH environment variables.

Info

SSH environment options potentially allow users to bypass access restriction in some configurations.

Solution

Configure RHEL 8 to allow the SSH daemon to not allow unattended or automatic logon to the system.

Add or edit the following line in the "/etc/ssh/sshd_config" file:

PermitUserEnvironment no

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230330r1069305_rule
STIG-ID	RHEL-08-010830
SWIFT-CSCV1	2.3
VULN-ID	V-230330

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i PermitUserEnvironment' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-020011 - RHEL 8 must automatically lock an account when three unsuccessful logon attempts occur.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to lock an account when three unsuccessful logon attempts occur.

Add/Modify the `/etc/security/faillock.conf` file to match the following line:

`deny = 3`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230333r1017145_rule
STIG-ID	RHEL-08-020011
TBA-FIISB	45.1.2

TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230333

Assets

linuxred-01

The following file(s) do not contain "`^\s]*deny[\s]*=[\s]*`":
 /etc/security/faillock.conf

RHEL-08-020013 - RHEL 8 must automatically lock an account when three unsuccessful logon attempts occur during a 15-minute time period.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account. In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to lock an account when three unsuccessful logon attempts occur in 15 minutes.

Add/Modify the `/etc/security/faillock.conf` file to match the following line:

`fail_interval = 900`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230335r1017147_rule
STIG-ID	RHEL-08-020013
TBA-FIISB	45.1.2

TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230335

Assets

linuxred-01

The following file(s) do not contain "`^[\\s]*fail_interval[\\s]*=[\\s]*`":
 /etc/security/faillock.conf

RHEL-08-020015 - RHEL 8 must automatically lock an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to lock an account until released by an administrator when three unsuccessful logon attempts occur in 15 minutes.

Add/Modify the `/etc/security/faillock.conf` file to match the following line:

```
unlock_time = 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230337r1134885_rule
STIG-ID	RHEL-08-020015

TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230337

Assets

linuxred-01

The following file(s) do not contain "`^[\\s]*unlock_time[\\s]*=[\\s]*`":
 /etc/security/faillock.conf

RHEL-08-020017 - RHEL 8 must ensure account lockouts persist.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system maintain the contents of the faillock directory after a reboot.

Add/Modify the `/etc/security/faillock.conf` file to match the following line:

`dir = /var/log/faillock`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230339r1017151_rule
STIG-ID	RHEL-08-020017
TBA-FIISB	45.1.2

TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230339

Assets

linuxred-01

The following file(s) do not contain "`^[\\s]*dir[\\s]*=[\\s]*`":
/etc/security/faillock.conf

RHEL-08-020019 - RHEL 8 must prevent system messages from being presented when three unsuccessful logon attempts occur.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account. In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout. From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to prevent informative messages from being presented at logon attempts. Add/Modify the `/etc/security/faillock.conf` file to match the following line:
silent

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230341r1017153_rule
STIG-ID	RHEL-08-020019
TBA-FIISB	45.1.2

TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230341

Assets

linuxred-01

The following file(s) do not contain "[\s]*silent":
/etc/security/faillock.conf

RHEL-08-020021 - RHEL 8 must log user name information when unsuccessful logon attempts occur.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to log user name information when unsuccessful logon attempts occur.

Add/Modify the `/etc/security/faillock.conf` file to match the following line:

`audit`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230343r1017155_rule
STIG-ID	RHEL-08-020021
TBA-FIISB	45.1.2

TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230343

Assets

linuxred-01

The following file(s) do not contain "[\s]*audit":
/etc/security/faillock.conf

RHEL-08-020023 - RHEL 8 must include root when automatically locking an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

In RHEL 8.2 the `/etc/security/faillock.conf` file was incorporated to centralize the configuration of the `pam_faillock.so` module. Also introduced is a `"local_users_only"` option that will only track failed user authentication attempts for local users in `/etc/passwd` and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From `"faillock.conf"` man pages: Note that the default directory that `"pam_faillock"` uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the `"dir"` option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to include root when locking an account after three unsuccessful logon attempts occur in 15 minutes.

Add/Modify the `/etc/security/faillock.conf` file to match the following line:

`even_deny_root`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230345r1017157_rule
STIG-ID	RHEL-08-020023

TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230345

Assets

linuxred-01

The following file(s) do not contain "^[\s]*even_deny_root":
/etc/security/faillock.conf

RHEL-08-020024 - RHEL 8 must limit the number of concurrent sessions to ten for all accounts and/or account types.

Info

Operating system management includes the ability to control the number of users and user sessions that utilize an operating system. Limiting the number of allowed users and sessions per user is helpful in reducing the risks related to DoS attacks.

This requirement addresses concurrent sessions for information system accounts and does not address concurrent sessions by single users via multiple system accounts. The maximum number of concurrent sessions should be defined based on mission needs and the operational environment for each system.

Solution

Configure the operating system to limit the number of concurrent sessions to "10" for all accounts and/or account types.

Add the following line to the top of the /etc/security/limits.conf or in a ".conf" file defined in /etc/security/limits.d/:

```
* hard maxlogins 10
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AC-10
800-53R5	AC-10
CAT	III
CCI	CCI-000054
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	AC-10
NESA	T5.5.1
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230346r1069306_rule
STIG-ID	RHEL-08-020024
VULN-ID	V-230346

Assets

linuxred-01

No matching files were found

Less than 1 matches of regex found

RHEL-08-020025 - RHEL 8 must configure the use of the pam_faillock.so module in the /etc/pam.d/system-auth file.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account. In RHEL 8.2 the "/etc/security/faillock.conf" file was incorporated to centralize the configuration of the pam_faillock.so module. Also introduced is a "local_users_only" option that will only track failed user authentication attempts for local users in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From "faillock.conf" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

The preauth argument must be used when the module is called before the modules which ask for the user credentials such as the password.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to include the use of the pam_faillock.so module in the /etc/pam.d/system-auth file. Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" file to match the following lines:

Note: The "preauth" line must be listed before pam_unix.so.

auth required pam_faillock.so preauth auth required pam_faillock.so authfail account required pam_faillock.so

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-244533r1069318_rule

STIG-ID	RHEL-08-020025
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-244533

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - preauth line
The following file(s) do not contain "^[\s]*auth[\s]*required[\s]*pam_faillock\.so[\s]*preauth":
/etc/pam.d/system-auth
```

```
-----
PASSED - preauth order
The command '/bin/awk 'BEGIN{l=-1;s="pass"} $3 ~ /pam_unix/{l=NR} $4 ~ /preauth/ && !/^(#|)/ &&
l>0 && l<NR { s="fail"; printf "preauth on line %d is after pam_unix on line %d\n", NR, l} END
{print s}' /etc/pam.d/system-auth' returned :
```

pass

RHEL-08-020026 - RHEL 8 must configure the use of the pam_faillock.so module in the /etc/pam.d/password-auth file.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

In RHEL 8.2 the "/etc/security/faillock.conf" file was incorporated to centralize the configuration of the pam_faillock.so module. Also introduced is a "local_users_only" option that will only track failed user authentication attempts for local users in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

From "faillock.conf" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

The preauth argument must be used when the module is called before the modules which ask for the user credentials such as the password.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to include the use of the pam_faillock.so module in the /etc/pam.d/password-auth file. Add/Modify the appropriate sections of the "/etc/pam.d/password-auth" file to match the following lines:

Note: The "preauth" line must be listed before pam_unix.so.

auth required pam_faillock.so preauth auth required pam_faillock.so authfail account required pam_faillock.so

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-244534r1069319_rule

STIG-ID	RHEL-08-020026
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-244534

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - preauth line
The following file(s) do not contain "^[\s]*auth[\s]*required[\s]*pam_faillock\.so[\s]*preauth":
/etc/pam.d/password-auth
```

```
-----
PASSED - preauth order
The command '/bin/awk 'BEGIN{l=-1;s="pass"} $3 ~ /pam_unix/{l=NR} $4 ~ /preauth/ && !/^(#|)/ &&
l>0 && l<NR { s="fail"; printf "preauth on line %d is after pam_unix on line %d\n", NR, l} END
{print s}' /etc/pam.d/password-auth' returned :
```

pass

RHEL-08-020027 - RHEL 8 systems, versions 8.2 and above, must configure SELinux context type to allow the use of a non-default faillock tally directory.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

From "faillock.conf" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be re-enabled after system reboot. If that is undesirable, a different tally directory must be set with the "dir" option.

SELinux, enforcing a targeted policy, will require any non-default tally directory's security context type to match the default directory's security context type. Without updating the security context type, the pam_faillock module will not write failed login attempts to the non-default tally directory.

Solution

Configure RHEL 8 to allow the use of a non-default faillock tally directory while SELinux enforces a targeted policy.

Create a non-default faillock tally directory (if it does not already exist) with the following example:

```
$ sudo mkdir /var/log/faillock
```

Update the /etc/selinux/targeted/contexts/files/file_contexts.local with "faillog_t" context type for the non-default faillock tally directory with the following command:

```
$ sudo semanage fcontext -a -t faillog_t "/var/log/faillock(/.*)?"
```

Next, update the context type of the non-default faillock directory/subdirectories and files with the following command:

```
$ sudo restorecon -R -v /var/log/faillock
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-171R3	03.01.08b.
800-53	AC-7a.
800-53	AC-7b.
800-53R5	AC-7a.
800-53R5	AC-7b.
CAT	II
CCI	CCI-000044
CCI	CCI-002238
CN-L3	7.1.2.7(f)
CN-L3	7.1.3.1(c)
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5

ITSG-33	AC-7a.
ITSG-33	AC-7b.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV3.2.1	8.1.7
PCI-DSSV4.0	8.3.4
RULE-ID	SV-250315r1017356_rule
STIG-ID	RHEL-08-020027
TBA-FIISB	36.2.4
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-250315

Assets

linuxred-01

The command 'dir=\$(/bin/awk '/^\s*dir/ { print \$3 }' /etc/security/faillock.conf); if [-z "\$dir"]; then echo "fail - dir directive not found in /etc/security/faillock.conf"; else /bin/ls -Zd \$dir; fi' returned :

fail - dir directive not found in /etc/security/faillock.conf

RHEL-08-020035 - RHEL 8.7 and higher must terminate idle user sessions.

Info

Terminating an idle session within a short time period reduces the window of opportunity for unauthorized personnel to take control of a management session enabled on the console or console port that has been left unattended.

Solution

Configure RHEL 8 to log out idle sessions after 10 minutes by editing the `/etc/systemd/logind.conf` file with the following line:

`StopIdleSessionSec=600`

The "logind" service must be restarted for the changes to take effect. To restart the "logind" service, run the following command:

```
$ sudo systemctl restart systemd-logind
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.9
800-171R3	03.13.09
800-53	SC-10
800-53R5	SC-10
CAT	II
CCI	CCI-001133
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.20
ITSG-33	SC-10
ITSG-33	SC-10a.
NESA	T2.3.8
NESA	T4.5.1
NESA	T5.5.1
RULE-ID	SV-257258r1069328_rule
STIG-ID	RHEL-08-020035
SWIFT-CSCV1	2.6
VULN-ID	V-257258

Assets

linuxred-01

The following file(s) do not contain `"(?i)^\[s]*StopIdleSessionSec\[s]*=":`
`/etc/systemd/logind.conf`

RHEL-08-020090 - RHEL 8 must map the authenticated identity to the user or group account for PKI-based authentication.

Info

Without mapping the certificate used to authenticate to the user account, the ability to determine the identity of the individual user or group will not be available for forensic analysis.

There are various methods of mapping certificates to user/group accounts for RHEL 8. For the purposes of this requirement, the check and fix will account for Active Directory mapping. Some of the other possible methods include joining the system to a domain and utilizing a Red Hat idM server, or a local system mapping, where the system is not part of a domain.

Solution

Configure the operating system to map the authenticated identity to the user or group account by adding or modifying the certmap section of the "/etc/sss/sss.conf file based on the following example:

```
[certmap/testing.test/rule_name] matchrule =<SAN>.*EDIPI@mil maprule = (userCertificate;binary={cert!bin})  
domains = testing.test
```

The "sss" service must be restarted for the changes to take effect. To restart the "sss" service, run the following command:

```
$ sudo systemctl restart sss.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.12
800-53	IA-5(2)(c)
800-53R5	IA-5(2)(a)(2)
CAT	II
CCI	CCI-000187
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(2)(c)
NESA	T5.2.3
QCSC-V1	5.2.2
QCSC-V1	13.2

RULE-ID	SV-230355r1017168_rule
STIG-ID	RHEL-08-020090
VULN-ID	V-230355

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-020104 - RHEL 8 systems, version 8.4 and above, must ensure the password complexity module is configured for three retries or less.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks. "pwquality" enforces complex password construction configuration and has the ability to limit brute-force attacks on the system.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. This is set in both: /etc/pam.d/password-auth /etc/pam.d/system-auth By limiting the number of attempts to meet the pwquality module complexity requirements before returning with an error, the system will audit abnormal attempts at password changes.

Solution

Configure RHEL 8 to limit the "pwquality" retry option to "3".

Add or update the following line in the "/etc/security/pwquality.conf" file or a file in the "/etc/security/pwquality.conf.d/" directory to contain the "retry" parameter:

```
retry = 3
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-251716r1069329_rule
STIG-ID	RHEL-08-020104
SWIFT-CSCV1	2.3
VULN-ID	V-251716

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-020110 - RHEL 8 must enforce password complexity by requiring that at least one uppercase character be used.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes pwquality as a mechanism to enforce password complexity. Note that in order to require uppercase characters, without degrading the "minlen" value, the credit value must be expressed as a negative number in "/etc/security/pwquality.conf".

Solution

Configure the operating system to enforce password complexity by requiring that at least one uppercase character be used by setting the "ucredit" option.

Add the following line to /etc/security/pwquality.conf (or modify the line to have the required value):

```
ucredit = -1
```

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07a.
800-53	IA-5(1)(a)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000192
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17

ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(a)
NESA	T5.2.3
NIAV2	AM19a
NIAV2	AM19b
NIAV2	AM19c
NIAV2	AM19d
NIAV2	AM22a
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230357r1017169_rule
STIG-ID	RHEL-08-020110
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.1
TBA-FIISB	26.2.4
VULN-ID	V-230357

Assets

linuxred-01

```
Non-compliant file(s):
    /etc/security/pwquality.conf - regex '^[\\s]*ucredit' found - expect
    '^[\\s]*ucredit[\\s]*=[\\s]*-[1-9][0-9]*[\\s]*$' not found in the following lines:
        20: ucredit = 0
```


RHEL-08-020120 - RHEL 8 must enforce password complexity by requiring that at least one lower-case character be used.

Info

Use of a complex password helps to increase the time and resources required to compromise the password.

Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes pwquality as a mechanism to enforce password complexity. Note that in order to require lower-case characters without degrading the "minlen" value, the credit value must be expressed as a negative number in "/etc/security/pwquality.conf".

Solution

Configure the operating system to enforce password complexity by requiring that at least one lower-case character be used by setting the "lcredit" option.

Add the following line to /etc/security/pwquality.conf (or modify the line to have the required value):

```
lcredit = -1
```

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07a.
800-53	IA-5(1)(a)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000193
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17

ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(a)
NESA	T5.2.3
NIAV2	AM19a
NIAV2	AM19b
NIAV2	AM19c
NIAV2	AM19d
NIAV2	AM22a
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230358r1017170_rule
STIG-ID	RHEL-08-020120
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.1
TBA-FIISB	26.2.4
VULN-ID	V-230358

Assets

linuxred-01

```
Non-compliant file(s):
    /etc/security/pwquality.conf - regex '^[\\s]*lcredit' found - expect
    '^[\\s]*lcredit[\\s]*=[\\s]*-[1-9][0-9]*[\\s]*$' not found in the following lines:
        25: lcredit = 0
```

RHEL-08-020130 - RHEL 8 must enforce password complexity by requiring that at least one numeric character be used.

Info

Use of a complex password helps to increase the time and resources required to compromise the password.

Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. Note that in order to require numeric characters, without degrading the minlen value, the credit value must be expressed as a negative number in "/etc/security/pwquality.conf".

Solution

Configure the operating system to enforce password complexity by requiring that at least one numeric character be used by setting the "dcredit" option.

Add the following line to /etc/security/pwquality.conf (or modify the line to have the required value):

```
dcredit = -1
```

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07a.
800-53	IA-5(1)(a)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000194
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17

ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(a)
NESA	T5.2.3
NIAV2	AM19a
NIAV2	AM19b
NIAV2	AM19c
NIAV2	AM19d
NIAV2	AM22a
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230359r1017171_rule
STIG-ID	RHEL-08-020130
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.1
TBA-FIISB	26.2.4
VULN-ID	V-230359

Assets

linuxred-01

```
Non-compliant file(s):
    /etc/security/pwquality.conf - regex '^[\\s]*dcredit' found - expect
    '^[\\s]*dcredit[\\s]*=[\\s]*-[1-9][0-9]*[\\s]*$' not found in the following lines:
        15: dcredit = 0
```

RHEL-08-020140 - RHEL 8 must require the maximum number of repeating characters of the same character class be limited to four when passwords are changed.

Info

Use of a complex password helps to increase the time and resources required to compromise the password.

Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. The "maxclassrepeat" option sets the maximum number of allowed same consecutive characters in the same class in the new password.

Solution

Configure the operating system to require the change of the number of repeating characters of the same character class when passwords are changed by setting the "maxclassrepeat" option.

Add the following line to "/etc/security/pwquality.conf" conf (or modify the line to have the required value):

```
maxclassrepeat = 4
```

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07b.
800-53	IA-5(1)(b)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000195
CCI	CCI-004066
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(b)
NESA	T5.2.3

NIAV2	AM22d
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230360r1017172_rule
STIG-ID	RHEL-08-020140
SWIFT-CSCV1	4.1
VULN-ID	V-230360

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-020150 - RHEL 8 must require the maximum number of repeating characters be limited to three when passwords are changed.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. The "maxrepeat" option sets the maximum number of allowed same consecutive characters in a new password.

Solution

Configure the operating system to require the change of the number of repeating consecutive characters when passwords are changed by setting the "maxrepeat" option.

Add the following line to "/etc/security/pwquality.conf conf" (or modify the line to have the required value):

maxrepeat = 3

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07b.
800-53	IA-5(1)(b)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000195
CCI	CCI-004066
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(b)
NESA	T5.2.3

NIAV2	AM22d
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230361r1017173_rule
STIG-ID	RHEL-08-020150
SWIFT-CSCV1	4.1
VULN-ID	V-230361

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-020160 - RHEL 8 must require the change of at least four character classes when passwords are changed.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. The "minclass" option sets the minimum number of required classes of characters for the new password (digits, uppercase, lowercase, others).

Solution

Configure the operating system to require the change of at least four character classes when passwords are changed by setting the "minclass" option.

Add the following line to "/etc/security/pwquality.conf" (or modify the line to have the required value):

minclass = 4

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07b.
800-53	IA-5(1)(b)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000195
CCI	CCI-004066
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(b)
NESA	T5.2.3

NIAV2	AM22d
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230362r1017174_rule
STIG-ID	RHEL-08-020160
SWIFT-CSCV1	4.1
VULN-ID	V-230362

Assets

linuxred-01

```
Non-compliant file(s):
/etc/security/pwquality.conf - regex '^[\\s]*minclass' found - expect
'^[\\s]*minclass[\\s]*=[\\s]*([4-9]|[1-9][0-9]+)[\\s]*$' not found in the following lines:
34: minclass = 3
```

RHEL-08-020170 - RHEL 8 must require the change of at least 8 characters when passwords are changed.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. The "difok" option sets the number of characters in a password that must not be present in the old password.

Solution

Configure the operating system to require the change of at least eight of the total number of characters when passwords are changed by setting the "difok" option.

Add the following line to "/etc/security/pwquality.conf" (or modify the line to have the required value):

difok = 8

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07b.
800-53	IA-5(1)(b)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000195
CCI	CCI-004066
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(b)
NESA	T5.2.3

NIAV2	AM22d
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230363r1017175_rule
STIG-ID	RHEL-08-020170
SWIFT-CSCV1	4.1
VULN-ID	V-230363

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-020180 - RHEL 8 passwords must have a 24 hours/1 day minimum password lifetime restriction in /etc/shadow.

Info

Enforcing a minimum password lifetime helps to prevent repeated password changes to defeat the password reuse or history enforcement requirement. If users are allowed to immediately and continually change their password, the password could be repeatedly changed in a short period of time to defeat the organization's policy regarding password reuse.

Solution

Configure non-compliant accounts to enforce a 24 hours/1 day minimum password lifetime:
\$ sudo chage -m 1 [user]

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.07d.
800-53	IA-5(1)(d)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000198
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(d)
NESA	T5.2.3
NIAV2	AM20

NIAV2	AM21
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230364r1017176_rule
STIG-ID	RHEL-08-020180
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.2
VULN-ID	V-230364

Assets

linuxred-01

The command 'v1=\$(/bin/awk '/^UID_MIN/ {print \$2}' /etc/login.defs);/bin/awk -v "uidmin=\${v1}" -F: 'FILENAME == "/etc/passwd" { if (\$3 >= uidmin && \$3 < 65534) users[\$1] } FILENAME == "/etc/shadow" { if (\$1 in users && \$4 < 1) badusers[\$1]; } END { if (length(badusers) > 0){ for (user in badusers) {print user} } else { print "No users found" } }' /etc/passwd /etc/shadow' returned :

awk: cmd. line:1: fatal: cannot open file `/etc/shadow' for reading (Permission denied)

RHEL-08-020190 - RHEL 8 passwords for new users or password changes must have a 24 hours/1 day minimum password lifetime restriction in /etc/login.defs.

Info

Enforcing a minimum password lifetime helps to prevent repeated password changes to defeat the password reuse or history enforcement requirement. If users are allowed to immediately and continually change their password, the password could be repeatedly changed in a short period of time to defeat the organization's policy regarding password reuse.

Solution

Configure the operating system to enforce 24 hours/1 day as the minimum password lifetime.
Add the following line in "/etc/login.defs" (or modify the line to have the required value):
PASS_MIN_DAYS 1

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.07d.
800-53	IA-5(1)(d)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000198
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(d)
NESA	T5.2.3

NIAV2	AM20
NIAV2	AM21
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230365r1017177_rule
STIG-ID	RHEL-08-020190
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.2
VULN-ID	V-230365

Assets

linuxred-01

```
Non-compliant file(s):
/etc/login.defs - regex '(?i)^\s*PASS_MIN_DAYS\s*' found - expect '(?i)^\s*PASS_MIN_DAYS\s*([1-9]|[1-9][0-9]+)\s*$' not found in the following lines:
40: PASS_MIN_DAYS 0
```


RHEL-08-020200 - RHEL 8 user account passwords must have a 60-day maximum password lifetime restriction.

Info

Any password, no matter how complex, can eventually be cracked. Therefore, passwords need to be changed periodically. If RHEL 8 does not limit the lifetime of passwords and force users to change their passwords, there is the risk that RHEL 8 passwords could be compromised.

Solution

Configure RHEL 8 to enforce a 60-day maximum password lifetime.
Add, or modify the following line in the "/etc/login.defs" file:
PASS_MAX_DAYS 60

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.07d.
800-53	IA-5(1)(d)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000199
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(d)
NESA	T5.2.3
NIAV2	AM20

NIAV2	AM21
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230366r1038967_rule
STIG-ID	RHEL-08-020200
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.2
VULN-ID	V-230366

Assets

linuxred-01

```
Non-compliant file(s):
/etc/login.defs - regex '^[\\s]*PASS_MAX_DAYS[\\s]*' found - expect
'^[\\s]*PASS_MAX_DAYS[\\s]*([1-9]|[1-5][0-9]|60)[\\s]*$' not found in the following lines:
39: PASS_MAX_DAYS 99999
```

RHEL-08-020210 - RHEL 8 user account passwords must be configured so that existing passwords are restricted to a 60-day maximum lifetime.

Info

Any password, no matter how complex, can eventually be cracked. Therefore, passwords need to be changed periodically. If RHEL 8 does not limit the lifetime of passwords and force users to change their passwords, there is the risk that RHEL 8 passwords could be compromised.

Solution

Configure non-compliant accounts to enforce a 60-day maximum password lifetime restriction.

```
$ sudo chage -M 60 [user]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.07d.
800-53	IA-5(1)(d)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000199
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(d)
NESA	T5.2.3
NIAV2	AM20

NIAV2	AM21
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230367r1038967_rule
STIG-ID	RHEL-08-020210
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.2
VULN-ID	V-230367

Assets

linuxred-01

```
The command 'v1=$(/bin/awk '/^UID_MIN/ {print $2}' /etc/login.defs);/bin/awk -v "uidmin=${v1}"
-F: 'FILENAME == "/etc/passwd" { if ($3 >= uidmin && $1 != "nfsnobody" && $1 != "nobody")
users[$1] } FILENAME == "/etc/shadow" { if ($1 in users && ($5 < 1 || $5 > 60)) badusers[$1]; }
END { if (length(badusers) > 0){ for (user in badusers) {print user} } else { print "No users
found" } }' /etc/passwd /etc/shadow' returned :
```

```
awk: cmd. line:1: fatal: cannot open file `/etc/shadow' for reading (Permission denied)
```

RHEL-08-020230 - RHEL 8 passwords must have a minimum of 15 characters.

Info

The shorter the password, the lower the number of possible combinations that need to be tested before the password is compromised.

Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks. Password length is one factor of several that helps to determine strength and how long it takes to crack a password. Use of more characters in a password helps to increase exponentially the time and/or resources required to compromise the password.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. Configurations are set in the "etc/security/pwquality.conf" file.

The "minlen", sometimes noted as minimum length, acts as a "score" of complexity based on the credit components of the "pwquality" module. By setting the credit components to a negative value, not only will those components be required, they will not count towards the total "score" of "minlen". This will enable "minlen" to require a 15-character minimum.

The DoD minimum password requirement is 15 characters.

Solution

Configure operating system to enforce a minimum 15-character password length.

Add the following line to "/etc/security/pwquality.conf" (or modify the line to have the required value):

```
minlen = 15
```

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07a.
800-53	IA-5(1)(a)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000205
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16

ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(a)
NESA	T5.2.3
NIAV2	AM19a
NIAV2	AM19b
NIAV2	AM19c
NIAV2	AM19d
NIAV2	AM22a
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230369r1017181_rule
STIG-ID	RHEL-08-020230
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.1
TBA-FIISB	26.2.4
VULN-ID	V-230369

Assets

linuxred-01

```
Non-compliant file(s):
/etc/security/pwquality.conf - regex '^[\\s]*minlen[\\s]*=[\\s]*' found - expect
'^[\\s]*minlen[\\s]*=[\\s]*(1[5-9]|[2-9][0-9])[\\s]*$' not found in the following lines:
11: minlen = 6
```

RHEL-08-020231 - RHEL 8 passwords for new users must have a minimum of 15 characters.

Info

The shorter the password, the lower the number of possible combinations that need to be tested before the password is compromised.

Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks. Password length is one factor of several that helps to determine strength and how long it takes to crack a password. Use of more characters in a password helps to increase exponentially the time and/or resources required to compromise the password.

The DoD minimum password requirement is 15 characters.

Solution

Configure operating system to enforce a minimum 15-character password length for new user accounts.

Add, or modify the following line in the "/etc/login.defs" file:

```
PASS_MIN_LEN 15
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07a.
800-53	IA-5(1)(a)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000205
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3
ITSG-33	IA-5(1)(a)

NESA	T5.2.3
NIAV2	AM19a
NIAV2	AM19b
NIAV2	AM19c
NIAV2	AM19d
NIAV2	AM22a
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230370r1017182_rule
STIG-ID	RHEL-08-020231
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.1
TBA-FIISB	26.2.4
VULN-ID	V-230370

Assets

linuxred-01

```
Non-compliant file(s):
/etc/login.defs - regex '(?i)^\s*PASS_MIN_LEN\s*' found - expect '(?i)^\s*PASS_MIN_LEN\s*(1[5-9]|[2-9][0-9])\s*$' not found in the following lines:
41: PASS_MIN_LEN 5
```


RHEL-08-020250 - RHEL 8 must implement smart card login for multifactor authentication for access to interactive accounts.

Info

Using an authentication device, such as a Common Access Card (CAC) or token that is separate from the information system, ensures that even if the information system is compromised, that compromise will not affect credentials stored on the authentication device.

Multifactor solutions that require devices separate from information systems gaining access include, for example, hardware tokens providing time-based or challenge-response authenticators and smart cards such as the U.S. Government Personal Identity Verification card and the DoD CAC.

There are various methods of implementing multifactor authentication for RHEL 8. Some methods include a local system multifactor account mapping or joining the system to a domain and utilizing a Red Hat idM server or Microsoft Windows Active Directory server. Any of these methods will require that the client operating system handle the multifactor authentication correctly.

Satisfies: SRG-OS-000105-GPOS-00052, SRG-OS-000106-GPOS-00053, SRG-OS-000107-GPOS-00054, SRG-OS-000108-GPOS-00055

Solution

Configure RHEL 8 to use multifactor authentication for local access to accounts.

Add or update the "pam_cert_auth" setting in the "/etc/sss/sss.conf" file to match the following line:

```
[pam] pam_cert_auth = True
```

Add or update "pam_sss.so" with "try_cert_auth" or "require_cert_auth" in the "/etc/pam.d/system-auth" and "/etc/pam.d/smartcard-auth" files based on the following examples:

```
/etc/pam.d/smartcard-auth:auth sufficient pam_sss.so try_cert_auth
```

```
/etc/pam.d/system-auth:auth [success=done authinfo_unavail=ignore ignore=ignore default=die] pam_sss.so try_cert_auth
```

The "sss" service must be restarted for the changes to take effect. To restart the "sss" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.3
800-171R3	03.05.03
800-53	IA-2(1)
800-53R5	IA-2(1)
CAT	II
CCI	CCI-000765
CN-L3	7.1.2.7(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)

ISO-27001-2022	A.5.16
ITSG-33	IA-2(1)
NESA	T5.4.2
NIAV2	AM36
NIAV2	VL3c
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230372r1017184_rule
STIG-ID	RHEL-08-020250
SWIFT-CSCV1	1.2
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-230372

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - pam_cert_auth
No matching files were found
Less than 1 matches of regex found

FAILED - pam_sss.so
The following file(s) do not contain "[\s]*auth[^\n\r]+pam_sss.so[^\n\r]+(try_cert_auth|require_cert_auth)[^\n\r]*\$":
 /etc/pam.d/smartcard-auth
 /etc/pam.d/system-auth

RHEL-08-020260 - RHEL 8 account identifiers (individuals, groups, roles, and devices) must be disabled after 35 days of inactivity.

Info

Inactive identifiers pose a risk to systems and applications because attackers may exploit an inactive identifier and potentially obtain undetected access to the system. Owners of inactive accounts will not notice if unauthorized access to their user account has been obtained.

RHEL 8 needs to track periods of inactivity and disable application identifiers after 35 days of inactivity.

Solution

Configure RHEL 8 to disable account identifiers after 35 days of inactivity after the password expiration.

Run the following command to change the configuration for useradd:

```
$ sudo useradd -D -f 35
```

DoD recommendation is 35 days, but a lower value is acceptable. The value "-1" will disable this feature, and "0" will disable the account immediately after the password expires.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.5
800-171	3.5.6
800-171R3	03.05.05
800-53	IA-4e.
800-53R5	AC-2(3)(a)
CAT	II
CCI	CCI-000795
CCI	CCI-003627
CN-L3	7.1.2.7(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ITSG-33	IA-4e.
PCI-DSSV3.2.1	8.1.4
PCI-DSSV4.0	8.2.6
QCSC-V1	5.2.2

QCSC-V1	13.2
RULE-ID	SV-230373r1017185_rule
STIG-ID	RHEL-08-020260
SWIFT-CSCV1	5
VULN-ID	V-230373

Assets

linuxred-01

Non-compliant file(s):
/etc/default/useradd - regex '^[\s]*INACTIVE[\s]*=[\s]*' found - expect
'^[\s]*INACTIVE[\s]*=[\s]*([0-9]|[12][0-9]|3[0-5])[\s]*\$' not found in the following lines:
4: INACTIVE=-1

RHEL-08-020280 - All RHEL 8 passwords must contain at least one special character.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. Note that to require special characters without degrading the "minlen" value, the credit value must be expressed as a negative number in "/etc/security/pwquality.conf".

Solution

Configure the operating system to enforce password complexity by requiring that at least one special character be used by setting the "ocredit" option.

Add the following line to /etc/security/pwquality.conf (or modify the line to have the required value):

```
ocredit = -1
```

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.7
800-171R3	03.05.07a.
800-53	IA-5(1)(a)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-001619
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3

ITSG-33	IA-5(1)(a)
NESA	T5.2.3
NIAV2	AM19a
NIAV2	AM19b
NIAV2	AM19c
NIAV2	AM19d
NIAV2	AM22a
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230375r1017187_rule
STIG-ID	RHEL-08-020280
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.1
TBA-FIISB	26.2.4
VULN-ID	V-230375

Assets

linuxred-01

```
Non-compliant file(s):
/etc/security/pwquality.conf - regex '^[\\s]*ocredit' found - expect
'^[\\s]*ocredit[\\s]*=[\\s]*-[1-9][0-9]*[\\s]*$' not found in the following lines:
30: ocredit = 0
```

RHEL-08-020300 - RHEL 8 must prevent the use of dictionary words for passwords.

Info

If RHEL 8 allows the user to select passwords based on dictionary words, this increases the chances of password compromise by increasing the opportunity for successful guesses, and brute-force attacks.

Solution

Configure RHEL 8 to prevent the use of dictionary words for passwords.

Add or update the following line in the "/etc/security/pwquality.conf" file or a configuration file in the /etc/pwquality.conf.d/ directory to contain the "dictcheck" parameter:

dictcheck=1

Remove any configurations that conflict with the above value.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230377r1017188_rule
STIG-ID	RHEL-08-020300
SWIFT-CSCV1	2.3
VULN-ID	V-230377

Assets

linuxred-01

No matching files were found

Less than 1 matches of regex found

RHEL-08-020310 - RHEL 8 must enforce a delay of at least four seconds between logon prompts following a failed logon attempt.

Info

Configuring the operating system to implement organization-wide security implementation guides and security checklists verifies compliance with federal standards and establishes a common security baseline across the DoD that reflects the most restrictive security posture consistent with operational requirements.

Configuration settings are the set of parameters that can be changed in hardware, software, or firmware components of the system that affect the security posture and/or functionality of the system. Security-related parameters are those parameters impacting the security state of the system, including the parameters required to satisfy other security control requirements. Security-related parameters include, for example, registry settings; account, file, and directory permission settings; and settings for functions, ports, protocols, services, and remote connections.

Solution

Configure the operating system to enforce a delay of at least four seconds between logon prompts following a failed console logon attempt.

Modify the "/etc/login.defs" file to set the "FAIL_DELAY" parameter to "4" or greater:

```
FAIL_DELAY 4
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230378r1017189_rule
STIG-ID	RHEL-08-020310
SWIFT-CSCV1	2.3
VULN-ID	V-230378

Assets

linuxred-01

The following file(s) do not contain "`^\s*FAIL_DELAY\s*`":
/etc/login.defs

RHEL-08-020330 - RHEL 8 must not allow accounts configured with blank or null passwords.

Info

If an account has an empty password, anyone could log on and run commands with the privileges of that account. Accounts with empty passwords should never be used in operational environments.

Solution

Edit the following line in "/etc/ssh/sshd_config" to prevent logons with empty passwords.

PermitEmptyPasswords no

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230380r1069308_rule
STIG-ID	RHEL-08-020330
SWIFT-CSCV1	2.3
VULN-ID	V-230380

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i PermitEmptyPasswords' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-020331 - RHEL 8 must not allow blank or null passwords in the system-auth file.

Info

If an account has an empty password, anyone could log on and run commands with the privileges of that account. Accounts with empty passwords should never be used in operational environments.

Solution

Remove any instances of the "nullok" option in the "/etc/pam.d/system-auth" file to prevent logons with empty passwords.

Note: Manual changes to the listed file may be overwritten by the "authselect" program.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-268322r1017568_rule
STIG-ID	RHEL-08-020331
SWIFT-CSCV1	2.3
VULN-ID	V-268322

Assets

linuxred-01

Non-compliant file(s):
/etc/pam.d/system-auth - regex '(?i)nullok' found - expect '(?i)^[^#]*nullok' found in the following lines:
5: auth sufficient pam_unix.so try_first_pass nullok
11: password sufficient pam_unix.so try_first_pass use_authtok nullok sha512 shadow

RHEL-08-020332 - RHEL 8 must not allow blank or null passwords in the password-auth file.

Info

If an account has an empty password, anyone could log on and run commands with the privileges of that account. Accounts with empty passwords should never be used in operational environments.

Solution

Remove any instances of the "nullok" option in the "/etc/pam.d/password-auth" file to prevent logons with empty passwords.

Note: Manual changes to the listed file may be overwritten by the "authselect" program.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244541r1017347_rule
STIG-ID	RHEL-08-020332
SWIFT-CSCV1	2.3
VULN-ID	V-244541

Assets

linuxred-01

Non-compliant file(s):
/etc/pam.d/password-auth - regex '(?i)nullok' found - expect '(?i)^[^#]*nullok' found in the following lines:
5: auth sufficient pam_unix.so try_first_pass nullok
11: password sufficient pam_unix.so try_first_pass use_authtok nullok sha512 shadow

RHEL-08-020350 - RHEL 8 must display the date and time of the last successful account logon upon an SSH logon.

Info

Providing users with feedback on when account accesses via SSH last occurred facilitates user recognition and reporting of unauthorized account use.

Solution

Configure SSH to provide users with feedback on when account accesses last occurred by setting the required configuration options in `/etc/pam.d/sshd` or in the `sshd_config` file used by the system (`/etc/ssh/sshd_config` will be used in the example) (this file may be named differently or be in a different location if using a version of SSH that is provided by a third-party vendor).

Modify the `PrintLastLog` line in `/etc/ssh/sshd_config` to match the following:

`PrintLastLog yes`

The SSH service must be restarted for changes to `sshd_config` to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AC-9
800-53R5	AC-9
CAT	II
CCI	CCI-000052
CSF2.0	DE.CM-09
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-9
NESA	T5.5.1
RULE-ID	SV-230382r1069309_rule
STIG-ID	RHEL-08-020350
TBA-FIISB	45.2.4
VULN-ID	V-230382

Assets

linuxred-01

The command `'/sbin/sshd -T | /bin/grep -i PrintLastLog'` returned :

`/etc/ssh/sshd_config: Permission denied`

RHEL-08-020351 - RHEL 8 must define default permissions for all authenticated users in such a way that the user can only read and modify their own files.

Info

Setting the most restrictive default permissions ensures that when new accounts are created, they do not have unnecessary access.

Solution

Configure the operating system to define default permissions for all authenticated users in such a way that the user can only read and modify their own files.

Add or edit the line for the "UMASK" parameter in "/etc/login.defs" file to "077":

UMASK 077

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230383r1017192_rule
STIG-ID	RHEL-08-020351
SWIFT-CSCV1	2.3
VULN-ID	V-230383

Assets

linuxred-01

```
Non-compliant file(s):
/etc/login.defs - regex '^[\s]*(?i)umask[\s]' found - expect '^[\s]*(?i)umask[\s]+077[\s]*$'
not found in the following lines:
25: UMASK 022
```

RHEL-08-020353 - RHEL 8 must define default permissions for logon and non-logon shells.

Info

The umask controls the default access mode assigned to newly created files. A umask of 077 limits new files to mode 600 or less permissive. Although umask can be represented as a four-digit number, the first digit representing special access modes is typically ignored or required to be "0". This requirement applies to the globally configured system defaults and the local interactive user defaults for each account on the system.

Solution

Configure the operating system to define default permissions for all authenticated users in such a way that the user can only read and modify their own files.

Add or edit the lines for the "UMASK" parameter in the "/etc/bashrc", "/etc/csh.cshrc" and "/etc/profile" files to "077":
UMASK 077

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230385r1017194_rule
STIG-ID	RHEL-08-020353
SWIFT-CSCV1	2.3
VULN-ID	V-230385

Assets

linuxred-01

Non-compliant file(s):
/etc/bashrc - regex '^[\s]*(?i)umask[\s]' found - expect '^[\s]*(?i)umask[\s]+077[\s]*\$' not found in the following lines:

```
73:      umask 002
75:      umask 022
/etc/csh.cshrc - regex '^[\\s]*(?i)umask[\\s]' found - expect '^[\\s]*(?i)umask[\\s]+077[\\s]*$'
not found in the following lines:
11:      umask 002
13:      umask 022
/etc/profile - regex '^[\\s]*(?i)umask[\\s]' found - expect '^[\\s]*(?i)umask[\\s]+077[\\s]*$'
not found in the following lines:
60:      umask 002
62:      umask 022
```


RHEL-08-020360 - RHEL 8 must automatically exit interactive command shell user sessions after 10 minutes of inactivity.

Info

Terminating an idle interactive command shell user session within a short time period reduces the window of opportunity for unauthorized personnel to take control of it when left unattended in a virtual terminal or physical console.

Satisfies: SRG-OS-000163-GPOS-00072, SRG-OS-000029-GPOS-00010

Solution

Configure RHEL 8 to exit interactive command shell user sessions after 10 minutes of inactivity.

Add or edit the following line in "/etc/profile.d/tmout.sh":

```
#!/bin/bash
```

```
declare -xr TMOUT=600
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.9
800-171R3	03.13.09
800-53	SC-10
800-53R5	SC-10
CAT	II
CCI	CCI-001133
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.20
ITSG-33	SC-10
ITSG-33	SC-10a.
NESA	T2.3.8
NESA	T4.5.1
NESA	T5.5.1
RULE-ID	SV-279929r1156340_rule
STIG-ID	RHEL-08-020360
SWIFT-CSCV1	2.6
VULN-ID	V-279929

Assets

linuxred-01

No matching files were found

Less than 1 matches of regex found

RHEL-08-030000 - The RHEL 8 audit system must be configured to audit the execution of privileged functions and prevent all software from executing at higher privilege levels than users executing the software.

Info

Misuse of privileged functions, either intentionally or unintentionally by authorized users, or by unauthorized external entities that have compromised information system accounts, is a serious and ongoing concern and can have significant adverse impacts on organizations. Auditing the use of privileged functions is one way to detect such misuse and identify the risk from insider threats and the advanced persistent threat.

Satisfies: SRG-OS-000326-GPOS-00126, SRG-OS-000327-GPOS-00127

Solution

Configure RHEL 8 to audit the execution of the "execve" system call.

Add or update the following file system rules to "/etc/audit/rules.d/audit.rules":

```
-a always,exit -F arch=b32 -S execve -C uid!=euid -F euid=0 -k execpriv
```

```
-a always,exit -F arch=b64 -S execve -C uid!=euid -F euid=0 -k execpriv
```

```
-a always,exit -F arch=b32 -S execve -C gid!=egid -F egid=0 -k execpriv
```

```
-a always,exit -F arch=b64 -S execve -C gid!=egid -F egid=0 -k execpriv
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.5
800-171R3	03.01.05a.
800-53	AC-6(8)
800-53R5	AC-6(8)
CAT	II
CCI	CCI-002233
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.10.6(a)
CSF	PR.AC-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.18

ITSG-33	AC-6
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15c
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-230386r958730_rule
STIG-ID	RHEL-08-030000
SWIFT-CSCV1	5.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3
VULN-ID	V-230386

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - execve b32 uid
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - execve b64 uid
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - execve b32 gid
No files found: /etc/audit/audit.rules
-----
```

FAILED - execve b64 gid
No files found: /etc/audit/audit.rules

RHEL-08-030020 - The RHEL 8 System Administrator (SA) and Information System Security Officer (ISSO) (at a minimum) must be alerted of an audit processing failure event.

Info

It is critical for the appropriate personnel to be aware if a system is at risk of failing to process audit logs as required. Without this notification, the security personnel may be unaware of an impending failure of the audit capability, and system operation may be adversely affected.

Audit processing failures include software/hardware errors, failures in the audit capturing mechanisms, and audit storage capacity being reached or exceeded.

This requirement applies to each audit data storage repository (i.e., distinct information system component where audit records are stored), the centralized audit storage capacity of organizations (i.e., all audit data storage repositories combined), or both.

Solution

Configure "auditd" service to notify the SA and ISSO in the event of an audit processing failure.

Edit the following line in "/etc/audit/auditd.conf" to ensure that administrators are notified via email for those situations:
action_mail_acct = root

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.4
800-171R3	03.03.04a.
800-53	AU-5a.
800-53R5	AU-5a.
CAT	II
CCI	CCI-000139
CN-L3	7.1.3.3(e)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ITSG-33	AU-5a.
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230388r1017196_rule
STIG-ID	RHEL-08-030020
VULN-ID	V-230388

Assets

linuxred-01

No files found: /etc/audit/auditd.conf

RHEL-08-030040 - The RHEL 8 System must take appropriate action when an audit processing failure occurs.

Info

It is critical for the appropriate personnel to be aware if a system is at risk of failing to process audit logs as required. Without this notification, the security personnel may be unaware of an impending failure of the audit capability, and system operation may be adversely affected.

Audit processing failures include software/hardware errors, failures in the audit capturing mechanisms, and audit storage capacity being reached or exceeded.

This requirement applies to each audit data storage repository (i.e., distinct information system component where audit records are stored), the centralized audit storage capacity of organizations (i.e., all audit data storage repositories combined), or both.

Solution

Configure RHEL 8 to shut down by default upon audit failure (unless availability is an overriding concern).

Add or update the following line (depending on configuration "disk_error_action" can be set to "SYSLOG" or "SINGLE" depending on configuration) in "/etc/audit/auditd.conf" file:

```
disk_error_action = HALT
```

If availability has been determined to be more important, and this decision is documented with the ISSO, configure the operating system to notify system administration staff and ISSO staff in the event of an audit processing failure by setting the "disk_error_action" to "SYSLOG".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.4
800-171R3	03.03.04b.
800-53	AU-5b.
800-53R5	AU-5b.
CAT	II
CCI	CCI-000140
CN-L3	7.1.3.3(e)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ITSG-33	AU-5b.
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230390r1038966_rule
STIG-ID	RHEL-08-030040
VULN-ID	V-230390

Assets

linuxred-01

No files found: /etc/audit/auditd.conf

RHEL-08-030060 - The RHEL 8 audit system must take appropriate action when the audit storage volume is full.

Info

It is critical that when RHEL 8 is at risk of failing to process audit logs as required, it takes action to mitigate the failure. Audit processing failures include software/hardware errors; failures in the audit capturing mechanisms; and audit storage capacity being reached or exceeded. Responses to audit failure depend upon the nature of the failure mode. When availability is an overriding concern, other approved actions in response to an audit failure are as follows:

- 1) If the failure was caused by the lack of audit record storage capacity, RHEL 8 must continue generating audit records if possible (automatically restarting the audit service if necessary) and overwriting the oldest audit records in a first-in-first-out manner.
- 2) If audit records are sent to a centralized collection server and communication with this server is lost or the server fails, RHEL 8 must queue audit records locally until communication is restored or until the audit records are retrieved manually. Upon restoration of the connection to the centralized collection server, action should be taken to synchronize the local audit data with the collection server.

Solution

Configure RHEL 8 to shut down by default upon audit failure (unless availability is an overriding concern). Add or update the following line (depending on configuration "disk_full_action" can be set to "SYSLOG" or "SINGLE" depending on configuration) in "/etc/audit/auditd.conf" file:

```
disk_full_action = HALT
```

If availability has been determined to be more important, and this decision is documented with the ISSO, configure the operating system to notify system administration staff and ISSO staff in the event of an audit processing failure by setting the "disk_full_action" to "SYSLOG".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.4
800-171R3	03.03.04b.
800-53	AU-5b.
800-53R5	AU-5b.
CAT	II
CCI	CCI-000140
CN-L3	7.1.3.3(e)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ITSG-33	AU-5b.
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230392r1038966_rule

STIG-ID

RHEL-08-030060

VULN-ID

V-230392

Assets

linuxred-01

No files found: /etc/audit/auditd.conf

RHEL-08-030061 - The RHEL 8 audit system must audit local events.

Info

Without establishing what type of events occurred, the source of events, where events occurred, and the outcome of events, it would be difficult to establish, correlate, and investigate the events leading up to an outage or attack. Audit record content that may be necessary to satisfy this requirement includes, for example, time stamps, source and destination addresses, user/process identifiers, event descriptions, success/fail indications, filenames involved, and access control or flow control rules invoked.

Solution

Configure RHEL 8 to audit local events on the system.
Add or update the following line in "/etc/audit/auditd.conf" file:
local_events = yes

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230393r1017200_rule
STIG-ID	RHEL-08-030061
SWIFT-CSCV1	2.3
VULN-ID	V-230393

Assets

linuxred-01

No files found: /etc/audit/auditd.conf

RHEL-08-030062 - RHEL 8 must label all off-loaded audit logs before sending them to the central log server.

Info

Without establishing what type of events occurred, the source of events, where events occurred, and the outcome of events, it would be difficult to establish, correlate, and investigate the events leading up to an outage or attack. Audit record content that may be necessary to satisfy this requirement includes, for example, time stamps, source and destination addresses, user/process identifiers, event descriptions, success/fail indications, filenames involved, and access control or flow control rules invoked.

Enriched logging is needed to determine who, what, and when events occur on a system. Without this, determining root cause of an event will be much more difficult.

When audit logs are not labeled before they are sent to a central log server, the audit data will not be able to be analyzed and tied back to the correct system.

Solution

Edit the `/etc/audit/auditd.conf` file and add or update the "name_format" option:

```
name_format = hostname
```

The audit daemon must be restarted for changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4(1)
800-53R5	AU-4(1)
CAT	II
CCI	CCI-001851
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230394r958754_rule
STIG-ID	RHEL-08-030062
VULN-ID	V-230394

Assets

linuxred-01

No files found: /etc/audit/auditd.conf

RHEL-08-030063 - RHEL 8 must resolve audit information before writing to disk.

Info

Without establishing what type of events occurred, the source of events, where events occurred, and the outcome of events, it would be difficult to establish, correlate, and investigate the events leading up to an outage or attack. Audit record content that may be necessary to satisfy this requirement includes, for example, time stamps, source and destination addresses, user/process identifiers, event descriptions, success/fail indications, filenames involved, and access control or flow control rules invoked.

Enriched logging aids in making sense of who, what, and when events occur on a system. Without this, determining root cause of an event will be much more difficult.

Solution

Edit the `/etc/audit/auditd.conf` file and add or update the `"log_format"` option:

`log_format = ENRICHED`

The audit daemon must be restarted for changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230395r1017201_rule
STIG-ID	RHEL-08-030063
SWIFT-CSCV1	2.3
VULN-ID	V-230395

Assets

linuxred-01

No files found: `/etc/audit/auditd.conf`

RHEL-08-030070 - RHEL 8 audit logs must have a mode of 0600 or less permissive to prevent unauthorized read access.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029, SRG-OS-000206-GPOS-00084

Solution

Configure the audit log to be protected from unauthorized read access by setting the correct permissive mode with the following command:

```
$ sudo chmod 0600 /var/log/audit/audit.log
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9

NESA	M5.2.3
NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230396r1017202_rule
STIG-ID	RHEL-08-030070
VULN-ID	V-230396

Assets

linuxred-01

```
The command 'logfile=$(/bin/grep -iw ^s*log_file /etc/audit/auditd.conf); if [ ! -z
"${logfile}" ]; then /bin/stat -c "%n %a" $(/bin/dirname ${logfile} | /bin/grep "/" )/* | /bin/
grep -Ev '^[^1-7][0-6]00' | /bin/awk '{print} END {if (NR == 0) print "All files have a mode of
0600 or less"; else print "Failing files found"}'; else echo "log_file variable in /etc/audit/
auditd.conf not set"; fi' returned :
```

```
/bin/grep: /etc/audit/auditd.conf: Permission denied
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030080 - RHEL 8 audit logs must be owned by root to prevent unauthorized read access.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029, SRG-OS-000206-GPOS-00084

Solution

Configure the audit log to be protected from unauthorized read access, by setting the correct owner as "root" with the following command:

```
$ sudo chown root [audit_log_file]
```

Replace "[audit_log_file]" to the correct audit log path, by default this location is "/var/log/audit/audit.log".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9

NESA	M5.2.3
NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230397r1017203_rule
STIG-ID	RHEL-08-030080
VULN-ID	V-230397

Assets

linuxred-01

The command 'logfile=\$(/bin/grep -iw ^\s*log_file /etc/audit/auditd.conf | /bin/awk -F= '{print \$2}'); if [! -z "\${logfile}"]; then /bin/stat -c "%n %U" \${logfile} | /bin/grep -Ev 'root' | /bin/awk '{print} END {if (NR == 0) print "Log file owned by root"; else print "Failing files found"}'; else echo "log_file variable in /etc/audit/auditd.conf not set"; fi' returned :

```
/bin/grep: /etc/audit/auditd.conf: Permission denied
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030090 - RHEL 8 audit logs must be group-owned by root to prevent unauthorized read access.

Info

Unauthorized disclosure of audit records can reveal system and configuration data to attackers, thus compromising its confidentiality.

Audit information includes all information (e.g., audit records, audit settings, audit reports) needed to successfully audit RHEL 8 activity.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029

Solution

Configure the audit log to be owned by root by configuring the log group in the `/etc/audit/auditd.conf` file:

`log_group = root`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3
NESA	M5.5.2

NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230398r1017204_rule
STIG-ID	RHEL-08-030090
VULN-ID	V-230398

Assets

linuxred-01

The command 'logfile=\$(/bin/grep -iw ^s*log_file /etc/audit/auditd.conf | /bin/awk -F= '{print \$2}'); if [! -z "\${logfile}"]; then /bin/stat -c "%n %G" "\${logfile} | /bin/grep -Ev 'root' | /bin/awk '{print} END {if (NR == 0) print "Log file group owned by root"; else print "Failing files found"}'; else echo "log_file variable in /etc/audit/auditd.conf not set"; fi' returned :

```
/bin/grep: /etc/audit/auditd.conf: Permission denied
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030100 - RHEL 8 audit log directory must be owned by root to prevent unauthorized read access.

Info

Unauthorized disclosure of audit records can reveal system and configuration data to attackers, thus compromising its confidentiality.

Audit information includes all information (e.g., audit records, audit settings, audit reports) needed to successfully audit RHEL 8 activity.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029

Solution

Configure the audit log to be protected from unauthorized read access, by setting the correct owner as "root" with the following command:

```
$ sudo chown root [audit_log_directory]
```

Replace "[audit_log_directory]" with the correct audit log directory path, by default this location is usually "/var/log/audit".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230399r1017205_rule
STIG-ID	RHEL-08-030100
VULN-ID	V-230399

Assets

linuxred-01

```
The command 'logfile=$(/bin/grep -iw ^\s*log_file /etc/audit/auditd.conf); if [ ! -z
"${logfile}" ]; then /bin/stat -c "%n %U" $(/bin/dirname ${logfile} | /bin/grep "/" ) | /bin/grep
-Ev 'root' | /bin/awk '{print} END {if (NR == 0) print "Log directory owned by root"; else print
"Failing files found"}'; else echo "log_file variable in /etc/audit/auditd.conf not set"; fi'
returned :
```

```
/bin/grep: /etc/audit/auditd.conf: Permission denied
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030110 - RHEL 8 audit log directory must be group-owned by root to prevent unauthorized read access.

Info

Unauthorized disclosure of audit records can reveal system and configuration data to attackers, thus compromising its confidentiality.

Audit information includes all information (e.g., audit records, audit settings, audit reports) needed to successfully audit RHEL 8 activity.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029

Solution

Configure the audit log to be protected from unauthorized read access by setting the correct group-owner as "root" with the following command:

```
$ sudo chgrp root [audit_log_directory]
```

Replace "[audit_log_directory]" with the correct audit log directory path, by default this location is usually "/var/log/audit".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230400r1017206_rule
STIG-ID	RHEL-08-030110
VULN-ID	V-230400

Assets

linuxred-01

```
The command 'logfile=$(/bin/grep -iw ^\s*log_file /etc/audit/auditd.conf); if [ ! -z
"${logfile}" ]; then /bin/stat -c "%n %G" $(/bin/dirname ${logfile} | /bin/grep "/" ) | /bin/grep
-Ev 'root' | /bin/awk '{print} END {if (NR == 0) print "Log directory group owned by root"; else
print "Failing files found"}'; else echo "log_file variable in /etc/audit/auditd.conf not set";
fi' returned :
```

```
/bin/grep: /etc/audit/auditd.conf: Permission denied
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030120 - RHEL 8 audit log directory must have a mode of 0700 or less permissive to prevent unauthorized read access.

Info

Unauthorized disclosure of audit records can reveal system and configuration data to attackers, thus compromising its confidentiality.

Audit information includes all information (e.g., audit records, audit settings, audit reports) needed to successfully audit RHEL 8 system activity.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029

Solution

Configure the audit log directory to be protected from unauthorized read access by setting the correct permissive mode with the following command:

```
$ sudo chmod 0700 [audit_log_directory]
```

Replace "[audit_log_directory]" to the correct audit log directory path, by default this location is "/var/log/audit".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230401r1017207_rule
STIG-ID	RHEL-08-030120
VULN-ID	V-230401

Assets

linuxred-01

```
The command 'logfile=$(/bin/grep -iw ^\s*log_file /etc/audit/auditd.conf); if [ ! -z
"${logfile}" ]; then /bin/stat -c "%n %a" $(/bin/dirname ${logfile} | /bin/grep "/" ) | /bin/grep
-Ev '^[^1-7][0-7]00' | /bin/awk '{print} END {if (NR == 0) print "Audit directory has a mode of
0700 or less"; else print "Failing files found"}'; else echo "log_file variable in /etc/audit/
auditd.conf not set"; fi' returned :
```

```
/bin/grep: /etc/audit/auditd.conf: Permission denied
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030121 - RHEL 8 audit system must protect auditing rules from unauthorized change.

Info

Unauthorized disclosure of audit records can reveal system and configuration data to attackers, thus compromising its confidentiality.

Audit information includes all information (e.g., audit records, audit settings, audit reports) needed to successfully audit RHEL 8 system activity.

In immutable mode, unauthorized users cannot execute changes to the audit system to potentially hide malicious activity and then put the audit rules back. A system reboot would be noticeable and a system administrator could then investigate the unauthorized changes.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029

Solution

Configure the audit system to set the audit rules to be immutable by adding the following line to "/etc/audit/rules.d/audit.rules"

-e 2

Note: Once set, the system must be rebooted for auditing to be changed. It is recommended to add this option as the last step in securing the system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9

NESA	M5.2.3
NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230402r1017208_rule
STIG-ID	RHEL-08-030121
VULN-ID	V-230402

Assets

linuxred-01

The command '/bin/grep -v "^\$" /etc/audit/audit.rules | /bin/tail -1' returned :
 /bin/grep: /etc/audit/audit.rules: Permission denied

RHEL-08-030122 - RHEL 8 audit system must protect logon UIDs from unauthorized change.

Info

Unauthorized disclosure of audit records can reveal system and configuration data to attackers, thus compromising its confidentiality.

Audit information includes all information (e.g., audit records, audit settings, audit reports) needed to successfully audit RHEL 8 system activity.

In immutable mode, unauthorized users cannot execute changes to the audit system to potentially hide malicious activity and then put the audit rules back. A system reboot would be noticeable and a system administrator could then investigate the unauthorized changes.

Satisfies: SRG-OS-000057-GPOS-00027, SRG-OS-000058-GPOS-00028, SRG-OS-000059-GPOS-00029

Solution

Configure the audit system to set the logon UIDs to be immutable by adding the following line to "/etc/audit/rules.d/audit.rules"

```
--loginuid-immutable
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-000162
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230403r1017209_rule
STIG-ID	RHEL-08-030122
VULN-ID	V-230403

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030130 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/shadow.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/shadow".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/shadow -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15

ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230404r1017210_rule
STIG-ID	RHEL-08-030130
SWIFT-CSCV1	6.4
VULN-ID	V-230404

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030140 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/security/opasswd.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/security/opasswd".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/security/opasswd -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15

ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230405r1017211_rule
STIG-ID	RHEL-08-030140
SWIFT-CSCV1	6.4
VULN-ID	V-230405

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030150 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/passwd.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/passwd".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/passwd -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15

ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230406r1017212_rule
STIG-ID	RHEL-08-030150
SWIFT-CSCV1	6.4
VULN-ID	V-230406

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030160 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/gshadow.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/gshadow".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/gshadow -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15

ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230407r1017213_rule
STIG-ID	RHEL-08-030160
SWIFT-CSCV1	6.4
VULN-ID	V-230407

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030170 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/group.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, CCI-002884, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/group".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/group -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230408r1017214_rule
STIG-ID	RHEL-08-030170
SWIFT-CSCV1	6.4
VULN-ID	V-230408

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030171 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/sudoers.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, CCI-002884, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/sudoers".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/sudoers -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230409r1017215_rule
STIG-ID	RHEL-08-030171
SWIFT-CSCV1	6.4
VULN-ID	V-230409

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030172 - RHEL 8 must generate audit records for all account creations, modifications, disabling, and termination events that affect /etc/sudoers.d/.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, CCI-002884, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Solution

Configure RHEL 8 to generate audit records for all account creations, modifications, disabling, and termination events that affect "/etc/sudoers.d/".

Add or update the following file system rule to "/etc/audit/rules.d/audit.rules":

```
-w /etc/sudoers.d/ -p wa -k identity
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230410r1017216_rule
STIG-ID	RHEL-08-030172
SWIFT-CSCV1	6.4
VULN-ID	V-230410

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030190 - Successful/unsuccessful uses of the su command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "su" command allows a user to run commands with a substitute user and group ID.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000064-GPOS-00003, SRG-OS-000392-GPOS-000172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000466-GPOS-00210

Solution

Configure RHEL 8 to generate audit records when successful/unsuccessful attempts to use the "su" command occur by adding or updating the following rule in "/etc/audit/rules.d/audit.rules":

```
-a always,exit -F path=/usr/bin/su -F perm=x -F auid>=1000 -F auid!=unset -k privileged-priv_change
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230412r1017218_rule
STIG-ID	RHEL-08-030190
SWIFT-CSCV1	6.4
VULN-ID	V-230412

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030200 - The RHEL 8 audit system must be configured to audit any usage of the setattr, fsetattr, lsetattr, removexattr, fremovexattr, and lremovexattr system calls.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). "Setxattr" is a system call used to set an extended attribute value.

"Fsetattr" is a system call used to set an extended attribute value. This is used to set extended attributes on a file.

"Lsetattr" is a system call used to set an extended attribute value. This is used to set extended attributes on a symbolic link.

"Removexattr" is a system call that removes extended attributes.

"Fremovexattr" is a system call that removes extended attributes. This is used for removal of extended attributes from a file.

"Lremovexattr" is a system call that removes extended attributes. This is used for removal of extended attributes from symbolic links.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

The system call rules are loaded into a matching engine that intercepts each syscall made by all programs on the system. Therefore, it is very important to use syscall rules only when absolutely necessary since these affect performance. The more rules, the bigger the performance hit. The performance can be helped, however, by combining syscalls into one rule whenever possible.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000458-GPOS-00203, SRG-OS-000462-GPOS-00206, SRG-OS-000463-GPOS-00207, SRG-OS-000468-GPOS-00212, SRG-OS-000471-GPOS-00215, SRG-OS-000474-GPOS-00219, SRG-OS-000466-GPOS-00210

Solution

Configure RHEL 8 to audit the execution of the "setattr", "fsetattr", "lsetattr", "removexattr", "fremovexattr", and "lremovexattr" system calls by adding or updating the following lines to "/etc/audit/rules.d/audit.rules":

```
-a always,exit -F arch=b32 -S setattr,fsetattr,lsetattr,removexattr,fremovexattr,lremovexattr -F auid>=1000 -F auid!=unset -k perm_mod
```

```
-a always,exit -F arch=b64 -S setattr,fsetattr,lsetattr,removexattr,fremovexattr,lremovexattr -F auid>=1000 -F auid!=unset -k perm_mod
```

```
-a always,exit -F arch=b32 -S setattr,fsetattr,lsetattr,removexattr,fremovexattr,lremovexattr -F auid=0 -k perm_mod
```

```
-a always,exit -F arch=b64 -S setattr,fsetattr,lsetattr,removexattr,fremovexattr,lremovexattr -F auid=0 -k perm_mod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1

CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230413r1017219_rule
STIG-ID	RHEL-08-030200
SWIFT-CSCV1	6.4
VULN-ID	V-230413

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - lsetxattr b32 auid=0
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - fsetxattr b64 auid>=1000
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - fsetxattr b64 auid=0
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - lremovexattr b32 auid=0
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - lremovexattr b64 auid=0
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - fsetxattr b32 auid=0
No files found: /etc/audit/audit.rules
-----
```

FAILED - lsetxattr b32 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - setxattr b64 auid=0
No files found: /etc/audit/audit.rules

FAILED - fremovexattr b32 auid=0
No files found: /etc/audit/audit.rules

FAILED - setxattr b64 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - removexattr b64 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - fsetxattr b32 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - removexattr b32 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - fremovexattr b32 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - fremovexattr b64 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - fremovexattr b64 auid=0
No files found: /etc/audit/audit.rules

FAILED - setxattr b32 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - lremovexattr b64 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - lsetxattr b64 auid>=1000
No files found: /etc/audit/audit.rules

FAILED - lsetxattr b64 auid=0
No files [...]

RHEL-08-030250 - Successful/unsuccessful uses of the chage command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "chage" command is used to change or view user password expiry information.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000468-GPOS-00212, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "chage" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/chage -F perm=x -F auid>=1000 -F auid!=unset -k privileged-chage
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230418r1017220_rule
STIG-ID	RHEL-08-030250
SWIFT-CSCV1	6.4
VULN-ID	V-230418

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030260 - Successful/unsuccessful uses of the chcon command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "chcon" command is used to change file SELinux security context.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000468-GPOS-00212, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "chcon" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/chcon -F perm=x -F auid>=1000 -F auid!=unset -k perm_mod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230419r1017221_rule
STIG-ID	RHEL-08-030260
SWIFT-CSCV1	6.4
VULN-ID	V-230419

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030280 - Successful/unsuccessful uses of the ssh-agent in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "ssh-agent" is a program to hold private keys used for public key authentication.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "ssh-agent" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/ssh-agent -F perm=x -F auid>=1000 -F auid!=unset -k privileged-ssh
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230421r1017222_rule
STIG-ID	RHEL-08-030280
SWIFT-CSCV1	6.4
VULN-ID	V-230421

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030290 - Successful/unsuccessful uses of the passwd command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "passwd" command is used to change passwords for user accounts.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "passwd" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/passwd -F perm=x -F auid>=1000 -F auid!=unset -k privileged-passwd
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230422r1017223_rule
STIG-ID	RHEL-08-030290
SWIFT-CSCV1	6.4
VULN-ID	V-230422

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030300 - Successful/unsuccessful uses of the mount command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "mount" command is used to mount a filesystem.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "mount" command by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/mount -F perm=x -F auid>=1000 -F auid!=unset -k privileged-mount
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230423r1017224_rule
STIG-ID	RHEL-08-030300
SWIFT-CSCV1	6.4
VULN-ID	V-230423

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030301 - Successful/unsuccessful uses of the umount command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "umount" command is used to unmount a filesystem.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "umount" command by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/umount -F perm=x -F auid>=1000 -F auid!=unset -k privileged-mount
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230424r1017225_rule
STIG-ID	RHEL-08-030301
SWIFT-CSCV1	6.4
VULN-ID	V-230424

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030302 - Successful/unsuccessful uses of the mount syscall in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "mount" syscall is used to mount a filesystem.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "mount" syscall by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F arch=b32 -S mount -F auid>=1000 -F auid!=unset -k privileged-mount
```

```
-a always,exit -F arch=b64 -S mount -F auid>=1000 -F auid!=unset -k privileged-mount
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230425r1017226_rule
STIG-ID	RHEL-08-030302
SWIFT-CSCV1	6.4
VULN-ID	V-230425

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - b32
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - b64
No files found: /etc/audit/audit.rules
```

RHEL-08-030310 - Successful/unsuccessful uses of the unix_update in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise.

"Unix_update" is a helper program for the "pam_unix" module that updates the password for a given user. It is not intended to be run directly from the command line and logs a security violation if done so.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "unix_update" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/unix_update -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230426r1017227_rule
STIG-ID	RHEL-08-030310
SWIFT-CSCV1	6.4
VULN-ID	V-230426

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030311 - Successful/unsuccessful uses of postdrop in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "postdrop" command creates a file in the maildrop directory and copies its standard input to the file.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "postdrop" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/postdrop -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230427r1017228_rule
STIG-ID	RHEL-08-030311
SWIFT-CSCV1	6.4
VULN-ID	V-230427

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030312 - Successful/unsuccessful uses of postqueue in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "postqueue" command implements the Postfix user interface for queue management.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "postqueue" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/postqueue -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230428r1017229_rule
STIG-ID	RHEL-08-030312
SWIFT-CSCV1	6.4
VULN-ID	V-230428

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030313 - Successful/unsuccessful uses of semanage in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "semanage" command is used to configure certain elements of SELinux policy without requiring modification to or recompilation from policy sources.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "semanage" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/semanage -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230429r1017230_rule
STIG-ID	RHEL-08-030313
SWIFT-CSCV1	6.4
VULN-ID	V-230429

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030314 - Successful/unsuccessful uses of setfiles in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "setfiles" command is primarily used to initialize the security context fields (extended attributes) on one or more filesystems (or parts of them). Usually it is initially run as part of the SELinux installation process (a step commonly known as labeling).

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "setfiles" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/setfiles -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230430r1017231_rule
STIG-ID	RHEL-08-030314
SWIFT-CSCV1	6.4
VULN-ID	V-230430

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030315 - Successful/unsuccessful uses of userhelper in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "userhelper" command is not intended to be run interactively. "Userhelper" provides a basic interface to change a user's password, gecol information, and shell. The main difference between this program and its traditional equivalents (passwd, chfn, chsh) is that prompts are written to standard out to make it easy for a graphical user interface wrapper to interface to it as a child process.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "userhelper" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/userhelper -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b

HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230431r1017232_rule
STIG-ID	RHEL-08-030315
SWIFT-CSCV1	6.4
VULN-ID	V-230431

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030316 - Successful/unsuccessful uses of setsebool in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "setsebool" command sets the current state of a particular SELinux boolean or a list of booleans to a given value. When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "setsebool" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/setsebool -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230432r1017233_rule
STIG-ID	RHEL-08-030316
SWIFT-CSCV1	6.4
VULN-ID	V-230432

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030317 - Successful/unsuccessful uses of unix_chkpwd in RHEL 8 must generate an audit record.

Info

Reconstruction of harmful events or forensic analysis is not possible if audit records do not contain enough information.

At a minimum, the organization must audit the full-text recording of privileged commands. The organization must maintain audit trails in sufficient detail to reconstruct events to determine the cause and impact of compromise. The "unix_chkpwd" command is a helper program for the pam_unix module that verifies the password of the current user. It also checks password and account expiration dates in shadow. It is not intended to be run directly from the command line and logs a security violation if done so.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "unix_chkpwd" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/unix_chkpwd -F perm=x -F auid>=1000 -F auid!=unset -k privileged-unix-update
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230433r1017234_rule
STIG-ID	RHEL-08-030317
SWIFT-CSCV1	6.4
VULN-ID	V-230433

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030320 - Successful/unsuccessful uses of the ssh-keysign in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "ssh-keysign" program is an SSH helper program for host-based authentication.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "ssh-keysign" by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/libexec/openssh/ssh-keysign -F perm=x -F auid>=1000 -F auid!=unset -k privileged-ssh
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230434r1017235_rule
STIG-ID	RHEL-08-030320
SWIFT-CSCV1	6.4
VULN-ID	V-230434

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030330 - Successful/unsuccessful uses of the setfacl command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "setfacl" command is used to set file access control lists.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "setfacl" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/setfacl -F perm=x -F auid>=1000 -F auid!=unset -k perm_mod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230435r1017236_rule
STIG-ID	RHEL-08-030330
SWIFT-CSCV1	6.4
VULN-ID	V-230435

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030340 - Successful/unsuccessful uses of the pam_timestamp_check command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "pam_timestamp_check" command is used to check if the default timestamp is valid.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "pam_timestamp_check" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:
-a always,exit -F path=/usr/sbin/pam_timestamp_check -F perm=x -F auid>=1000 -F auid!=unset -k privileged-pam_timestamp_check

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230436r1017237_rule
STIG-ID	RHEL-08-030340
SWIFT-CSCV1	6.4
VULN-ID	V-230436

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030350 - Successful/unsuccessful uses of the newgrp command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "newgrp" command is used to change the current group ID during a login session.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "newgrp" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/newgrp -F perm=x -F auid>=1000 -F auid!=unset -k priv_cmd
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230437r1017238_rule
STIG-ID	RHEL-08-030350
SWIFT-CSCV1	6.4
VULN-ID	V-230437

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030360 - Successful/unsuccessful uses of the init_module and finit_module system calls in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "init_module" and "finit_module" system calls are used to load a kernel module.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

The system call rules are loaded into a matching engine that intercepts each syscall made by all programs on the system. Therefore, it is very important to use syscall rules only when absolutely necessary since these affect performance. The more rules, the bigger the performance hit. The performance can be helped, however, by combining syscalls into one rule whenever possible.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "init_module" and "finit_module" system calls by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F arch=b32 -S init_module,finit_module -F auid>=1000 -F auid!=unset -k module_chng  
-a always,exit -F arch=b64 -S init_module,finit_module -F auid>=1000 -F auid!=unset -k module_chng
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b

HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230438r1017241_rule
STIG-ID	RHEL-08-030360
SWIFT-CSCV1	6.4
VULN-ID	V-230438

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - 32b init_module
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - 64b init_module
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - 32b finit_module
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - 64b finit_module
No files found: /etc/audit/audit.rules
```


RHEL-08-030361 - Successful/unsuccessful uses of the rename, unlink, rmdir, renameat, and unlinkat system calls in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "rename" system call will rename the specified files by replacing the first occurrence of expression in their name by replacement.

The "unlink" system call deletes a name from the filesystem. If that name was the last link to a file and no processes have the file open, the file is deleted and the space it was using is made available for reuse.

The "rmdir" system call removes empty directories.

The "renameat" system call renames a file, moving it between directories if required.

The "unlinkat" system call operates in exactly the same way as either "unlink" or "rmdir" except for the differences described in the manual page.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

The system call rules are loaded into a matching engine that intercepts each syscall made by all programs on the system. Therefore, it is very important to use syscall rules only when absolutely necessary since these affect performance. The more rules, the bigger the performance hit. Performance can be helped, however, by combining syscalls into one rule whenever possible.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "rename", "unlink", "rmdir", "renameat", and "unlinkat" system calls by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F arch=b32 -S rename,unlink,rmdir,renameat,unlinkat -F auid>=1000 -F auid!=unset -k delete
```

```
-a always,exit -F arch=b64 -S rename,unlink,rmdir,renameat,unlinkat -F auid>=1000 -F auid!=unset -k delete
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03

CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230439r1017243_rule
STIG-ID	RHEL-08-030361
SWIFT-CSCV1	6.4
VULN-ID	V-230439

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```

-----
FAILED - rename b32
No files found: /etc/audit/audit.rules

-----
FAILED - rename b64
No files found: /etc/audit/audit.rules

-----
FAILED - renameat b32
No files found: /etc/audit/audit.rules

-----
FAILED - renameat b64
No files found: /etc/audit/audit.rules

-----
FAILED - rmdir b32
No files found: /etc/audit/audit.rules

-----
FAILED - rmdir b64
No files found: /etc/audit/audit.rules

-----
FAILED - unlink b32
No files found: /etc/audit/audit.rules

-----
FAILED - unlink b64

```

No files found: /etc/audit/audit.rules

FAILED - unlinkat b32

No files found: /etc/audit/audit.rules

FAILED - unlinkat b64

No files found: /etc/audit/audit.rules

RHEL-08-030370 - Successful/unsuccessful uses of the gpasswd command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "gpasswd" command is used to administer /etc/group and /etc/gshadow. Every group can have administrators, members and a password.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "gpasswd" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/gpasswd -F perm=x -F auid>=1000 -F auid!=unset -k privileged-gpasswd
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230444r1017244_rule
STIG-ID	RHEL-08-030370
SWIFT-CSCV1	6.4
VULN-ID	V-230444

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030390 - Successful/unsuccessful uses of the delete_module command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "delete_module" command is used to unload a kernel module.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "delete_module" command by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F arch=b32 -S delete_module -F auid>=1000 -F auid!=unset -k module_chng  
-a always,exit -F arch=b64 -S delete_module -F auid>=1000 -F auid!=unset -k module_chng
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230446r1017245_rule
STIG-ID	RHEL-08-030390
SWIFT-CSCV1	6.4
VULN-ID	V-230446

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - delete_module b32
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - delete_module b64
No files found: /etc/audit/audit.rules
```

RHEL-08-030400 - Successful/unsuccessful uses of the crontab command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "crontab" command is used to maintain crontab files for individual users. Crontab is the program used to install, remove, or list the tables used to drive the cron daemon. This is similar to the task scheduler used in other operating systems.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "crontab" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/crontab -F perm=x -F auid>=1000 -F auid!=unset -k privileged-crontab
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230447r1017246_rule
STIG-ID	RHEL-08-030400
SWIFT-CSCV1	6.4
VULN-ID	V-230447

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030410 - Successful/unsuccessful uses of the chsh command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "chsh" command is used to change the login shell.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "chsh" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/chsh -F perm=x -F auid>=1000 -F auid!=unset -k priv_cmd
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230448r1017247_rule
STIG-ID	RHEL-08-030410
SWIFT-CSCV1	6.4
VULN-ID	V-230448

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030420 - Successful/unsuccessful uses of the truncate, ftruncate, creat, open, openat, and open_by_handle_at system calls in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "truncate" and "ftruncate" functions are used to truncate a file to a specified length.

The "creat" system call is used to open and possibly create a file or device.

The "open" system call opens a file specified by a pathname. If the specified file does not exist, it may optionally be created by "open".

The "openat" system call opens a file specified by a relative pathname.

The "name_to_handle_at" and "open_by_handle_at" system calls split the functionality of "openat" into two parts: "name_to_handle_at" returns an opaque handle that corresponds to a specified file; "open_by_handle_at" opens the file corresponding to a handle returned by a previous call to "name_to_handle_at" and returns an open file descriptor. When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

The system call rules are loaded into a matching engine that intercepts each syscall made by all programs on the system. Therefore, it is very important to use syscall rules only when absolutely necessary since these affect performance. The more rules, the bigger the performance hit. The performance can be helped, however, by combining syscalls into one rule whenever possible.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000064-GPOS-00033

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "truncate", "ftruncate", "creat", "open", "openat", and "open_by_handle_at" system calls by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F arch=b32 -S truncate,ftruncate,creat,open,openat,open_by_handle_at -F exit=-EPERM -F auid>=1000 -F auid!=unset -k perm_access
-a always,exit -F arch=b64 -S truncate,ftruncate,creat,open,openat,open_by_handle_at -F exit=-EPERM -F auid>=1000 -F auid!=unset -k perm_access
-a always,exit -F arch=b32 -S truncate,ftruncate,creat,open,openat,open_by_handle_at -F exit=-EACCES -F auid>=1000 -F auid!=unset -k perm_access
-a always,exit -F arch=b64 -S truncate,ftruncate,creat,open,openat,open_by_handle_at -F exit=-EACCES -F auid>=1000 -F auid!=unset -k perm_access
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7

CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230449r1017249_rule
STIG-ID	RHEL-08-030420
SWIFT-CSCV1	6.4
VULN-ID	V-230449

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - truncate b32 EPERM
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - truncate b64 EPERM
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - truncate b32 EACCES
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - truncate b64 EACCES
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - openat b32 EPERM
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - openat b64 EPERM
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - openat b32 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - openat b64 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - open b32 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED - open b64 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED - open b32 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - open b64 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - open_by_handle_at b32 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED - open_by_handle_at b64 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED - open_by_handle_at b32 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - open_by_handle_at b64 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - ftruncate b32 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED - ftruncate b64 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED - ftruncate b32 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - ftruncate b64 EACCES
No files found: /etc/audit/audit.rules

-----
FAILED - creat b32 EPERM
No files found: /etc/audit/audit.rules

-----
FAILED [...]
```

RHEL-08-030480 - Successful/unsuccessful uses of the chown, fchown, fchownat, and lchown system calls in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "chown" command is used to change file owner and group.

The "fchown" system call is used to change the ownership of a file referred to by the open file descriptor.

The "fchownat" system call is used to change ownership of a file relative to a directory file descriptor.

The "lchown" system call is used to change the ownership of the file specified by a path, which does not dereference symbolic links.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

The system call rules are loaded into a matching engine that intercepts each syscall made by all programs on the system. Therefore, it is very important to use syscall rules only when absolutely necessary since these affect performance. The more rules, the bigger the performance hit. The performance can be helped, however, by combining syscalls into one rule whenever possible.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000064-GPOS-00033, SRG-OS-000466-GPOS-00210

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "chown", "fchown", "fchownat", and "lchown" system calls by adding or updating the following line to "/etc/audit/rules.d/audit.rules":

```
-a always,exit -F arch=b32 -S chown,fchown,fchownat,lchown -F auid>=1000 -F auid!=unset -k perm_mod  
-a always,exit -F arch=b64 -S chown,fchown,fchownat,lchown -F auid>=1000 -F auid!=unset -k perm_mod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04

DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230455r1017251_rule
STIG-ID	RHEL-08-030480
SWIFT-CSCV1	6.4
VULN-ID	V-230455

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```

-----
FAILED - chown b32
No files found: /etc/audit/audit.rules

-----
FAILED - chown b64
No files found: /etc/audit/audit.rules

-----
FAILED - fchownat b32
No files found: /etc/audit/audit.rules

-----
FAILED - fchownat b64
No files found: /etc/audit/audit.rules

-----
FAILED - lchown b32
No files found: /etc/audit/audit.rules

-----
FAILED - lchown b64
No files found: /etc/audit/audit.rules

-----
FAILED - fchown b32
No files found: /etc/audit/audit.rules

-----
FAILED - fchown b64
No files found: /etc/audit/audit.rules

```


RHEL-08-030490 - Successful/unsuccessful uses of the chmod, fchmod, and fchmodat system calls in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "chmod" system call changes the file mode bits of each given file according to mode, which can be either a symbolic representation of changes to make, or an octal number representing the bit pattern for the new mode bits. The "fchmod" system call is used to change permissions of a file.

The "fchmodat" system call is used to change permissions of a file relative to a directory file descriptor.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

The system call rules are loaded into a matching engine that intercepts each syscall made by all programs on the system. Therefore, it is very important to use syscall rules only when absolutely necessary since these affect performance. The more rules, the bigger the performance hit. Performance can be helped, however, by combining syscalls into one rule whenever possible.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000064-GPOS-00033, SRG-OS-000466-GPOS-00210

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "chmod", "fchmod", and "fchmodat" syscalls by adding or updating the following line to "/etc/audit/rules.d/audit.rules":

```
-a always,exit -F arch=b32 -S chmod,fchmod,fchmodat -F auid>=1000 -F auid!=unset -k perm_mod
```

```
-a always,exit -F arch=b64 -S chmod,fchmod,fchmodat -F auid>=1000 -F auid!=unset -k perm_mod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04

DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230456r1017253_rule
STIG-ID	RHEL-08-030490
SWIFT-CSCV1	6.4
VULN-ID	V-230456

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - b32 chmod
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - b64 chmod
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - b32 fchmodat
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - b64 fchmodat
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - b32 fchmod
No files found: /etc/audit/audit.rules
```

```
-----
FAILED - b64 fchmod
No files found: /etc/audit/audit.rules
```

RHEL-08-030550 - Successful/unsuccessful uses of the sudo command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "sudo" command allows a permitted user to execute a command as the superuser or another user, as specified by the security policy.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000466-GPOS-00210

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "sudo" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/sudo -F perm=x -F auid>=1000 -F auid!=unset -k priv_cmd
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230462r1017254_rule
STIG-ID	RHEL-08-030550
SWIFT-CSCV1	6.4
VULN-ID	V-230462

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030560 - Successful/unsuccessful uses of the usermod command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "usermod" command modifies the system account files to reflect the changes that are specified on the command line.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000466-GPOS-00210

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful uses of the "usermod" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/sbin/usermod -F perm=x -F auid>=1000 -F auid!=unset -k privileged-usermod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230463r1017255_rule
STIG-ID	RHEL-08-030560
SWIFT-CSCV1	6.4
VULN-ID	V-230463

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030570 - Successful/unsuccessful uses of the chacl command in RHEL 8 must generate an audit record.

Info

Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one. Audit records can be generated from various components within the information system (e.g., module or policy filter). The "chacl" command is used to change the access control list of a file or directory.

When a user logs on, the AUID is set to the UID of the account that is being authenticated. Daemons are not user sessions and have the loginuid set to "-1". The AUID representation is an unsigned 32-bit integer, which equals "4294967295". The audit system interprets "-1", "4294967295", and "unset" in the same way.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000466-GPOS-00210

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful use of the "chacl" command by adding or updating the following rule in the "/etc/audit/rules.d/audit.rules" file:

```
-a always,exit -F path=/usr/bin/chacl -F perm=x -F auid>=1000 -F auid!=unset -k perm_mod
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)

ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230464r1017256_rule
STIG-ID	RHEL-08-030570
SWIFT-CSCV1	6.4
VULN-ID	V-230464

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030580 - Successful/unsuccessful uses of the kmod command in RHEL 8 must generate an audit record.

Info

Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter). The "kmod" command is used to control Linux Kernel modules.

The list of audited events is the set of events for which audits are to be generated. This set of events is typically a subset of the list of all events for which the system is capable of generating audit records.

DoD has defined the list of events for which RHEL 8 will provide an audit record generation capability as the following:

- 1) Successful and unsuccessful attempts to access, modify, or delete privileges, security objects, security levels, or categories of information (e.g., classification levels);
- 2) Access actions, such as successful and unsuccessful logon attempts, privileged activities or other system-level access, starting and ending time for user access to the system, concurrent logons from different workstations, successful and unsuccessful accesses to objects, all program initiations, and all direct access to the information system;
- 3) All account creations, modifications, disabling, and terminations; and
- 4) All kernel module load, unload, and restart actions.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000471-GPOS-00216, SRG-OS-000477-GPOS-00222

Solution

Configure RHEL 8 to audit the execution of the module management program "kmod" by adding or updating the following line to "/etc/audit/rules.d/audit.rules":

```
-a always,exit -F path=/usr/bin/kmod -F perm=x -F auid>=1000 -F auid!=unset -k modules
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04

DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230465r1017257_rule
STIG-ID	RHEL-08-030580
SWIFT-CSCV1	6.4
VULN-ID	V-230465

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030590 - Successful/unsuccessful modifications to the faillock log file in RHEL 8 must generate an audit record.

Info

Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter).

The list of audited events is the set of events for which audits are to be generated. This set of events is typically a subset of the list of all events for which the system is capable of generating audit records.

DoD has defined the list of events for which RHEL 8 will provide an audit record generation capability as the following:

1) Successful and unsuccessful attempts to access, modify, or delete privileges, security objects, security levels, or categories of information (e.g., classification levels);

2) Access actions, such as successful and unsuccessful logon attempts, privileged activities or other system-level access, starting and ending time for user access to the system, concurrent logons from different workstations, successful and unsuccessful accesses to objects, all program initiations, and all direct access to the information system;

3) All account creations, modifications, disabling, and terminations; and

4) All kernel module load, unload, and restart actions.

From "Pam_Faillock man" pages: Note the default directory that pam_faillock uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000473-GPOS-00218

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful modifications to the "faillock" file by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-w /var/log/faillock -p wa -k logins
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09

CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230466r1017258_rule
STIG-ID	RHEL-08-030590
SWIFT-CSCV1	6.4
VULN-ID	V-230466

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030600 - Successful/unsuccessful modifications to the lastlog file in RHEL 8 must generate an audit record.

Info

Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter). The list of audited events is the set of events for which audits are to be generated. This set of events is typically a subset of the list of all events for which the system is capable of generating audit records.

DoD has defined the list of events for which RHEL 8 will provide an audit record generation capability as the following:

- 1) Successful and unsuccessful attempts to access, modify, or delete privileges, security objects, security levels, or categories of information (e.g., classification levels);
- 2) Access actions, such as successful and unsuccessful logon attempts, privileged activities or other system-level access, starting and ending time for user access to the system, concurrent logons from different workstations, successful and unsuccessful accesses to objects, all program initiations, and all direct access to the information system;
- 3) All account creations, modifications, disabling, and terminations; and
- 4) All kernel module load, unload, and restart actions.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000473-GPOS-00218

Solution

Configure the audit system to generate an audit event for any successful/unsuccessful modifications to the "lastlog" file by adding or updating the following rules in the "/etc/audit/rules.d/audit.rules" file:

```
-w /var/log/lastlog -p wa -k logins
```

The audit daemon must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG

GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230467r1017259_rule
STIG-ID	RHEL-08-030600
SWIFT-CSCV1	6.4
VULN-ID	V-230467

Assets

linuxred-01

No files found: /etc/audit/audit.rules

RHEL-08-030601 - RHEL 8 must enable auditing of processes that start prior to the audit daemon.

Info

Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

If auditing is enabled late in the startup process, the actions of some startup processes may not be audited. Some audit systems also maintain state information only available if auditing is enabled before a given process is created. Audit records can be generated from various components within the information system (e.g., module or policy filter). The list of audited events is the set of events for which audits are to be generated. This set of events is typically a subset of the list of all events for which the system is capable of generating audit records.

DoD has defined the list of events for which RHEL 8 will provide an audit record generation capability as the following:

- 1) Successful and unsuccessful attempts to access, modify, or delete privileges, security objects, security levels, or categories of information (e.g., classification levels);
- 2) Access actions, such as successful and unsuccessful logon attempts, privileged activities or other system-level access, starting and ending time for user access to the system, concurrent logons from different workstations, successful and unsuccessful accesses to objects, all program initiations, and all direct access to the information system;
- 3) All account creations, modifications, disabling, and terminations; and
- 4) All kernel module load, unload, and restart actions.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000473-GPOS-00218

Solution

Configure RHEL 8 to audit processes that start prior to the audit daemon with the following command:

```
$ sudo grubby --update-kernel=ALL --args="audit=1"
```

Add or modify the following line in "/etc/default/grub" to ensure the configuration survives kernel updates:

```
GRUB_CMDLINE_LINUX="audit=1"
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	III
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04

DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230468r1017260_rule
STIG-ID	RHEL-08-030601
SWIFT-CSCV1	6.4
VULN-ID	V-230468

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - grub2-editenv

The command '/bin/grub2-editenv list | /bin/grep audit' returned :

/bin/grub2-editenv: error: cannot open `/boot/grub2/grubenv.new': Permission denied.

FAILED - Check that auditing is enabled by default to persist in kernel updates

Non-compliant file(s):

/etc/default/grub - regex '^[^s]*GRUB_CMDLINE_LINUX=' found - expect '^[^#]+\baudit=1\b' not found in the following lines:

6: GRUB_CMDLINE_LINUX="loglevel=3 crashkernel=auto console=tty1 console=ttyS0
earlyprintk=ttyS0 rootdelay=300 nvme_core.io_timeout=240"

RHEL-08-030602 - RHEL 8 must allocate an audit_backlog_limit of sufficient size to capture processes that start prior to the audit daemon.

Info

Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

If auditing is enabled late in the startup process, the actions of some startup processes may not be audited. Some audit systems also maintain state information only available if auditing is enabled before a given process is created. Audit records can be generated from various components within the information system (e.g., module or policy filter). Allocating an audit_backlog_limit of sufficient size is critical in maintaining a stable boot process. With an insufficient limit allocated, the system is susceptible to boot failures and crashes.

Solution

Configure RHEL 8 to allocate sufficient audit_backlog_limit to capture processes that start prior to the audit daemon with the following command:

```
$ sudo grubby --update-kernel=ALL --args="audit_backlog_limit=8192"
```

Add or modify the following line in "/etc/default/grub" to ensure the configuration survives kernel updates:

```
GRUB_CMDLINE_LINUX="audit_backlog_limit=8192"
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4
800-53R5	AU-4
CAT	III
CCI	CCI-001849
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230469r958752_rule
STIG-ID	RHEL-08-030602
VULN-ID	V-230469

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - grub2-editenv

The command '/bin/grub2-editenv list | /bin/grep audit' returned :

/bin/grub2-editenv: error: cannot open `/boot/grub2/grubenv.new': Permission denied.

FAILED - /etc/default/grub

Non-compliant file(s):

/etc/default/grub - regex '^[\\s]*GRUB_CMDLINE_LINUX=' found - expect '^[^#]+
\\baudit_backlog_limit=(819[2-9]|8[2-9][0-9][0-9]|9[0-9][0-9][0-9]|1[0-9][0-9]{4,})\\b' not found in
the following lines:

6: GRUB_CMDLINE_LINUX="loglevel=3 crashkernel=auto console=tty1 console=ttyS0
earlyprintk=ttyS0 rootdelay=300 nvme_core.io_timeout=240"

RHEL-08-030610 - RHEL 8 must allow only the Information System Security Manager (ISSM) (or individuals or roles appointed by the ISSM) to select which auditable events are to be audited.

Info

Without the capability to restrict the roles and individuals that can select which events are audited, unauthorized personnel may be able to prevent the auditing of critical events. Misconfigured audits may degrade the system's performance by overwhelming the audit log. Misconfigured audits may also make it more difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Solution

Configure the files in directory `/etc/audit/rules.d/` and the `/etc/audit/auditd.conf` file to have a mode of `"0640"` with the following commands:

```
$ sudo chmod 0640 /etc/audit/rules.d/audit.rules $ sudo chmod 0640 /etc/audit/rules.d/[customrulesfile].rules $ sudo  
chmod 0640 /etc/audit/auditd.conf
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03
800-53	AU-12b.
800-53R5	AU-12b.
CAT	II
CCI	CCI-000171
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12b.
PCI-DSSV3.2.1	10.1

QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230471r1069296_rule
STIG-ID	RHEL-08-030610
SWIFT-CSCV1	6.4
VULN-ID	V-230471

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - /etc/audit/rules.d/*.rules  
No files found: /etc/audit/rules.d/*.rules
```

```
-----  
FAILED - auditd.conf  
No files found: /etc/audit/auditd.conf
```

Info

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

To address this risk, audit tools must be cryptographically signed to provide the capability to identify when the audit tools have been modified, manipulated, or replaced. An example is a checksum hash of the file or files.

```
# Audit Tools /usr/sbin/auditctl p+i+n+u+g+s+b+acl+xattrs+sha512 /usr/sbin/auditd p+i+n+u+g+s+b+acl+xattrs
+sha512 /usr/sbin/ausearch p+i+n+u+g+s+b+acl+xattrs+sha512 /usr/sbin/aureport p+i+n+u+g+s+b+acl+xattrs
+sha512 /usr/sbin/autrace p+i+n+u+g+s+b+acl+xattrs+sha512 /usr/sbin/rsyslogd p+i+n+u+g+s+b+acl+xattrs+sha512 /
usr/sbin/auditrules p+i+n+u+g+s+b+acl+xattrs+sha512
```

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9(3)
800-53R5	AU-9(3)
CAT	II
CCI	CCI-001496
CN-L3	8.1.4.3(d)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9(3)
NESA	M5.2.3
NESA	M5.5.2

NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230475r1017266_rule
STIG-ID	RHEL-08-030650
TBA-FIISB	37.3.3
VULN-ID	V-230475

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl
No files found: /etc/aide.conf
```

```
-----
FAILED - autrace
No files found: /etc/aide.conf
```

```
-----
FAILED - aureport
No files found: /etc/aide.conf
```

```
-----
FAILED - ausearch
No files found: /etc/aide.conf
```

```
-----
FAILED - augenrules
No files found: /etc/aide.conf
```

```
-----
FAILED - auditd
No files found: /etc/aide.conf
```

```
-----
FAILED - rsyslogd
No files found: /etc/aide.conf
```

RHEL-08-030655 - RHEL 8 must audit any script or executable called by cron as root or by any privileged user.

Info

Any script or executable called by cron as root or by any privileged user must be owned by that user, must have the permissions set to 755 or more restrictive, and have no extended rights that allow a nonprivileged user to modify the script or executable.

Solution

Configure RHEL 8 to audit the execution of any system call made by cron as root or as any privileged user.

Add or update the following file system rules to "/etc/audit/rules.d/audit.rules":

```
-w /etc/cron.d/ -p wa -k cronjobs
```

```
-w /var/spool/cron/ -p wa -k cronjobs
```

To load the rules to the kernel immediately, use the following command:

```
$ sudo augenrules --load
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12c.
800-53R5	AU-12c.
CAT	II
CCI	CCI-000172
CN-L3	7.1.3.3(a)
CN-L3	7.1.3.3(b)
CN-L3	7.1.3.3(c)
CN-L3	8.1.3.5(a)
CN-L3	8.1.3.5(b)
CN-L3	8.1.4.3(a)
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04

DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.1
ITSG-33	AU-12c.
NESA	T3.6.2
NESA	T3.6.5
NESA	T3.6.6
NIAV2	SM8
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-274877r1155381_rule
STIG-ID	RHEL-08-030655
SWIFT-CSCV1	6.4
TBA-FIISB	45.1.1
VULN-ID	V-274877

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - auditctl /etc/cron.d
The command '/sbin/auditctl -l | /bin/grep /etc/cron.d' returned :

You must be root to run this program.
```

```
-----
FAILED - auditctl /var/spool/cron
The command '/sbin/auditctl -l | /bin/grep /var/spool/cron' returned :

You must be root to run this program.
```


RHEL-08-030690 - The RHEL 8 audit records must be off-loaded onto a different system or storage media from the system being audited.

Info

Information stored in one location is vulnerable to accidental or incidental deletion or alteration.

Off-loading is a common process in information systems with limited audit storage capacity.

RHEL 8 installation media provides "rsyslogd". "rsyslogd" is a system utility providing support for message logging.

Support for both internet and UNIX domain sockets enables this utility to support both local and remote logging.

Couple this utility with "gnutls" (which is a secure communications library implementing the SSL, TLS and DTLS protocols), and you have a method to securely encrypt and off-load auditing.

Rsyslog provides three ways to forward message: the traditional UDP transport, which is extremely lossy but standard; the plain TCP based transport, which loses messages only during certain situations but is widely available; and the RELP transport, which does not lose messages but is currently available only as part of the rsyslogd 3.15.0 and above.

Examples of each configuration:

UDP *.* @remotesystemname TCP *.* @@remotesystemname RELP *.* :omrelp:remotesystemname:2514 Note that a port number was given as there is no standard port for RELP.

Satisfies: SRG-OS-000342-GPOS-00133, SRG-OS-000479-GPOS-00224

Solution

Configure the operating system to offload audit records onto a different system or media from the system being audited by specifying the remote logging server in "/etc/rsyslog.conf" or "/etc/rsyslog.d/[customfile].conf" with the name or IP address of the log aggregation server.

For UDP:

. @[logaggregationserver.example.mil]:[port]

For TCP:

. @@[logaggregationserver.example.mil]:[port]

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4(1)
800-53R5	AU-4(1)
CAT	II
CCI	CCI-001851
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2

RULE-ID	SV-230479r958754_rule
STIG-ID	RHEL-08-030690
VULN-ID	V-230479

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-030700 - RHEL 8 must take appropriate action when the internal event queue is full.

Info

Information stored in one location is vulnerable to accidental or incidental deletion or alteration. Off-loading is a common process in information systems with limited audit storage capacity. RHEL 8 installation media provides "rsyslogd". "rsyslogd" is a system utility providing support for message logging. Support for both internet and UNIX domain sockets enables this utility to support both local and remote logging. Couple this utility with "gnutls" (which is a secure communications library implementing the SSL, TLS and DTLS protocols), and you have a method to securely encrypt and off-load auditing. Satisfies: SRG-OS-000342-GPOS-00133, SRG-OS-000479-GPOS-00224

Solution

Edit the /etc/audit/auditd.conf file and add or update the "overflow_action" option:
overflow_action = syslog
The audit daemon must be restarted for changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4(1)
800-53R5	AU-4(1)
CAT	II
CCI	CCI-001851
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230480r958754_rule
STIG-ID	RHEL-08-030700
VULN-ID	V-230480

Assets

linuxred-01

No files found: /etc/audit/auditd.conf

RHEL-08-030710 - RHEL 8 must encrypt the transfer of audit records off-loaded onto a different system or media from the system being audited.

Info

Information stored in one location is vulnerable to accidental or incidental deletion or alteration. Off-loading is a common process in information systems with limited audit storage capacity. RHEL 8 installation media provides "rsyslogd". "rsyslogd" is a system utility providing support for message logging. Support for both internet and UNIX domain sockets enables this utility to support both local and remote logging. Couple this utility with "gnutls" (which is a secure communications library implementing the SSL, TLS and DTLS protocols), and you have a method to securely encrypt and off-load auditing. Satisfies: SRG-OS-000342-GPOS-00133, SRG-OS-000479-GPOS-00224

Solution

Configure the operating system to encrypt off-loaded audit records by setting the following options in "/etc/rsyslog.conf" or "/etc/rsyslog.d/[customfile].conf":
\$DefaultNetstreamDriver gtls \$ActionSendStreamDriverMode 1

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4(1)
800-53R5	AU-4(1)
CAT	II
CCI	CCI-001851
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230481r958754_rule
STIG-ID	RHEL-08-030710
VULN-ID	V-230481

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - ActionSendStreamDriverMode
No matching files were found
Less than 1 matches of regex found

FAILED - DefaultNetstreamDriver
No matching files were found
Less than 1 matches of regex found

RHEL-08-030730 - RHEL 8 must take action when allocated audit record storage volume reaches 75 percent of the repository maximum audit record storage capacity.

Info

If security personnel are not notified immediately when storage volume reaches 75 percent utilization, they are unable to plan for audit record storage capacity expansion.

Solution

Configure the operating system to initiate an action to notify the SA and ISSO (at a minimum) when allocated audit record storage volume reaches 75 percent of the repository maximum audit record storage capacity by adding/modifying the following line in the `/etc/audit/auditd.conf` file.

`space_left = 25%`

Note: Option names and values in the `auditd.conf` file are case insensitive.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.4
800-171R3	03.03.04
800-53	AU-5(1)
800-53R5	AU-5(1)
CAT	II
CCI	CCI-001855
CN-L3	7.1.3.7(e)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ITSG-33	AU-5(1)
NESA	T3.3.1
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230483r971542_rule
STIG-ID	RHEL-08-030730
TBA-FIISB	37.3.2
VULN-ID	V-230483

Assets

linuxred-01

No files found: `/etc/audit/auditd.conf`

RHEL-08-030731 - RHEL 8 must notify the System Administrator (SA) and Information System Security Officer (ISSO) (at a minimum) when allocated audit record storage volume 75 percent utilization.

Info

If security personnel are not notified immediately when storage volume reaches 75 percent utilization, they are unable to plan for audit record storage capacity expansion.

Solution

Configure the operating system to initiate an action to notify the SA and ISSO (at a minimum) when allocated audit record storage volume reaches 75 percent of the repository maximum audit record storage capacity by adding/modifying the following line in the `/etc/audit/auditd.conf` file.

`space_left_action = email`

Note: Option names and values in the `auditd.conf` file are case insensitive.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.4
800-171R3	03.03.04
800-53	AU-5(1)
800-53R5	AU-5(1)
CAT	II
CCI	CCI-001855
CN-L3	7.1.3.7(e)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ITSG-33	AU-5(1)
NESA	T3.3.1
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-244543r971542_rule
STIG-ID	RHEL-08-030731
TBA-FIISB	37.3.2
VULN-ID	V-244543

Assets

linuxred-01

No files found: `/etc/audit/auditd.conf`

RHEL-08-030740 - RHEL 8 must securely compare internal information system clocks at least every 24 hours with a server synchronized to an authoritative time source, such as the United States Naval Observatory (USNO) time servers, or a time server designated for the appropriate DoD network (NIPRNet/SIPRNet), and/or the Global Positioning System (GPS).

Info

Inaccurate time stamps make it more difficult to correlate events and can lead to an inaccurate analysis. Determining the correct time a particular event occurred on a system is critical when conducting forensic analysis and investigating system events. Sources outside the configured acceptable allowance (drift) may be inaccurate.

Synchronizing internal information system clocks provides uniformity of time stamps for information systems with multiple system clocks and systems connected over a network.

Organizations should consider endpoints that may not have regular access to the authoritative time server (e.g., mobile, teleworking, and tactical endpoints).

If time stamps are not consistently applied and there is no common time reference, it is difficult to perform forensic analysis.

Time stamps generated by the operating system include date and time. Time is commonly expressed in Coordinated Universal Time (UTC), a modern continuation of Greenwich Mean Time (GMT), or local time with an offset from UTC. RHEL 8 utilizes the "timedatectl" command to view the status of the "systemd-timesyncd.service". The "timedatectl" status will display the local time, UTC, and the offset from UTC.

Note that USNO offers authenticated NTP service to DoD and U.S. Government agencies operating on the NIPR and SIPR networks. Visit <https://www.usno.navy.mil/USNO/time/ntp/dod-customers> for more information.

Satisfies: SRG-OS-000355-GPOS-00143, SRG-OS-000356-GPOS-00144, SRG-OS-000359-GPOS-00146

Solution

Configure the operating system to securely compare internal information system clocks at least every 24 hours with an NTP server by adding/modifying the following line in the /etc/chrony.conf file.

server [ntp.server.name] iburst maxpoll 16

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.7
800-171R3	03.03.07
800-53	AU-8(1)(a)
800-53R5	SC-45(1)(a)
CAT	II
CCI	CCI-001891
CCI	CCI-004923
CN-L3	8.1.4.3(b)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.17
ISO/IEC-27001	A.12.4.4
ITSG-33	AU-8(1)

NESA	T3.6.7
NIAV2	NS44
NIAV2	NS45
NIAV2	NS46
NIAV2	NS47
PCI-DSSV3.2.1	10.4
PCI-DSSV3.2.1	10.4.1
PCI-DSSV3.2.1	10.4.3
PCI-DSSV4.0	10.6
PCI-DSSV4.0	10.6.1
PCI-DSSV4.0	10.6.2
PCI-DSSV4.0	10.6.3
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230484r1038944_rule
STIG-ID	RHEL-08-030740
TBA-FIISB	37.4
VULN-ID	V-230484

Assets

linuxred-01

The following file(s) do not contain "^[\s]*(?:server|pool|peer)[\s]+0.us.pool.ntp.mil":
 /etc/chrony.conf

RHEL-08-030741 - RHEL 8 must disable the chrony daemon from acting as a server.

Info

Inaccurate time stamps make it more difficult to correlate events and can lead to an inaccurate analysis. Determining the correct time a particular event occurred on a system is critical when conducting forensic analysis and investigating system events. Sources outside the configured acceptable allowance (drift) may be inaccurate.

Minimizing the exposure of the server functionality of the chrony daemon diminishes the attack surface.

RHEL 8 utilizes the "timedatectl" command to view the status of the "systemd-timesyncd.service". The "timedatectl" status will display the local time, UTC, and the offset from UTC.

Note that USNO offers authenticated NTP service to DOD and U.S. Government agencies operating on the NIPR and SIPR networks. Visit <https://www.usno.navy.mil/USNO/time/ntp/DOD-customers> for more information.

Solution

Configure the operating system to disable the chrony daemon from acting as a server by adding or modifying the following line in the "/etc/chrony.conf" file:
port 0

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230485r1017269_rule

STIG-ID	RHEL-08-030741
---------	----------------

SWIFT-CSCV1	2.3
-------------	-----

VULN-ID	V-230485
---------	----------

Assets

linuxred-01

The following file(s) do not contain "[\s]*port[\s]+":
 /etc/chrony.conf

RHEL-08-030742 - RHEL 8 must disable network management of the chrony daemon.

Info

Inaccurate time stamps make it more difficult to correlate events and can lead to an inaccurate analysis. Determining the correct time a particular event occurred on a system is critical when conducting forensic analysis and investigating system events. Sources outside the configured acceptable allowance (drift) may be inaccurate.

Not exposing the management interface of the chrony daemon on the network diminishes the attack space.

RHEL 8 utilizes the "timedatectl" command to view the status of the "systemd-timesyncd.service". The "timedatectl" status will display the local time, UTC, and the offset from UTC.

Note that USNO offers authenticated NTP service to DOD and U.S. Government agencies operating on the NIPR and SIPR networks. Visit <https://www.usno.navy.mil/USNO/time/ntp/DOD-customers> for more information.

Solution

Configure the operating system disable network management of the chrony daemon by adding or modifying the following line in the "/etc/chrony.conf" file.

```
cmdport 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230486r1017270_rule

STIG-ID	RHEL-08-030742
---------	----------------

SWIFT-CSCV1	2.3
-------------	-----

VULN-ID	V-230486
---------	----------

Assets

linuxred-01

The following file(s) do not contain "^[\s]*cmdport[\s]+":
 /etc/chrony.conf

RHEL-08-040004 - RHEL 8 must enable mitigations against processor-based vulnerabilities.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

Examples of non-essential capabilities include, but are not limited to, games, software packages, tools, and demonstration software not related to requirements or providing a wide array of functionality not required for every mission, but which cannot be disabled.

Verify the operating system is configured to disable non-essential capabilities. The most secure way of ensuring a non-essential capability is disabled is to not have the capability installed.

Kernel page-table isolation is a kernel feature that mitigates the Meltdown security vulnerability and hardens the kernel against attempts to bypass kernel address space layout randomization (KASLR).

Solution

Configure RHEL 8 to enable kernel page-table isolation with the following command:

```
$ sudo grubby --update-kernel=ALL --args="pti=on"
```

Add or modify the following line in "/etc/default/grub" to ensure the configuration survives kernel updates:

```
GRUB_CMDLINE_LINUX="pti=on"
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1

PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230491r1017274_rule
STIG-ID	RHEL-08-040004
SWIFT-CSCV1	2.3
VULN-ID	V-230491

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - Check that kernel enables page-table isolation
The command '/bin/grub2-editenv list | /bin/grep pti' returned :

/bin/grub2-editenv: error: cannot open `/boot/grub2/grubenv.new': Permission denied.

FAILED - page-table isolation enabled

Non-compliant file(s):

/etc/default/grub - regex '^[\\s]*GRUB_CMDLINE_LINUX=' found - expect '^[^#]+\\bpti=on\\b' not found in the following lines:

6: GRUB_CMDLINE_LINUX="loglevel=3 crashkernel=auto console=tty1 console=ttyS0
earlyprintk=ttyS0 rootdelay=300 nvme_core.io_timeout=240"

RHEL-08-040021 - RHEL 8 must disable the asynchronous transfer mode (ATM) protocol.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors. Failing to disconnect unused protocols can result in a system compromise. The Asynchronous Transfer Mode (ATM) is a protocol operating on network, data link, and physical layers, based on virtual circuits and virtual paths. Disabling ATM protects the system against exploitation of any flaws in its implementation.

Solution

Configure the operating system to disable the ability to use the ATM protocol kernel module.
Add or update the following lines in the file "/etc/modprobe.d/blacklist.conf":
install atm /bin/false blacklist atm
Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230494r1069310_rule

STIG-ID	RHEL-08-040021
SWIFT-CSCV1	2.3
VULN-ID	V-230494

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - atm /bin/false  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - atm blacklist  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040022 - RHEL 8 must disable the controller area network (CAN) protocol.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Failing to disconnect unused protocols can result in a system compromise.

The Controller Area Network (CAN) is a serial communications protocol, which was initially developed for automotive and is now also used in marine, industrial, and medical applications. Disabling CAN protects the system against exploitation of any flaws in its implementation.

Solution

Configure the operating system to disable the ability to use the CAN protocol kernel module.

Add or update the following lines in the file "/etc/modprobe.d/blacklist.conf":

install can /bin/false blacklist can

Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230495r1069311_rule

STIG-ID RHEL-08-040022

SWIFT-CSCV1 2.3

VULN-ID V-230495

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - can /bin/false  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - can blacklist  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040023 - RHEL 8 must disable the stream control transmission protocol (SCTP).

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors. Failing to disconnect unused protocols can result in a system compromise. The Stream Control Transmission Protocol (SCTP) is a transport layer protocol, designed to support the idea of message-oriented communication, with several streams of messages within one connection. Disabling SCTP protects the system against exploitation of any flaws in its implementation.

Solution

Configure the operating system to disable the ability to use the SCTP kernel module.
Add or update the following lines in the file "/etc/modprobe.d/blacklist.conf":
install sctp /bin/false blacklist sctp
Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230496r1069312_rule

STIG-ID RHEL-08-040023

SWIFT-CSCV1 2.3

VULN-ID V-230496

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - sctp /bin/false  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sctp blacklist  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040024 - RHEL 8 must disable the transparent inter-process communication (TIPC) protocol.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors. Failing to disconnect unused protocols can result in a system compromise. The Transparent Inter-Process Communication (TIPC) protocol is designed to provide communications between nodes in a cluster. Disabling TIPC protects the system against exploitation of any flaws in its implementation.

Solution

Configure the operating system to disable the ability to use the TIPC protocol kernel module.
Add or update the following lines in the file "/etc/modprobe.d/blacklist.conf":
install tipc /bin/false blacklist tipc
Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230497r1069313_rule

STIG-ID RHEL-08-040024

SWIFT-CSCV1 2.3

VULN-ID V-230497

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - tipc /bin/false  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - tipc blacklist  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040025 - RHEL 8 must disable mounting of cramfs.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors. Removing support for unneeded filesystem types reduces the local attack surface of the server. Compressed ROM/RAM file system (or cramfs) is a read-only file system designed for simplicity and space-efficiency. It is mainly used in embedded and small-footprint systems.

Solution

Configure the operating system to disable the ability to use the cramfs kernel module.
Add or update the following lines in the file "/etc/modprobe.d/blacklist.conf":
install cramfs /bin/false blacklist cramfs
Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230498r1069314_rule

STIG-ID RHEL-08-040025

SWIFT-CSCV1 2.3

VULN-ID V-230498

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - cramfs blacklist  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - cramfs /bin/false  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040026 - RHEL 8 must disable IEEE 1394 (FireWire) Support.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The IEEE 1394 (FireWire) is a serial bus standard for high-speed real-time communication. Disabling FireWire protects the system against exploitation of any flaws in its implementation.

Solution

Configure the operating system to disable the ability to use the firewire-core kernel module.

Add or update the following lines in the file `/etc/modprobe.d/blacklist.conf`:

```
install firewire-core /bin/false blacklist firewire-core
```

Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	III
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230499r1069315_rule
STIG-ID	RHEL-08-040026

SWIFT-CSCV1

2.3

VULN-ID

V-230499

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - firewire-core /bin/false  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - firewire-core modprobe  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040080 - RHEL 8 must be configured to disable USB mass storage.

Info

USB mass storage permits easy introduction of unknown devices, thereby facilitating malicious activity.
Satisfies: SRG-OS-000114-GPOS-00059, SRG-OS-000378-GPOS-00163

Solution

Configure the operating system to disable the ability to use the USB Storage kernel module and the ability to use USB mass storage devices.

Add or update the following lines in the file `/etc/modprobe.d/blacklist.conf`:

```
install usb-storage /bin/false blacklist usb-storage
```

Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.02
800-53	IA-3
800-53R5	IA-3
CAT	II
CCI	CCI-000778
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ITSG-33	IA-3
ITSG-33	IA-3a.
NESA	T5.4.3
QCSC-V1	13.2
RULE-ID	SV-230503r1069316_rule
STIG-ID	RHEL-08-040080
TBA-FIISB	27.1
VULN-ID	V-230503

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - install usb-storage /bin/false
No matching files were found
Less than 1 matches of regex found

FAILED - blacklist usb-storage
No matching files were found
Less than 1 matches of regex found

RHEL-08-040090 - A RHEL 8 firewall must employ a deny-all, allow-by-exception policy for allowing connections to other systems.

Info

Failure to restrict network connectivity only to authorized systems permits inbound connections from malicious systems. It also permits outbound connections that may facilitate exfiltration of DoD data.

RHEL 8 incorporates the "firewalld" daemon, which allows for many different configurations. One of these configurations is zones. Zones can be utilized to a deny-all, allow-by-exception approach. The default "drop" zone will drop all incoming network packets unless it is explicitly allowed by the configuration file or is related to an outgoing network connection.

Solution

Configure the "firewalld" daemon to employ a deny-all, allow-by-exception with the following commands:

```
$ sudo firewall-cmd --permanent --new-zone=[custom]
```

```
$ sudo cp /usr/lib/firewalld/zones/drop.xml /etc/firewalld/zones/[custom].xml
```

This will provide a clean configuration file to work with that employs a deny-all approach.

Note: Add the exceptions that are required for mission functionality and update the short title in the xml file to match the [custom] zone name.

Reload the firewall rules to make the new [custom] zone available to load:

```
$ sudo firewall-cmd --reload
```

Set the default zone to the new [custom] zone:

```
$ sudo firewall-cmd --set-default-zone=[custom]
```

Note: This is a runtime and permanent change.

Add any interfaces to the new [custom] zone:

```
$ sudo firewall-cmd --permanent --zone=[custom] --change-interface=ens33
```

Reload the firewall rules for changes to take effect:

```
$ sudo firewall-cmd --reload
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.12
800-171R3	03.01.12
800-53	AC-17(1)
800-53R5	AC-17(1)
CAT	II
CCI	CCI-002314
CN-L3	8.1.4.4(c)
CN-L3	8.1.10.6(i)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.8.16

ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(1)
NESA	T5.4.4
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230504r958672_rule
STIG-ID	RHEL-08-040090
SWIFT-CSCV1	2.6
VULN-ID	V-230504

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - --info-zone
The command '/bin/firewall-cmd --get-active-zones | /bin/awk '!:/ {print $1}' | while read ZN;
do /bin/firewall-cmd --info-zone=$ZN; done | /bin/grep target' returned :
```

Authorization failed.
Make sure polkit agent is running or run the application as superuser.

```
-----
FAILED - --state
The command '/bin/firewall-cmd --state' returned :
```

Authorization failed.
Make sure polkit agent is running or run the application as superuser.

RHEL-08-040111 - RHEL 8 Bluetooth must be disabled.

Info

Without protection of communications with wireless peripherals, confidentiality and integrity may be compromised because unprotected communications can be intercepted and either read, altered, or used to compromise the RHEL 8 operating system.

This requirement applies to wireless peripheral technologies (e.g., wireless mice, keyboards, displays, etc.) used with RHEL 8 systems. Wireless peripherals (e.g., Wi-Fi/Bluetooth/IR Keyboards, Mice, and Pointing Devices and Near Field Communications [NFC]) present a unique challenge by creating an open, unsecured port on a computer. Wireless peripherals must meet DoD requirements for wireless data transmission and be approved for use by the Authorizing Official (AO). Even though some wireless peripherals, such as mice and pointing devices, do not ordinarily carry information that need to be protected, modification of communications with these wireless peripherals may be used to compromise the RHEL 8 operating system. Communication paths outside the physical protection of a controlled boundary are exposed to the possibility of interception and modification.

Protecting the confidentiality and integrity of communications with wireless peripherals can be accomplished by physical means (e.g., employing physical barriers to wireless radio frequencies) or by logical means (e.g., employing cryptographic techniques). If physical means of protection are employed, then logical means (cryptography) do not have to be employed, and vice versa. If the wireless peripheral is only passing telemetry data, encryption of the data may not be required.

Solution

Configure the operating system to disable the Bluetooth adapter when not in use.

Build or modify the "/etc/modprobe.d/bluetooth.conf" file with the following line:

```
install bluetooth /bin/false
```

Disable the ability to use the Bluetooth kernel module.

```
$ sudo vi /etc/modprobe.d/blacklist.conf
```

Add or update the line:

```
blacklist bluetooth
```

Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.17
800-171R3	03.01.16
800-53	AC-18(1)
800-53R5	AC-18(1)
CAT	II
CCI	CCI-001443
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.14
ISO-27001-2022	A.8.20
ITSG-33	AC-18(1)

NESA	T5.4.2
NIAV2	NS33
NIAV2	NS34
NIAV2	NS38
QCSC-V1	5.2.1
RULE-ID	SV-230507r1017287_rule
STIG-ID	RHEL-08-040111
SWIFT-CSCV1	2.3
VULN-ID	V-230507

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
FAILED - install bluetooth /bin/false
No matching files were found
Less than 1 matches of regex found
```

```
-----
FAILED - blacklist bluetooth
No matching files were found
Less than 1 matches of regex found
```

RHEL-08-040123 - RHEL 8 must mount /tmp with the nodev option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /tmp is mounted with the "nodev" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-tmp /tmp xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230511r958804_rule
STIG-ID	RHEL-08-040123
SWIFT-CSCV1	2.3

Assets**linuxred-01**

Non-compliant file(s):

```
/etc/fstab - regex '^#[\n\r]+[\s]+/tmp[\s]' found - expect '^#[\n\r]+[\s]+/tmp[\s]+#[\n\r]*nodev' not found in the following lines:  
16: /dev/mapper/rootvg-tmplv /tmp                xfs      defaults      0 0
```

RHEL-08-040124 - RHEL 8 must mount /tmp with the nosuid option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /tmp is mounted with the "nosuid" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-tmp /tmp xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230512r958804_rule
STIG-ID	RHEL-08-040124
SWIFT-CSCV1	2.3

Assets**linuxred-01**

Non-compliant file(s):

```
/etc/fstab - regex '^#[\n\r]+[\s]+/tmp[\s]' found - expect '^#[\n\r]+[\s]+/tmp[\s]+#[\n\r]*nosuid' not found in the following lines:  
16: /dev/mapper/rootvg-tmplv /tmp                xfs      defaults      0 0
```

RHEL-08-040125 - RHEL 8 must mount /tmp with the noexec option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /tmp is mounted with the "noexec" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-tmp /tmp xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230513r958804_rule
STIG-ID	RHEL-08-040125
SWIFT-CSCV1	2.3

Assets**linuxred-01**

Non-compliant file(s):

```
/etc/fstab - regex '^#[\n\r]+[\s]+/tmp[\s]' found - expect '^#[\n\r]+[\s]+/tmp[\s]+#[\n\r]*noexec' not found in the following lines:  
16: /dev/mapper/rootvg-tmplv /tmp                xfs      defaults      0 0
```

RHEL-08-040126 - RHEL 8 must mount /var/log with the nodev option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/log is mounted with the "nodev" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-log /var/log xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230514r958804_rule
STIG-ID	RHEL-08-040126
SWIFT-CSCV1	2.3

VULN-ID

V-230514

Assets

linuxred-01

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/log[\s]:"`:
/etc/fstab

RHEL-08-040127 - RHEL 8 must mount /var/log with the nosuid option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/log is mounted with the "nosuid" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-log /var/log xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230515r958804_rule
STIG-ID	RHEL-08-040127
SWIFT-CSCV1	2.3

VULN-ID

V-230515

Assets

linuxred-01

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/log[\s]:"`:
/etc/fstab

RHEL-08-040128 - RHEL 8 must mount /var/log with the noexec option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/log is mounted with the "noexec" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-log /var/log xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230516r958804_rule
STIG-ID	RHEL-08-040128
SWIFT-CSCV1	2.3

Assets**linuxred-01**

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/log[\s]:"`:
 /etc/fstab

RHEL-08-040129 - RHEL 8 must mount /var/log/audit with the nodev option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/log/audit is mounted with the "nodev" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-log-audit /var/log/audit xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230517r958804_rule
STIG-ID	RHEL-08-040129
SWIFT-CSCV1	2.3

VULN-ID

V-230517

Assets

linuxred-01

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/log/audit[\s]:"`:
/etc/fstab

RHEL-08-040130 - RHEL 8 must mount /var/log/audit with the nosuid option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/log/audit is mounted with the "nosuid" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-log-audit /var/log/audit xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230518r958804_rule
STIG-ID	RHEL-08-040130
SWIFT-CSCV1	2.3

VULN-ID

V-230518

Assets

linuxred-01

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/log/audit[\s]:"`:
/etc/fstab

RHEL-08-040131 - RHEL 8 must mount /var/log/audit with the noexec option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/log/audit is mounted with the "noexec" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-log-audit /var/log/audit xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230519r958804_rule
STIG-ID	RHEL-08-040131
SWIFT-CSCV1	2.3

Assets**linuxred-01**

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/log/audit[\s]:"`:
/etc/fstab

RHEL-08-040132 - RHEL 8 must mount /var/tmp with the nodev option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/tmp is mounted with the "nodev" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-tmp /var/tmp xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230520r958804_rule
STIG-ID	RHEL-08-040132
SWIFT-CSCV1	2.3

VULN-ID

V-230520

Assets

linuxred-01

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/tmp[\s]:"`:
/etc/fstab

RHEL-08-040133 - RHEL 8 must mount /var/tmp with the nosuid option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/tmp is mounted with the "nosuid" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-tmp /var/tmp xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230521r958804_rule
STIG-ID	RHEL-08-040133
SWIFT-CSCV1	2.3

VULN-ID

V-230521

Assets

linuxred-01

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/tmp[\s]:"`:
 /etc/fstab

RHEL-08-040134 - RHEL 8 must mount /var/tmp with the noexec option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /var/tmp is mounted with the "noexec" option by adding /modifying the /etc/fstab with the following line:

```
/dev/mapper/rhel-var-tmp /var/tmp xfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230522r958804_rule
STIG-ID	RHEL-08-040134
SWIFT-CSCV1	2.3

Assets**linuxred-01**

The following file(s) do not contain "`^[^#\n\r]+[\s]+/var/tmp[\s]":`
/etc/fstab

RHEL-08-040135 - The RHEL 8 fapolicy module must be installed.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

Utilizing a whitelist provides a configuration management method for allowing the execution of only authorized software. Using only authorized software decreases risk by limiting the number of potential vulnerabilities. Verification of whitelisted software occurs prior to execution or at system startup.

User home directories/folders may contain information of a sensitive nature. Non-privileged users should coordinate any sharing of information with an SA through shared resources.

RHEL 8 ships with many optional packages. One such package is a file access policy daemon called "fapolicyd".

"fapolicyd" is a userspace daemon that determines access rights to files based on attributes of the process and file. It can be used to either blacklist or whitelist processes or file access.

Proceed with caution with enforcing the use of this daemon. Improper configuration may render the system non-functional. The "fapolicyd" API is not namespace aware and can cause issues when launching or running containers. Satisfies: SRG-OS-000368-GPOS-00154, SRG-OS-000370-GPOS-00155, SRG-OS-000480-GPOS-00232

Solution

Install "fapolicyd" with the following command:

```
$ sudo yum install fapolicyd.x86_64
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230523r958804_rule
STIG-ID	RHEL-08-040135
SWIFT-CSCV1	2.3

VULN-ID

V-230523

Assets

linuxred-01

The package 'fapolicyd-0.0.0-0' is not installed

RHEL-08-040136 - The RHEL 8 fapolicy module must be enabled.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

Utilizing a whitelist provides a configuration management method for allowing the execution of only authorized software. Using only authorized software decreases risk by limiting the number of potential vulnerabilities. Verification of whitelisted software occurs prior to execution or at system startup.

User home directories/folders may contain information of a sensitive nature. Non-privileged users should coordinate any sharing of information with an SA through shared resources.

RHEL 8 ships with many optional packages. One such package is a file access policy daemon called "fapolicyd".

"fapolicyd" is a userspace daemon that determines access rights to files based on attributes of the process and file. It can be used to either blacklist or whitelist processes or file access.

Proceed with caution with enforcing the use of this daemon. Improper configuration may render the system non-functional. The "fapolicyd" API is not namespace aware and can cause issues when launching or running containers. Satisfies: SRG-OS-000368-GPOS-00154, SRG-OS-000370-GPOS-00155, SRG-OS-000480-GPOS-00232

Solution

Enable "fapolicyd" using the following command:

```
$ sudo systemctl enable --now fapolicyd
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-244545r958804_rule
STIG-ID	RHEL-08-040136
SWIFT-CSCV1	2.3

VULN-ID

V-244545

Assets

linuxred-01

The command '/bin/systemctl status fapolicyd.service' returned :

Unit fapolicyd.service could not be found.

RHEL-08-040137 - The RHEL 8 fapolicy module must be configured to employ a deny-all, permit-by-exception policy to allow the execution of authorized software programs.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

Utilizing a whitelist provides a configuration management method for allowing the execution of only authorized software. Using only authorized software decreases risk by limiting the number of potential vulnerabilities. Verification of whitelisted software occurs prior to execution or at system startup.

User home directories/folders may contain information of a sensitive nature. Non-privileged users should coordinate any sharing of information with an SA through shared resources.

RHEL 8 ships with many optional packages. One such package is a file access policy daemon called "fapolicyd".

"fapolicyd" is a userspace daemon that determines access rights to files based on attributes of the process and file. It can be used to either blacklist or whitelist processes or file access.

Proceed with caution with enforcing the use of this daemon. Improper configuration may render the system non-functional. The "fapolicyd" API is not namespace aware and can cause issues when launching or running containers. Satisfies: SRG-OS-000368-GPOS-00154, SRG-OS-000370-GPOS-00155, SRG-OS-000480-GPOS-00232

Solution

Configure RHEL 8 to employ a deny-all, permit-by-exception application whitelisting policy with "fapolicyd".

With the "fapolicyd" installed and enabled, configure the daemon to function in permissive mode until the whitelist is built correctly to avoid system lockout. Do this by editing the "/etc/fapolicyd/fapolicyd.conf" file with the following line:

permissive = 1

For RHEL 8.4 systems and older:

Build the whitelist in the "/etc/fapolicyd/fapolicyd.rules" file ensuring the last rule is "deny perm=any all : all".

For RHEL 8.5 systems and newer:

Build the whitelist in a file within the "/etc/fapolicyd/rules.d" directory ensuring the last rule is "deny perm=any all : all".

Once it is determined the whitelist is built correctly, set the fapolicyd to enforcing mode by editing the "permissive" line in the /etc/fapolicyd/fapolicyd.conf file.

permissive = 0

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a

PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-244546r1017349_rule
STIG-ID	RHEL-08-040137
SWIFT-CSCV1	2.3
VULN-ID	V-244546

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - permissive

No files found: /etc/fapolicyd/fapolicyd.conf

FAILED - deny all all

The command '/bin/tail -1 /etc/fapolicyd/fapolicyd.rules 2>/dev/null;/bin/tail -1 /etc/fapolicyd/compiled.rules 2>/dev/null' did not return any result

RHEL-08-040150 - A firewall must be able to protect against or limit the effects of Denial of Service (DoS) attacks by ensuring RHEL 8 can implement rate-limiting measures on impacted network interfaces.

Info

DoS is a condition when a resource is not available for legitimate users. When this occurs, the organization either cannot accomplish its mission or must operate at degraded capacity.

This requirement addresses the configuration of RHEL 8 to mitigate the impact of DoS attacks that have occurred or are ongoing on system availability. For each system, known and potential DoS attacks must be identified and solutions for each type implemented. A variety of technologies exists to limit or, in some cases, eliminate the effects of DoS attacks (e.g., limiting processes or establishing memory partitions). Employing increased capacity and bandwidth, combined with service redundancy, may reduce the susceptibility to some DoS attacks.

Since version 0.6.0, "firewalld" has incorporated "nftables" as its backend support. Utilizing the limit statement in "nftables" can help to mitigate DoS attacks.

Solution

Configure "nftables" to be the default "firewallbackend" for "firewalld" by adding or editing the following line in "/etc/firewalld/firewalld.conf":

FirewallBackend=nftables

Establish rate-limiting rules based on organization-defined types of DoS attacks on impacted network interfaces.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SC-5
800-53R5	SC-5a.
CAT	II
CCI	CCI-002385
CSF	DE.CM-1
CSF	PR.DS-4
CSF2.0	DE.CM-01
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-5
ITSG-33	SC-5a.
NESA	T3.3.1
NIAV2	GS8e
NIAV2	GS10c
QCSC-V1	8.2.1
RULE-ID	SV-230525r958902_rule
STIG-ID	RHEL-08-040150

VULN-ID

V-230525

Assets

linuxred-01

No files found: /etc/firewalld/firewalld.conf

RHEL-08-040161 - RHEL 8 must force a frequent session key renegotiation for SSH connections to the server.

Info

Without protection of the transmitted information, confidentiality and integrity may be compromised because unprotected communications can be intercepted and either read or altered.

This requirement applies to both internal and external networks and all types of information system components from which information can be transmitted (e.g., servers, mobile devices, notebook computers, printers, copiers, scanners, and facsimile machines). Communication paths outside the physical protection of a controlled boundary are exposed to the possibility of interception and modification.

Protecting the confidentiality and integrity of organizational information can be accomplished by physical means (e.g., employing physical distribution systems) or by logical means (e.g., employing cryptographic techniques). If physical means of protection are employed, then logical means (cryptography) do not have to be employed, and vice versa. Session key regeneration limits the chances of a session key becoming compromised.

Satisfies: SRG-OS-000033-GPOS-00014, SRG-OS-000420-GPOS-00186, SRG-OS-000424-GPOS-00188

Solution

Configure the system to force a frequent session key renegotiation for SSH connections to the server by add or modifying the following line in the "/etc/ssh/sshd_config" file:

```
RekeyLimit 1G 1h
```

Restart the SSH daemon for the settings to take effect.

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	II
CCI	CCI-000068
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.14
ISO-27001-2022	A.6.7

ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7
QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230527r1017288_rule
STIG-ID	RHEL-08-040161
SWIFT-CSCV1	2.6
VULN-ID	V-230527

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i RekeyLimit' returned :
 /etc/ssh/sshd_config: Permission denied

RHEL-08-040170 - The x86 Ctrl-Alt-Delete key sequence must be disabled on RHEL 8.

Info

A locally logged-on user, who presses Ctrl-Alt-Delete when at the console, can reboot the system. If accidentally pressed, as could happen in the case of a mixed OS environment, this can create the risk of short-term loss of availability of systems due to unintentional reboot. In a graphical user environment, risk of unintentional reboot from the Ctrl-Alt-Delete sequence is reduced because the user will be prompted before any action is taken.

Solution

Configure the system to disable the Ctrl-Alt-Delete sequence for the command line with the following commands:

```
$ sudo systemctl disable ctrl-alt-del.target
$ sudo systemctl mask ctrl-alt-del.target
Created symlink /etc/systemd/system/ctrl-alt-del.target -> /dev/null
Reload the daemon for this change to take effect.
$ sudo systemctl daemon-reload
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230529r1017289_rule
STIG-ID	RHEL-08-040170
SWIFT-CSCV1	2.3
VULN-ID	V-230529

Assets

linuxred-01

The command `'/bin/systemctl status ctrl-alt-del.target | /bin/awk '{print} END {if (NR == 0) print "No results found"}'` returned :

```
* reboot.target - Reboot
  Loaded: loaded (/usr/lib/systemd/system/reboot.target; enabled; vendor preset: enabled)
  Active: inactive (dead)
  Docs: man:systemd.special(7)
```

RHEL-08-040172 - The systemd Ctrl-Alt-Delete burst key sequence in RHEL 8 must be disabled.

Info

A locally logged-on user who presses Ctrl-Alt-Delete when at the console can reboot the system. If accidentally pressed, as could happen in the case of a mixed OS environment, this can create the risk of short-term loss of availability of systems due to unintentional reboot. In a graphical user environment, risk of unintentional reboot from the Ctrl-Alt-Delete sequence is reduced because the user will be prompted before any action is taken.

Solution

Configure RHEL 8 to disable the CtrlAltDelBurstAction by adding it to a drop file in a "/etc/systemd/system.conf.d/" configuration file:

If no drop file exists, create one with the following command:

```
$ sudo mkdir -p /etc/systemd/system.conf.d && sudo vi /etc/systemd/system.conf.d/55-CtrlAltDel-BurstAction
```

Edit the file to contain the setting by adding the following text:

```
CtrlAltDelBurstAction=none
```

Reload the daemon for this change to take effect.

```
$ sudo systemctl daemon-reload
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230531r1155396_rule
STIG-ID	RHEL-08-040172
SWIFT-CSCV1	2.3
VULN-ID	V-230531

Assets

linuxred-01

No matching files were found
Less than 1 matches of regex found

RHEL-08-040180 - The debug-shell systemd service must be disabled on RHEL 8.

Info

The debug-shell requires no authentication and provides root privileges to anyone who has physical access to the machine. While this feature is disabled by default, masking it adds an additional layer of assurance that it will not be enabled via a dependency in systemd. This also prevents attackers with physical access from trivially bypassing security on the machine through valid troubleshooting configurations and gaining root access when the system is rebooted.

Solution

Configure the system to mask the debug-shell systemd service with the following command:

```
$ sudo systemctl mask debug-shell.service
```

```
Created symlink /etc/systemd/system/debug-shell.service -> /dev/null
```

Reload the daemon to take effect.

```
$ sudo systemctl daemon-reload
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230532r1017294_rule
STIG-ID	RHEL-08-040180
SWIFT-CSCV1	2.3
VULN-ID	V-230532

Assets

linuxred-01

The command `'/bin/systemctl status debug-shell.service | /bin/awk '{print} END {if(NR==0) print "No results found" }'` returned :

```
* debug-shell.service - Early root shell on /dev/tty9 FOR DEBUGGING ONLY
   Loaded: loaded (/usr/lib/systemd/system/debug-shell.service; disabled; vendor preset: disabled)
   Active: inactive (dead)
     Docs: man:systemd-debug-generator(8)
```

RHEL-08-040209 - RHEL 8 must prevent IPv4 Internet Control Message Protocol (ICMP) redirect messages from being accepted.

Info

ICMP redirect messages are used by routers to inform hosts that a more direct route exists for a particular destination. These messages modify the host's route table and are unauthenticated. An illicit ICMP redirect message could result in a man-in-the-middle attack.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to prevent IPv4 ICMP redirect messages from being accepted.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv4.conf.default.accept_redirects = 0
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244550r1017350_rule

STIG-ID RHEL-08-040209

SWIFT-CSCV1 2.3

VULN-ID V-244550

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sysctl  
The command '/sbin/sysctl net.ipv4.conf.default.accept_redirects' returned :  
  
net.ipv4.conf.default.accept_redirects = 1
```

RHEL-08-040210 - RHEL 8 must prevent IPv6 Internet Control Message Protocol (ICMP) redirect messages from being accepted.

Info

ICMP redirect messages are used by routers to inform hosts that a more direct route exists for a particular destination. These messages modify the host's route table and are unauthenticated. An illicit ICMP redirect message could result in a man-in-the-middle attack.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to prevent IPv6 ICMP redirect messages from being accepted.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv6.conf.default.accept_redirects = 0
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230535r1017297_rule

STIG-ID RHEL-08-040210

SWIFT-CSCV1 2.3

VULN-ID V-230535

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sysctl  
The command '/sbin/sysctl net.ipv6.conf.default.accept_redirects' returned :  
  
net.ipv6.conf.default.accept_redirects = 1
```

RHEL-08-040220 - RHEL 8 must not send Internet Control Message Protocol (ICMP) redirects.

Info

ICMP redirect messages are used by routers to inform hosts that a more direct route exists for a particular destination. These messages contain information from the system's route table, possibly revealing portions of the network topology.

There are notable differences between Internet Protocol version 4 (IPv4) and Internet Protocol version 6 (IPv6). There is only a directive to disable sending of IPv4 redirected packets. Refer to RFC4294 for an explanation of "IPv6 Node Requirements", which resulted in this difference between IPv4 and IPv6.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not allow interfaces to perform IPv4 ICMP redirects.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv4.conf.all.send_redirects=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1

RULE-ID	SV-230536r1017298_rule
STIG-ID	RHEL-08-040220
SWIFT-CSCV1	2.3
VULN-ID	V-230536

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sysctl  
The command '/sbin/sysctl net.ipv4.conf.all.send_redirects' returned :  
  
net.ipv4.conf.all.send_redirects = 1
```

RHEL-08-040230 - RHEL 8 must not respond to Internet Control Message Protocol (ICMP) echoes sent to a broadcast address.

Info

Responding to broadcast ICMP echoes facilitates network mapping and provides a vector for amplification attacks. There are notable differences between Internet Protocol version 4 (IPv4) and Internet Protocol version 6 (IPv6). IPv6 does not implement the same method of broadcast as IPv4. Instead, IPv6 uses multicast addressing to the all-hosts multicast group. Refer to RFC4294 for an explanation of "IPv6 Node Requirements", which resulted in this difference between IPv4 and IPv6.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to not respond to IPv4 ICMP echoes sent to a broadcast address.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv4.icmp_echo_ignore_broadcasts=1
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1

RULE-ID	SV-230537r1017299_rule
STIG-ID	RHEL-08-040230
SWIFT-CSCV1	2.3
VULN-ID	V-230537

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - sysctl

The command '/sbin/sysctl net.ipv4.icmp_echo_ignore_broadcasts' returned :

net.ipv4.icmp_echo_ignore_broadcasts = 1

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

RHEL-08-040240 - RHEL 8 must not forward IPv6 source-routed packets.

Info

Source-routed packets allow the source of the packet to suggest that routers forward the packet along a different path than configured on the router, which can be used to bypass network security measures. This requirement applies only to the forwarding of source-routed traffic, such as when forwarding is enabled and the system is functioning as a router.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not forward IPv6 source-routed packets.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv6.conf.all.accept_source_route=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230538r1017300_rule

STIG-ID RHEL-08-040240

SWIFT-CSCV1 2.3

VULN-ID V-230538

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
PASSED - sysctl  
The command '/sbin/sysctl net.ipv6.conf.all.accept_source_route' returned :  
  
net.ipv6.conf.all.accept_source_route = 0
```

RHEL-08-040249 - RHEL 8 must not forward IPv4 source-routed packets by default.

Info

Source-routed packets allow the source of the packet to suggest that routers forward the packet along a different path than configured on the router, which can be used to bypass network security measures. This requirement applies only to the forwarding of source-routed traffic, such as when forwarding is enabled and the system is functioning as a router.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not forward IPv4 source-routed packets by default.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv4.conf.default.accept_source_route=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244552r1017352_rule

STIG-ID RHEL-08-040249

SWIFT-CSCV1 2.3

VULN-ID V-244552

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - sysctl

The command '/sbin/sysctl net.ipv4.conf.default.accept_source_route' returned :

net.ipv4.conf.default.accept_source_route = 1

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

RHEL-08-040250 - RHEL 8 must not forward IPv6 source-routed packets by default.

Info

Source-routed packets allow the source of the packet to suggest that routers forward the packet along a different path than configured on the router, which can be used to bypass network security measures. This requirement applies only to the forwarding of source-routed traffic, such as when forwarding is enabled and the system is functioning as a router.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not forward IPv6 source-routed packets by default.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv6.conf.default.accept_source_route=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230539r1017301_rule

STIG-ID	RHEL-08-040250
SWIFT-CSCV1	2.3
VULN-ID	V-230539

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files.  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
PASSED - sysctl  
The command '/sbin/sysctl net.ipv6.conf.default.accept_source_route' returned :  
  
net.ipv6.conf.default.accept_source_route = 0
```

RHEL-08-040259 - RHEL 8 must not enable IPv4 packet forwarding unless the system is a router.

Info

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to not allow IPv4 packet forwarding, unless the system is a router.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv4.conf.all.forwarding=0
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-250317r1017358_rule
STIG-ID	RHEL-08-040259

SWIFT-CSCV1

2.3

VULN-ID

V-250317

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - sysctl

The command '/sbin/sysctl net.ipv4.conf.all.forwarding' returned :

net.ipv4.conf.all.forwarding = 0

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

RHEL-08-040260 - RHEL 8 must not enable IPv6 packet forwarding unless the system is a router.

Info

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to not allow IPv6 packet forwarding, unless the system is a router.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv6.conf.all.forwarding=0
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230540r1017302_rule
STIG-ID	RHEL-08-040260

SWIFT-CSCV1

2.3

VULN-ID

V-230540

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

PASSED - sysctl net.ipv6.conf.all.forwarding

The command '/sbin/sysctl net.ipv6.conf.all.forwarding' returned :

net.ipv6.conf.all.forwarding = 0

RHEL-08-040261 - RHEL 8 must not accept router advertisements on all IPv6 interfaces.

Info

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

An illicit router advertisement message could result in a man-in-the-middle attack.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not accept router advertisements on all IPv6 interfaces unless the system is a router.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv6.conf.all.accept_ra=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230541r1017303_rule

STIG-ID RHEL-08-040261

SWIFT-CSCV1 2.3

VULN-ID V-230541

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

FAILED - sysctl

The command '/sbin/sysctl net.ipv6.conf.all.accept_ra' returned :

net.ipv6.conf.all.accept_ra = 1

RHEL-08-040262 - RHEL 8 must not accept router advertisements on all IPv6 interfaces by default.

Info

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

An illicit router advertisement message could result in a man-in-the-middle attack.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not accept router advertisements on all IPv6 interfaces by default unless the system is a router. Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv6.conf.default.accept_ra=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230542r1017304_rule

STIG-ID RHEL-08-040262

SWIFT-CSCV1 2.3

VULN-ID V-230542

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sysctl  
The command '/sbin/sysctl net.ipv6.conf.default.accept_ra' returned :  
  
net.ipv6.conf.default.accept_ra = 1
```

RHEL-08-040270 - RHEL 8 must not allow interfaces to perform Internet Control Message Protocol (ICMP) redirects by default.

Info

ICMP redirect messages are used by routers to inform hosts that a more direct route exists for a particular destination. These messages contain information from the system's route table, possibly revealing portions of the network topology.

There are notable differences between Internet Protocol version 4 (IPv4) and Internet Protocol version 6 (IPv6). There is only a directive to disable sending of IPv4 redirected packets. Refer to RFC4294 for an explanation of "IPv6 Node Requirements", which resulted in this difference between IPv4 and IPv6.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not allow interfaces to perform Internet Protocol version 4 (IPv4) ICMP redirects by default.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv4.conf.default.send_redirects = 0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1

RULE-ID	SV-230543r1017305_rule
STIG-ID	RHEL-08-040270
SWIFT-CSCV1	2.3
VULN-ID	V-230543

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sysctl  
The command '/sbin/sysctl net.ipv4.conf.default.send_redirects' returned :  
  
net.ipv4.conf.default.send_redirects = 1
```

RHEL-08-040279 - RHEL 8 must ignore IPv4 Internet Control Message Protocol (ICMP) redirect messages.

Info

ICMP redirect messages are used by routers to inform hosts that a more direct route exists for a particular destination. These messages modify the host's route table and are unauthenticated. An illicit ICMP redirect message could result in a man-in-the-middle attack.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to ignore IPv4 ICMP redirect messages.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv4.conf.all.accept_redirects = 0
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244553r1017353_rule

STIG-ID RHEL-08-040279

SWIFT-CSCV1 2.3

VULN-ID V-244553

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - sysctl

The command '/sbin/sysctl net.ipv4.conf.all.accept_redirects' returned :

net.ipv4.conf.all.accept_redirects = 1

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

RHEL-08-040280 - RHEL 8 must ignore IPv6 Internet Control Message Protocol (ICMP) redirect messages.

Info

ICMP redirect messages are used by routers to inform hosts that a more direct route exists for a particular destination. These messages modify the host's route table and are unauthenticated. An illicit ICMP redirect message could result in a man-in-the-middle attack.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

```
/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf
```

Solution

Configure RHEL 8 to ignore IPv6 ICMP redirect messages.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

```
net.ipv6.conf.all.accept_redirects = 0
```

Remove any configurations that conflict with the above from the following locations:

```
/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230544r1017306_rule

STIG-ID RHEL-08-040280

SWIFT-CSCV1 2.3

VULN-ID V-230544

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - sysctl

The command '/sbin/sysctl net.ipv6.conf.all.accept_redirects' returned :

net.ipv6.conf.all.accept_redirects = 1

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

RHEL-08-040281 - RHEL 8 must disable access to network bpf syscall from unprivileged processes.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to prevent privilege escalation thru the kernel by disabling access to the bpf syscall by adding the following line to a file, in the `"/etc/sysctl.d"` directory:

```
kernel.unprivileged_bpf_disabled = 1
```

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

The system configuration files need to be reloaded for the changes to take effect. To reload the contents of the files, run the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230545r1017307_rule

STIG-ID	RHEL-08-040281
SWIFT-CSCV1	2.3
VULN-ID	V-230545

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
PASSED - sysctl  
The command '/sbin/sysctl kernel.unprivileged_bpf_disabled' returned :  
  
kernel.unprivileged_bpf_disabled = 1  
  
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

RHEL-08-040282 - RHEL 8 must restrict usage of ptrace to descendant processes.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore, may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographical order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to restrict usage of ptrace to descendant processes by adding the following line in a dropfile, in the `"/etc/sysctl.d"` directory with the following commands:

Create the dropfile if it doesn't already exist:

```
$ sudo vi /etc/sysctl.d/99-pttrace-restrict.conf
```

Add the following line to the file:

```
kernel.yama.ptrace_scope = 1
```

The system configuration files need to be reloaded for the changes to take effect. To reload the contents of the files, run the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230546r1155413_rule

STIG-ID RHEL-08-040282

SWIFT-CSCV1 2.3

VULN-ID V-230546

Assets

linuxred-01

The command `'/sbin/sysctl kernel.yama.ptrace_scope'` returned :

`kernel.yama.ptrace_scope = 0`

RHEL-08-040284 - RHEL 8 must disable the use of user namespaces.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to disable the use of user namespaces by adding the following line to a file, in the `/etc/sysctl.d` directory:

```
user.max_user_namespaces = 0
```

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

The system configuration files need to be reloaded for the changes to take effect. To reload the contents of the files, run the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230548r1017310_rule

STIG-ID RHEL-08-040284

SWIFT-CSCV1 2.3

VULN-ID V-230548

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - sysctl

The command '/sbin/sysctl user.max_user_namespaces' returned :

user.max_user_namespaces = 14487

FAILED - conf files

No matching files were found

Less than 1 matches of regex found

RHEL-08-040285 - RHEL 8 must use reverse path filtering on all IPv4 interfaces.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore, may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographical order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to use reverse path filtering on IPv4 interfaces by default.

Add or edit the following line in a single system configuration file in the `/etc/sysctl.d/` directory:

Create a configuration file if it does not already exist:

```
$ sudo vi /etc/sysctl.d/ipv4_rp_filter.conf
```

```
net.ipv4.conf.default.rp_filter = 1
```

Load settings from all system configuration files with the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230549r1155416_rule
STIG-ID	RHEL-08-040285

SWIFT-CSCV1

2.3

VULN-ID

V-230549

Assets

linuxred-01

The command '/sbin/sysctl net.ipv4.conf.default.rp_filter' returned :

net.ipv4.conf.default.rp_filter = 0

RHEL-08-040286 - RHEL 8 must enable hardening for the Berkeley Packet Filter Just-in-time compiler.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Enabling hardening for the Berkeley Packet Filter (BPF) Just-in-time (JIT) compiler aids in mitigating JIT spraying attacks. Setting the value to "2" enables JIT hardening for all users.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to enable hardening for the BPF JIT compiler by adding the following line to a file, in the `/etc/sysctl.d` directory:

```
net.core.bpf_jit_harden = 2
```

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

The system configuration files need to be reloaded for the changes to take effect. To reload the contents of the files, run the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1

RULE-ID	SV-244554r1017354_rule
STIG-ID	RHEL-08-040286
SWIFT-CSCV1	2.3
VULN-ID	V-244554

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----  
FAILED - conf files  
No matching files were found  
Less than 1 matches of regex found
```

```
-----  
FAILED - sysctl  
The command '/sbin/sysctl net.core.bpf_jit_harden' returned :  
  
sysctl: permission denied on key 'net.core.bpf_jit_harden'
```

RHEL-08-040340 - RHEL 8 remote X connections for interactive users must be disabled unless to fulfill documented and validated mission requirements.

Info

The security risk of using X11 forwarding is that the client's X11 display server may be exposed to attack when the SSH client requests forwarding. A system administrator may have a stance in which they want to protect clients that may expose themselves to attack by unwittingly requesting X11 forwarding, which can warrant a "no" setting. X11 forwarding should be enabled with caution. Users with the ability to bypass file permissions on the remote host (for the user's X11 authorization database) can access the local X11 display through the forwarded connection. An attacker may then be able to perform activities such as keystroke monitoring if the ForwardX11Trusted option is also enabled.

If X11 services are not required for the system's intended function, they should be disabled or restricted as appropriate to the system's needs.

Solution

Edit the "/etc/ssh/sshd_config" file to uncomment or add the line for the "X11Forwarding" keyword and set its value to "no" (this file may be named differently or be in a different location if using a version of SSH that is provided by a third-party vendor):

```
X11Forwarding no
```

The SSH service must be restarted for changes to take effect:

```
$ sudo systemctl restart sshd
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230555r1017317_rule
STIG-ID	RHEL-08-040340
SWIFT-CSCV1	2.3

VULN-ID

V-230555

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i X11Forwarding' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-040341 - The RHEL 8 SSH daemon must prevent remote hosts from connecting to the proxy display.

Info

When X11 forwarding is enabled, there may be additional exposure to the server and client displays if the sshd proxy display is configured to listen on the wildcard address. By default, sshd binds the forwarding server to the loopback address and sets the hostname part of the DISPLAY environment variable to localhost. This prevents remote hosts from connecting to the proxy display.

Solution

Configure the SSH daemon to prevent remote hosts from connecting to the proxy display.

Edit the "/etc/ssh/sshd_config" file to uncomment or add the line for the "X11UseLocalhost" keyword and set its value to "yes" (this file may be named differently or be in a different location if using a version of SSH that is provided by a third-party vendor):

X11UseLocalhost yes

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230556r1017318_rule
STIG-ID	RHEL-08-040341
SWIFT-CSCV1	2.3
VULN-ID	V-230556

Assets

linuxred-01

The command '/sbin/sshd -T | /bin/grep -i X11UseLocalhost' returned :

/etc/ssh/sshd_config: Permission denied

RHEL-08-040390 - The tuned package must not be installed unless mission essential on RHEL 8.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

The tuned package contains a daemon that tunes the system settings dynamically. It does so by monitoring the usage of several system components periodically. Based on that information, components will then be put into lower or higher power savings modes to adapt to the current usage. The tuned package is not needed for normal OS operations.

Solution

Document the tuned package with the ISSO as an operational requirement or remove it from the system with the following command:

```
$ sudo yum remove tuned
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230561r1017322_rule
STIG-ID	RHEL-08-040390
SWIFT-CSCV1	2.3
VULN-ID	V-230561

Assets

linuxred-01

The local RPM is newer than tuned-0.0.0-0 (tuned-2.22.1-6.el8_10)

Audits SKIPPED

Audits PASSED

DISA_STIG_Red_Hat_Enterprise_Linux_8_v2r6.audit from DISA Red Hat Enterprise Linux 8 STIG v2r6

Info

Solution

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - Red Hat Enterprise Linux 8 is installed

Compliant file(s):

```
/etc/system-release - regex '^[\s]*Red Hat Enterprise Linux.*release' found - expect  
'^[\s]*Red Hat Enterprise Linux.*release 8' found in the following lines:  
1: Red Hat Enterprise Linux release 8.10 (Ootpa)
```


RHEL-08-010000 - RHEL 8 must be a vendor-supported release.

Info

An operating system release is considered "supported" if the vendor continues to provide security patches for the product. With an unsupported release, it will not be possible to resolve security issues discovered in the system software.

Red Hat offers the Extended Update Support (EUS) add-on to a Red Hat Enterprise Linux subscription, for a fee, for those customers who wish to standardize on a specific minor release for an extended period. The RHEL 8 minor releases eligible for EUS are 8.1, 8.2, 8.4, 8.6, and 8.8. Each RHEL 8 EUS stream is available for 24 months from the availability of the minor release. RHEL 8.10 will be the final minor release overall. For more details on the Red Hat Enterprise Linux Life Cycle visit <https://access.redhat.com/support/policy/updates/errata/>.

Note: The life-cycle time spans and dates are subject to adjustment.

Solution

Upgrade to a supported version of RHEL 8.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230221r1017040_rule
STIG-ID	RHEL-08-010000
SWIFT-CSCV1	2.3
VULN-ID	V-230221

Assets

linuxred-01

Compliant file(s):

```
/etc/redhat-release - regex '^[\s]*Red[\s]+Hat[\s]+Enterprise[\s]+Linux' found - expect
'^[\s]*Red[\s]+Hat[\s]+Enterprise[\s]+Linux[\s]+release[\s]+8\.[0-9]+.*$' found in the following
lines:
    1: Red Hat Enterprise Linux release 8.10 (Ootpa)
```

RHEL-08-010015 - RHEL 8 must have the crypto-policies package installed.

Info

Centralized cryptographic policies simplify applying secure ciphers across an operating system and the applications that run on that operating system. Use of weak or untested encryption algorithms undermines the purposes of using encryption to protect data.

Satisfies: SRG-OS-000396-GPOS-00176, SRG-OS-000393-GPOS-00173, SRG-OS-000394-GPOS-00174

Solution

Install the crypto-policies package (if the package is not already installed) with the following command:

```
$ sudo dnf -y install crypto-policies
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.11
800-171R3	03.13.11
800-53	SC-13
800-53R5	SC-13b.
CAT	I
CCI	CCI-002450
CSF	PR.DS-5
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iv)
HIPAA	164.312(e)(2)(ii)
ISO-27001-2022	A.8.24
ISO/IEC-27001	A.10.1.1
ITSG-33	SC-13
ITSG-33	SC-13a.
NESA	M5.2.6
NESA	T7.4.1
NIAV2	CY3

NIAV2	CY4
NIAV2	CY5b
NIAV2	CY5c
NIAV2	CY5d
NIAV2	CY7
NIAV2	NS5e
QCSC-V1	6.2
RULE-ID	SV-279933r1156352_rule
STIG-ID	RHEL-08-010015
VULN-ID	V-279933

Assets

linuxred-01

The local RPM is newer than crypto-policies-0.0.0-0 (crypto-policies-20230731-1.git3177e06.el8)

RHEL-08-010019 - RHEL 8 must ensure cryptographic verification of vendor software packages.

Info

Cryptographic verification of vendor software packages ensures that all software packages are obtained from a valid source and protects against spoofing that could lead to installation of malware on the system. Red Hat cryptographically signs all software packages, which includes updates, with a GPG key to verify that they are valid.

Solution

Install Red Hat package-signing keys on the system and verify their fingerprints match vendor values.
Insert RHEL 8 installation disc or attach RHEL 8 installation image to the system. Mount the disc or image to make the contents accessible inside the system.
Assuming the mounted location is "/media/cdrom", use the following command to copy Red Hat GPG key file onto the system:
\$ sudo cp /media/cdrom/RPM-GPG-KEY-redhat-release /etc/pki/rpm-gpg/
Import Red Hat GPG keys from key file into system keyring:
\$ sudo rpm --import /etc/pki/rpm-gpg/RPM-GPG-KEY-redhat-release
Using the steps listed in the Check Text, confirm the newly imported keys show as installed on the system and verify their fingerprints match vendor values.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(3)
800-53R5	CM-14
CAT	II
CCI	CCI-001749
CCI	CCI-003992
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(3)
NESA	T3.2.3

NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-256973r1017373_rule
STIG-ID	RHEL-08-010019
VULN-ID	V-256973

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - release key 2

The command '/bin/rpm rpm -q --queryformat "%{SUMMARY}\n" gpg-pubkey' returned :

The RPM package management system

gpg(Microsoft (Release signing) <gpgsecurity@microsoft.com>)

gpg(Red Hat, Inc. (release key 2) <security@redhat.com>)

gpg(Red Hat, Inc. (auxiliary key) <security@redhat.com>)

PASSED - auxiliary key

The command '/bin/rpm rpm -q --queryformat "%{SUMMARY}\n" gpg-pubkey' returned :

The RPM package management system

gpg(Microsoft (Release signing) <gpgsecurity@microsoft.com>)

gpg(Red Hat, Inc. (release key 2) <security@redhat.com>)

gpg(Red Hat, Inc. (auxiliary key) <security@redhat.com>)

PASSED - key fingerprint 1

The command '/bin/gpg -q --keyid-format short --with-fingerprint /etc/pki/rpm-gpg/RPM-GPG-KEY-redhat-release' returned :

```
pub   rsa4096/FD431D51 2009-10-22 [SC]
      Key fingerprint = 567E 347A D004 4ADE 55BA 8A5F 199E 2F91 FD43 1D51
uid           Red Hat, Inc. (release key 2) <security@redhat.com>
pub   rsa4096/D4082792 2018-06-27 [SC]
      Key fingerprint = 6A6A A7C9 7C88 90AE C6AE BFE2 F76F 66C3 D408 2792
uid           Red Hat, Inc. (auxiliary key) <security@redhat.com>
sub   rsa4096/1B5584D3 2018-06-27 [E]
```

PASSED - key fingerprint 2

The command '/bin/gpg -q --keyid-format short --with-fingerprint /etc/pki/rpm-gpg/RPM-GPG-KEY-redhat-release' returned :

```
pub   rsa4096/FD431D51 2009-10-22 [SC]
      Key fingerprint = 567E 347A D004 4ADE 55BA 8A5F 199E 2F91 FD43 1D51
uid           Red Hat, Inc. (release key 2) <security@redhat.com>
pub   rsa4096/D4082792 2018-06-27 [SC]
      Key fingerprint = 6A6A A7C9 7C88 90AE C6AE BFE2 F76F 66C3 D408 2792
uid           Red Hat, Inc. (auxiliary key) <security@redhat.com>
sub   rsa4096/1B5584D3 2018-06-27 [E]
```

RHEL-08-010049 - RHEL 8 must display a banner before granting local or remote access to the system via a graphical user logon.

Info

Display of a standardized and approved use notification before granting access to the operating system ensures privacy and security notification verbiage used is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via logon interfaces with human users and are not required when such human interfaces do not exist.

Satisfies: SRG-OS-000023-GPOS-00006, SRG-OS-000228-GPOS-00088

Solution

Configure the operating system to display a banner before granting access to the system.

Note: If the system does not have a graphical user interface installed, this requirement is Not Applicable.

Create a database to contain the system-wide graphical user logon settings (if it does not already exist) with the following command:

```
$ sudo touch /etc/dconf/db/local.d/01-banner-message
```

Add the following lines to the [org/gnome/login-screen] section of the "/etc/dconf/db/local.d/01-banner-message":
[org/gnome/login-screen]

```
banner-message-enable=true
```

Run the following command to update the database:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.9
800-171R3	03.01.09
800-53	AC-8a.
800-53R5	AC-8a.
CAT	II
CCI	CCI-000048
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-8a.
NESA	M5.2.5
NESA	T5.5.1
NIAV2	AM10a
NIAV2	AM10b
NIAV2	AM10c
NIAV2	AM10d
NIAV2	AM10e

RULE-ID	SV-244519r1017326_rule
STIG-ID	RHEL-08-010049
TBA-FIISB	45.2.4
VULN-ID	V-244519

Assets

linuxred-01

RHEL-08-010050 - RHEL 8 must display the Standard Mandatory DoD Notice and Consent Banner before granting local or remote access to the system via a graphical user logon.

Info

Display of a standardized and approved use notification before granting access to the operating system ensures privacy and security notification verbiage used is consistent with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance.

System use notifications are required only for access via logon interfaces with human users and are not required when such human interfaces do not exist.

The banner must be formatted in accordance with applicable DoD policy. Use the following verbiage for operating systems that can accommodate banners of 1300 characters:

"You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only. By using this IS (which includes any device attached to this IS), you consent to the following conditions:

- The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

- At any time, the USG may inspect and seize data stored on this IS.

- Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

- This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

- Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details."

Satisfies: SRG-OS-000023-GPOS-00006, SRG-OS-000228-GPOS-00088

Solution

Configure the operating system to display the Standard Mandatory DoD Notice and Consent Banner before granting access to the system.

Note: If the system does not have a graphical user interface installed, this requirement is Not Applicable.

Add the following lines to the [org/gnome/login-screen] section of the "/etc/dconf/db/local.d/01-banner-message":
banner-message-text='You are accessing a U.S. Government (USG) Information System (IS) that is provided for USG-authorized use only.

By using this IS (which includes any device attached to this IS), you consent to the following conditions:

- The USG routinely intercepts and monitors communications on this IS for purposes including, but not limited to, penetration testing, COMSEC monitoring, network operations and defense, personnel misconduct (PM), law enforcement (LE), and counterintelligence (CI) investigations.

- At any time, the USG may inspect and seize data stored on this IS.

- Communications using, or data stored on, this IS are not private, are subject to routine monitoring, interception, and search, and may be disclosed or used for any USG-authorized purpose.

- This IS includes security measures (e.g., authentication and access controls) to protect USG interests--not for your personal benefit or privacy.

- Notwithstanding the above, using this IS does not constitute consent to PM, LE or CI investigative searching or monitoring of the content of privileged communications, or work product, related to personal representation or services by attorneys, psychotherapists, or clergy, and their assistants. Such communications and work product are private and confidential. See User Agreement for details. '

Note: The "

" characters are for formatting only. They will not be displayed on the graphical interface.

Run the following command to update the database:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.9
800-171R3	03.01.09
800-53	AC-8a.
800-53R5	AC-8a.

CAT	II
CCI	CCI-000048
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-8a.
NESA	M5.2.5
NESA	T5.5.1
NIAV2	AM10a
NIAV2	AM10b
NIAV2	AM10c
NIAV2	AM10d
NIAV2	AM10e
RULE-ID	SV-230226r1069298_rule
STIG-ID	RHEL-08-010050
TBA-FIISB	45.2.4
VULN-ID	V-230226

Assets

linuxred-01

RHEL-08-010110 - RHEL 8 must encrypt all stored passwords with a FIPS 140-2 approved cryptographic hashing algorithm.

Info

Passwords need to be protected at all times, and encryption is the standard method for protecting passwords. If passwords are not encrypted, they can be plainly read (i.e., clear text) and easily compromised. Unapproved mechanisms that are used for authentication to the cryptographic module are not verified and therefore cannot be relied upon to provide confidentiality or integrity, and DoD data may be compromised. FIPS 140-2 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meets DoD requirements.

Solution

Configure RHEL 8 to encrypt all stored passwords.
Edit/Modify the following line in the "/etc/login.defs" file and set "[ENCRYPT_METHOD]" to SHA512.
ENCRYPT_METHOD SHA512

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.10
800-171R3	03.05.07c.
800-53	IA-5(1)(c)
800-53R5	IA-5(1)(d)
CAT	II
CCI	CCI-000196
CCI	CCI-004062
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(1)(c)
NESA	T5.2.3
NIAV2	CY6
QCSC-V1	5.2.2

QCSC-V1	13.2
RULE-ID	SV-230231r1017050_rule
STIG-ID	RHEL-08-010110
SWIFT-CSCV1	4.1
TBA-FIISB	26.1
VULN-ID	V-230231

Assets

linuxred-01

Compliant file(s):
 /etc/login.defs - regex '(?i)^\s*ENCRYPT_METHOD' found - expect '(?
 i)^\s*ENCRYPT_METHOD[\s]+SHA512[\s]*\$' found in the following lines:
 85: ENCRYPT_METHOD SHA512

RHEL-08-010120 - RHEL 8 must employ FIPS 140-2 approved cryptographic hashing algorithms for all stored passwords.

Info

The system must use a strong hashing algorithm to store the password. Passwords need to be protected at all times, and encryption is the standard method for protecting passwords. If passwords are not encrypted, they can be plainly read (i.e., clear text) and easily compromised.

Solution

Lock all interactive user accounts not using SHA-512 hashing until the passwords can be regenerated with SHA-512.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.10
800-171R3	03.05.07c.
800-53	IA-5(1)(c)
800-53R5	IA-5(1)(d)
CAT	II
CCI	CCI-000196
CCI	CCI-004062
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(1)(c)
NESA	T5.2.3
NIAV2	CY6
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230232r1017051_rule
STIG-ID	RHEL-08-010120

SWIFT-CSCV1	4.1
TBA-FIISB	26.1
VULN-ID	V-230232

Assets

linuxred-01

The command `'/bin/cut -d: -f1,2 /etc/shadow | /bin/grep -Pv ':[*!\\$]' | /bin/grep -Pv '^\\$6\\$' | /bin/awk -F: '{print $1} END {if (NR == 0) print "All interactive user passwords are encrypted"; else print "There are interactive user passwords that are not encrypted"}'` returned :

```
/bin/cut: /etc/shadow: Permission denied
All interactive user passwords are encrypted
```

RHEL-08-010121 - The RHEL 8 operating system must not have accounts configured with blank or null passwords.

Info

If an account has an empty password, anyone could log on and run commands with the privileges of that account. Accounts with empty passwords should never be used in operational environments.

Solution

Configure all accounts on the system to have a password or lock the account with the following commands:

Perform a password reset:

\$ sudo passwd [username] Lock an account:

\$ sudo passwd -l [username]

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-251706r1017359_rule
STIG-ID	RHEL-08-010121
SWIFT-CSCV1	2.3
VULN-ID	V-251706

Assets

linuxred-01

The command `'/bin/awk -F: '!$2 {print $1}' /etc/shadow | /bin/awk '{print} END {if (NR == 0) print "No accounts have blank or null passwords"; else print "Blank or null passwords found on system"}'` returned :

```
awk: fatal: cannot open file `/etc/shadow' for reading (Permission denied)
No accounts have blank or null passwords
```


RHEL-08-010149 - RHEL 8 operating systems booted with a BIOS must require a unique superusers name upon booting into single-user and maintenance modes.

Info

If the system does not require valid authentication before it boots into single-user or maintenance mode, anyone who invokes single-user or maintenance mode is granted privileged access to all files on the system. GRUB 2 is the default boot loader for RHEL 8 and is designed to require a password to boot into single-user mode or make modifications to the boot menu.

The GRUB 2 superuser account is an account of last resort. Establishing a unique username for this account hardens the boot loader against brute force attacks. Due to the nature of the superuser account database being distinct from the OS account database, this allows the use of a username that is not among those within the OS account database. Examples of non-unique superusers names are root, superuser, unlock, etc.

Solution

Configure the system to have a unique name for the grub superusers account.

Edit the /etc/grub.d/01_users file and add or modify the following lines:

```
set superusers="[someuniquestringhere]"
```

```
export superusers password_pbkdf2 [someuniquestringhere] ${GRUB2_PASSWORD}
```

Generate a new grub.cfg file with the following command:

```
$ sudo grub2-mkconfig -o /boot/grub2/grub.cfg
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	II
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-244522r1137691_rule
STIG-ID	RHEL-08-010149
TBA-FIISB	31.1
VULN-ID	V-244522

Assets
linuxred-01

RHEL-08-010150 - RHEL 8 operating systems booted with a BIOS must require authentication upon booting into single-user and maintenance modes.

Info

If the system does not require valid authentication before it boots into single-user or maintenance mode, anyone who invokes single-user or maintenance mode is granted privileged access to all files on the system. GRUB 2 is the default boot loader for RHEL 8 and is designed to require a password to boot into single-user mode or make modifications to the boot menu.

Solution

Configure the system to require a grub bootloader password for the grub superusers account with the grub2-setpassword command, which creates/overwrites the /boot/grub2/user.cfg file.

Generate an encrypted grub2 password for the grub superusers account with the following command:

```
$ sudo grub2-setpassword Enter password:
```

```
Confirm password:
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	I
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15

ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230235r1137691_rule
STIG-ID	RHEL-08-010150
TBA-FIISB	31.1
VULN-ID	V-230235

Assets

linuxred-01

RHEL-08-010151 - RHEL 8 operating systems must require authentication upon booting into rescue mode.

Info

If the system does not require valid root authentication before it boots into emergency or rescue mode, anyone who invokes emergency or rescue mode is granted privileged access to all files on the system.

Solution

Configure the system to require authentication upon booting into rescue mode by adding the following line to the `"/usr/lib/systemd/system/rescue.service"` file.

```
ExecStart=-/usr/lib/systemd/systemd-sulogin-shell rescue
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	II
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3

ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230236r1137691_rule
STIG-ID	RHEL-08-010151
TBA-FIISB	31.1
VULN-ID	V-230236

Assets

linuxred-01

Compliant file(s):
 /usr/lib/systemd/system/rescue.service - regex '^ExecStart=-' found - expect '^ExecStart=-/
 usr/lib/systemd/systemd-sulogin-shell rescue' found in the following lines:
 22: ExecStart=-/usr/lib/systemd/systemd-sulogin-shell rescue

RHEL-08-010152 - RHEL 8 operating systems must require authentication upon booting into emergency mode.

Info

If the system does not require valid root authentication before it boots into emergency or rescue mode, anyone who invokes emergency or rescue mode is granted privileged access to all files on the system.

Solution

Configure the system to require authentication upon booting into emergency mode by adding the following line to the `/usr/lib/systemd/system/emergency.service` file.

```
ExecStart=-/usr/lib/systemd/systemd-sulogin-shell emergency
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	II
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3

ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-244523r1137691_rule
STIG-ID	RHEL-08-010152
TBA-FIISB	31.1
VULN-ID	V-244523

Assets

linuxred-01

Compliant file(s):
 /usr/lib/systemd/system/emergency.service - regex '^ExecStart=-' found - expect
 '^ExecStart=-/usr/lib/systemd/systemd-sulogin-shell emergency' found in the following lines:
 23: ExecStart=-/usr/lib/systemd/systemd-sulogin-shell emergency

RHEL-08-010159 - The RHEL 8 pam_unix.so module must be configured in the system-auth file to use a FIPS 140-2 approved cryptographic hashing algorithm for system authentication.

Info

Unapproved mechanisms that are used for authentication to the cryptographic module are not verified and therefore cannot be relied upon to provide confidentiality or integrity, and DoD data may be compromised.

RHEL 8 systems utilizing encryption are required to use FIPS-compliant mechanisms for authenticating to cryptographic modules.

FIPS 140-2 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meets DoD requirements. This allows for Security Levels 1, 2, 3, or 4 for use on a general-purpose computing system.

Solution

Configure RHEL 8 to use a FIPS 140-2 approved cryptographic hashing algorithm for system authentication. Edit/modify the following line in the "/etc/pam.d/system-auth" file to include the sha512 option for pam_unix.so: password sufficient pam_unix.so sha512

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	IA-7
800-53R5	IA-7
CAT	II
CCI	CCI-000803
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
ITSG-33	IA-7
ITSG-33	IA-7a.
NESA	M5.2.1
NESA	M5.2.6
NESA	M5.3.1
NESA	T7.4.1
QCSC-V1	13.2
RULE-ID	SV-244524r1017330_rule
STIG-ID	RHEL-08-010159
VULN-ID	V-244524

Assets

linuxred-01

Compliant file(s):

```
/etc/pam.d/system-auth - regex '^[\s]*password([\#\n\r]+)pam_unix\.so' found - expect
'^[\s]*password([\#\n\r]+)pam_unix\.so([\#\n\r]+)(?i)SHA512(?-i)' found in the following lines:
    11: password    sufficient    pam_unix.so try_first_pass use_authtok nullok sha512
shadow
```

RHEL-08-010160 - The RHEL 8 pam_unix.so module must be configured in the password-auth file to use a FIPS 140-2 approved cryptographic hashing algorithm for system authentication.

Info

Unapproved mechanisms that are used for authentication to the cryptographic module are not verified and therefore cannot be relied upon to provide confidentiality or integrity, and DoD data may be compromised.

RHEL 8 systems utilizing encryption are required to use FIPS-compliant mechanisms for authenticating to cryptographic modules.

FIPS 140-2 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meets DoD requirements. This allows for Security Levels 1, 2, 3, or 4 for use on a general-purpose computing system.

Solution

Configure RHEL 8 to use a FIPS 140-2 approved cryptographic hashing algorithm for system authentication.

Edit/modify the following line in the "/etc/pam.d/password-auth" file to include the sha512 option for pam_unix.so:
password sufficient pam_unix.so sha512

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	IA-7
800-53R5	IA-7
CAT	II
CCI	CCI-000803
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
ITSG-33	IA-7
ITSG-33	IA-7a.
NESA	M5.2.1
NESA	M5.2.6
NESA	M5.3.1
NESA	T7.4.1
QCSC-V1	13.2
RULE-ID	SV-230237r1017056_rule
STIG-ID	RHEL-08-010160
VULN-ID	V-230237

Assets

linuxred-01

Compliant file(s):

```
/etc/pam.d/password-auth - regex '^[\s]*password([\#\n\r]+)pam_unix\.so' found - expect
'^[\s]*password([\#\n\r]+)pam_unix\.so([\#\n\r]+)(?i)SHA512(?-i)' found in the following lines:
    11: password    sufficient    pam_unix.so try_first_pass use_authtok nullok sha512
shadow
```

RHEL-08-010161 - RHEL 8 must prevent system daemons from using Kerberos for authentication.

Info

Unapproved mechanisms that are used for authentication to the cryptographic module are not verified and therefore cannot be relied upon to provide confidentiality or integrity, and DoD data may be compromised.

RHEL 8 systems utilizing encryption are required to use FIPS-compliant mechanisms for authenticating to cryptographic modules.

The key derivation function (KDF) in Kerberos is not FIPS compatible. Ensuring the system does not have any keytab files present prevents system daemons from using Kerberos for authentication. A keytab is a file containing pairs of Kerberos principals and encrypted keys.

FIPS 140-2 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meets DoD requirements. This allows for Security Levels 1, 2, 3, or 4 for use on a general-purpose computing system.

Solution

Configure RHEL 8 to prevent system daemons from using Kerberos for authentication.

Remove any files with the .keytab extension from the operating system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	IA-7
800-53R5	IA-7
CAT	II
CCI	CCI-000803
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
ITSG-33	IA-7
ITSG-33	IA-7a.
NESA	M5.2.1
NESA	M5.2.6
NESA	M5.3.1
NESA	T7.4.1
QCSC-V1	13.2
RULE-ID	SV-230238r1017057_rule
STIG-ID	RHEL-08-010161
VULN-ID	V-230238

Assets

linuxred-01

No results found.

RHEL-08-010162 - The krb5-workstation package must not be installed on RHEL 8.

Info

Unapproved mechanisms that are used for authentication to the cryptographic module are not verified and therefore cannot be relied upon to provide confidentiality or integrity, and DoD data may be compromised.

RHEL 8 systems utilizing encryption are required to use FIPS-compliant mechanisms for authenticating to cryptographic modules.

Currently, Kerberos does not utilize FIPS 140-2 cryptography.

FIPS 140-2 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meets DoD requirements. This allows for Security Levels 1, 2, 3, or 4 for use on a general-purpose computing system.

Solution

Document the krb5-workstation package with the ISSO as an operational requirement or remove it from the system with the following command:

```
$ sudo yum remove krb5-workstation
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	IA-7
800-53R5	IA-7
CAT	II
CCI	CCI-000803
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
ITSG-33	IA-7
ITSG-33	IA-7a.
NESA	M5.2.1
NESA	M5.2.6
NESA	M5.3.1
NESA	T7.4.1
QCSC-V1	13.2
RULE-ID	SV-230239r1017058_rule
STIG-ID	RHEL-08-010162
VULN-ID	V-230239

Assets

linuxred-01

The package 'krb5-workstation-0.0.0-0' is not installed

RHEL-08-010163 - The krb5-server package must not be installed on RHEL 8.

Info

Unapproved mechanisms that are used for authentication to the cryptographic module are not verified and therefore cannot be relied upon to provide confidentiality or integrity, and DoD data may be compromised.

RHEL 8 systems utilizing encryption are required to use FIPS-compliant mechanisms for authenticating to cryptographic modules.

Currently, Kerberos does not utilize FIPS 140-2 cryptography.

FIPS 140-2 is the current standard for validating that mechanisms used to access cryptographic modules utilize authentication that meets DoD requirements. This allows for Security Levels 1, 2, 3, or 4 for use on a general-purpose computing system.

Solution

Document the krb5-server package with the ISSO as an operational requirement or remove it from the system with the following command:

```
$ sudo yum remove krb5-server
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	IA-7
800-53R5	IA-7
CAT	II
CCI	CCI-000803
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
ITSG-33	IA-7
ITSG-33	IA-7a.
NESA	M5.2.1
NESA	M5.2.6
NESA	M5.3.1
NESA	T7.4.1
QCSC-V1	13.2
RULE-ID	SV-237640r1017323_rule
STIG-ID	RHEL-08-010163
VULN-ID	V-237640

Assets

linuxred-01

The package 'krb5-server-0.0.0-0' is not installed

RHEL-08-010170 - RHEL 8 must use a Linux Security Module configured to enforce limits on system services.

Info

Without verification of the security functions, security functions may not operate correctly and the failure may go unnoticed. Security function is defined as the hardware, software, and/or firmware of the information system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based. Security functionality includes, but is not limited to, establishing system accounts, configuring access authorizations (i.e., permissions, privileges), setting events to be audited, and setting intrusion detection parameters.

This requirement applies to operating systems performing security function verification/testing and/or systems and environments that require this functionality.

Solution

Configure the operating system to verify correct operation of all security functions.

Set the "SELinux" status and the "Enforcing" mode by modifying the "/etc/selinux/config" file to have the following line:
SELINUX=enforcing

A reboot is required for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SC-3
800-53R5	SC-3
CAT	II
CCI	CCI-001084
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-3
ITSG-33	SC-3a.
NESA	T3.4.1
NESA	T4.3.1
NESA	T4.3.2
RULE-ID	SV-230240r1017059_rule
STIG-ID	RHEL-08-010170
VULN-ID	V-230240

Assets

linuxred-01

The command '/sbin/getenforce' returned :

Enforcing

RHEL-08-010171 - RHEL 8 must have policycoreutils package installed.

Info

Without verification of the security functions, security functions may not operate correctly and the failure may go unnoticed. Security function is defined as the hardware, software, and/or firmware of the information system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based. Security functionality includes, but is not limited to, establishing system accounts, configuring access authorizations (i.e., permissions, privileges), setting events to be audited, and setting intrusion detection parameters.

Policycoreutils contains the policy core utilities that are required for basic operation of an SELinux-enabled system. These utilities include load_policy to load SELinux policies, setfile to label filesystems, newrole to switch roles, and run_init to run /etc/init.d scripts in the proper context.

Solution

Configure the operating system to have the policycoreutils package installed with the following command:

```
$ sudo yum install policycoreutils
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SC-3
800-53R5	SC-3
CAT	III
CCI	CCI-001084
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-3
ITSG-33	SC-3a.
NESA	T3.4.1
NESA	T4.3.1
NESA	T4.3.2
RULE-ID	SV-230241r1017060_rule
STIG-ID	RHEL-08-010171
VULN-ID	V-230241

Assets

linuxred-01

The local RPM is newer than policycoreutils-0.0.0-0 (policycoreutils-2.9-26.el8_10)

RHEL-08-010210 - The RHEL 8 /var/log/messages file must have mode 0640 or less permissive.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Solution

Change the permissions of the file "/var/log/messages" to "0640" by running the following command:

```
$ sudo chmod 0640 /var/log/messages
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-11b.
800-53R5	SI-11b.
CAT	II
CCI	CCI-001314
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-11c.
RULE-ID	SV-230245r1017063_rule
STIG-ID	RHEL-08-010210
VULN-ID	V-230245

Assets

linuxred-01

The file /var/log/messages with fmode owner: root group: root mode: 0600 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/var/log/messages

RHEL-08-010220 - The RHEL 8 /var/log/messages file must be owned by root.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Solution

Change the owner of the file /var/log/messages to root by running the following command:

```
$ sudo chown root /var/log/messages
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-11b.
800-53R5	SI-11b.
CAT	II
CCI	CCI-001314
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-11c.
RULE-ID	SV-230246r1017064_rule
STIG-ID	RHEL-08-010220
VULN-ID	V-230246

Assets

linuxred-01

The file /var/log/messages with fmode owner: root group: root mode: 0600 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/var/log/messages

RHEL-08-010230 - The RHEL 8 /var/log/messages file must be group-owned by root.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Solution

Change the group of the file "/var/log/messages" to "root" by running the following command:

```
$ sudo chgrp root /var/log/messages
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-11b.
800-53R5	SI-11b.
CAT	II
CCI	CCI-001314
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-11c.
RULE-ID	SV-230247r1017065_rule
STIG-ID	RHEL-08-010230
VULN-ID	V-230247

Assets

linuxred-01

The file /var/log/messages with fmode owner: root group: root mode: 0600 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/var/log/messages

RHEL-08-010240 - The RHEL 8 /var/log directory must have mode 0755 or less permissive.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Solution

Change the permissions of the directory "/var/log" to "0755" by running the following command:

```
$ sudo chmod 0755 /var/log
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-11b.
800-53R5	SI-11b.
CAT	II
CCI	CCI-001314
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-11c.
RULE-ID	SV-230248r1069291_rule
STIG-ID	RHEL-08-010240
VULN-ID	V-230248

Assets

linuxred-01

The file /var/log with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/var/log

RHEL-08-010250 - The RHEL 8 /var/log directory must be owned by root.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Solution

Change the owner of the directory /var/log to root by running the following command:

```
$ sudo chown root /var/log
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-11b.
800-53R5	SI-11b.
CAT	II
CCI	CCI-001314
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-11c.
RULE-ID	SV-230249r1017067_rule
STIG-ID	RHEL-08-010250
VULN-ID	V-230249

Assets

linuxred-01

The file /var/log with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/var/log

RHEL-08-010260 - The RHEL 8 /var/log directory must be group-owned by root.

Info

Only authorized personnel should be aware of errors and the details of the errors. Error messages are an indicator of an organization's operational state or can identify the RHEL 8 system or platform. Additionally, Personally Identifiable Information (PII) and operational information must not be revealed through error messages to unauthorized personnel or their designated representatives.

The structure and content of error messages must be carefully considered by the organization and development team. The extent to which the information system is able to identify and handle error conditions is guided by organizational policy and operational requirements.

Solution

Change the group of the directory "/var/log" to "root" by running the following command:

```
$ sudo chgrp root /var/log
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-11b.
800-53R5	SI-11b.
CAT	II
CCI	CCI-001314
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-11c.
RULE-ID	SV-230250r1017068_rule
STIG-ID	RHEL-08-010260
VULN-ID	V-230250

Assets

linuxred-01

The file /var/log with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/var/log

RHEL-08-010270 - RHEL 8 cryptographic policy must not be overridden.

Info

Centralized cryptographic policies simplify applying secure ciphers across an operating system and the applications that run on that operating system. Use of weak or untested encryption algorithms undermines the purposes of using encryption to protect data.

Satisfies: SRG-OS-000396-GPOS-00176, SRG-OS-000393-GPOS-00173, SRG-OS-000394-GPOS-00174

Solution

Configure RHEL 8 to correctly implement the systemwide cryptographic policies by reinstalling the crypto-policies package contents.

Reinstall crypto-policies with the following command:

```
$ sudo dnf -y reinstall crypto-policies
```

Set the crypto-policy to FIPS with the following command:

```
$ sudo update-crypto-policies --set FIPS
```

Setting system policy to FIPS

Note: Systemwide crypto policies are applied on application startup. It is recommended to restart the system for the change of policies to fully take place.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.11
800-171R3	03.13.11
800-53	SC-13
800-53R5	SC-13b.
CAT	I
CCI	CCI-002450
CSF	PR.DS-5
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iv)
HIPAA	164.312(e)(2)(ii)
ISO-27001-2022	A.8.24
ISO/IEC-27001	A.10.1.1
ITSG-33	SC-13
ITSG-33	SC-13a.

NESA	M5.2.6
NESA	T7.4.1
NIAV2	CY3
NIAV2	CY4
NIAV2	CY5b
NIAV2	CY5c
NIAV2	CY5d
NIAV2	CY7
NIAV2	NS5e
QCSC-V1	6.2
RULE-ID	SV-279932r1156349_rule
STIG-ID	RHEL-08-010270
VULN-ID	V-279932

Assets

linuxred-01

The command '/bin/update-crypto-policies --is-applied' returned :

The configured policy is applied

RHEL-08-010275 - RHEL 8 must implement DOD-approved encryption in the bind package.

Info

Without cryptographic integrity protections, information can be altered by unauthorized users without detection. Cryptographic mechanisms used for protecting the integrity of information include, for example, signed hash functions using asymmetric cryptography enabling distribution of the public key to verify the hash information while maintaining the confidentiality of the secret key used to generate the hash.

RHEL 8 incorporates systemwide crypto policies by default. The employed algorithms can be viewed in the `/etc/crypto-policies/back-ends/` directory.

Satisfies: SRG-OS-000423-GPOS-00187, SRG-OS-000426-GPOS-00190

Solution

Configure BIND to use the system crypto policy.

Add the following line to the "options" section in `/etc/named.conf`:

include `"/etc/crypto-policies/back-ends/bind.config"`;

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.8
800-171R3	03.13.08
800-53	SC-8
800-53R5	SC-8
CAT	II
CCI	CCI-002418
CN-L3	8.1.2.2(a)
CN-L3	8.1.2.2(b)
CN-L3	8.1.4.7(a)
CN-L3	8.1.4.8(a)
CN-L3	8.2.4.5(c)
CN-L3	8.2.4.5(d)
CN-L3	8.5.2.2
CSF	PR.DS-2
CSF	PR.DS-5
CSF2.0	PR.DS-02
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(e)(1)

HIPAA	164.312(e)(2)(i)
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.14
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.20
ITSG-33	SC-8
ITSG-33	SC-8a.
NESA	T4.3.1
NESA	T4.3.2
NESA	T4.5.1
NESA	T4.5.2
NESA	T7.3.3
NESA	T7.4.1
NIAV2	IE8
NIAV2	IE9
NIAV2	IE12
NIAV2	NS29
NIAV2	SS24
PCI-DSSV3.2.1	2.3
PCI-DSSV3.2.1	4.1
PCI-DSSV4.0	2.2.7
PCI-DSSV4.0	4.2.1
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-279931r1156346_rule
STIG-ID	RHEL-08-010275
VULN-ID	V-279931

Assets
linuxred-01

RHEL-08-010280 - RHEL 8 IP tunnels must use FIPS 140-3-approved cryptographic algorithms.

Info

Overriding the system crypto policy makes the behavior of the Libreswan service violate expectations and makes system configuration more fragmented.

Solution

Configure Libreswan to use the system cryptographic policy.
Add the following line to "/etc/ipsec.conf":
include /etc/crypto-policies/back-ends/libreswan.config

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.13
800-171R3	03.13.08
800-53	AC-17(2)
800-53R5	AC-17(2)
CAT	II
CCI	CCI-000068
CN-L3	7.1.2.7(g)
CN-L3	7.1.3.1(d)
CN-L3	8.1.4.1(c)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.14
ISO-27001-2022	A.6.7
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(2)
NESA	T5.4.2
NIAV2	AM37
PCI-DSSV3.2.1	2.3
PCI-DSSV4.0	2.2.7

QCSC-V1	3.2
QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-279930r1156343_rule
STIG-ID	RHEL-08-010280
SWIFT-CSCV1	2.6
VULN-ID	V-279930

Assets

linuxred-01

RHEL-08-010300 - RHEL 8 system commands must have mode 755 or less permissive.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the system commands to be protected from unauthorized access.

Run the following command, replacing "[FILE]" with any system command with a mode more permissive than "755".

```
$ sudo chmod 755 [FILE]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1

NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230257r1017077_rule
STIG-ID	RHEL-08-010300
VULN-ID	V-230257

Assets

linuxred-01

No results found.

RHEL-08-010310 - RHEL 8 system commands must be owned by root.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the system commands to be protected from unauthorized access.

Run the following command, replacing "[FILE]" with any system command file not owned by "root".

```
$ sudo chown root [FILE]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1

NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230258r1017078_rule
STIG-ID	RHEL-08-010310
VULN-ID	V-230258

Assets

linuxred-01

No results found.

RHEL-08-010320 - RHEL 8 system commands must be group-owned by root or a system account.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the system commands to be protected from unauthorized access.

Run the following command, replacing "[FILE]" with any system command file not group-owned by "root" or a required system account.

```
$ sudo chgrp root [FILE]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1

NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230259r1017079_rule
STIG-ID	RHEL-08-010320
VULN-ID	V-230259

Assets

linuxred-01

No results found.

RHEL-08-010330 - RHEL 8 library files must have mode 755 or less permissive.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the systemwide shared library files contained in the directories `"/lib"`, `"/lib64"`, `"/usr/lib"`, and `"/usr/lib64"` have mode 0755 or less permissive with the following command.

```
$ sudo find /lib /lib64 /usr/lib /usr/lib64 -type f -name '*.so*' -perm /022 -exec chmod go-w {} +
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1

NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230260r1101888_rule
STIG-ID	RHEL-08-010330
VULN-ID	V-230260

Assets

linuxred-01

No results found.

RHEL-08-010331 - RHEL 8 library directories must have mode 755 or less permissive.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the library directories to be protected from unauthorized access. Run the following command, replacing "[DIRECTORY]" with any library directory with a mode more permissive than 755.

```
$ sudo chmod 755 [DIRECTORY]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1

NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-251707r1017360_rule
STIG-ID	RHEL-08-010331
VULN-ID	V-251707

Assets

linuxred-01

No results found.

RHEL-08-010340 - RHEL 8 library files must be owned by root.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the systemwide shared library files contained in the directories `"/lib"`, `"/lib64"`, `"/usr/lib"`, and `"/usr/lib64"` to be owned by root with the following command:

```
$ sudo find /lib /lib64 /usr/lib /usr/lib64 -type f -name '*.so*' ! -user root -exec chown root {} +
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1

NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230261r1101891_rule
STIG-ID	RHEL-08-010340
VULN-ID	V-230261

Assets

linuxred-01

No results found.

RHEL-08-010341 - RHEL 8 library directories must be owned by root.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the system-wide shared library directories within (/lib, /lib64, /usr/lib and /usr/lib64) to be protected from unauthorized access.

Run the following command, replacing "[DIRECTORY]" with any library directory not owned by "root".

```
$ sudo chown root [DIRECTORY]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1

NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-251708r1017362_rule
STIG-ID	RHEL-08-010341
VULN-ID	V-251708

Assets

linuxred-01

No results found.

RHEL-08-010350 - RHEL 8 library files must be group-owned by root.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the systemwide shared library files contained in the directories `"/lib"`, `"/lib64"`, `"/usr/lib"`, and `"/usr/lib64"` are group owned by root with the following command:

```
$ sudo find /lib /lib64 /usr/lib /usr/lib64 -type f -name '*.so*' ! -group root -exec chown :root {} +
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1

NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230262r1155384_rule
STIG-ID	RHEL-08-010350
VULN-ID	V-230262

Assets

linuxred-01

No results found.

RHEL-08-010351 - RHEL 8 library directories must be group-owned by root or a system account.

Info

If RHEL 8 were to allow any user to make changes to software libraries, then those changes might be implemented without undergoing the appropriate testing and approvals that are part of a robust change management process. This requirement applies to RHEL 8 with software libraries that are accessible and configurable, as in the case of interpreted languages. Software libraries also include privileged programs that execute with escalated privileges. Only qualified and authorized individuals will be allowed to obtain access to information system components for purposes of initiating changes, including upgrades and modifications.

Solution

Configure the system-wide shared library directories (/lib, /lib64, /usr/lib and /usr/lib64) to be protected from unauthorized access.

Run the following command, replacing "[DIRECTORY]" with any library directory not group-owned by "root".

```
$ sudo chgrp root [DIRECTORY]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(6)
800-53R5	CM-5(6)
CAT	II
CCI	CCI-001499
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(6)
NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1

NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-251709r1017364_rule
STIG-ID	RHEL-08-010351
VULN-ID	V-251709

Assets

linuxred-01

No results found.

RHEL-08-010370 - RHEL 8 must prevent the installation of software, patches, service packs, device drivers, or operating system components from a repository without verification they have been digitally signed using a certificate that is issued by a Certificate Authority (CA) that is recognized and approved by the organization.

Info

Changes to any software components can have significant effects on the overall security of the operating system. This requirement ensures the software has not been tampered with and that it has been provided by a trusted vendor. Accordingly, patches, service packs, device drivers, or operating system components must be signed with a certificate recognized and approved by the organization.

Verifying the authenticity of the software prior to installation validates the integrity of the patch or upgrade received from a vendor. This verifies the software has not been tampered with and that it has been provided by a trusted vendor. Self-signed certificates are disallowed by this requirement. The operating system should not have to verify the software again. This requirement does not mandate DoD certificates for this purpose; however, the certificate used to verify the software must be from an approved CA.

Solution

Configure the operating system to verify the signature of packages from a repository prior to install by setting the following option in the "/etc/yum.repos.d/[your_repo_name].repo" file:
gpgcheck=1

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.5
800-171R3	03.04.05
800-53	CM-5(3)
800-53R5	CM-14
CAT	I
CCI	CCI-001749
CCI	CCI-003992
CSF	PR.IP-1
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.4
ISO-27001-2022	A.8.9
ISO-27001-2022	A.8.19
ISO-27001-2022	A.8.31
ISO-27001-2022	A.8.32
ITSG-33	CM-5(3)

NESA	T3.2.3
NESA	T5.1.1
NESA	T5.6.1
NESA	T7.5.1
NESA	T7.5.3
NESA	T7.6.3
QCSC-V1	7.2
RULE-ID	SV-230264r1017377_rule
STIG-ID	RHEL-08-010370
VULN-ID	V-230264

Assets

linuxred-01

```
Compliant file(s):
/etc/yum.repos.d/redhat.repo - regex not found
/etc/yum.repos.d/rh-cloud-base.repo - regex '^[\s]*gpgcheck[\s]*=' found - expect
'^[\s]*gpgcheck[\s]*=[\s]*1[\s]*$' found in the following lines:
  5: gpgcheck=1
 16: gpgcheck=1
 27: gpgcheck=1
 38: gpgcheck=1
 49: gpgcheck=1
 60: gpgcheck=1
 71: gpgcheck=1
 82: gpgcheck=1
 93: gpgcheck=1
104: gpgcheck=1
115: gpgcheck=1
126: gpgcheck=1
137: gpgcheck=1
148: gpgcheck=1
159: gpgcheck=1
170: gpgcheck=1
```

RHEL-08-010379 - RHEL 8 must specify the default "include" directory for the /etc/sudoers file.

Info

The "sudo" command allows authorized users to run programs (including shells) as other users, system users, and root. The "/etc/sudoers" file is used to configure authorized "sudo" users as well as the programs they are allowed to run. Some configuration options in the "/etc/sudoers" file allow configured users to run programs without re-authenticating. Use of these configuration options makes it easier for one compromised account to be used to compromise other accounts.

It is possible to include other sudoers files from within the sudoers file currently being parsed using the #include and #includedir directives. When sudo reaches this line it will suspend processing of the current file (/etc/sudoers) and switch to the specified file/directory. Once the end of the included file(s) is reached, the rest of /etc/sudoers will be processed. Files that are included may themselves include other files. A hard limit of 128 nested include files is enforced to prevent include file loops.

Solution

Configure the /etc/sudoers file to only include the /etc/sudoers.d directory.

Edit the /etc/sudoers file with the following command:

```
$ sudo visudo
```

Add or modify the following line:

```
#includedir /etc/sudoers.d
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-251711r1017365_rule
STIG-ID	RHEL-08-010379
SWIFT-CSCV1	2.3

VULN-ID

V-251711

Assets

linuxred-01

RHEL-08-010385 - The RHEL 8 operating system must not be configured to bypass password requirements for privilege escalation.

Info

Without re-authentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to escalate a functional capability, it is critical the user re-authenticate. Satisfies: SRG-OS-000373-GPOS-00156, SRG-OS-000373-GPOS-00157, SRG-OS-000373-GPOS-00158

Solution

Configure the operating system to require users to supply a password for privilege escalation.
Check the configuration of the "/etc/pam.d/sudo" file with the following command:
\$ sudo vi /etc/pam.d/sudo
Remove any occurrences of "pam_succeed_if" in the file.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.01b.
800-53	IA-11
800-53R5	SC-11b.
CAT	II
CCI	CCI-002038
CCI	CCI-004895
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
QCSC-V1	13.2
RULE-ID	SV-251712r1050789_rule
STIG-ID	RHEL-08-010385
VULN-ID	V-251712

Assets

linuxred-01

The following file(s) do not contain "pam_succeed_if":
/etc/pam.d/sudo

RHEL-08-010390 - RHEL 8 must have the packages required for multifactor authentication installed.

Info

Using an authentication device, such as a DoD Common Access Card (CAC) or token that is separate from the information system, ensures that even if the information system is compromised, credentials stored on the authentication device will not be affected.

Multifactor solutions that require devices separate from information systems gaining access include, for example, hardware tokens providing time-based or challenge-response authenticators and smart cards such as the U.S. Government Personal Identity Verification (PIV) card and the DoD CAC.

A privileged account is defined as an information system account with authorizations of a privileged user.

Remote access is access to DoD nonpublic information systems by an authorized user (or an information system) communicating through an external, non-organization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

This requirement only applies to components where this is specific to the function of the device or has the concept of an organizational user (e.g., VPN, proxy capability). This does not apply to authentication for the purpose of configuring the device itself (management).

Solution

Configure the operating system to implement multifactor authentication by installing the required package with the following command:

```
$ sudo yum install openssl-pkcs11
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.1
800-171R3	03.05.01a.
800-53	IA-2(11)
800-53R5	IA-2(6)(a)
CAT	II
CCI	CCI-001948
CCI	CCI-004046
CN-L3	8.1.4.1(d)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ITSG-33	IA-2(100)
NESA	T5.4.2

NIAV2	AM2
NIAV2	AM8
NIAV2	AM14b
PCI-DSSV3.2.1	8.3
PCI-DSSV3.2.1	8.3.1
PCI-DSSV3.2.1	8.3.2
PCI-DSSV4.0	8.4.1
PCI-DSSV4.0	8.4.3
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230273r1017381_rule
STIG-ID	RHEL-08-010390
SWIFT-CSCV1	4.2
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-230273

Assets

linuxred-01

The local RPM is newer than openssl-pkcs11-0.0.0-0 (openssl-pkcs11-0.4.10-3.el8)

RHEL-08-010420 - RHEL 8 must implement non-executable data to protect its memory from unauthorized code execution.

Info

Some adversaries launch attacks with the intent of executing code in non-executable regions of memory or in memory locations that are prohibited. Security safeguards employed to protect memory include, for example, data execution prevention and address space layout randomization. Data execution prevention safeguards can be either hardware-enforced or software-enforced with hardware providing the greater strength of mechanism.

Examples of attacks are buffer overflow attacks.

Solution

The NX bit execute protection must be enabled in the system BIOS.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-16
800-53R5	SI-16
CAT	II
CCI	CCI-002824
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-16
RULE-ID	SV-230276r958928_rule
STIG-ID	RHEL-08-010420
VULN-ID	V-230276

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
PASSED - dmesg
The command '/bin/dmesg | /bin/grep '[NX|DX]*protection'' returned :

[    0.000000] NX (Execute Disable) protection: active

-----
PASSED - /proc/cpuinfo
Compliant file(s):
    /proc/cpuinfo - regex '(?i)^[\\s]*flags' found - expect '(?i)^[\\s]*flags[\\s]*:[\\s]*([\\^\\n\\r]+[\\s]+)?nx([\\s]+|$)' found in the following lines:
    20: flags      : fpu vme de pse tsc msr pae mce cx8 apic sep mtrr pge mca cmov pat pse36
    clflush mmx fxsr sse sse2 ht syscall nx mmxext fxsr_opt pdpe1gb rdtscp lm constant_tsc rep_good
    nopl tsc_reliable nonstop_tsc cpuid extd_apicid aperfmperf pni pclmulqdq ssse3 fma cx16 pcid
    sse4_1 sse4_2 movbe popcnt aes xsave avx f16c rdrand hypervisor lahf_lm cmp_legacy svm cr8_legacy
    abm sse4a misalignsse 3dnowprefetch osvw topoext invpcid_single vmcall fsgsbase bmi1 avx2 smep
    bmi2 erms invpcid avx512f avx512dq rdseed adx smap avx512ifma clflushopt clwb avx512cd sha_ni
    avx512bw avx512vl xsaveopt xsavec xgetbv1 xsaves avx512_bf16 clzero xsaveerptr arat npt nrip_save
    tsc_scale vmcb_clean flushbyasid decodeassists pausefilter pfthreshold v_vmsave_vmload avx512vbmi
    umip avx512_vbmi2 gfni vaes vpclmulqdq avx512_vnni avx512_bitalg avx512_vpopcntdq rdpid fsrm
```

48: flags : fpu vme de pse tsc msr pae mce cx8 apic sep mtrr pge mca cmov pat pse36
clflush mmx fxsr sse sse2 ht syscall nx mmxext fxsr_opt pdpe1gb rdtscp lm constant_tsc rep_good
nopl tsc_reliable nonstop_tsc cpuid extd_apicid aperfmperf pni pclmulqdq ssse3 fma cx16 pcid
sse4_1 sse4_2 movbe popcnt aes xsave avx f16c rdrand hypervisor lahf_lm cmp_legacy svm cr8_legacy
abm sse4a misalignsse 3dnowprefetch osvw topoext invpcid_single vmmcall fsgsbase bmi1 avx2 smep
bmi2 erms invpcid avx512f avx512dq rdseed adx smap avx512ifma clflushopt clwb avx512cd sha_ni
avx512bw avx512vl xsaveopt xsavec xgetbv1 xsaves avx512_bf16 clzero xsaveerptr arat npt nrip_save
tsc_scale vmcb_clean flushbyasid [...]

RHEL-08-010440 - YUM must remove all software components after updated versions have been installed on RHEL 8.

Info

Previous versions of software components that are not removed from the information system after updates have been installed may be exploited by adversaries. Some information technology products may remove older versions of software automatically from the information system.

Solution

Configure the operating system to remove all software components after updated versions have been installed. Set the "clean_requirements_on_remove" option to "True" in the "/etc/dnf/dnf.conf" file:
clean_requirements_on_remove=True

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.14.1
800-171R3	03.14.01
800-53	SI-2(6)
800-53R5	SI-2(6)
CAT	III
CCI	CCI-002617
CN-L3	8.1.4.4(e)
CN-L3	8.1.10.5(a)
CN-L3	8.1.10.5(b)
CN-L3	8.5.4.1(b)
CN-L3	8.5.4.1(d)
CN-L3	8.5.4.1(e)
CSF	ID.RA-1
CSF	PR.IP-12
CSF2.0	ID.IM-01
CSF2.0	ID.IM-02
CSF2.0	ID.IM-03
CSF2.0	PR.PS-02
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.6.8
ISO-27001-2022	A.8.8

ISO-27001-2022	A.8.32
ITSG-33	SI-2
NESA	T7.6.2
NESA	T7.7.1
NIAV2	PR9
PCI-DSSV3.2.1	6.2
PCI-DSSV4.0	6.3
PCI-DSSV4.0	6.3.3
QCSC-V1	11.2
RULE-ID	SV-230281r958936_rule
STIG-ID	RHEL-08-010440
SWIFT-CSCV1	2.2
VULN-ID	V-230281

Assets

linuxred-01

```
Compliant file(s):
  /etc/dnf/dnf.conf - regex '(?i)^\s*clean_requirements_on_remove\s*=\s*' found - expect
  '(?i)^\s*clean_requirements_on_remove\s*=\s*(True|yes|1)\s*$' found in the following
  lines:
    4: clean_requirements_on_remove=True
```

RHEL-08-010450 - RHEL 8 must enable the SELinux targeted policy.

Info

Without verification of the security functions, security functions may not operate correctly and the failure may go unnoticed. Security function is defined as the hardware, software, and/or firmware of the information system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based. Security functionality includes, but is not limited to, establishing system accounts, configuring access authorizations (i.e., permissions, privileges), setting events to be audited, and setting intrusion detection parameters.

This requirement applies to operating systems performing security function verification/testing and/or systems and environments that require this functionality.

Solution

Configure the operating system to verify correct operation of all security functions.

Set the "SELinuxtype" to the "targeted" policy by modifying the "/etc/selinux/config" file to have the following line:

SELINUXTYPE=targeted

A reboot is required for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	SI-6a.
800-53R5	SI-6a.
CAT	II
CCI	CCI-002696
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SI-6a.
RULE-ID	SV-230282r958944_rule
STIG-ID	RHEL-08-010450
VULN-ID	V-230282

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - SELinux targeted

The command '/sbin/sestatus' returned :

```
SELinux status:                enabled
SELinuxfs mount:              /sys/fs/selinux
SELinux root directory:      /etc/selinux
Loaded policy name:          targeted
Current mode:                 enforcing
Mode from config file:       enforcing
Policy MLS status:           enabled
Policy deny_unknown status:   allowed
Memory protection checking:   actual (secure)
Max kernel policy version:    33
```

PASSED - Verify /etc/selinux/config is configured with SELINUXTYPE = targeted
Compliant file(s):

```
/etc/selinux/config - regex '(?i)^\s*SELINUXTYPE\s*=\s*'\s*' found - expect '(?  
i)^\s*SELINUXTYPE\s*=\s*'\s*targeted\s*$' found in the following lines:  
12: SELINUXTYPE=targeted
```

RHEL-08-010460 - There must be no shosts.equiv files on the RHEL 8 operating system.

Info

The "shosts.equiv" files are used to configure host-based authentication for the system via SSH. Host-based authentication is not sufficient for preventing unauthorized access to the system, as it does not require interactive identification and authentication of a connection request, or for the use of two-factor authentication.

Solution

Remove any found "shosts.equiv" files from the system.
\$ sudo rm /etc/ssh/shosts.equiv

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230283r1017094_rule
STIG-ID	RHEL-08-010460
SWIFT-CSCV1	2.3
VULN-ID	V-230283

Assets

linuxred-01

No results found.

RHEL-08-010470 - There must be no .shosts files on the RHEL 8 operating system.

Info

The ".shosts" files are used to configure host-based authentication for individual users or the system via SSH. Host-based authentication is not sufficient for preventing unauthorized access to the system, as it does not require interactive identification and authentication of a connection request, or for the use of two-factor authentication.

Solution

Remove any found ".shosts" files from the system.
\$ sudo rm /[path]/[to]/[file]/.shosts

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230284r1017095_rule
STIG-ID	RHEL-08-010470
SWIFT-CSCV1	2.3
VULN-ID	V-230284

Assets

linuxred-01

No results found.

RHEL-08-010472 - RHEL 8 must have the packages required to use the hardware random number generator entropy gatherer service.

Info

The most important characteristic of a random number generator is its randomness, namely its ability to deliver random numbers that are impossible to predict. Entropy in computer security is associated with the unpredictability of a source of randomness. The random source with high entropy tends to achieve a uniform distribution of random values. Random number generators are one of the most important building blocks of cryptosystems.

The rngd service feeds random data from hardware device to kernel random device. Quality (non-predictable) random number generation is important for several security functions (i.e., ciphers).

Solution

Install the packages required to enable the hardware random number generator entropy gatherer service with the following command:

```
$ sudo yum install rng-tools
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244527r1017333_rule
STIG-ID	RHEL-08-010472
SWIFT-CSCV1	2.3
VULN-ID	V-244527

Assets

linuxred-01

The local RPM is newer than rng-tools-0.0.0-0 (rng-tools-6.16-1.el8)

RHEL-08-010480 - The RHEL 8 SSH public host key files must have mode 0644 or less permissive.

Info

If a public host key file is modified by an unauthorized user, the SSH service may be compromised.

Solution

Change the mode of public host key files under "/etc/ssh" to "0644" with the following command:

```
$ sudo chmod 0644 /etc/ssh/*key.pub
```

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230286r1017097_rule
STIG-ID	RHEL-08-010480
SWIFT-CSCV1	2.3
VULN-ID	V-230286

Assets

linuxred-01

The file /etc/ssh/ssh_host_ecdsa_key.pub with fmode owner: root group: root mode: 0644 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

The file /etc/ssh/ssh_host_ed25519_key.pub with fmode owner: root group: root mode: 0644 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

The file /etc/ssh/ssh_host_rsa_key.pub with fmode owner: root group: root mode: 0644 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/etc/ssh/ssh_host_ecdsa_key.pub, /etc/ssh/ssh_host_ed25519_key.pub, /etc/ssh/ssh_host_rsa_key.pub

RHEL-08-010490 - The RHEL 8 SSH private host key files must have mode 0640 or less permissive.

Info

If an unauthorized user obtains the private SSH host key file, the host could be impersonated.

Solution

Configure the mode of SSH private host key files under "/etc/ssh" to "0640" with the following command:

```
$ sudo chmod 0640 /etc/ssh/ssh_host*key
```

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230287r1017098_rule
STIG-ID	RHEL-08-010490
SWIFT-CSCV1	2.3
VULN-ID	V-230287

Assets

linuxred-01

The file /etc/ssh/ssh_host_ecdsa_key with fmode owner: root group: ssh_keys mode: 0640 uid: 0 gid: 994 uneven permissions : FALSE is compliant with the policy value

The file /etc/ssh/ssh_host_ed25519_key with fmode owner: root group: ssh_keys mode: 0640 uid: 0 gid: 994 uneven permissions : FALSE is compliant with the policy value

The file /etc/ssh/ssh_host_rsa_key with fmode owner: root group: ssh_keys mode: 0640 uid: 0 gid: 994 uneven permissions : FALSE is compliant with the policy value

/etc/ssh/ssh_host_ecdsa_key, /etc/ssh/ssh_host_ed25519_key, /etc/ssh/ssh_host_rsa_key

RHEL-08-010540 - RHEL 8 must use a separate file system for /var.

Info

The use of separate file systems for different paths can protect the system from failures resulting from a file system becoming full or failing.

Solution

Migrate the "/var" path onto a separate file system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230292r1017103_rule
STIG-ID	RHEL-08-010540
SWIFT-CSCV1	2.3
VULN-ID	V-230292

Assets

linuxred-01

```
Compliant file(s):
/etc/fstab - regex '^(\#?\n\r)+[\s]+/var[\s]+' found - expect '^(\#?\n\r)+[\s]+/var[\s]+'
found in the following lines:
18: /dev/mapper/rootvg-varlv /var          xfs      defaults      0 0
```


RHEL-08-010543 - A separate RHEL 8 filesystem must be used for the /tmp directory.

Info

The use of separate file systems for different paths can protect the system from failures resulting from a file system becoming full or failing.

Solution

Migrate the "/tmp" directory onto a separate file system/partition.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230295r1017106_rule
STIG-ID	RHEL-08-010543
SWIFT-CSCV1	2.3
VULN-ID	V-230295

Assets

linuxred-01

```
Compliant file(s):
/etc/fstab - regex '^(\#\\n\\r)+[\\s]+/tmp[\\s]+' found - expect '^(\#\\n\\r)+[\\s]+/tmp[\\s]+'
found in the following lines:
16: /dev/mapper/rootvg-tmplv /tmp          xfs      defaults      0 0
```

RHEL-08-010561 - The rsyslog service must be running in RHEL 8.

Info

Configuring RHEL 8 to implement organization-wide security implementation guides and security checklists ensures compliance with federal standards and establishes a common security baseline across the DoD that reflects the most restrictive security posture consistent with operational requirements.

Configuration settings are the set of parameters that can be changed in hardware, software, or firmware components of the system that affect the security posture and/or functionality of the system. Security-related parameters are those parameters impacting the security state of the system, including the parameters required to satisfy other security control requirements. Security-related parameters include, for example: registry settings; account, file, directory permission settings; and settings for functions, ports, protocols, services, and remote connections.

Solution

Start the auditd service, and enable the rsyslog service with the following commands:

```
$ sudo systemctl start rsyslog.service
```

```
$ sudo systemctl enable rsyslog.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230298r1017108_rule
STIG-ID	RHEL-08-010561
SWIFT-CSCV1	2.3
VULN-ID	V-230298

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - is-enabled

The command '/bin/systemctl is-enabled rsyslog' returned :

enabled

PASSED - is-active

The command '/bin/systemctl is-active rsyslog' returned :

active

RHEL-08-010571 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on the /boot directory.

Info

The "nosuid" mount option causes the system not to execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nosuid" option on the /boot directory.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230300r1017110_rule
STIG-ID	RHEL-08-010571
SWIFT-CSCV1	2.3
VULN-ID	V-230300

Assets

linuxred-01

RHEL-08-010600 - RHEL 8 must prevent special devices on file systems that are used with removable media.

Info

The "nodev" mount option causes the system not to interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nodev" option on file systems that are associated with removable media.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230303r1017113_rule
STIG-ID	RHEL-08-010600
SWIFT-CSCV1	2.3
VULN-ID	V-230303

Assets

linuxred-01

No matching files were found

RHEL-08-010610 - RHEL 8 must prevent code from being executed on file systems that are used with removable media.

Info

The "noexec" mount option causes the system not to execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "noexec" option on file systems that are associated with removable media.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230304r1017114_rule
STIG-ID	RHEL-08-010610
SWIFT-CSCV1	2.3
VULN-ID	V-230304

Assets

linuxred-01

No matching files were found

RHEL-08-010620 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on file systems that are used with removable media.

Info

The "nosuid" mount option causes the system not to execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nosuid" option on file systems that are associated with removable media.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230305r1017115_rule
STIG-ID	RHEL-08-010620
SWIFT-CSCV1	2.3
VULN-ID	V-230305

Assets

linuxred-01

No matching files were found

RHEL-08-010630 - RHEL 8 must prevent code from being executed on file systems that are imported via Network File System (NFS).

Info

The "noexec" mount option causes the system not to execute binary files. This option must be used for mounting any file system not containing approved binary as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "noexec" option on file systems that are being imported via NFS.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230306r1155386_rule
STIG-ID	RHEL-08-010630
SWIFT-CSCV1	2.3
VULN-ID	V-230306

Assets

linuxred-01

No matching files were found

RHEL-08-010640 - RHEL 8 must prevent special devices on file systems that are imported via Network File System (NFS).

Info

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nodev" option on file systems that are being imported via NFS.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230307r1155388_rule
STIG-ID	RHEL-08-010640
SWIFT-CSCV1	2.3
VULN-ID	V-230307

Assets

linuxred-01

No matching files were found

RHEL-08-010650 - RHEL 8 must prevent files with the setuid and setgid bit set from being executed on file systems that are imported via Network File System (NFS).

Info

The "nosuid" mount option causes the system not to execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the "/etc/fstab" to use the "nosuid" option on file systems that are being imported via NFS.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230308r1155390_rule
STIG-ID	RHEL-08-010650
SWIFT-CSCV1	2.3
VULN-ID	V-230308

Assets

linuxred-01

No matching files were found

RHEL-08-010700 - All RHEL 8 world-writable directories must be owned by root, sys, bin, or an application user.

Info

If a world-writable directory is not owned by root, sys, bin, or an application User Identifier (UID), unauthorized users may be able to modify files created by others.

The only authorized public directories are those temporary directories supplied with the system or those designed to be temporary file repositories. The setting is normally reserved for directories used by the system and by users for temporary file storage, (e.g., /tmp), and for directories requiring global read/write access.

Solution

Configure all RHEL 8 public directories to be owned by root or a system account to prevent unauthorized and unintended information transferred via shared system resources.

Use the following command template to set ownership of public directories to root or a system account:

```
$ sudo chown [root or system account] [Public Directory]
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230318r1155352_rule
STIG-ID	RHEL-08-010700
SWIFT-CSCV1	2.3
VULN-ID	V-230318

Assets

linuxred-01

No results found.

RHEL-08-010710 - All RHEL 8 world-writable directories must be group-owned by root, sys, bin, or an application group.

Info

If a world-writable directory is not group-owned by root, sys, bin, or an application Group Identifier (GID), unauthorized users may be able to modify files created by others.

The only authorized public directories are those temporary directories supplied with the system or those designed to be temporary file repositories. The setting is normally reserved for directories used by the system and by users for temporary file storage, (e.g., /tmp), and for directories requiring global read/write access.

Solution

All directories in local partitions which are world-writable must be group-owned by root or another system account. If any world-writable directories are not group-owned by a system account, this must be investigated. Following this, the directories must be deleted or assigned to an appropriate group.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230319r1017130_rule
STIG-ID	RHEL-08-010710
SWIFT-CSCV1	2.3
VULN-ID	V-230319

Assets

linuxred-01

No results found.

RHEL-08-010720 - All RHEL 8 local interactive users must have a home directory assigned in the /etc/passwd file.

Info

If local interactive users are not assigned a valid home directory, there is no place for the storage and control of files they should own.

Solution

Assign home directories to all local interactive users on RHEL 8 that currently do not have a home directory assigned.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230320r1017131_rule
STIG-ID	RHEL-08-010720
SWIFT-CSCV1	2.3
VULN-ID	V-230320

Assets

linuxred-01

No issues found.

RHEL-08-010730 - All RHEL 8 local interactive user home directories must have mode 0750 or less permissive.

Info

Excessive permissions on local interactive user home directories may allow unauthorized access to user files by other users.

Solution

Change the mode of interactive user's home directories to "0750". To change the mode of a local interactive user's home directory, use the following command:

Note: The example will be for the user "smithj".

```
$ sudo chmod 0750 /home/smithj
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230321r1017132_rule
STIG-ID	RHEL-08-010730
SWIFT-CSCV1	2.3
VULN-ID	V-230321

Assets

linuxred-01

No issues found.

RHEL-08-010731 - All RHEL 8 local interactive user home directory files must have mode 0750 or less permissive.

Info

Excessive permissions on local interactive user home directories may allow unauthorized access to user files by other users.

Solution

Set the mode on files and directories in the local interactive user home directory with the following command:

Note: The example will be for the user smithj, who has a home directory of "/home/smithj" and is a member of the users group.

```
$ sudo chmod 0750 /home/smithj/<file or directory>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244531r1017338_rule
STIG-ID	RHEL-08-010731
SWIFT-CSCV1	2.3
VULN-ID	V-244531

Assets

linuxred-01

No results found.

RHEL-08-010740 - All RHEL 8 local interactive user home directories must be group-owned by the home directory owner's primary group.

Info

If the Group Identifier (GID) of a local interactive user's home directory is not the same as the primary GID of the user, this would allow unauthorized access to the user's files, and users that share the same group may not be able to access files that they legitimately should.

Solution

Change the group owner of a local interactive user's home directory to the group found in "/etc/passwd". To change the group owner of a local interactive user's home directory, use the following command:

Note: The example will be for the user "smithj", who has a home directory of "/home/smithj", and has a primary group of users.

```
$ sudo chgrp users /home/smithj
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230322r1017133_rule
STIG-ID	RHEL-08-010740
SWIFT-CSCV1	2.3
VULN-ID	V-230322

Assets

linuxred-01

```
The command 'home_dirs=`/bin/awk -F: '($3>=1000)&&($7 !~ /nologin/)&&($1 !~ /nobody/){print $6}' /etc/passwd | /bin/sort -u`; for dirs in $home_dirs; do g=$(/bin/stat -c %G $dirs); o=$(/bin/stat -
```

```
c %U $dirs); p=$(/bin/id -gn $o); if [ $p != $g ]; then echo "${dirs} group-owned by ${g} (should  
be owned by ${p})"; fi; done | /bin/awk '{print} END {if (NR <= 0) print "All local interactive  
user home directories have correct group ownership"}' returned :
```

All local interactive user home directories have correct group ownership

RHEL-08-010741 - RHEL 8 must be configured so that all files and directories contained in local interactive user home directories are group-owned by a group of which the home directory owner is a member.

Info

If a local interactive user's files are group-owned by a group of which the user is not a member, unintended users may be able to access them.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Change the group of a local interactive user's files and directories to a group that the interactive user is a member. To change the group owner of a local interactive user's files and directories, use the following command:

Note: The example will be for the user smithj, who has a home directory of "/home/smithj" and is a member of the users group.

```
$ sudo chgrp smithj /home/smithj/<file or directory>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244532r1101906_rule
STIG-ID	RHEL-08-010741
SWIFT-CSCV1	2.3
VULN-ID	V-244532

Assets

linuxred-01

The command `/bin/awk -F: '{if ($3 >= 1000 && $7 !~ "nologin") print $6 " " $1}' /etc/passwd | /bin/xargs -l /bin/bash -c 'IDS=$(id -G $1 | /bin/sed -e "s/ */ -o -group /g"); /bin/find $0 ! \(-group $IDS\) | /bin/awk '{print} END {if (NR == 0) print "pass";}'` returned :

pass

RHEL-08-010750 - All RHEL 8 local interactive user home directories defined in the /etc/passwd file must exist.

Info

If a local interactive user has a home directory defined that does not exist, the user may be given access to the "/" directory as the current working directory upon logon. This could create a denial of service because the user would not be able to access their logon configuration files, and it may give them visibility to system files they normally would not be able to access.

Solution

Create home directories to all local interactive users that currently do not have a home directory assigned. Use the following commands to create the user home directory assigned in "/etc/passwd":

Note: The example will be for the user smithj, who has a home directory of "/home/smithj", a UID of "smithj", and a Group Identifier (GID) of "users assigned" in "/etc/passwd".

```
$ sudo mkdir /home/smithj $ sudo chown smithj /home/smithj $ sudo chgrp users /home/smithj $ sudo chmod 0750 /home/smithj
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230323r1017134_rule
STIG-ID	RHEL-08-010750
SWIFT-CSCV1	2.3
VULN-ID	V-230323

Assets

linuxred-01

No issues found.

RHEL-08-010760 - All RHEL 8 local interactive user accounts must be assigned a home directory upon creation.

Info

If local interactive users are not assigned a valid home directory, there is no place for the storage and control of files they should own.

Solution

Configure RHEL 8 to assign home directories to all new local interactive users by setting the "CREATE_HOME" parameter in "/etc/login.defs" to "yes" as follows.

CREATE_HOME yes

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230324r1017135_rule
STIG-ID	RHEL-08-010760
SWIFT-CSCV1	2.3
VULN-ID	V-230324

Assets

linuxred-01

```
Compliant file(s):
/etc/login.defs - regex '(?i)^\s*CREATE_HOME\s*' found - expect '(?i)^\s*CREATE_HOME\s*yes\s*$' found in the following lines:
74: CREATE_HOME yes
```

RHEL-08-010780 - All RHEL 8 local files and directories must have a valid owner.

Info

Unowned files and directories may be unintentionally inherited if a user is assigned the same User Identifier "UID" as the UID of the un-owned files.

Solution

Either remove all files and directories from the system that do not have a valid user, or assign a valid user to all unowned files and directories on RHEL 8 with the "chown" command:

```
$ sudo chown <user> <file>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230326r1069284_rule
STIG-ID	RHEL-08-010780
SWIFT-CSCV1	2.3
VULN-ID	V-230326

Assets

linuxred-01

No issues found.

RHEL-08-010790 - All RHEL 8 local files and directories must have a valid group owner.

Info

Files without a valid group owner may be unintentionally inherited if a group is assigned the same Group Identifier (GID) as the GID of the files without a valid group owner.

Solution

Either remove all files and directories from RHEL 8 that do not have a valid group, or assign a valid group to all files and directories on the system with the "chgrp" command:

```
$ sudo chgrp <group> <file>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230327r1069285_rule
STIG-ID	RHEL-08-010790
SWIFT-CSCV1	2.3
VULN-ID	V-230327

Assets

linuxred-01

No issues found.

RHEL-08-010800 - A separate RHEL 8 filesystem must be used for user home directories (such as /home or an equivalent).

Info

The use of separate file systems for different paths can protect the system from failures resulting from a file system becoming full or failing.

Solution

Migrate the "/home" directory onto a separate file system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230328r1155410_rule
STIG-ID	RHEL-08-010800
SWIFT-CSCV1	2.3
VULN-ID	V-230328

Assets

linuxred-01

```
Compliant file(s):
/etc/fstab - regex '^#[\n\r]+[\s]+/home[\s]+' found - expect '^#[\n\r]+[\s]+/home[\s]+'
found in the following lines:
    15: /dev/mapper/rootvg-homelv /home                xfs      defaults      0 0
```

RHEL-08-010820 - Unattended or automatic login via the RHEL 8 graphical user interface must not be allowed.

Info

Failure to restrict system access to authenticated users negatively impacts operating system security.

Solution

Configure the operating system to not allow an unattended or automatic login to the system via a graphical user interface.

Add or edit the line for the "AutomaticLoginEnable" parameter in the [daemon] section of the "/etc/gdm/custom.conf" file to "false":

```
[daemon] AutomaticLoginEnable=false
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230329r1017140_rule
STIG-ID	RHEL-08-010820
SWIFT-CSCV1	2.3
VULN-ID	V-230329

Assets

linuxred-01

RHEL-08-020010 - RHEL 8 must automatically lock an account when three unsuccessful logon attempts occur.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to lock an account when three unsuccessful logon attempts occur.

Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230332r1017144_rule

STIG-ID	RHEL-08-020010
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230332

Assets

linuxred-01

RHEL-08-020012 - RHEL 8 must automatically lock an account when three unsuccessful logon attempts occur during a 15-minute time period.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to lock an account when three unsuccessful logon attempts occur in 15 minutes. Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230334r1017146_rule

STIG-ID	RHEL-08-020012
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230334

Assets

linuxred-01

RHEL-08-020014 - RHEL 8 must automatically lock an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to lock an account until released by an administrator when three unsuccessful logon attempts occur in 15 minutes.

Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4

RULE-ID	SV-230336r1017148_rule
STIG-ID	RHEL-08-020014
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230336

Assets

linuxred-01

RHEL-08-020016 - RHEL 8 must ensure account lockouts persist.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system maintain the contents of the faillock directory after a reboot.

Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

Note: Using the default faillock directory of /var/run/faillock will result in the contents being cleared in the event of a reboot.

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4

RULE-ID	SV-230338r1017150_rule
STIG-ID	RHEL-08-020016
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230338

Assets

linuxred-01

RHEL-08-020018 - RHEL 8 must prevent system messages from being presented when three unsuccessful logon attempts occur.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to prevent informative messages from being presented at logon attempts.

Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230340r1017152_rule

STIG-ID	RHEL-08-020018
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230340

Assets

linuxred-01

RHEL-08-020020 - RHEL 8 must log user name information when unsuccessful logon attempts occur.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

In RHEL 8.2 the "/etc/security/faillock.conf" file was incorporated to centralize the configuration of the pam_faillock.so module. Also introduced is a "local_users_only" option that will only track failed user authentication attempts for local users in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to log user name information when unsuccessful logon attempts occur.

Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6

PCI-DSSV4.0	8.3.4
RULE-ID	SV-230342r1017154_rule
STIG-ID	RHEL-08-020020
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230342

Assets

linuxred-01

RHEL-08-020022 - RHEL 8 must include root when automatically locking an account until the locked account is released by an administrator when three unsuccessful logon attempts occur during a 15-minute time period.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account.

RHEL 8 can utilize the "pam_faillock.so" for this purpose. Note that manual changes to the listed files may be overwritten by the "authselect" program.

From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable a different tally directory must be set with the "dir" option.

In RHEL 8.2 the "/etc/security/faillock.conf" file was incorporated to centralize the configuration of the pam_faillock.so module. Also introduced is a "local_users_only" option that will only track failed user authentication attempts for local users in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users to allow the centralized platform to solely manage user lockout.

Satisfies: SRG-OS-000021-GPOS-00005, SRG-OS-000329-GPOS-00128

Solution

Configure the operating system to include root when locking an account after three unsuccessful logon attempts occur in 15 minutes.

Add/Modify the appropriate sections of the "/etc/pam.d/system-auth" and "/etc/pam.d/password-auth" files to match the following lines:

```
auth required pam_faillock.so preauth dir=/var/log/faillock silent audit deny=3 even_deny_root fail_interval=900
unlock_time=0 auth required pam_faillock.so authfail dir=/var/log/faillock unlock_time=0 account required
pam_faillock.so
```

The "sssd" service must be restarted for the changes to take effect. To restart the "sssd" service, run the following command:

```
$ sudo systemctl restart sssd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-53	AC-7a.
800-53R5	AC-7a.
CAT	II
CCI	CCI-000044
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.
NESA	T5.5.1
NIAV2	AM24

PCI-DSSV3.2.1	8.1.6
PCI-DSSV4.0	8.3.4
RULE-ID	SV-230344r1017156_rule
STIG-ID	RHEL-08-020022
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-230344

Assets

linuxred-01

RHEL-08-020028 - RHEL 8 systems below version 8.2 must configure SELinux context type to allow the use of a non-default faillock tally directory.

Info

By limiting the number of failed logon attempts, the risk of unauthorized system access via user password guessing, otherwise known as brute-force attacks, is reduced. Limits are imposed by locking the account. From "Pam_Faillock" man pages: Note that the default directory that "pam_faillock" uses is usually cleared on system boot so the access will be reenabled after system reboot. If that is undesirable, a different tally directory must be set with the "dir" option.

SELinux, enforcing a targeted policy, will require any non-default tally directory's security context type to match the default directory's security context type. Without updating the security context type, the pam_faillock module will not write failed login attempts to the non-default tally directory.

Solution

Configure RHEL 8 to allow the use of a non-default faillock tally directory while SELinux enforces a targeted policy. Update the /etc/selinux/targeted/contexts/files/file_contexts.local with "faillog_t" context type for the non-default faillock tally directory with the following command:

```
$ sudo semanage fcontext -a -t faillog_t "/var/log/faillock(/.*)?"
```

Next, update the context type of the non-default faillock directory/subdirectories and files with the following command:

```
$ sudo restorecon -R -v /var/log/faillock
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.8
800-171R3	03.01.08a.
800-171R3	03.01.08b.
800-53	AC-7a.
800-53	AC-7b.
800-53R5	AC-7a.
800-53R5	AC-7b.
CAT	II
CCI	CCI-000044
CCI	CCI-002238
CN-L3	7.1.2.7(f)
CN-L3	7.1.3.1(c)
CN-L3	8.1.4.1(b)
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.5
ITSG-33	AC-7a.

ITSG-33	AC-7b.
NESA	T5.5.1
NIAV2	AM24
PCI-DSSV3.2.1	8.1.6
PCI-DSSV3.2.1	8.1.7
PCI-DSSV4.0	8.3.4
RULE-ID	SV-250316r1017357_rule
STIG-ID	RHEL-08-020028
TBA-FIISB	36.2.4
TBA-FIISB	45.1.2
TBA-FIISB	45.2.1
TBA-FIISB	45.2.2
VULN-ID	V-250316

Assets

linuxred-01

RHEL-08-020030 - RHEL 8 must enable a user session lock until that user re-establishes access using established identification and authentication procedures for graphical user sessions.

Info

A session lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not want to log out because of the temporary nature of the absence.

The session lock is implemented at the point where session activity can be determined.

Regardless of where the session lock is determined and implemented, once invoked, the session lock must remain in place until the user reauthenticates. No other activity aside from reauthentication must unlock the system.

Satisfies: SRG-OS-000028-GPOS-00009, SRG-OS-000030-GPOS-00011

Solution

Configure the operating system to enable a user's session lock until that user re-establishes access using established identification and authentication procedures.

Create a database to contain the system-wide screensaver settings (if it does not already exist) with the following example:

```
$ sudo vi /etc/dconf/db/local.d/00-screensaver
```

Edit the "[org/gnome/desktop/screensaver]" section of the database file and add or update the following lines:

```
# Set this to true to lock the screen when the screensaver activates lock-enabled=true
```

Update the system databases:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10b.
800-53	AC-11b.
800-53R5	AC-11b.
CAT	II
CCI	CCI-000056
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11b.
NIAV2	AM23e
PCI-DSSV3.2.1	8.1.8
PCI-DSSV4.0	8.2.8
RULE-ID	SV-230347r1017160_rule

STIG-ID

RHEL-08-020030

VULN-ID

V-230347

Assets

linuxred-01

RHEL-08-020031 - RHEL 8 must initiate a session lock for graphical user interfaces when the screensaver is activated.

Info

A session time-out lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not log out because of the temporary nature of the absence. Rather than relying on the user to manually lock their operating system session prior to vacating the vicinity, operating systems need to be able to identify when a user's session has idled and take action to initiate the session lock. The session lock is implemented at the point where session activity can be determined and/or controlled. Satisfies: SRG-OS-000029-GPOS-00010, SRG-OS-000031-GPOS-00012, SRG-OS-000480-GPOS-00227

Solution

Configure the operating system to initiate a session lock for graphical user interfaces when a screensaver is activated. Create a database to contain the system-wide screensaver settings (if it does not already exist) with the following command:

Note: The example below is using the database "local" for the system, so if the system is using another database in "/etc/dconf/profile/user", the file should be created under the appropriate subdirectory.

```
$ sudo touch /etc/dconf/db/local.d/00-screensaver  
[org/gnome/desktop/screensaver] lock-delay=uint32 5
```

The "uint32" must be included along with the integer key values as shown.

Update the system databases:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10a.
800-53	AC-11a.
800-53R5	AC-11a.
CAT	II
CCI	CCI-000057
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11a.
NESA	T2.3.8
NESA	T2.3.9
NIAV2	AM23a

NIAV2	AM23b
PCI-DSSV3.2.1	8.1.8
PCI-DSSV4.0	8.2.8
RULE-ID	SV-244535r1017342_rule
STIG-ID	RHEL-08-020031
VULN-ID	V-244535

Assets

linuxred-01

RHEL-08-020032 - RHEL 8 must disable the user list at logon for graphical user interfaces.

Info

Leaving the user list enabled is a security risk since it allows anyone with physical access to the system to enumerate known user accounts without authenticated access to the system.

Solution

Configure the operating system to disable the user list at logon for graphical user interfaces.

Create a database to contain the system-wide screensaver settings (if it does not already exist) with the following command:

Note: The example below is using the database "local" for the system, so if the system is using another database in "/etc/dconf/profile/user", the file should be created under the appropriate subdirectory.

```
$ sudo touch /etc/dconf/db/local.d/02-login-screen
```

```
[org/gnome/login-screen] disable-user-list=true
```

Update the system databases:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244536r1017343_rule
STIG-ID	RHEL-08-020032
SWIFT-CSCV1	2.3
VULN-ID	V-244536

Assets

linuxred-01

RHEL-08-020050 - RHEL 8 must be able to initiate directly a session lock for all connection types using smartcard when the smartcard is removed.

Info

A session lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not want to log out because of the temporary nature of the absence. The session lock is implemented at the point where session activity can be determined. Rather than be forced to wait for a period of time to expire before the user session can be locked, RHEL 8 needs to provide users with the ability to manually invoke a session lock so users can secure their session if it is necessary to temporarily vacate the immediate physical vicinity.

Satisfies: SRG-OS-000028-GPOS-00009, SRG-OS-000030-GPOS-00011

Solution

Configure the operating system to enable a user's session lock until that user re-establishes access using established identification and authentication procedures.

Select/Create an authselect profile and incorporate the "with-smartcard-lock-on-removal" feature with the following example:

```
$ sudo authselect select sssd with-smartcard with-smartcard-lock-on-removal
```

Alternatively, the dconf settings can be edited in the /etc/dconf/db/* location.

Edit or add the "[org/gnome/settings-daemon/peripherals/smartcard]" section of the database file and add or update the following lines:

```
removal-action='lock-screen'
```

Update the system databases:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10b.
800-53	AC-11b.
800-53R5	AC-11b.
CAT	II
CCI	CCI-000056
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11b.
NIAV2	AM23e
PCI-DSSV3.2.1	8.1.8

PCI-DSSV4.0	8.2.8
RULE-ID	SV-230351r1017164_rule
STIG-ID	RHEL-08-020050
VULN-ID	V-230351

Assets

linuxred-01

RHEL-08-020060 - RHEL 8 must automatically lock graphical user sessions after 15 minutes of inactivity.

Info

A session lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not want to log out because of the temporary nature of the absence. The session lock is implemented at the point where session activity can be determined. Rather than be forced to wait for a period of time to expire before the user session can be locked, RHEL 8 needs to provide users with the ability to manually invoke a session lock so users can secure their session if it is necessary to temporarily vacate the immediate physical vicinity.

Satisfies: SRG-OS-000029-GPOS-00010, SRG-OS-000031-GPOS-00012

Solution

Configure RHEL 8 to initiate a screensaver after a 15-minute period of inactivity for graphical user interfaces. Create a database to contain the systemwide screensaver settings (if it does not already exist) with the following command:

```
$ sudo touch /etc/dconf/db/local.d/00-screensaver
```

Edit /etc/dconf/db/local.d/00-screensaver and add or update the following lines:

```
[org/gnome/desktop/session] # Set the lock time out to 900 seconds before the session is considered idle idle-delay=uint32 900
```

Update the system databases:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10a.
800-53	AC-11a.
800-53R5	AC-11a.
CAT	II
CCI	CCI-000057
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11a.
NESA	T2.3.8
NESA	T2.3.9
NIAV2	AM23a

NIAV2	AM23b
PCI-DSSV3.2.1	8.1.8
PCI-DSSV4.0	8.2.8
RULE-ID	SV-230352r1155401_rule
STIG-ID	RHEL-08-020060
VULN-ID	V-230352

Assets

linuxred-01

RHEL-08-020080 - RHEL 8 must prevent a user from overriding the session lock-delay setting for the graphical user interface.

Info

A session time-out lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not log out because of the temporary nature of the absence. Rather than relying on the user to manually lock their operating system session prior to vacating the vicinity, operating systems need to be able to identify when a user's session has idled and take action to initiate the session lock. The session lock is implemented at the point where session activity can be determined and/or controlled. Implementing session settings will have little value if a user is able to manipulate these settings from the defaults prescribed in the other requirements of this implementation guide. Locking these settings from non-privileged users is crucial to maintaining a protected baseline. Satisfies: SRG-OS-000029-GPOS-00010, SRG-OS-000031-GPOS-00012, SRG-OS-000480-GPOS-00227

Solution

Configure the operating system to prevent a user from overriding settings for graphical user interfaces. Create a database to contain the system-wide screensaver settings (if it does not already exist) with the following command:

Note: The example below is using the database "local" for the system, so if the system is using another database in "/etc/dconf/profile/user", the file should be created under the appropriate subdirectory.

```
$ sudo touch /etc/dconf/db/local.d/locks/session
```

Add the following setting to prevent non-privileged users from modifying it:

```
/org/gnome/desktop/screensaver/lock-delay
```

Run the following command to update the database:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10a.
800-53	AC-11a.
800-53R5	AC-11a.
CAT	II
CCI	CCI-000057
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11a.
NESA	T2.3.8
NESA	T2.3.9

NIAV2	AM23a
NIAV2	AM23b
PCI-DSSV3.2.1	8.1.8
PCI-DSSV4.0	8.2.8
RULE-ID	SV-230354r1069323_rule
STIG-ID	RHEL-08-020080
VULN-ID	V-230354

Assets

linuxred-01

RHEL-08-020081 - RHEL 8 must prevent a user from overriding the session idle-delay setting for the graphical user interface.

Info

A session time-out lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not log out because of the temporary nature of the absence. Rather than relying on the user to manually lock their operating system session prior to vacating the vicinity, operating systems need to be able to identify when a user's session has idled and take action to initiate the session lock. The session lock is implemented at the point where session activity can be determined and/or controlled. Implementing session settings will have little value if a user is able to manipulate these settings from the defaults prescribed in the other requirements of this implementation guide. Locking these settings from non-privileged users is crucial to maintaining a protected baseline. Satisfies: SRG-OS-000029-GPOS-00010, SRG-OS-000031-GPOS-00012, SRG-OS-000480-GPOS-00227

Solution

Configure the operating system to prevent a user from overriding settings for graphical user interfaces. Create a database to contain the system-wide screensaver settings (if it does not already exist) with the following command:

Note: The example below is using the database "local" for the system, so if the system is using another database in "/etc/dconf/profile/user", the file should be created under the appropriate subdirectory.

```
$ sudo touch /etc/dconf/db/local.d/locks/session
```

Add the following setting to prevent non-privileged users from modifying it:

```
/org/gnome/desktop/session/idle-delay
```

Run the following command to update the database:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10a.
800-53	AC-11a.
800-53R5	AC-11a.
CAT	II
CCI	CCI-000057
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11a.
NESA	T2.3.8
NESA	T2.3.9

NIAV2	AM23a
NIAV2	AM23b
PCI-DSSV3.2.1	8.1.8
PCI-DSSV4.0	8.2.8
RULE-ID	SV-244538r1069324_rule
STIG-ID	RHEL-08-020081
VULN-ID	V-244538

Assets

linuxred-01

RHEL-08-020082 - RHEL 8 must prevent a user from overriding the screensaver lock-enabled setting for the graphical user interface.

Info

A session time-out lock is a temporary action taken when a user stops work and moves away from the immediate physical vicinity of the information system but does not log out because of the temporary nature of the absence. Rather than relying on the user to manually lock their operating system session prior to vacating the vicinity, operating systems need to be able to identify when a user's session has idled and take action to initiate the session lock. The session lock is implemented at the point where session activity can be determined and/or controlled. Implementing session settings will have little value if a user is able to manipulate these settings from the defaults prescribed in the other requirements of this implementation guide. Locking these settings from non-privileged users is crucial to maintaining a protected baseline. Satisfies: SRG-OS-000029-GPOS-00010, SRG-OS-000031-GPOS-00012, SRG-OS-000480-GPOS-00227

Solution

Configure the operating system to prevent a user from overriding settings for graphical user interfaces. Create a database to contain the system-wide screensaver settings (if it does not already exist) with the following command:

Note: The example below is using the database "local" for the system, so if the system is using another database in "/etc/dconf/profile/user", the file should be created under the appropriate subdirectory.

```
$ sudo touch /etc/dconf/db/local.d/locks/session
```

Add the following setting to prevent non-privileged users from modifying it:

```
/org/gnome/desktop/screensaver/lock-enabled
```

Run the following command to update the database:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.10
800-171R3	03.01.10a.
800-53	AC-11a.
800-53R5	AC-11a.
CAT	II
CCI	CCI-000057
CN-L3	8.1.4.1(b)
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iii)
ISO-27001-2022	A.7.7
ISO-27001-2022	A.8.1
ISO/IEC-27001	A.11.2.8
ITSG-33	AC-11a.
NESA	T2.3.8
NESA	T2.3.9

NIAV2	AM23a
NIAV2	AM23b
PCI-DSSV3.2.1	8.1.8
PCI-DSSV4.0	8.2.8
RULE-ID	SV-244539r1069325_rule
STIG-ID	RHEL-08-020082
VULN-ID	V-244539

Assets

linuxred-01

RHEL-08-020100 - RHEL 8 must ensure the password complexity module is enabled in the password-auth file.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks. "pwquality" enforces complex password construction configuration and has the ability to limit brute-force attacks on the system.

RHEL 8 utilizes "pwquality" as a mechanism to enforce password complexity. This is set in both: /etc/pam.d/password-auth /etc/pam.d/system-auth

Solution

Configure the operating system to use "pwquality" to enforce password complexity rules.
Add the following line to the "/etc/pam.d/password-auth" file (or modify the line to have the required value):
password requisite pam_pwquality.so

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230356r982195_rule
STIG-ID	RHEL-08-020100
SWIFT-CSCV1	2.3
VULN-ID	V-230356

Assets

linuxred-01

Compliant file(s):

```
/etc/pam.d/password-auth - regex '^[\\s]*password[^#\\n\\r]+pam_pwquality\\.so' found - expect  
'^[\\s]*password[^#\\n\\r]+pam_pwquality\\.so' found in the following lines:  
10: password      requisite      pam_pwquality.so try_first_pass local_users_only retry=3  
authtok_type=
```

RHEL-08-020101 - RHEL 8 must ensure the password complexity module is enabled in the system-auth file.

Info

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks. "pwquality" enforces complex password construction configuration and has the ability to limit brute-force attacks on the system.

RHEL 8 uses "pwquality" as a mechanism to enforce password complexity. This is set in both: /etc/pam.d/password-auth /etc/pam.d/system-auth

Solution

Configure the operating system to use "pwquality" to enforce password complexity rules.
Add the following line to the "/etc/pam.d/system-auth" file (or modify the line to have the required value):
password requisite pam_pwquality.so

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-251713r1017366_rule
STIG-ID	RHEL-08-020101
SWIFT-CSCV1	2.3
VULN-ID	V-251713

Assets

linuxred-01

Compliant file(s):

```
/etc/pam.d/system-auth - regex '^[\\s]*password[\\s]+(?:required|requisite)[\\s]+pam_pwquality
\\.so' found - expect '^[\\s]*password[\\s]+(?:required|requisite)[\\s]+pam_pwquality\\.so' found in
the following lines:
    10: password    requisite    pam_pwquality.so try_first_pass local_users_only retry=3
authtok_type=
```

RHEL-08-020240 - RHEL 8 duplicate User IDs (UIDs) must not exist for interactive users.

Info

To ensure accountability and prevent unauthenticated access, interactive users must be identified and authenticated to prevent potential misuse and compromise of the system.

Interactive users include organizational employees or individuals the organization deems to have equivalent status of employees (e.g., contractors). Interactive users (and processes acting on behalf of users) must be uniquely identified and authenticated to all accesses, except for the following:

- 1) Accesses explicitly identified and documented by the organization. Organizations document specific user actions that can be performed on the information system without identification or authentication; and
- 2) Accesses that occur through authorized use of group authenticators without individual authentication. Organizations may require unique identification of individuals in group accounts (e.g., shared privilege accounts) or for detailed accountability of individual activity.

Satisfies: SRG-OS-000104-GPOS-00051, SRG-OS-000121-GPOS-00062, SRG-OS-000042-GPOS-00020

Solution

Edit the file "/etc/passwd" and provide each interactive user account that has a duplicate User ID (UID) with a unique UID.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.1
800-171R3	03.05.01a.
800-53	IA-2
800-53R5	IA-2
CAT	II
CCI	CCI-000764
CN-L3	7.1.3.1(a)
CN-L3	7.1.3.1(e)
CN-L3	8.1.4.1(a)
CN-L3	8.1.4.2(a)
CN-L3	8.5.4.1(a)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16

ITSG-33	IA-2
ITSG-33	IA-2a.
NESA	T2.3.8
NESA	T5.3.1
NESA	T5.4.2
NESA	T5.5.1
NESA	T5.5.2
NESA	T5.5.3
NIAV2	AM2
NIAV2	AM8
NIAV2	AM14b
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230371r1017183_rule
STIG-ID	RHEL-08-020240
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-230371

Assets

linuxred-01

No duplicate User IDs detected

RHEL-08-020290 - RHEL 8 must prohibit the use of cached authentications after one day.

Info

If cached authentication information is out-of-date, the validity of the authentication information may be questionable. RHEL 8 includes multiple options for configuring authentication, but this requirement will be focus on the System Security Services Daemon (SSSD). By default sssd does not cache credentials.

Solution

Configure the SSSD to prohibit the use of cached authentications after one day.
Add or change the following line in "/etc/sss/sss.conf" just below the line "[pam]".
offline_credentials_expiration = 1

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.12
800-53	IA-5(13)
800-53R5	IA-5(13)
CAT	II
CCI	CCI-002007
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5
NESA	T5.2.3
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230376r1069307_rule
STIG-ID	RHEL-08-020290
VULN-ID	V-230376

Assets

linuxred-01

No matching files were found

RHEL-08-020352 - RHEL 8 must set the umask value to 077 for all local interactive user accounts.

Info

The umask controls the default access mode assigned to newly created files. A umask of 077 limits new files to mode 600 or less permissive. Although umask can be represented as a four-digit number, the first digit representing special access modes is typically ignored or required to be "0". This requirement applies to the globally configured system defaults and the local interactive user defaults for each account on the system.

Solution

Remove the umask statement from all local interactive user's initialization files.

If the account is for an application, the requirement for a umask less restrictive than "077" can be documented with the Information System Security Officer, but the user agreement for access to the account must specify that the local interactive user must log on to their account first and then switch the user to the application account with the correct option to gain the account's environment variables.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230384r1017193_rule
STIG-ID	RHEL-08-020352
SWIFT-CSCV1	2.3
VULN-ID	V-230384

Assets

linuxred-01

No matching files were found

RHEL-08-030010 - Cron logging must be implemented in RHEL 8.

Info

Cron logging can be used to trace the successful or unsuccessful execution of cron jobs. It can also be used to spot intrusions into the use of the cron facility by unauthorized and malicious users.

Solution

Configure "rsyslog" to log all cron messages by adding or updating the following line to "/etc/rsyslog.conf" or a configuration file in the /etc/rsyslog.d/ directory:

```
cron.* /var/log/cron
```

The rsyslog daemon must be restarted for the changes to take effect:

```
$ sudo systemctl restart rsyslog.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230387r1017195_rule
STIG-ID	RHEL-08-030010
SWIFT-CSCV1	2.3
VULN-ID	V-230387

Assets

linuxred-01

Compliant file(s):

```
/etc/rsyslog.conf - regex '^[^#]*cron\.[^none]' found - expect '^[^#]*cron\.[^none]' found  
in the following lines:  
57: cron.* /var/log/cron
```

/etc/rsyslog.d/21-cloudinit.conf - regex not found

RHEL-08-030030 - The RHEL 8 Information System Security Officer (ISSO) and System Administrator (SA) (at a minimum) must have mail aliases to be notified of an audit processing failure.

Info

It is critical for the appropriate personnel to be aware if a system is at risk of failing to process audit logs as required. Without this notification, the security personnel may be unaware of an impending failure of the audit capability, and system operation may be adversely affected.

Audit processing failures include software/hardware errors, failures in the audit capturing mechanisms, and audit storage capacity being reached or exceeded.

This requirement applies to each audit data storage repository (i.e., distinct information system component where audit records are stored), the centralized audit storage capacity of organizations (i.e., all audit data storage repositories combined), or both.

Solution

Configure RHEL 8 to notify administrators in the event of an audit processing failure.

Add/update the following line in "/etc/aliases":

```
postmaster: root
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.4
800-171R3	03.03.04a.
800-53	AU-5a.
800-53R5	AU-5a.
CAT	II
CCI	CCI-000139
CN-L3	7.1.3.3(e)
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ITSG-33	AU-5a.
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230389r1017197_rule
STIG-ID	RHEL-08-030030
VULN-ID	V-230389

Assets

linuxred-01

Compliant file(s):

```
/etc/aliases - regex '^[\\s]*postmaster[\\s]*:' found - expect '^[\\s]*postmaster[\\s]*:
[\\s]*root([\\s]|$)' found in the following lines:
    12: postmaster: root
```


RHEL-08-030180 - The RHEL 8 audit package must be installed.

Info

Without establishing what type of events occurred, the source of events, where events occurred, and the outcome of events, it would be difficult to establish, correlate, and investigate the events leading up to an outage or attack. Audit record content that may be necessary to satisfy this requirement includes, for example, time stamps, source and destination addresses, user/process identifiers, event descriptions, success/fail indications, filenames involved, and access control or flow control rules invoked.

Associating event types with detected events in RHEL 8 audit logs provides a means of investigating an attack, recognizing resource utilization or capacity thresholds, or identifying an improperly configured RHEL 8 system.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000038-GPOS-00016, SRG-OS-000039-GPOS-00017, SRG-OS-000040-GPOS-00018, SRG-OS-000041-GPOS-00019, SRG-OS-000042-GPOS-00021, SRG-OS-000051-GPOS-00024, SRG-OS-000054-GPOS-00025, SRG-OS-000122-GPOS-00063, SRG-OS-000254-GPOS-00095, SRG-OS-000255-GPOS-00096, SRG-OS-000337-GPOS-00129, SRG-OS-000348-GPOS-00136, SRG-OS-000349-GPOS-00137, SRG-OS-000350-GPOS-00138, SRG-OS-000351-GPOS-00139, SRG-OS-000352-GPOS-00140, SRG-OS-000353-GPOS-00141, SRG-OS-000354-GPOS-00142, SRG-OS-000358-GPOS-00145, SRG-OS-000365-GPOS-00152, SRG-OS-000392-GPOS-00172, SRG-OS-000475-GPOS-00220

Solution

Configure the audit service to produce audit records containing the information needed to establish when (date and time) an event occurred.

Install the audit service (if the audit service is not already installed) with the following command:

```
$ sudo yum install audit
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230411r1017217_rule
STIG-ID	RHEL-08-030180
SWIFT-CSCV1	6.4
VULN-ID	V-230411

Assets

linuxred-01

The local RPM is newer than audit-0.0.0-0 (audit-3.1.2-1.el8)

RHEL-08-030181 - RHEL 8 audit records must contain information to establish what type of events occurred, the source of events, where events occurred, and the outcome of events.

Info

Without establishing what type of events occurred, the source of events, where events occurred, and the outcome of events, it would be difficult to establish, correlate, and investigate the events leading up to an outage or attack. Audit record content that may be necessary to satisfy this requirement includes, for example, time stamps, source and destination addresses, user/process identifiers, event descriptions, success/fail indications, filenames involved, and access control or flow control rules invoked.

Associating event types with detected events in RHEL 8 audit logs provides a means of investigating an attack, recognizing resource utilization or capacity thresholds, or identifying an improperly configured RHEL 8 system.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000038-GPOS-00016, SRG-OS-000039-GPOS-00017, SRG-OS-000040-GPOS-00018, SRG-OS-000041-GPOS-00019, SRG-OS-000042-GPOS-00021, SRG-OS-000051-GPOS-00024, SRG-OS-000054-GPOS-00025, SRG-OS-000122-GPOS-00063, SRG-OS-000254-GPOS-00095, SRG-OS-000255-GPOS-00096, SRG-OS-000337-GPOS-00129, SRG-OS-000348-GPOS-00136, SRG-OS-000349-GPOS-00137, SRG-OS-000350-GPOS-00138, SRG-OS-000351-GPOS-00139, SRG-OS-000352-GPOS-00140, SRG-OS-000353-GPOS-00141, SRG-OS-000354-GPOS-00142, SRG-OS-000358-GPOS-00145, SRG-OS-000365-GPOS-00152, SRG-OS-000392-GPOS-00172, SRG-OS-000475-GPOS-00220

Solution

Configure the audit service to produce audit records containing the information needed to establish when (date and time) an event occurred with the following commands:

```
$ sudo systemctl enable auditd.service
$ sudo systemctl start auditd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	II
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b

HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-244542r1017348_rule
STIG-ID	RHEL-08-030181
SWIFT-CSCV1	6.4
VULN-ID	V-244542

Assets

linuxred-01

The command '/bin/systemctl status auditd.service' returned :

```
* auditd.service - Security Auditing Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; enabled; vendor preset: enabled)
   Active: active (running) since Thu 2026-03-05 02:47:37 UTC; 42min ago
     Docs: man:auditd(8)
           https://github.com/linux-audit/audit-documentation
  Main PID: 800 (auditd)
    Tasks: 4 (limit: 23179)
   Memory: 7.0M
    CGroup: /system.slice/auditd.service
            |-800 /sbin/auditd
            `-802 /usr/sbin/sedispach

Mar 05 02:47:37 linuxRed-01 augenrules[815]: enabled 1
Mar 05 02:47:37 linuxRed-01 augenrules[815]: failure 1
Mar 05 02:47:37 linuxRed-01 augenrules[815]: pid 800
Mar 05 02:47:37 linuxRed-01 augenrules[815]: rate_limit 0
Mar 05 02:47:37 linuxRed-01 augenrules[815]: backlog_limit 8192
Mar 05 02:47:37 linuxRed-01 augenrules[815]: lost 0
Mar 05 02:47:37 linuxRed-01 augenrules[815]: backlog 0
Mar 05 02:47:37 linuxRed-01 augenrules[815]: backlog_wait_time 60000
Mar 05 02:47:37 linuxRed-01 augenrules[815]: backlog_wait_time_actual 0
Mar 05 02:47:37 linuxRed-01 systemd[1]: Started Security Auditing Service.
```

RHEL-08-030603 - RHEL 8 must enable Linux audit logging for the USBGuard daemon.

Info

Without the capability to generate audit records, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

If auditing is enabled late in the startup process, the actions of some startup processes may not be audited. Some audit systems also maintain state information only available if auditing is enabled before a given process is created. Audit records can be generated from various components within the information system (e.g., module or policy filter). The list of audited events is the set of events for which audits are to be generated. This set of events is typically a subset of the list of all events for which the system is capable of generating audit records.

DoD has defined the list of events for which RHEL 8 will provide an audit record generation capability as the following:

- 1) Successful and unsuccessful attempts to access, modify, or delete privileges, security objects, security levels, or categories of information (e.g., classification levels);
- 2) Access actions, such as successful and unsuccessful logon attempts, privileged activities or other system-level access, starting and ending time for user access to the system, concurrent logons from different workstations, successful and unsuccessful accesses to objects, all program initiations, and all direct access to the information system;
- 3) All account creations, modifications, disabling, and terminations; and
- 4) All kernel module load, unload, and restart actions.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000471-GPOS-00215

Solution

Configure RHEL 8 to enable Linux audit logging of the USBGuard daemon by adding or modifying the following line in `/etc/usbguard/usbguard-daemon.conf`:

`AuditBackend=LinuxAudit`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.1
800-171	3.3.2
800-171R3	03.03.03a.
800-53	AU-12a.
800-53R5	AU-12a.
CAT	III
CCI	CCI-000169
CSF	DE.CM-1
CSF	DE.CM-3
CSF	DE.CM-7
CSF	PR.PT-1
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	DE.CM-09
CSF2.0	PR.PS-04
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b

HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.15
ITSG-33	AU-12a.
PCI-DSSV3.2.1	10.1
QCSC-V1	3.2
QCSC-V1	6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230470r1017261_rule
STIG-ID	RHEL-08-030603
SWIFT-CSCV1	6.4
VULN-ID	V-230470

Assets

linuxred-01

RHEL-08-030620 - RHEL 8 audit tools must have a mode of 0755 or less permissive.

Info

Protecting audit information also includes identifying and protecting the tools used to view and manipulate log data. Therefore, protecting audit tools is necessary to prevent unauthorized operation on audit information.

RHEL 8 systems providing tools to interface with audit information will leverage user permissions and roles identifying the user accessing the tools, and the corresponding rights the user enjoys, to make access decisions regarding the access to audit tools.

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Solution

Configure the audit tools to be protected from unauthorized access by setting the correct permissive mode using the following command:

```
$ sudo chmod 0755 [audit_tool]
```

Replace "[audit_tool]" with the audit tool that does not have the correct permissive mode.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-001493
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230472r1017263_rule
STIG-ID	RHEL-08-030620
VULN-ID	V-230472

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
PASSED - rsyslogd
The file /sbin/rsyslogd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value
```

/sbin/rsyslogd

```
-----
PASSED - auditctl
The file /sbin/auditctl with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value
```

/sbin/auditctl

```
-----
PASSED - auditd
The file /sbin/auditd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value
```

/sbin/auditd

```
-----
PASSED - ausearch
The file /sbin/ausearch with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value
```

/sbin/ausearch

```
-----
PASSED - autrace
The file /sbin/autrace with fmode owner: root group: root mode: 0750 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value
```

/sbin/autrace

```
-----
PASSED - augenrules
The file /sbin/augenrules with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value
```


/sbin/augenrules

PASSED - aureport

The file /sbin/aureport with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/aureport

RHEL-08-030630 - RHEL 8 audit tools must be owned by root.

Info

Protecting audit information also includes identifying and protecting the tools used to view and manipulate log data. Therefore, protecting audit tools is necessary to prevent unauthorized operation on audit information.

RHEL 8 systems providing tools to interface with audit information will leverage user permissions and roles identifying the user accessing the tools, and the corresponding rights the user enjoys, to make access decisions regarding the access to audit tools.

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Satisfies: SRG-OS-000256-GPOS-00097, SRG-OS-000257-GPOS-00098, SRG-OS-000258-GPOS-00099

Solution

Configure the audit tools to be owned by "root", by running the following command:

```
$ sudo chown root [audit_tool]
```

Replace "[audit_tool]" with each audit tool not owned by "root".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-001493
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230473r1017264_rule
STIG-ID	RHEL-08-030630
VULN-ID	V-230473

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - ausearch

The file /sbin/ausearch with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/ausearch

PASSED - auditd

The file /sbin/auditd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/auditd

PASSED - aureport

The file /sbin/aureport with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/aureport

PASSED - auditctl

The file /sbin/auditctl with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/auditctl

PASSED - rsyslogd

The file /sbin/rsyslogd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/rsyslogd

PASSED - autrace

The file /sbin/autrace with fmode owner: root group: root mode: 0750 uid: 0 gid: 0 uneven permissions : FALSE is compliant with the policy value

/sbin/autrace

PASSED - augenrules

The file /sbin/augenrules with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/augenrules

RHEL-08-030640 - RHEL 8 audit tools must be group-owned by root.

Info

Protecting audit information also includes identifying and protecting the tools used to view and manipulate log data. Therefore, protecting audit tools is necessary to prevent unauthorized operation on audit information.

RHEL 8 systems providing tools to interface with audit information will leverage user permissions and roles identifying the user accessing the tools, and the corresponding rights the user enjoys, to make access decisions regarding the access to audit tools.

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Satisfies: SRG-OS-000256-GPOS-00097, SRG-OS-000257-GPOS-00098, SRG-OS-000258-GPOS-00099

Solution

Configure the audit tools to be group-owned by "root", by running the following command:

```
$ sudo chgrp root [audit_tool]
```

Replace "[audit_tool]" with each audit tool not group-owned by "root".

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.3.8
800-171R3	03.03.08
800-53	AU-9
800-53R5	AU-9a.
CAT	II
CCI	CCI-001493
CN-L3	7.1.2.3(d)
CN-L3	7.1.3.3(f)
CN-L3	8.1.3.5(c)
CN-L3	8.1.4.3(c)
CSF	PR.PT-1
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.15
ISO/IEC-27001	A.12.4.2
ITSG-33	AU-9
NESA	M5.2.3

NESA	M5.5.2
NESA	T3.6.4
NESA	T8.2.9
NIAV2	SM5
NIAV2	SM6
PCI-DSSV3.2.1	10.5
PCI-DSSV3.2.1	10.5.2
PCI-DSSV4.0	10.3.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230474r1017265_rule
STIG-ID	RHEL-08-030640
VULN-ID	V-230474

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```

-----
PASSED - rsyslogd
The file /sbin/rsyslogd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/rsyslogd

-----
PASSED - auditd
The file /sbin/auditd with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/auditd

-----
PASSED - autrace
The file /sbin/autrace with fmode owner: root group: root mode: 0750 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/autrace

-----
PASSED - auditctl
The file /sbin/auditctl with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/auditctl

-----
PASSED - augenrules
The file /sbin/augenrules with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/augenrules

-----
PASSED - aureport
The file /sbin/aureport with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

```

/sbin/aureport

PASSED - ausearch

The file /sbin/ausearch with fmode owner: root group: root mode: 0755 uid: 0 gid: 0 uneven
permissions : FALSE is compliant with the policy value

/sbin/ausearch

RHEL-08-030670 - RHEL 8 must have the packages required for offloading audit logs installed.

Info

Information stored in one location is vulnerable to accidental or incidental deletion or alteration.

Off-loading is a common process in information systems with limited audit storage capacity.

RHEL 8 installation media provides "rsyslogd". "rsyslogd" is a system utility providing support for message logging.

Support for both internet and UNIX domain sockets enables this utility to support both local and remote logging.

Couple this utility with "gnutls" (which is a secure communications library implementing the SSL, TLS and DTLS protocols), and you have a method to securely encrypt and off-load auditing.

Rsyslog provides three ways to forward message: the traditional UDP transport, which is extremely lossy but standard; the plain TCP based transport, which loses messages only during certain situations but is widely available; and the RELP transport, which does not lose messages but is currently available only as part of the rsyslogd 3.15.0 and above.

Examples of each configuration:

UDP *.* @remotesystemname TCP *.* @@remotesystemname RELP *.* :omrelp:remotesystemname:2514 Note that a port number was given as there is no standard port for RELP.

Solution

Configure the operating system to offload audit logs by installing the required packages with the following command:

```
$ sudo yum install rsyslog
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230477r1017267_rule
STIG-ID	RHEL-08-030670
SWIFT-CSCV1	2.3

VULN-ID

V-230477

Assets

linuxred-01

The local RPM is newer than rsyslog-0.0.0-0 (rsyslog-8.2102.0-15.el8_10.1)

RHEL-08-030680 - RHEL 8 must have the packages required for encrypting offloaded audit logs installed.

Info

Information stored in one location is vulnerable to accidental or incidental deletion or alteration.

Off-loading is a common process in information systems with limited audit storage capacity.

RHEL 8 installation media provides "rsyslogd". "rsyslogd" is a system utility providing support for message logging.

Support for both internet and UNIX domain sockets enables this utility to support both local and remote logging.

Couple this utility with "rsyslog-gnutls" (which is a secure communications library implementing the SSL, TLS and DTLS protocols), and you have a method to securely encrypt and off-load auditing.

Rsyslog provides three ways to forward message: the traditional UDP transport, which is extremely lossy but standard; the plain TCP based transport, which loses messages only during certain situations but is widely available; and the RELP transport, which does not lose messages but is currently available only as part of the rsyslogd 3.15.0 and above.

Examples of each configuration:

UDP *.* @remotesystemname TCP *.* @@remotesystemname RELP *.* :omrelp:remotesystemname:2514 Note that a port number was given as there is no standard port for RELP.

Solution

Configure the operating system to encrypt offloaded audit logs by installing the required packages with the following command:

```
$ sudo yum install rsyslog-gnutls
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230478r1017268_rule
STIG-ID	RHEL-08-030680

SWIFT-CSCV1

2.3

VULN-ID

V-230478

Assets

linuxred-01

The local RPM is newer than rsyslog-gnutls-0.0.0-0 (rsyslog-gnutls-8.2102.0-15.el8_10.1)

RHEL-08-040000 - RHEL 8 must not have the telnet-server package installed.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

Examples of non-essential capabilities include, but are not limited to, games, software packages, tools, and demonstration software not related to requirements or providing a wide array of functionality not required for every mission, but which cannot be disabled.

Verify the operating system is configured to disable non-essential capabilities. The most secure way of ensuring a non-essential capability is disabled is to not have the capability installed.

The telnet service provides an unencrypted remote access service that does not provide for the confidentiality and integrity of user passwords or the remote session.

If a privileged user were to log on using this service, the privileged user password could be compromised.

Solution

Configure the operating system to disable non-essential capabilities by removing the telnet-server package from the system with the following command:

```
$ sudo yum remove telnet-server
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	I
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1

PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230487r1017271_rule
STIG-ID	RHEL-08-040000
SWIFT-CSCV1	2.3
VULN-ID	V-230487

Assets

linuxred-01

The package 'telnet-server-0.0.0-0' is not installed

RHEL-08-040001 - RHEL 8 must not have any automated bug reporting tools installed.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

Examples of non-essential capabilities include, but are not limited to, games, software packages, tools, and demonstration software not related to requirements or providing a wide array of functionality not required for every mission, but which cannot be disabled.

Verify the operating system is configured to disable non-essential capabilities. The most secure way of ensuring a non-essential capability is disabled is to not have the capability installed.

Solution

Configure the operating system to disable non-essential capabilities by removing automated bug reporting packages from the system with the following command:

```
$ sudo yum remove abrt*
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2

RULE-ID	SV-230488r1017272_rule
STIG-ID	RHEL-08-040001
SWIFT-CSCV1	2.3
VULN-ID	V-230488

Assets

linuxred-01

The command '/bin/yum -q list installed abrt* | /bin/awk '{print} END {if (NR == 0) print "No entries found"}' returned :

Error: No matching Packages to list
No entries found

RHEL-08-040002 - RHEL 8 must not have the sendmail package installed.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

Examples of non-essential capabilities include, but are not limited to, games, software packages, tools, and demonstration software not related to requirements or providing a wide array of functionality not required for every mission, but which cannot be disabled.

Verify the operating system is configured to disable non-essential capabilities. The most secure way of ensuring a non-essential capability is disabled is to not have the capability installed.

Solution

Configure the operating system to disable non-essential capabilities by removing the sendmail package from the system with the following command:

```
$ sudo yum remove sendmail
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2

RULE-ID	SV-230489r1017273_rule
STIG-ID	RHEL-08-040002
SWIFT-CSCV1	2.3
VULN-ID	V-230489

Assets

linuxred-01

The package 'sendmail-0.0.0-0' is not installed

RHEL-08-040010 - RHEL 8 must not install packages from the Extra Packages for Enterprise Linux (EPEL) repository.

Info

The EPEL is a repository of high-quality open-source packages for enterprise-class Linux distributions such as RHEL, CentOS, AlmaLinux, Rocky Linux, and Oracle Linux. These packages are not part of the official distribution but are built using the same Fedora build system to ensure compatibility and maintain quality standards.

Solution

The repo package can be manually removed with the following command:

```
$ sudo dnf remove epel-release
```

Configure the operating system to disable use of the EPEL repository with the following command:

```
$ sudo dnf config-manager --set-disabled epel
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	I
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230492r1134888_rule
STIG-ID	RHEL-08-040010

SWIFT-CSCV1

2.3

VULN-ID

V-230492

Assets

linuxred-01

The command '/bin/dnf repolist | /bin/grep epel | /bin/awk '{print} END {if (NR == 0) print "pass"}' returned :

pass

RHEL-08-040020 - RHEL 8 must cover or disable the built-in or attached camera when not in use.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Failing to disconnect from collaborative computing devices (i.e., cameras) can result in subsequent compromises of organizational information. Providing easy methods to physically disconnect from such devices after a collaborative computing session helps to ensure participants actually carry out the disconnect activity without having to go through complex and tedious procedures.

Satisfies: SRG-OS-000095-GPOS-00049, SRG-OS-000370-GPOS-00155

Solution

Configure the operating system to disable the built-in or attached camera when not in use.

Build or modify the "/etc/modprobe.d/blacklist.conf" file by using the following example:

```
install uvcvideo /bin/false blacklist uvcvideo
```

Reboot the system for the settings to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230493r1017276_rule

STIG-ID	RHEL-08-040020
---------	----------------

SWIFT-CSCV1	2.3
-------------	-----

VULN-ID	V-230493
---------	----------

Assets

linuxred-01

RHEL-08-040070 - The RHEL 8 file system automounter must be disabled.

Info

Automatically mounting file systems permits easy introduction of unknown devices, thereby facilitating malicious activity.

Solution

Configure RHEL 8 to disable the ability to automount devices.
Turn off the automount service with the following commands:
\$ sudo systemctl stop autofs \$ sudo systemctl disable autofs

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.02
800-53	IA-3
800-53R5	IA-3
CAT	II
CCI	CCI-000778
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ITSG-33	IA-3
ITSG-33	IA-3a.
NESA	T5.4.3
QCSC-V1	13.2
RULE-ID	SV-230502r1155393_rule
STIG-ID	RHEL-08-040070
TBA-FIISB	27.1
VULN-ID	V-230502

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - is-active

The command '/bin/systemctl is-active autofs.service 2>/dev/null | /bin/grep '^active' | /bin/awk '{print} END {if (NR == 0) print "pass" ; else print "fail"}'' returned :

pass

PASSED - is-enabled

The command '/bin/systemctl is-enabled autofs.service 2>/dev/null | /bin/grep 'enabled' | /bin/awk '{print} END {if (NR == 0) print "pass" ; else print "fail"}'' returned :

pass

RHEL-08-040100 - A firewall must be installed on RHEL 8.

Info

"Firewalld" provides an easy and effective way to block/limit remote access to the system via ports, services, and protocols.

Remote access services, such as those providing remote access to network devices and information systems, which lack automated control capabilities, increase risk and make remote user access management difficult at best.

Remote access is access to DoD nonpublic information systems by an authorized user (or an information system) communicating through an external, non-organization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

RHEL 8 functionality (e.g., RDP) must be capable of taking enforcement action if the audit reveals unauthorized activity. Automated control of remote access sessions allows organizations to ensure ongoing compliance with remote access policies by enforcing connection rules of remote access applications on a variety of information system components (e.g., servers, workstations, notebook computers, smartphones, and tablets).

Solution

Install "firewalld" with the following command:

```
$ sudo yum install firewalld.noarch
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.12
800-171R3	03.01.12
800-53	AC-17(1)
800-53R5	AC-17(1)
CAT	II
CCI	CCI-002314
CN-L3	8.1.4.4(c)
CN-L3	8.1.10.6(i)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.8.16
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(1)
NESA	T5.4.4
QCSC-V1	3.2

QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-230505r958672_rule
STIG-ID	RHEL-08-040100
SWIFT-CSCV1	2.6
VULN-ID	V-230505

Assets

linuxred-01

The local RPM is newer than firewalld-0.0.0-0 (firewalld-0.9.11-10.el8_10)

RHEL-08-040101 - A firewall must be active on RHEL 8.

Info

"Firewalld" provides an easy and effective way to block/limit remote access to the system via ports, services, and protocols.

Remote access services, such as those providing remote access to network devices and information systems, which lack automated control capabilities, increase risk and make remote user access management difficult at best.

Remote access is access to DoD nonpublic information systems by an authorized user (or an information system) communicating through an external, non-organization-controlled network. Remote access methods include, for example, dial-up, broadband, and wireless.

RHEL 8 functionality (e.g., RDP) must be capable of taking enforcement action if the audit reveals unauthorized activity. Automated control of remote access sessions allows organizations to ensure ongoing compliance with remote access policies by enforcing connection rules of remote access applications on a variety of information system components (e.g., servers, workstations, notebook computers, smartphones, and tablets).

Solution

Configure "firewalld" to protect the operating system with the following command:

```
$ sudo systemctl enable firewalld
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.12
800-171R3	03.01.12
800-53	AC-17(1)
800-53R5	AC-17(1)
CAT	II
CCI	CCI-002314
CN-L3	8.1.4.4(c)
CN-L3	8.1.10.6(i)
CSF	PR.AC-3
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.8.16
ISO/IEC-27001	A.6.2.2
ITSG-33	AC-17(1)
NESA	T5.4.4
QCSC-V1	3.2

QCSC-V1	5.2.1
QCSC-V1	5.2.2
RULE-ID	SV-244544r958672_rule
STIG-ID	RHEL-08-040101
SWIFT-CSCV1	2.6
VULN-ID	V-244544

Assets

linuxred-01

The command '/bin/systemctl is-active firewalld' returned :
active

RHEL-08-040110 - RHEL 8 wireless network adapters must be disabled.

Info

Without protection of communications with wireless peripherals, confidentiality and integrity may be compromised because unprotected communications can be intercepted and either read, altered, or used to compromise the RHEL 8 operating system.

This requirement applies to wireless peripheral technologies (e.g., wireless mice, keyboards, displays, etc.) used with RHEL 8 systems. Wireless peripherals (e.g., Wi-Fi/Bluetooth/IR Keyboards, Mice, and Pointing Devices and Near Field Communications [NFC]) present a unique challenge by creating an open, unsecured port on a computer. Wireless peripherals must meet DoD requirements for wireless data transmission and be approved for use by the Authorizing Official (AO). Even though some wireless peripherals, such as mice and pointing devices, do not ordinarily carry information that need to be protected, modification of communications with these wireless peripherals may be used to compromise the RHEL 8 operating system. Communication paths outside the physical protection of a controlled boundary are exposed to the possibility of interception and modification.

Protecting the confidentiality and integrity of communications with wireless peripherals can be accomplished by physical means (e.g., employing physical barriers to wireless radio frequencies) or by logical means (e.g., employing cryptographic techniques). If physical means of protection are employed, then logical means (cryptography) do not have to be employed, and vice versa. If the wireless peripheral is only passing telemetry data, encryption of the data may not be required.

Satisfies: SRG-OS-000299-GPOS-00117, SRG-OS-000300-GPOS-00118, SRG-OS-000481-GPOS-000481

Solution

Configure the system to disable all wireless network interfaces with the following command:

```
$ sudo nmcli radio all off
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.17
800-171R3	03.01.16
800-53	AC-18(1)
800-53R5	AC-18(1)
CAT	II
CCI	CCI-001444
CSF	PR.PT-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.14
ISO-27001-2022	A.8.20
ITSG-33	AC-18(1)
NESA	T5.4.2
NIAV2	NS33

NIAV2	NS34
NIAV2	NS38
QCSC-V1	5.2.1
RULE-ID	SV-230506r1017286_rule
STIG-ID	RHEL-08-040110
SWIFT-CSCV1	2.3
VULN-ID	V-230506

Assets

linuxred-01

RHEL-08-040120 - RHEL 8 must mount /dev/shm with the nodev option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /dev/shm is mounted with the "nodev" option by adding /modifying the /etc/fstab with the following line:

```
tmpfs /dev/shm tmpfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230508r958804_rule
STIG-ID	RHEL-08-040120
SWIFT-CSCV1	2.3

VULN-ID

V-230508

Assets

linuxred-01

No matching files were found

RHEL-08-040121 - RHEL 8 must mount /dev/shm with the nosuid option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /dev/shm is mounted with the "nosuid" option by adding /modifying the /etc/fstab with the following line:

```
tmpfs /dev/shm tmpfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230509r958804_rule
STIG-ID	RHEL-08-040121
SWIFT-CSCV1	2.3

VULN-ID

V-230509

Assets

linuxred-01

No matching files were found

RHEL-08-040122 - RHEL 8 must mount /dev/shm with the noexec option.

Info

The organization must identify authorized software programs and permit execution of authorized software. The process used to identify software programs that are authorized to execute on organizational information systems is commonly referred to as whitelisting.

The "noexec" mount option causes the system to not execute binary files. This option must be used for mounting any file system not containing approved binary files, as they may be incompatible. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nodev" mount option causes the system to not interpret character or block special devices. Executing character or block special devices from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

The "nosuid" mount option causes the system to not execute "setuid" and "setgid" files with owner privileges. This option must be used for mounting any file system not containing approved "setuid" and "setgid" files. Executing files from untrusted file systems increases the opportunity for unprivileged users to attain unauthorized administrative access.

Solution

Configure the system so that /dev/shm is mounted with the "noexec" option by adding /modifying the /etc/fstab with the following line:

```
tmpfs /dev/shm tmpfs defaults,nodev,nosuid,noexec 0 0
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.7
800-171R3	03.04.06
800-53	CM-7(2)
800-53R5	CM-7(2)
CAT	II
CCI	CCI-001764
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7(2)
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.2
QCSC-V1	3.2
RULE-ID	SV-230510r958804_rule
STIG-ID	RHEL-08-040122
SWIFT-CSCV1	2.3

VULN-ID

V-230510

Assets

linuxred-01

No matching files were found

RHEL-08-040139 - RHEL 8 must have the USBGuard installed.

Info

Without authenticating devices, unidentified or unknown devices may be introduced, thereby facilitating malicious activity.

Peripherals include, but are not limited to, such devices as flash drives, external storage, and printers.

A new feature that RHEL 8 provides is the USBGuard software framework. The USBguard-daemon is the main component of the USBGuard software framework. It runs as a service in the background and enforces the USB device authorization policy for all USB devices. The policy is defined by a set of rules using a rule language described in the usbguard-rules.conf file. The policy and the authorization state of USB devices can be modified during runtime using the usbguard tool.

The System Administrator (SA) must work with the site Information System Security Officer (ISSO) to determine a list of authorized peripherals and establish rules within the USBGuard software framework to allow only authorized devices.

Solution

Install the USBGuard package with the following command:

```
$ sudo yum install usbguard.x86_64
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.02
800-53	IA-3
800-53R5	IA-3
CAT	II
CCI	CCI-001958
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ITSG-33	IA-3
ITSG-33	IA-3a.
NESA	T5.4.3
QCSC-V1	13.2
RULE-ID	SV-244547r1014811_rule
STIG-ID	RHEL-08-040139
TBA-FIISB	27.1

VULN-ID

V-244547

Assets

linuxred-01

RHEL-08-040140 - RHEL 8 must block unauthorized peripherals before establishing a connection.

Info

Without authenticating devices, unidentified or unknown devices may be introduced, thereby facilitating malicious activity.

Peripherals include, but are not limited to, such devices as flash drives, external storage, and printers.

A new feature that RHEL 8 provides is the USBGuard software framework. The USBguard-daemon is the main component of the USBGuard software framework. It runs as a service in the background and enforces the USB device authorization policy for all USB devices. The policy is defined by a set of rules using a rule language described in the usbguard-rules.conf file. The policy and the authorization state of USB devices can be modified during runtime using the usbguard tool.

The system administrator (SA) must work with the site information system security officer (ISSO) to determine a list of authorized peripherals and establish rules within the USBGuard software framework to allow only authorized devices.

Solution

Configure the operating system to enable the blocking of unauthorized peripherals with the following command:

This command must be run from a root shell and will create an allow list for any usb devices currently connect to the system.

```
# usbguard generate-policy > /etc/usbguard/rules.conf
```

Note: Enabling and starting usbguard without properly configuring it for an individual system will immediately prevent any access over a usb device such as a keyboard or mouse.

Restart usbguard service after creation or update of rules with the following command:

```
$ sudo systemctl restart usbguard
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.02
800-53	IA-3
800-53R5	IA-3
CAT	II
CCI	CCI-001958
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ITSG-33	IA-3
ITSG-33	IA-3a.
NESA	T5.4.3
QCSC-V1	13.2
RULE-ID	SV-230524r1155418_rule

STIG-ID	RHEL-08-040140
---------	----------------

TBA-FIISB	27.1
-----------	------

VULN-ID	V-230524
---------	----------

Assets

linuxred-01

RHEL-08-040141 - RHEL 8 must enable the USBGuard.

Info

Without authenticating devices, unidentified or unknown devices may be introduced, thereby facilitating malicious activity.

Peripherals include, but are not limited to, such devices as flash drives, external storage, and printers.

A new feature that RHEL 8 provides is the USBGuard software framework. The USBguard-daemon is the main component of the USBGuard software framework. It runs as a service in the background and enforces the USB device authorization policy for all USB devices. The policy is defined by a set of rules using a rule language described in the usbguard-rules.conf file. The policy and the authorization state of USB devices can be modified during runtime using the usbguard tool.

The System Administrator (SA) must work with the site Information System Security Officer (ISSO) to determine a list of authorized peripherals and establish rules within the USBGuard software framework to allow only authorized devices.

Solution

Configure the operating system to enable the blocking of unauthorized peripherals with the following commands:

```
$ sudo systemctl enable usbguard.service
```

```
$ sudo systemctl start usbguard.service
```

Note: Enabling and starting usbguard without properly configuring it for an individual system will immediately prevent any access over a usb device such as a keyboard or mouse

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.02
800-53	IA-3
800-53R5	IA-3
CAT	II
CCI	CCI-001958
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ITSG-33	IA-3
ITSG-33	IA-3a.
NESA	T5.4.3
QCSC-V1	13.2
RULE-ID	SV-244548r1014815_rule
STIG-ID	RHEL-08-040141

TBA-FIISB	27.1
-----------	------

VULN-ID	V-244548
---------	----------

Assets

linuxred-01

RHEL-08-040159 - All RHEL 8 networked systems must have SSH installed.

Info

Without protection of the transmitted information, confidentiality and integrity may be compromised because unprotected communications can be intercepted and either read or altered.

This requirement applies to both internal and external networks and all types of information system components from which information can be transmitted (e.g., servers, mobile devices, notebook computers, printers, copiers, scanners, and facsimile machines). Communication paths outside the physical protection of a controlled boundary are exposed to the possibility of interception and modification.

Protecting the confidentiality and integrity of organizational information can be accomplished by physical means (e.g., employing physical distribution systems) or by logical means (e.g., employing cryptographic techniques). If physical means of protection are employed, then logical means (cryptography) do not have to be employed, and vice versa.

Satisfies: SRG-OS-000423-GPOS-00187, SRG-OS-000424-GPOS-00188, SRG-OS-000425-GPOS-00189, SRG-OS-000426-GPOS-00190

Solution

Install SSH packages onto the host with the following command:

```
$ sudo yum install openssh-server.x86_64
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.8
800-171R3	03.13.08
800-53	SC-8
800-53R5	SC-8
CAT	II
CCI	CCI-002418
CN-L3	8.1.2.2(a)
CN-L3	8.1.2.2(b)
CN-L3	8.1.4.7(a)
CN-L3	8.1.4.8(a)
CN-L3	8.2.4.5(c)
CN-L3	8.2.4.5(d)
CN-L3	8.5.2.2
CSF	PR.DS-2
CSF	PR.DS-5
CSF2.0	PR.DS-02
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(e)(1)
HIPAA	164.312(e)(2)(i)
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.14
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.20
ITSG-33	SC-8
ITSG-33	SC-8a.
NESA	T4.3.1
NESA	T4.3.2
NESA	T4.5.1
NESA	T4.5.2
NESA	T7.3.3
NESA	T7.4.1
NIAV2	IE8
NIAV2	IE9
NIAV2	IE12
NIAV2	NS29
NIAV2	SS24
PCI-DSSV3.2.1	2.3
PCI-DSSV3.2.1	4.1
PCI-DSSV4.0	2.2.7
PCI-DSSV4.0	4.2.1
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-244549r958908_rule
STIG-ID	RHEL-08-040159
VULN-ID	V-244549

Assets

linuxred-01

The local RPM is newer than openssh-server-0.0.0-0 (openssh-server-8.0p1-25.el8_10)

RHEL-08-040160 - All RHEL 8 networked systems must have and implement SSH to protect the confidentiality and integrity of transmitted and received information, as well as information during preparation for transmission.

Info

Without protection of the transmitted information, confidentiality and integrity may be compromised because unprotected communications can be intercepted and either read or altered.

This requirement applies to both internal and external networks and all types of information system components from which information can be transmitted (e.g., servers, mobile devices, notebook computers, printers, copiers, scanners, and facsimile machines). Communication paths outside the physical protection of a controlled boundary are exposed to the possibility of interception and modification.

Protecting the confidentiality and integrity of organizational information can be accomplished by physical means (e.g., employing physical distribution systems) or by logical means (e.g., employing cryptographic techniques). If physical means of protection are employed, then logical means (cryptography) do not have to be employed, and vice versa.

Satisfies: SRG-OS-000423-GPOS-00187, SRG-OS-000424-GPOS-00188, SRG-OS-000425-GPOS-00189, SRG-OS-000426-GPOS-00190

Solution

Configure the SSH service to automatically start after reboot with the following command:

```
$ sudo systemctl enable sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.8
800-171R3	03.13.08
800-53	SC-8
800-53R5	SC-8
CAT	II
CCI	CCI-002418
CN-L3	8.1.2.2(a)
CN-L3	8.1.2.2(b)
CN-L3	8.1.4.7(a)
CN-L3	8.1.4.8(a)
CN-L3	8.2.4.5(c)
CN-L3	8.2.4.5(d)
CN-L3	8.5.2.2
CSF	PR.DS-2
CSF	PR.DS-5
CSF2.0	PR.DS-02
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.a
GDPR	32.1.b

HIPAA	164.306(a)(1)
HIPAA	164.312(e)(1)
HIPAA	164.312(e)(2)(i)
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.14
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.20
ITSG-33	SC-8
ITSG-33	SC-8a.
NESA	T4.3.1
NESA	T4.3.2
NESA	T4.5.1
NESA	T4.5.2
NESA	T7.3.3
NESA	T7.4.1
NIAV2	IE8
NIAV2	IE9
NIAV2	IE12
NIAV2	NS29
NIAV2	SS24
PCI-DSSV3.2.1	2.3
PCI-DSSV3.2.1	4.1
PCI-DSSV4.0	2.2.7
PCI-DSSV4.0	4.2.1
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-230526r958908_rule
STIG-ID	RHEL-08-040160
VULN-ID	V-230526

Assets

linuxred-01

The command `'/bin/systemctl status sshd'` returned :

```
* sshd.service - OpenSSH server daemon
```

```

Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
Active: active (running) since Thu 2026-03-05 02:47:41 UTC; 43min ago
Docs: man:sshd(8)
      man:sshd_config(5)
Main PID: 1316 (sshd)
Tasks: 1 (limit: 23179)
Memory: 8.6M
CGroup: /system.slice/ssh.service
        └─1316 /usr/sbin/sshd -D -oCiphers=aes256-gcm@openssh.com,chacha20-
poly1305@openssh.com,aes256-ctr,aes256-cbc,aes128-gcm@openssh.com,aes128-ctr,aes128-cbc -
oMACs=hmac-sha2-256-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-128-etm@openssh.com,hmac-
sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha1,umac-128@openssh.com,hmac-sha2-512 -
oGSSAPIKexAlgorithms=gss-curve25519-sha256-,gss-nistp256-sha256-,gss-group14-sha256-,gss-
group16-sha512-,gss-gex-sha1-,gss-group14-sha1- -oKexAlgorithms=curve25519-sha256,curve25519-
sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-
group-exchange-sha256,diffie-hellman-group14-sha256,diffie-hellman-group16-sha512,diffie-
hellman-group18-sha512,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1 -
oHostKeyAlgorithms=ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-
sha2-nistp384,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521,ecdsa-sha2-
nistp521-cert-v01@openssh.com,ssh-ed25519,ssh-ed25519-cert-v01@openssh.com,rsa-sha2-256,rsa-
sha2-256-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-512-cert-v01@openssh.com,ssh-rsa,ssh-
rsa-cert-v01@openssh.com -oPubkeyAcceptedKeyTypes=ecdsa-sha2-nistp256,ecdsa-sha2-nistp256-
cert-v01@openssh.com,ecdsa-sha2-nistp384,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-
sha2-nistp521,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519,ssh-ed25519-cert-
v01@openssh.com,rsa-sha2-256,rsa-sha2-256-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-512-
cert-v01@openssh.com,ssh-rsa,ssh-rsa-cert-v01@openssh.com -oCASignatureAlgorithms=ecdsa-sha2-
nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,ssh-ed25519,rsa-sha2-256,rsa-sha2-512,ssh-rsa

Mar [...]

```

RHEL-08-040171 - The x86 Ctrl-Alt-Delete key sequence in RHEL 8 must be disabled if a graphical user interface is installed.

Info

A locally logged-on user, who presses Ctrl-Alt-Delete, when at the console, can reboot the system. If accidentally pressed, as could happen in the case of a mixed OS environment, this can create the risk of short-term loss of availability of systems due to unintentional reboot. In a graphical user environment, risk of unintentional reboot from the Ctrl-Alt-Delete sequence is reduced because the user will be prompted before any action is taken.

Solution

Configure the system to disable the Ctrl-Alt-Delete sequence when using a graphical user interface by creating or editing the `/etc/dconf/db/local.d/00-disable-CAD` file.

Add the setting to disable the Ctrl-Alt-Delete sequence for a graphical user interface:

```
[org/gnome/settings-daemon/plugins/media-keys] logout="
```

Note: The value above is set to two single quotations.

Then update the dconf settings:

```
$ sudo dconf update
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230530r1069317_rule
STIG-ID	RHEL-08-040171
SWIFT-CSCV1	2.3
VULN-ID	V-230530

Assets

RHEL-08-040190 - The Trivial File Transfer Protocol (TFTP) server package must not be installed if not required for RHEL 8 operational support.

Info

If TFTP is required for operational support (such as the transmission of router configurations) its use must be documented with the Information System Security Officer (ISSO), restricted to only authorized personnel, and have access control rules established.

Solution

Remove the TFTP package from the system with the following command:
\$ sudo yum remove tftp-server

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230533r1017295_rule
STIG-ID	RHEL-08-040190
SWIFT-CSCV1	2.3
VULN-ID	V-230533

Assets

linuxred-01

The package 'tftp-server-0.0.0-0' is not installed

RHEL-08-040200 - The root account must be the only account having unrestricted access to the RHEL 8 system.

Info

If an account other than root also has a User Identifier (UID) of "0", it has root authority, giving that account unrestricted access to the entire operating system. Multiple accounts with a UID of "0" afford an opportunity for potential intruders to guess a password for a privileged account.

Solution

Change the UID of any account on the system, other than root, that has a UID of "0".

If the account is associated with system commands or applications, the UID should be changed to one greater than "0" but less than "1000". Otherwise, assign a UID of greater than "1000" that has not already been assigned.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230534r1017296_rule
STIG-ID	RHEL-08-040200
SWIFT-CSCV1	2.3
VULN-ID	V-230534

Assets

linuxred-01

No issues found.

RHEL-08-040239 - RHEL 8 must not forward IPv4 source-routed packets.

Info

Source-routed packets allow the source of the packet to suggest that routers forward the packet along a different path than configured on the router, which can be used to bypass network security measures. This requirement applies only to the forwarding of source-routed traffic, such as when forwarding is enabled and the system is functioning as a router.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to not forward IPv4 source-routed packets.

Add or edit the following line in a system configuration file, in the `/etc/sysctl.d/` directory:

`net.ipv4.conf.all.accept_source_route=0`

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

Load settings from all system configuration files with the following command:

`$ sudo sysctl --system`

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-244551r1017351_rule

STIG-ID	RHEL-08-040239
SWIFT-CSCV1	2.3
VULN-ID	V-244551

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

PASSED - sysctl

The command '/sbin/sysctl net.ipv4.conf.all.accept_source_route' returned :

net.ipv4.conf.all.accept_source_route = 0

PASSED - conf files

Compliant file(s):

/etc/sysctl.conf - regex not found

/etc/sysctl.d/99-sysctl.conf - regex not found

/lib/sysctl.d/10-default-yama-scope.conf - regex not found

/lib/sysctl.d/50-coredump.conf - regex not found

/lib/sysctl.d/50-default.conf - regex '^[\s]*net\.ipv4\.conf\.all\.accept_source_route'

found - expect '^[\s]*net\.ipv4\.conf\.all\.accept_source_route[\s]*=[\s]*0[\s]*\$' found in the following lines:

31: net.ipv4.conf.all.accept_source_route = 0

/lib/sysctl.d/50-libkcap-optmem_max.conf - regex not found

/lib/sysctl.d/50-pid-max.conf - regex not found

/usr/lib/sysctl.d/10-default-yama-scope.conf - regex not found

/usr/lib/sysctl.d/50-coredump.conf - regex not found

/usr/lib/sysctl.d/50-default.conf - regex '^[\s]*net\.ipv4\.conf\.all\.accept_source_route'

found - expect '^[\s]*net\.ipv4\.conf\.all\.accept_source_route[\s]*=[\s]*0[\s]*\$' found in the following lines:

31: net.ipv4.conf.all.accept_source_route = 0

/usr/lib/sysctl.d/50-libkcap-optmem_max.conf - regex not found

/usr/lib/sysctl.d/50-pid-max.conf - regex not found

RHEL-08-040283 - RHEL 8 must restrict exposed kernel pointer addresses access.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

The `sysctl --system` command will load settings from all system configuration files. All configuration files are sorted by their filename in lexicographic order, regardless of which of the directories they reside in. If multiple files specify the same option, the entry in the file with the lexicographically latest name will take precedence. Files are read from directories in the following list from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.

`/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`

Solution

Configure RHEL 8 to restrict exposed kernel pointer addresses access by adding the following line to a file, in the `"/etc/sysctl.d"` directory:

```
kernel.kptr_restrict = 1
```

Remove any configurations that conflict with the above from the following locations:

`/run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf /etc/sysctl.d/*.conf`

The system configuration files need to be reloaded for the changes to take effect. To reload the contents of the files, run the following command:

```
$ sudo sysctl --system
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230547r1017309_rule

STIG-ID	RHEL-08-040283
SWIFT-CSCV1	2.3
VULN-ID	V-230547

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

```
-----
PASSED - sysctl
The command '/sbin/sysctl kernel.kptr_restrict' returned :

kernel.kptr_restrict = 1

-----
PASSED - conf files
Compliant file(s):
/etc/sysctl.conf - regex not found
/etc/sysctl.d/99-sysctl.conf - regex not found
/lib/sysctl.d/10-default-yama-scope.conf - regex not found
/lib/sysctl.d/50-coredump.conf - regex not found
/lib/sysctl.d/50-default.conf - regex '^[\s]*kernel\.kptr_restrict' found - expect
'^[\s]*kernel\.kptr_restrict[\s]*=[\s]*[12][\s]*$' found in the following lines:
    25: kernel.kptr_restrict = 1
/lib/sysctl.d/50-libkcap-optmem_max.conf - regex not found
/lib/sysctl.d/50-pid-max.conf - regex not found
/usr/lib/sysctl.d/10-default-yama-scope.conf - regex not found
/usr/lib/sysctl.d/50-coredump.conf - regex not found
/usr/lib/sysctl.d/50-default.conf - regex '^[\s]*kernel\.kptr_restrict' found - expect
'^[\s]*kernel\.kptr_restrict[\s]*=[\s]*[12][\s]*$' found in the following lines:
    25: kernel.kptr_restrict = 1
/usr/lib/sysctl.d/50-libkcap-optmem_max.conf - regex not found
/usr/lib/sysctl.d/50-pid-max.conf - regex not found
```

RHEL-08-040290 - RHEL 8 must be configured to prevent unrestricted mail relaying.

Info

If unrestricted mail relaying is permitted, unauthorized senders could use this host as a mail relay for the purpose of sending spam or other unauthorized activity.

Solution

If "postfix" is installed, modify the "/etc/postfix/main.cf" file to restrict client connections to the local network with the following command:

```
$ sudo postconf -e 'smtpd_client_restrictions = permit_mynetworks,reject'
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230550r1017312_rule
STIG-ID	RHEL-08-040290
SWIFT-CSCV1	2.3
VULN-ID	V-230550

Assets

linuxred-01

The package 'postfix-0.0.0-0' is not installed

RHEL-08-040310 - The RHEL 8 file integrity tool must be configured to verify Access Control Lists (ACLs).

Info

ACLs can provide permissions beyond those permitted through the file mode and must be verified by file integrity tools.

Selection lines in the aide.conf file determine which files and directories AIDE will monitor for changes. They follow this format:

<path> <rules>

The <path> specifies a file, directory or wildcard pattern to monitor.

The <rules> define which attributes (hashes, permissions, timestamps, etc.) to check.

RHEL 8 installation media come with a file integrity tool, Advanced Intrusion Detection Environment (AIDE).

Solution

Configure the file integrity tool to check file and directory ACLs.

If AIDE is installed, ensure the "acl" rule is present on all file and directory selection lists.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230552r1101902_rule
STIG-ID	RHEL-08-040310
SWIFT-CSCV1	2.3
VULN-ID	V-230552

Assets

linuxred-01

RHEL-08-040320 - The graphical display manager must not be installed on RHEL 8 unless approved.

Info

Internet services that are not required for system or application processes must not be active to decrease the attack surface of the system. Graphical display managers have a long history of security vulnerabilities and must not be used, unless approved and documented.

Solution

Document the requirement for a graphical user interface with the ISSO or reinstall the operating system without the graphical user interface. If reinstallation is not feasible, then continue with the following procedure:

Open an SSH session and enter the following commands:

```
$ sudo yum remove xorg-x11-server-Xorg xorg-x11-server-common xorg-x11-server-utils xorg-x11-server-Xwayland
```

A reboot is required for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230553r1017315_rule
STIG-ID	RHEL-08-040320
SWIFT-CSCV1	2.3
VULN-ID	V-230553

Assets

linuxred-01

The package 'xorg-x11-server-common-0.0.0-0' is not installed

RHEL-08-040321 - The graphical display manager must not be the default target on RHEL 8 unless approved.

Info

Internet services that are not required for system or application processes must not be active to decrease the attack surface of the system. Graphical display managers have a long history of security vulnerabilities and must not be used, unless approved and documented.

Solution

Document the requirement for a graphical user interface with the ISSO or reinstall the operating system without the graphical user interface. If reinstallation is not feasible, then continue with the following procedure:

Open an SSH session and enter the following commands:

```
$ sudo systemctl set-default multi-user.target
```

A reboot is required for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-251718r1017371_rule
STIG-ID	RHEL-08-040321
SWIFT-CSCV1	2.3
VULN-ID	V-251718

Assets

linuxred-01

The command `'/bin/systemctl get-default'` returned :

multi-user.target

RHEL-08-040330 - RHEL 8 network interfaces must not be in promiscuous mode.

Info

Network interfaces in promiscuous mode allow for the capture of all network traffic visible to the system. If unauthorized individuals can access these applications, it may allow them to collect information such as logon IDs, passwords, and key exchanges between systems.

If the system is being used to perform a network troubleshooting function, the use of these tools must be documented with the Information System Security Officer (ISSO) and restricted to only authorized personnel.

Solution

Configure network interfaces to turn off promiscuous mode unless approved by the ISSO and documented.

Set the promiscuous mode of an interface to off with the following command:

```
$ sudo ip link set dev <devicename> multicast off promisc off
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230554r1017316_rule
STIG-ID	RHEL-08-040330
SWIFT-CSCV1	2.3
VULN-ID	V-230554

Assets

linuxred-01

```
The command '/sbin/ip link | /bin/grep -i promisc | /bin/awk '{print} END {if(NR==0) print "none" }'' returned :
```

none

RHEL-08-040350 - If the Trivial File Transfer Protocol (TFTP) server is required, the RHEL 8 TFTP daemon must be configured to operate in secure mode.

Info

Restricting TFTP to a specific directory prevents remote users from copying, transferring, or overwriting system files.

Solution

Configure the TFTP daemon to operate in secure mode with the following command:

```
$ sudo systemctl edit tftp.service
```

In the editor enter:

```
[Service] ExecStart=/usr/sbin/in.tftpd -s /var/lib/tftpboot
```

After making changes, reload the systemd daemon and restart the TFTP service as follows:

```
$ sudo systemctl daemon-reload $ sudo systemctl restart tftp.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230557r1088855_rule
STIG-ID	RHEL-08-040350
SWIFT-CSCV1	2.3
VULN-ID	V-230557

Assets

linuxred-01

The package 'tftp-server-0.0.0-0' is not installed

RHEL-08-040360 - A File Transfer Protocol (FTP) server package must not be installed unless mission essential on RHEL 8.

Info

The FTP service provides an unencrypted remote access that does not provide for the confidentiality and integrity of user passwords or the remote session. If a privileged user were to log on using this service, the privileged user password could be compromised. SSH or other encrypted file transfer methods must be used in place of this service.

Solution

Document the FTP server package with the ISSO as an operational requirement or remove it from the system with the following command:

```
$ sudo yum remove vsftpd
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230558r1017320_rule
STIG-ID	RHEL-08-040360
SWIFT-CSCV1	2.3
VULN-ID	V-230558

Assets

linuxred-01

The package 'vsftpd-0.0.0-0' is not installed

RHEL-08-040370 - The gssproxy package must not be installed unless mission essential on RHEL 8.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

The gssproxy package is a proxy for GSS API credential handling and could expose secrets on some networks. It is not needed for normal function of the OS.

Solution

Document the gssproxy package with the ISSO as an operational requirement or remove it from the system with the following command:

```
$ sudo yum remove gssproxy
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-230559r1155398_rule

STIG-ID	RHEL-08-040370
---------	----------------

SWIFT-CSCV1	2.3
-------------	-----

VULN-ID	V-230559
---------	----------

Assets

linuxred-01

The package 'gssproxy-0.0.0-0' is not installed

RHEL-08-040380 - The iprutils package must not be installed unless mission essential on RHEL 8.

Info

It is detrimental for operating systems to provide, or install by default, functionality exceeding requirements or mission objectives. These unnecessary capabilities or services are often overlooked and therefore may remain unsecured. They increase the risk to the platform by providing additional attack vectors.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services, provided by default, may not be necessary to support essential organizational operations (e.g., key missions, functions).

The iprutils package provides a suite of utilities to manage and configure SCSI devices supported by the ipr SCSI storage device driver.

Solution

Document the iprutils package with the ISSO as an operational requirement or remove it from the system with the following command:

```
$ sudo yum remove iprutils
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230560r1017321_rule
STIG-ID	RHEL-08-040380
SWIFT-CSCV1	2.3
VULN-ID	V-230560

Assets

linuxred-01

The package 'iprutils-0.0.0-0' is not installed

Audits INFO,WARNING,ERROR

RHEL-08-010010 - RHEL 8 vendor packaged system security patches and updates must be installed and up to date.

Info

Timely patching is critical for maintaining the operational availability, confidentiality, and integrity of information technology (IT) systems. However, failure to keep operating system and application software patched is a common mistake made by IT professionals. New patches are released daily, and it is often difficult for even experienced System Administrators to keep abreast of all the new patches. When new weaknesses in an operating system exist, patches are usually made available by the vendor to resolve the problems. If the most recent security patches and updates are not installed, unauthorized users may take advantage of weaknesses in the unpatched software. The lack of prompt attention to patching could result in a system compromise.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Install the operating system patches or updated packages available from Red Hat within 30 days or sooner as local policy dictates.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230222r1017041_rule
STIG-ID	RHEL-08-010010
SWIFT-CSCV1	2.3
VULN-ID	V-230222

Assets

linuxred-01

The command '/bin/yum history list' returned :

ID	Command line	Date and time	Action(s)	Altered
7	update -q -y --disablere	2026-02-28 17:13	Upgrade	1
6	remove --oldinstallonly	2025-05-26 05:19	C, E	4
5	update -y	2025-05-26 05:07	I, U	179
4	install -y cloud-init cl	2025-05-26 05:01	I, U	27 EE
3	install -y lsscsi psmisc	2025-05-26 05:01	I, U	9
2	install -c /var/run/inst	2025-05-23 05:31	Install	1
1		2025-05-23 05:26	Install	597 EE

RHEL-08-010030 - All RHEL 8 local disk partitions must implement cryptographic mechanisms to prevent unauthorized disclosure or modification of all information that requires at rest protection.

Info

RHEL 8 systems handling data requiring "data at rest" protections must employ cryptographic mechanisms to prevent unauthorized disclosure and modification of the information at rest.

Selection of a cryptographic mechanism is based on the need to protect the integrity of organizational information.

The strength of the mechanism is commensurate with the security category and/or classification of the information.

Organizations have the flexibility to either encrypt all information on storage devices (i.e., full disk encryption) or encrypt specific data structures (e.g., files, records, or fields).

Satisfies: SRG-OS-000185-GPOS-00079, SRG-OS-000404-GPOS-00183, SRG-OS-000405-GPOS-00184

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Configure RHEL 8 to prevent unauthorized modification of all information at rest by using disk encryption.

Encrypting a partition in an already installed system is more difficult, because existing partitions will need to be resized and changed. To encrypt an entire partition, dedicate a partition for encryption in the partition layout.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.13.16
800-171R3	03.13.08
800-53	SC-28
800-53R5	SC-28
CAT	I
CCI	CCI-001199
CN-L3	8.1.4.7(b)
CN-L3	8.1.4.8(b)
CSF	PR.DS-1
CSF2.0	PR.DS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iv)
HIPAA	164.312(e)(2)(ii)
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.33
ITSG-33	SC-28
ITSG-33	SC-28a.

PCI-DSSV3.2.1	3.4
PCI-DSSV4.0	3.3.2
PCI-DSSV4.0	3.5.1
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-230224r1044787_rule
STIG-ID	RHEL-08-010030
VULN-ID	V-230224

Assets

linuxred-01

The command '/sbin/blkid' returned :

```
/dev/nvme0n1p1: UUID="64191697-4854-484c-bb8b-52a42243088f" BLOCK_SIZE="4096" TYPE="xfs"
PARTUUID="2206dfb0-7a18-4cfe-85ee-41225a98213c"
/dev/nvme0n1p2: UUID="s2K1dk-6YMJ-dLat-jPFy-v4H4-Pu0p-pVPXoR" TYPE="LVM2_member"
PARTUUID="85bd4ffc-40ec-401b-85c7-9d5001354ee6"
/dev/nvme0n1p15: SEC_TYPE="msdos" UUID="6E66-F38E" BLOCK_SIZE="512" TYPE="vfat" PARTLABEL="EFI
System Partition" PARTUUID="552f246d-5c79-48ca-9288-3856349ef914"
/dev/mapper/rootvg-tmplv: UUID="045d619e-0df7-4cee-8944-b8c7659a9a43" BLOCK_SIZE="4096" TYPE="xfs"
/dev/mapper/rootvg-usrlv: UUID="8bab6677-ae30-4452-9a1d-49fbd5617c4" BLOCK_SIZE="4096" TYPE="xfs"
/dev/mapper/rootvg-homelv: UUID="bc9ff616-f919-43fa-9282-de97d199a5be" BLOCK_SIZE="4096"
TYPE="xfs"
/dev/mapper/rootvg-varlv: UUID="ed97133b-c5c2-4b02-9f73-74bece8c4af8" BLOCK_SIZE="4096" TYPE="xfs"
/dev/mapper/rootvg-rootlv: UUID="9b3c2cc0-0c21-4c1c-8a8a-df842d98cf99" BLOCK_SIZE="4096"
TYPE="xfs"
```

RHEL-08-010090 - RHEL 8, for PKI-based authentication, must validate certificates by constructing a certification path (which includes status information) to an accepted trust anchor.

Info

Without path validation, an informed trust decision by the relying party cannot be made when presented with any certificate not already explicitly trusted.

A trust anchor is an authoritative entity represented via a public key and associated data. It is used in the context of public key infrastructures, X.509 digital certificates, and DNSSEC.

When there is a chain of trust, usually the top entity to be trusted becomes the trust anchor; it can be, for example, a Certification Authority (CA). A certification path starts with the subject certificate and proceeds through a number of intermediate certificates up to a trusted root certificate, typically issued by a trusted CA.

This requirement verifies that a certification path to an accepted trust anchor is used for certificate validation and that the path includes status information. Path validation is necessary for a relying party to make an informed trust decision when presented with any certificate not already explicitly trusted. Status information for certification paths includes certificate revocation lists or online certificate status protocol responses. Validation of the certificate status information is out of scope for this requirement.

Satisfies: SRG-OS-000066-GPOS-00034, SRG-OS-000384-GPOS-00167

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Configure RHEL 8, for PKI-based authentication, to validate certificates by constructing a certification path (which includes status information) to an accepted trust anchor.

Obtain a valid copy of the DoD root CA file from the PKI CA certificate bundle at cyber.mil and copy into the following file:

```
/etc/sss/pki/sss_auth_ca_db.pem
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.12
800-53	IA-5(2)(a)
800-53R5	IA-5(2)(b)(1)
CAT	II
CCI	CCI-000185
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(2)(a)

NESA	T5.2.3
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230229r1017048_rule
STIG-ID	RHEL-08-010090
VULN-ID	V-230229

Assets

linuxred-01

The command '/bin/openssl x509 -text -in /etc/sssdpki/sssdpki_auth_ca_db.pem | /bin/grep -Ei '^\\s*(issuer|subject|not before|not after)'' returned :

```
Can't open /etc/sssdpki/sssdpki_auth_ca_db.pem for reading, Permission denied
140314794895168:error:0200100D:system library:fopen:Permission denied:crypto/bio/
bss_file.c:69:fopen('/etc/sssdpki/sssdpki_auth_ca_db.pem','r')
140314794895168:error:2006D002:BIORoutines:BIOR_new_file:system lib:crypto/bio/bss_file.c:78:
unable to load certificate
```

RHEL-08-010100 - RHEL 8, for certificate-based authentication, must enforce authorized access to the corresponding private key.

Info

If an unauthorized user obtains access to a private key without a passcode, that user would have unauthorized access to any system where the associated public key has been installed.

NOTE: Nessus has not performed this check. Please review the benchmark to ensure target compliance.

Solution

Create a new private and public key pair that utilizes a passcode with the following command:

```
$ sudo ssh-keygen -p -f /path/to/file
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.12
800-53	IA-5(2)(b)
800-53R5	IA-5(2)(a)(1)
CAT	II
CCI	CCI-000186
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(2)(b)
NESA	T5.2.3
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-230230r1069287_rule
STIG-ID	RHEL-08-010100
VULN-ID	V-230230

Assets

RHEL-08-010292 - RHEL 8 must ensure the SSH server uses strong entropy.

Info

The most important characteristic of a random number generator is its randomness, namely its ability to deliver random numbers that are impossible to predict. Entropy in computer security is associated with the unpredictability of a source of randomness. The random source with high entropy tends to achieve a uniform distribution of random values. Random number generators are one of the most important building blocks of cryptosystems.

The SSH implementation in RHEL 8 uses the OPENSSL library, which does not use high-entropy sources by default. By using the SSH_USE_STRONG_RNG environment variable the OPENSSL random generator is reseeded from /dev/random. This setting is not recommended on computers without the hardware random generator because insufficient entropy causes the connection to be blocked until enough entropy is available.

Solution

Configure the operating system SSH server to use strong entropy.

Add or modify the following line in the "/etc/sysconfig/sshd" file.

SSH_USE_STRONG_RNG=32

The SSH service must be restarted for changes to take effect.

Restart the SSH Daemon with the following command:

```
$ sudo systemctl restart sshd.service
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230253r1044799_rule
STIG-ID	RHEL-08-010292
SWIFT-CSCV1	2.3
VULN-ID	V-230253

RHEL-08-010380 - RHEL 8 must require users to provide a password for privilege escalation.

Info

Without reauthentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to escalate a functional capability, it is critical the user reauthenticate. Satisfies: SRG-OS-000373-GPOS-00156, SRG-OS-000373-GPOS-00157, SRG-OS-000373-GPOS-00158

Solution

Remove any occurrence of "NOPASSWD" found in "/etc/sudoers" file or files in the "/etc/sudoers.d" directory.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.01b.
800-53	IA-11
800-53R5	SC-11b.
CAT	II
CCI	CCI-002038
CCI	CCI-004895
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
QCSC-V1	13.2
RULE-ID	SV-230271r1101896_rule
STIG-ID	RHEL-08-010380
VULN-ID	V-230271

Assets

linuxred-01

RHEL-08-010381 - RHEL 8 must require users to reauthenticate for privilege escalation.

Info

Without reauthentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to escalate a functional capability, it is critical the user reauthenticate. Satisfies: SRG-OS-000373-GPOS-00156, SRG-OS-000373-GPOS-00157, SRG-OS-000373-GPOS-00158

Solution

Remove any occurrence of "!authenticate" found in "/etc/sudoers" file or files in the "/etc/sudoers.d" directory.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171R3	03.05.01b.
800-53	IA-11
800-53R5	SC-11b.
CAT	II
CCI	CCI-002038
CCI	CCI-004895
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(d)
QCSC-V1	13.2
RULE-ID	SV-230272r1101898_rule
STIG-ID	RHEL-08-010381
VULN-ID	V-230272

Assets

linuxred-01

RHEL-08-010382 - RHEL 8 must restrict privilege elevation to authorized personnel.

Info

The sudo command allows a user to execute programs with elevated (administrator) privileges. It prompts the user for their password and confirms your request to execute a command by checking a file, called sudoers. If the "sudoers" file is not configured correctly, any user defined on the system can initiate privileged actions on the target system.

Solution

Remove the following entries from the sudoers file:
ALL ALL=(ALL) ALL ALL ALL=(ALL:ALL) ALL

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-237641r1101904_rule
STIG-ID	RHEL-08-010382
SWIFT-CSCV1	2.3
VULN-ID	V-237641

Assets

linuxred-01

RHEL-08-010690 - Executable search paths within the initialization files of all local interactive RHEL 8 users must only contain paths that resolve to the system default or the users home directory.

Info

The executable search path (typically the PATH environment variable) contains a list of directories for the shell to search to find executables. If this path includes the current working directory (other than the user's home directory), executables in these directories may be executed instead of system commands. This variable is formatted as a colon-separated list of directories. If there is an empty entry, such as a leading or trailing colon or two consecutive colons, this is interpreted as the current working directory. If deviations from the default system search path for the local interactive user are required, they must be documented with the Information System Security Officer (ISSO).

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Edit the local interactive user initialization files to change any PATH variable statements that reference directories other than their home directory.

If a local interactive user requires path variables to reference a directory owned by the application, it must be documented with the ISSO.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230317r1069320_rule
STIG-ID	RHEL-08-010690
SWIFT-CSCV1	2.3
VULN-ID	V-230317

Assets

linuxred-01

```
/home/cddar
* /home/cddar/.bash_logout
* /home/cddar/.bash_profile
* /home/cddar/.bashrc
* /home/cddar/.bash_history
```

RHEL-08-020270 - RHEL 8 must automatically expire temporary accounts within 72 hours.

Info

Temporary accounts are privileged or nonprivileged accounts that are established during pressing circumstances, such as new software or hardware configuration or an incident response, where the need for prompt account activation requires bypassing normal account authorization procedures. If any inactive temporary accounts are left enabled on the system and are not either manually removed or automatically expired within 72 hours, the security posture of the system will be degraded and exposed to exploitation by unauthorized users or insider threat actors. Temporary accounts are different from emergency accounts. Emergency accounts, also known as "last resort" or "break glass" accounts, are local logon accounts enabled on the system for emergency use by authorized system administrators to manage a system when standard logon methods are failing or not available. Emergency accounts are not subject to manual removal or scheduled expiration requirements.

The automatic expiration of temporary accounts may be extended as needed by the circumstances but it must not be extended indefinitely. A documented permanent account should be established for privileged users who need long-term maintenance accounts.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Configure the operating system to expire temporary accounts after 72 hours with the following command:

```
$ sudo chage -E $(date -d +3days +%Y-%m-%d) <temporary_account_name>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.01
800-53	AC-2(2)
800-53R5	AC-2(2)
CAT	II
CCI	CCI-001682
CN-L3	7.1.3.2(e)
CSF	PR.AC-1
CSF	PR.AC-4
CSF2.0	DE.CM-01
CSF2.0	DE.CM-03
CSF2.0	PR.AA-01
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.16

ISO-27001-2022	A.5.18
ISO-27001-2022	A.8.2
ISO/IEC-27001	A.9.2.1
ITSG-33	AC-2(2)
NIAV2	AM28
NIAV2	NS5j
NIAV2	SS14e
QCSC-V1	5.2.2
QCSC-V1	8.2.1
QCSC-V1	13.2
QCSC-V1	15.2
RULE-ID	SV-230374r1069293_rule
STIG-ID	RHEL-08-020270
VULN-ID	V-230374

Assets

linuxred-01

The command '/bin/awk -F: '{if (\$3 >= 1000 && \$7 !~ "nologin") print \$1}' /etc/passwd | /bin/xargs -I {} /bin/bash -c '/bin/echo Username: {}; /bin/echo "====="; /bin/chage -l {} | /bin/grep -i "account expires"; /bin/echo \'' returned :

```
Username: cddar
=====
```

```
Account expires      : never
```

RHEL-08-020320 - RHEL 8 must not have unnecessary accounts.

Info

Accounts providing no operational purpose provide additional opportunities for system compromise. Unnecessary accounts include user accounts for individuals not requiring access to the system and application accounts for applications not installed on the system.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Remove unauthorized local interactive user accounts with the following command where <unauthorized_user> is the unauthorized account:

```
$ sudo userdel <unauthorized_user>
```

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230379r1017190_rule
STIG-ID	RHEL-08-020320
SWIFT-CSCV1	2.3
VULN-ID	V-230379

Assets

linuxred-01

The command `'/bin/awk -F: '{ print $1 }' /etc/passwd'` returned :

```
root
bin
daemon
```

adm
lp
sync
shutdown
halt
mail
operator
games
ftp
nobody
dbus
systemd-coredump
systemd-resolve
tss
polkitd
clevis
unbound
sshd
libstoragemgmt
cockpit-ws
cockpit-wsinstance
sssd
setroubleshoot
chrony
tcpdump
cddar

RHEL-08-030660 - RHEL 8 must allocate audit record storage capacity to store at least one week of audit records, when audit records are not immediately sent to a central audit record storage facility.

Info

To ensure RHEL 8 systems have a sufficient storage capacity in which to write the audit logs, RHEL 8 needs to be able to allocate audit record storage capacity.

The task of allocating audit record storage capacity is usually performed during initial installation of RHEL 8.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Allocate enough storage capacity for at least one week of audit records when audit records are not immediately sent to a central audit record storage facility.

If audit records are stored on a partition made specifically for audit records, resize the partition with sufficient space to contain one week of audit records.

If audit records are not stored on a partition made specifically for audit records, a new partition with sufficient space will need be to be created.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4
800-53R5	AU-4
CAT	II
CCI	CCI-001849
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230476r958752_rule
STIG-ID	RHEL-08-030660
VULN-ID	V-230476

Assets

linuxred-01

```
The command 'logfile=$(/bin/grep -iw ^\s*log_file /etc/audit/auditd.conf); if [ ! -z  
"${logfile}" ]; then /bin/df -h $(/bin/dirname ${logfile} | /bin/grep "/"); else echo "log_file  
variable in /etc/audit/auditd.conf not set"; fi' returned :  
  
/bin/grep: /etc/audit/auditd.conf: Permission denied  
log_file variable in /etc/audit/auditd.conf not set
```

RHEL-08-030720 - RHEL 8 must authenticate the remote logging server for off-loading audit logs.

Info

Information stored in one location is vulnerable to accidental or incidental deletion or alteration. Off-loading is a common process in information systems with limited audit storage capacity. RHEL 8 installation media provides "rsyslogd". "rsyslogd" is a system utility providing support for message logging. Support for both internet and UNIX domain sockets enables this utility to support both local and remote logging. Couple this utility with "gnutls" (which is a secure communications library implementing the SSL, TLS and DTLS protocols), and you have a method to securely encrypt and off-load auditing. "Rsyslog" supported authentication modes include:
anon - anonymous authentication x509/fingerprint - certificate fingerprint authentication x509/certvalid - certificate validation only x509/name - certificate validation and subject name authentication.
Satisfies: SRG-OS-000342-GPOS-00133, SRG-OS-000479-GPOS-00224
NOTE: Nessus has not performed this check. Please review the benchmark to ensure target compliance.
NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Configure the operating system to authenticate the remote logging server for off-loading audit logs by setting the following option in "/etc/rsyslog.conf" or "/etc/rsyslog.d/[customfile].conf":
\$ActionSendStreamDriverAuthMode x509/name

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-53	AU-4(1)
800-53R5	AU-4(1)
CAT	II
CCI	CCI-001851
CSF	PR.DS-4
CSF	PR.PT-1
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(b)
ISO-27001-2022	A.8.6
ITSG-33	AU-4
NESA	T3.3.1
NESA	T3.6.2
QCSC-V1	8.2.1
QCSC-V1	13.2
RULE-ID	SV-230482r1069330_rule
STIG-ID	RHEL-08-030720
VULN-ID	V-230482

Assets

linuxred-01

All of the following must pass to satisfy this requirement:

FAILED - \$ActionSendStreamDriverAuthMode
No matching files were found
Less than 1 matches of regex found

WARNING - Manual Review Required - StreamDriverAuthMode
No matching files were found

RHEL-08-040030 - RHEL 8 must be configured to prohibit or restrict the use of functions, ports, protocols, and/or services, as defined in the Ports, Protocols, and Services Management (PPSM) Category Assignments List (CAL) and vulnerability assessments.

Info

To prevent unauthorized connection of devices, unauthorized transfer of information, or unauthorized tunneling (i.e., embedding of data types within data types), organizations must disable or restrict unused or unnecessary physical and logical ports/protocols on information systems.

Operating systems are capable of providing a wide variety of functions and services. Some of the functions and services provided by default may not be necessary to support essential organizational operations. Additionally, it is sometimes convenient to provide multiple services from a single component (e.g., VPN and IPS); however, doing so increases risk over limiting the services provided by any one component.

To support the requirements and principles of least functionality, the operating system must support the organizational requirements, providing only essential capabilities and limiting the use of ports, protocols, and/or services to only those required, authorized, and approved to conduct official business or to address authorized quality-of-life issues.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Update the host's firewall settings and/or running services to comply with the PPSM Component Local Service Assessment (CLSA) for the site or program and the PPSM CAL.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06b.
800-53	CM-7b.
800-53R5	CM-7b.
CAT	II
CCI	CCI-000382
CN-L3	7.1.3.5(c)
CN-L3	7.1.3.7(d)
CN-L3	8.1.4.4(b)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS13b
NIAV2	SS14a

NIAV2	SS14c
PCI-DSSV3.2.1	2.2.2
PCI-DSSV4.0	2.2.4
QCSC-V1	3.2
RULE-ID	SV-230500r1101900_rule
STIG-ID	RHEL-08-040030
SWIFT-CSCV1	2.3
VULN-ID	V-230500

Assets

linuxred-01

The command '/bin/firewall-cmd --list-all-zones | /bin/grep -e "active" -e "services"' returned :

Authorization failed.

Make sure polkit agent is running or run the application as superuser.

RHEL-08-040300 - The RHEL 8 file integrity tool must be configured to verify extended attributes.

Info

Extended attributes in file systems are used to contain arbitrary data and file metadata with security implications. RHEL 8 installation media come with a file integrity tool, Advanced Intrusion Detection Environment (AIDE). NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Configure the file integrity tool to check file and directory extended attributes.
If AIDE is installed, ensure the "xattrs" rule is present on all uncommented file and directory selection lists.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	RHEL_8_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-230551r1017313_rule
STIG-ID	RHEL-08-040300
SWIFT-CSCV1	2.3
VULN-ID	V-230551

Assets

linuxred-01

The command `'/bin/echo 'Uncommented selection lines with out xattrs:'; /bin/grep -E "^s*[\\"/\\!\\=]" /etc/aide.conf | /bin/grep -vi xattrs'` returned :

`/bin/grep: /etc/aide.conf: No such file or directory`
Uncommented selection lines with out xattrs:

RHEL-08-040400 - RHEL 8 must prevent nonprivileged users from executing privileged functions, including disabling, circumventing, or altering implemented security safeguards/countermeasures.

Info

Preventing nonprivileged users from executing privileged functions mitigates the risk that unauthorized individuals or processes may gain unnecessary access to information or privileges. Privileged functions include, for example, establishing accounts, performing system integrity checks, or administering cryptographic key management activities. Nonprivileged users are individuals who do not possess appropriate authorizations. Circumventing intrusion detection and prevention mechanisms or malicious code protection mechanisms are examples of privileged functions that require protection from nonprivileged users. NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Configure RHEL 8 to prevent nonprivileged users from executing privileged functions, including disabling, circumventing, or altering implemented security safeguards/countermeasures. Use the following command to map a new user to the "sysadm_u" role:
\$ sudo semanage login -a -s sysadm_u <username>
Use the following command to map an existing user to the "sysadm_u" role:
\$ sudo semanage login -m -s sysadm_u <username>
Use the following command to map a new user to the "staff_u" role:
\$ sudo semanage login -a -s staff_u <username>
Use the following command to map an existing user to the "staff_u" role:
\$ sudo semanage login -m -s staff_u <username>
Use the following command to map a new user to the "user_u" role:
\$ sudo semanage login -a -s user_u <username>
Use the following command to map an existing user to the "user_u" role:
\$ sudo semanage login -m -s user_u <username>
Note: SELinux confined users mapped to sysadm_u are not allowed to log in to the system over SSH, by default. If this is a required function, it can be configured by setting the ssh_sysadm_login SELinux boolean to "on" with the following command:
\$ sudo setsebool -P ssh_sysadm_login on
This must be documented with the information system security officer (ISSO) as an operational requirement.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_RHEL_8_V2R6_STIG.zip

References

800-171	3.1.7
800-171R3	03.01.07a.
800-53	AC-6(10)
800-53R5	AC-6(10)
CAT	II
CCI	CCI-002235
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.10.6(a)
CSF	PR.AC-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	RHEL_8_STIG

GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.18
ITSG-33	AC-6
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15c
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-254520r1069331_rule
STIG-ID	RHEL-08-040400
SWIFT-CSCV1	5.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3
VULN-ID	V-254520

Assets

linuxred-01

The command '/sbin/semanage login -l 2>&1' returned :

ValueError: SELinux policy is not managed or store cannot be accessed.